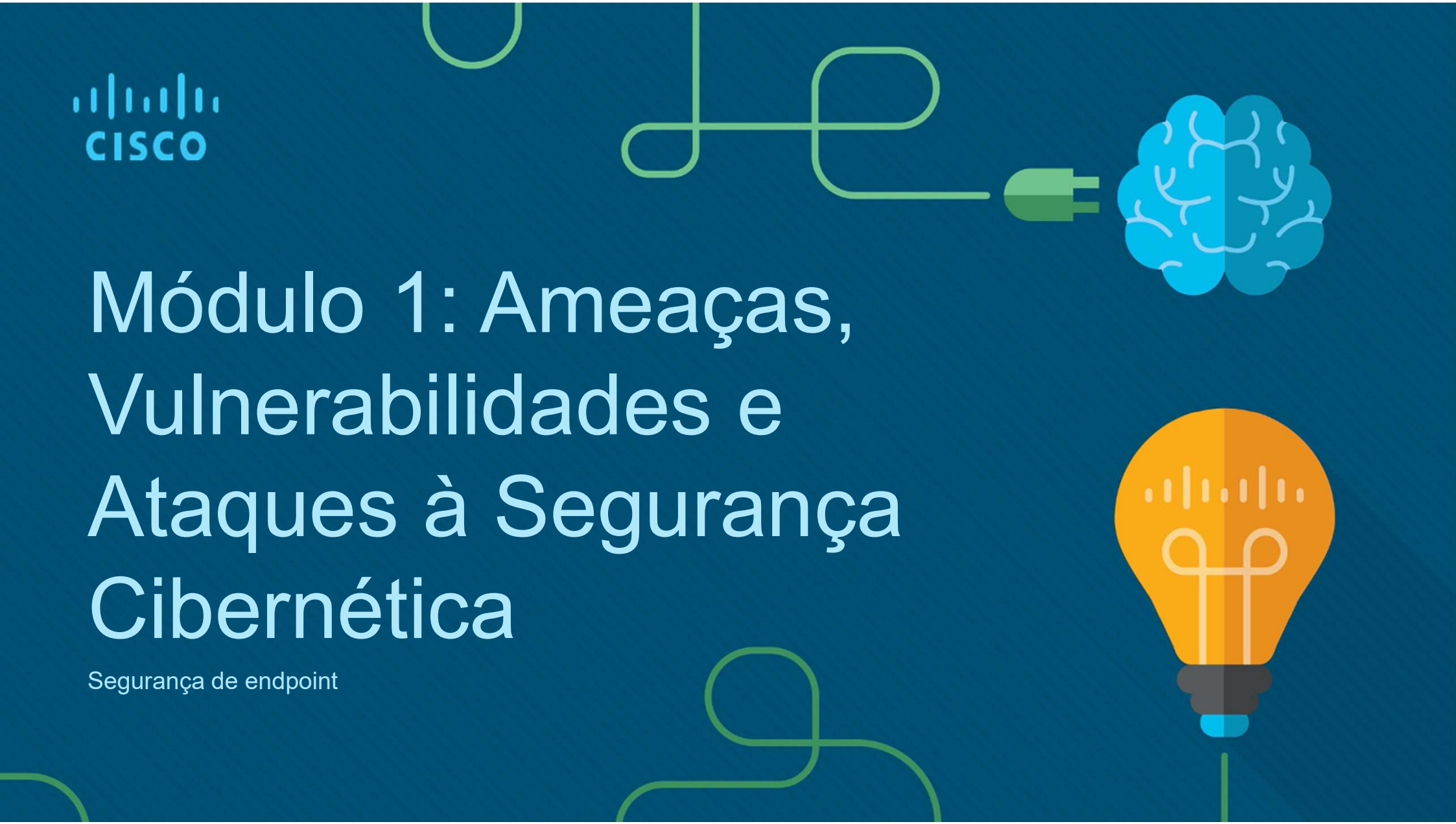


Módulo 1: Ameaças, Vulnerabilidades e Ataques à Segurança Cibernética

Segurança de endpoint

Objetivos do módulo

Título do Módulo: Ameaças, Vulnerabilidades e Ataques de Cibersegurança

Objetivo do Módulo: Explicar como os agentes de ameaças executam alguns dos tipos mais comuns de ataques cibernéticos.

Título do Tópico	Objetivo do Tópico
Ameaças comuns	Explicar as ameaças, as vulnerabilidades e os ataques que ocorrem nos vários domínios.
Disfarce	Identificar os diferentes métodos de fraude usados pelos invasores para enganar as vítimas.
Ataques cibernéticos	Descrever alguns tipos de ataques de rede comuns.
Ataques a dispositivos móveis e sem fio	Descrever os tipos comuns de ataques a dispositivos móveis e sem fio.
Ataques a aplicativos	Descrever os tipos de ataques a aplicações.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

1.1 Ameaças comuns

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ameaças comuns

Domínios de ameaça

Um "domínio de ameaça" é considerado uma área de controle, autoridade ou proteção que os atacantes podem explorar para obter acesso a um sistema.

Os atacantes podem explorar sistemas dentro de um domínio por meio de:

- Acesso direto e físico a sistemas e redes.
- A rede sem fio se estende além dos limites de uma organização.
- Dispositivos Bluetooth ou de comunicação de campo próximo (NFC).
- Anexos de e-mail maliciosos.
- Elementos menos seguros na cadeia de fornecimento de uma empresa.
- As contas de mídia social de uma empresa.
- Mídia removível, como unidades flash.
- Aplicativos baseados em nuvem.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ameaças comuns

Tipos de Ameaças Cibernéticas

Categoria	Tipos de Ameaças Cibernéticas
Ataques de software	• Um ataque de negação de serviço bem-sucedido (ataque DoS). • Um vírus de computador.
Erros de software	• Um bug de software. • Um aplicativo que fica off-line. • Um cross-site script ou compartilhamento ilegal de servidor de arquivos.
Sabotagem	• Um usuário autorizado comprometendo o banco de dados principal de uma organização. • A desfiguração do site de uma organização.
Erro humano	• Erros de entrada de dados inadvertidos. • Uma configuração incorreta do firewall.
Roubo	• Laptops ou equipamentos sendo roubados de uma sala destrancada.
Falhas de hardware	• Falhas de disco rígido
Interrupção de utilitário	• Interrupções de energia elétrica. • Danos causados pela água por falha de sprinkler.
Desastres naturais	• Tempestades severas, como furacões ou tornados. • Terremotos. • Inundações. • Incêndios.

Ameaças comuns

Ameaças Internas versus Ameaças Externas

Informações valiosas e confidenciais são registros pessoais, propriedade intelectual e dados financeiros.

Ameaças internas

- Realizado acidentalmente ou intencionalmente por funcionários atuais ou antigos e outros parceiros contratados.
- Operação de servidores ou infraestrutura de rede

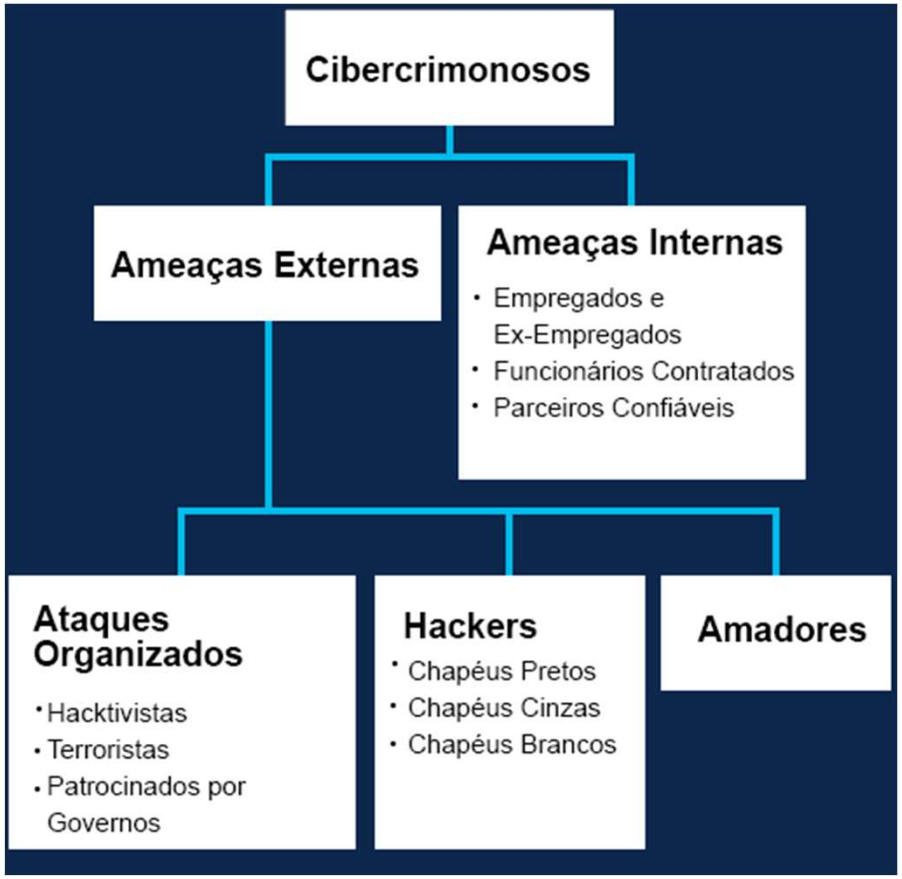
os dispositivos são comprometidos pela conexão de dispositivos infectados

mídia ou acessando e-mails ou sites maliciosos.

Ameaças Externas

- Geralmente vem de atacantes amadores ou habilidosos.
- Os ataques podem explorar vulnerabilidades em redes dispositivos ou podem ser utilizadas técnicas de

engenharia social.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ameaças e Vulnerabilidades de Usuário

Um domínio de usuário inclui qualquer pessoa que acesse o sistema de informações de uma organização, incluindo funcionários, clientes e parceiros contratados. Os usuários são o elo mais fraco nos sistemas de segurança da informação, representando uma ameaça significativa para a confidencialidade, integridade e disponibilidade dos dados de uma organização.

Exemplos de ameaças ao usuário são:

- Falta de conscientização das políticas de segurança.
- Políticas de segurança aplicadas incorretamente
- Roubo de dados
- Atividade não autorizada: downloads, mídia, VPNs, sites
- Destruição de sistemas, aplicativos ou dados



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ameaças comuns

Ameaças aos Dispositivos

- Dispositivos deixados ligados e sem vigilância.
- Baixar arquivos, fotos, músicas ou vídeos de fontes não confiáveis.
- Software com vulnerabilidades instaladas nos dispositivos de uma organização.
- Novos vírus, worms e outros tipos de malware.
- Inserção de unidades USB, CDs ou DVDs não autorizados em dispositivos de rede.
- Ausência de políticas para proteger a infraestrutura de TI de uma organização.
- Uso de hardware ou software desatualizado



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ameaças à Rede Local (LAN)

Exemplos de ameaças à rede local (LAN) incluem:

- Acesso não autorizado a armários de cabeamento, data centers e salas de computadores.
- Acesso não autorizado a sistemas, aplicações e dados
- Sistema operacional de rede ou vulnerabilidades e atualizações de software.
- Usuários não autorizados ganham acesso não autorizado às redes sem fio.
- Explorações de dados em trânsito.
- Servidores da LAN com hardware ou sistemas operacionais diferentes.
- Sondagem de rede e varredura de porta não autorizadas.
- Firewalls mal configurados.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ameaças comuns

Ameaças à Nuvem Privada.

O domínio da nuvem privada inclui servidores privados, recursos e infraestrutura de TI disponíveis para membros de uma única organização por meio da Internet.

As ameaças ao domínio da nuvem privada incluem:

- Sondagem de rede e varredura de porta não autorizadas.
- Acesso não autorizado a recursos.
- Vulnerabilidades no sistema operacional ou software de roteadores, firewalls ou dispositivos de rede.
- Erros de configuração em roteadores,firewalls ou dispositivos de rede.
- Usuários remotos acessam a infraestrutura de uma organização e baixam dados sensíveis.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ameaças à Nuvem Pública.

O domínio da nuvem pública são os serviços de computação hospedados por um provedor de nuvem, serviço ou provedor de Internet que estão disponíveis para o público e compartilhados entre organizações.

Três modelos de serviços de nuvem pública baseados em assinatura que as organizações podem escolher utilizar:

- Software como Serviço (SaaS): Fornece às organizações software (armazenado na nuvem) que é hospedado centralmente e acessado pelos usuários por meio de um navegador da web, aplicativo ou outro software.

- Plataforma como Serviço (PaaS): Permite que uma organização desenvolva, execute e gerencie suas aplicações no hardware do serviço usando suas próprias ferramentas.

- Infraestrutura como Serviço (IaaS): Fornece recursos de computação virtual, como hardware, software, servidores, armazenamento e outros componentes de infraestrutura. Uma organização comprará o acesso a eles.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ameaças à Aplicações

O domínio de aplicação inclui todos os sistemas críticos, aplicativos e dados usados por uma organização para apoiar suas operações.

As ameaças comuns aos aplicativos incluem:

- Alguém obtendo acesso não autorizado a data centers, salas de computadores, armários de fiação ou sistemas.
- Tempo de inatividade do servidor durante períodos de manutenção.
- Vulnerabilidades de software do sistema operacional de rede.
- Perda de dados.
- Vulnerabilidades de desenvolvimento de aplicativos cliente-servidor ou web.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Complexidade das ameaças

Vulnerabilidades de software ocorrem devido a erros de programação, vulnerabilidades de protocolo ou configurações incorretas do sistema.

Alguns dos métodos de ataque dos cibercriminosos são:

- Ameaça persistente avançada (APT, na sigla em inglês): um ataque contínuo que utiliza táticas elaboradas de espionagem envolvendo múltiplos agentes e malware sofisticado.

- Ataques a algoritmos: aproveitam os algoritmos em um software legítimo para gerar comportamentos não intencionais.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ameaças comuns

Backdoors e Rootkits

Criminosos cibernéticos também usam diversos tipos de malware para realizar seus ataques. Alguns tipos comuns são:

Portas dos fundos (Backdoors)

- Criminosos cibernéticos usam programas para obter acesso não autorizado a um sistema, contornando os procedimentos de autenticação padrão.
- Um programa de ferramenta administrativa remota (RAT) é executado na máquina do usuário para instalar um backdoor para fornecer controle administrativo sobre um computador de destino.

Rootkits

- Modificar o sistema operacional para criar uma porta dos fundos, que os atacantes podem usar para acessar o computador remotamente.
- A maioria utiliza vulnerabilidades de software para acessar recursos que não deveriam ser acessíveis (escalada de privilégios) e modificar arquivos do sistema.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Fontes de Inteligência de Ameaças e Pesquisa

O United States Computer Emergency Readiness Team (US-CERT) e o Departamento de Segurança Interna dos Estados Unidos patrocinaram um dicionário de vulnerabilidades e exposições comuns (CVE).Algumas outras fontes de inteligência de ameaças são:

- A dark web: um conteúdo web criptografado que requer software específico, autorização ou configurações para acessar, e que não é indexado pelos motores de busca convencionais.

- Indicador de comprometimento (IOC): IOCs, como assinaturas de malware ou nomes de domínio, fornecem evidências de violações de segurança e detalhes sobre elas.

- Compartilhamento Automatizado de Indicadores (AIS): A capacidade da Agência de Segurança Cibernética e de Infraestrutura (CISA) que permite a troca em tempo real de indicadores de ameaças cibernéticas usando uma linguagem padronizada e estruturada chamada STIX e TAXII.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

1.2 Fraude

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Disfarce

Engenharia social

A engenharia social é uma estratégia não técnica que tenta manipular indivíduos para realizar ações específicas ou divulgar informações confidenciais.

Alguns tipos comuns de ataques de engenharia social são:

- Pretexto: Isso ocorre quando uma pessoa mente para obter acesso a dados confidenciais.
- Algo por algo (quid pro quo): Envolve uma solicitação de informações pessoais em troca de algo, como um presente.
- Fraude de identidade: Utiliza a identidade roubada de uma pessoa para obter bens ou serviços por meio de engano.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Disfarce

Táticas de Engenharia social

Criminosos cibernéticos contam com várias táticas de engenharia social para obter acesso a informações sensíveis:

- Autoridade
- Intimidação
- Consenso
- Escassez
- Urgência
- Familiaridade
- Confiança

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Disfarce

Shoulder Surfing e busca de informações na lixeira

Shoulder Surfing (Espionagem visual)

- Um ataque simples envolve observar ou olhar por cima do ombro de um alvo para obter informações valiosas, como senhas PIN, códigos de acesso ou detalhes de cartões de crédito.

- Os criminosos nem sempre precisam estar próximos de suas vítimas para fazer espionagem visual — eles podem usar binóculos ou câmeras de segurança para obter essas informações.

Busca de lixo (Dumpster Diving)

- O processo de passar pelo lixo de um alvo para ver as informações descartadas.

- Documentos contendo informações sensíveis devem ser triturados ou armazenados em sacos de queima até serem destruídos pelo fogo após um determinado período.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Disfarce

Representação e farsas

Os criminosos digitais têm muitas outras técnicas de dissimulação para ajudá-los a obter sucesso.

Representação

- Ato de enganar alguém para fazer algo que normalmente não faria, fingindo ser outra pessoa.

- Os criminosos também usam a representação para atacar os outros.

Farsa

- Um ato destinado a enganar ou ludibriar alguém pode causar tanta perturbação quanto uma violação de segurança real.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Disfarce

Piggybacking e tailgating

Isso ocorre quando um criminoso segue uma pessoa autorizada para obter acesso físico a um local seguro ou uma área restrita.

Os criminosos podem conseguir isso:

- Dar a impressão de ser escoltado para a instalação por uma pessoa autorizada.
- Juntar-se e fingir ser parte de uma grande multidão que entra na instalação.
- Visar uma pessoa autorizada que não tem cuidado com as regras da instalação.

Uma maneira de evitar isso é usar dois conjuntos de portas (armadilha), o que significa que os indivíduos entram por uma porta externa e devem fechar antes de obter acesso por uma porta interna.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Disfarce

Outros Métodos de Engano

Esteja ciente de que os invasores têm muito mais truques na manga para enganar suas vítimas.

Alguns desses métodos são:

- Fraude da fatura
- Ataque do regador
- Typosquatting
- Adendo
- Influenciar campanhas

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Disfarce

Defesa contra disfarce

As organizações devem promover a conscientização sobre táticas de engenharia social e educar adequadamente os funcionários sobre medidas de prevenção. Aqui estão algumas dicas importantes:

- Nunca divulgue informações confidenciais ou credenciais por e-mail, chat, mensagens de texto, pessoalmente ou por telefone para partes desconhecidas.
- Resista ao desejo de clicar em e-mails atraentes e links da web.
- Desconfie de downloads não iniciados ou automáticos.
- Estabelecer e educar os funcionários sobre as principais políticas de segurança.
- Incentive os funcionários a assumirem responsabilidade pelos problemas de segurança.
- Não ceda à pressão de pessoas desconhecidas.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Disfarce

Laboratório - Técnicas de Exploração de Engenharia Social

Neste laboratório, você completará os seguintes objetivos:

- Parte 1: Técnicas de Exploração de Engenharia Social
- Parte 2: Crie um pôster de conscientização sobre segurança cibernética

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

1.3 Ataques cibernéticos

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ataques cibernéticos

Qual é a diferença?

Os criminosos cibernéticos utilizam diversos tipos de malware para realizar ataques.

Os três tipos mais comuns de malware são:

Vírus
- Tipo de programa de computador que, quando executado, se replica e se anexa a outros arquivos, como um programa legítimo, inserindo seu código neles.

Worms
- Ele se replica explorando independentemente vulnerabilidades em redes.

cavalo de troia
- Ele realiza operações maliciosas ao mascarar sua verdadeira intenção. Pode parecer legítimo, mas é, de fato, muito perigoso.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ataques cibernéticos

Bombas lógicas

- Um programa malicioso que aguarda por um gatilho, como uma data específica ou uma entrada em um banco de dados, para iniciar o código malicioso. Até que este evento de disparo aconteça, a bomba lógica permanecerá inativa.

- Uma vez ativado, ele implementa um código malicioso que causa danos a um computador de várias maneiras. Ele pode sabotar registros de banco de dados, apagar arquivos e atacar sistemas operacionais ou aplicativos.

- Bomba lógica ataca e destrói os componentes de hardware em um dispositivo ou servidor, incluindo os ventiladores de refrigeração, CPU, memória, discos rígidos e fontes de alimentação foram recentemente descobertos.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ataques cibernéticos

Ransomware

- Projetadas para manter um sistema de computador ou os dados que ele contém como reféns até que um pagamento seja efetuado.
- Normalmente, funciona criptografando os dados para que o proprietário não consiga acessá-los.
- Um resgate exigido pago por meio de um sistema de pagamento não rastreável, o cibercriminoso fornece um programa que descriptografa arquivos ou envia um código de desbloqueio – mas muitas vítimas não obtêm acesso aos seus dados mesmo após o pagamento.
- Algumas versões de ransomware podem tirar proveito de vulnerabilidades específicas do sistema para bloqueá-lo.
- Espalhado por meio de e-mails de phishing que incentivam o download de anexos maliciosos ou explorando vulnerabilidades de software.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ataques de Negação de Serviços

O tipo de ataque de rede é relativamente simples de ser realizado, mesmo para um atacante inexperiente. Normalmente, esses ataques resultam em interrupção dos serviços de rede, causando uma perda significativa de tempo e dinheiro.

Os dois principais tipos de ataques de negação de serviço (DoS) são:

- A quantidade esmagadora de tráfego: quando uma rede, host ou aplicativo envia uma quantidade enorme de dados a uma taxa que não pode suportar, isso causa uma transmissão ou resposta lenta ou faz com que o dispositivo ou serviço trave.

- Pacotes formatados maliciosamente: Envia um pacote formatado de forma maliciosa e o receptor não conseguirá processá-lo.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ataques cibernéticos

Domain Name System (Sistema de Nomes de Domínios).

- Muitos serviços técnicos essenciais são necessários para que uma rede funcione, como roteamento, endereçamento e nomeação de domínio. Esses são os principais alvos de ataques.
- Os cibercriminosos podem aproveitar as vulnerabilidades dos serviços de DNS para lançar os seguintes ataques:

Reputação de domínio	O DNS é usado pelos servidores DNS para traduzir um nome de domínio em um endereço IP numérico para que os computadores possam entendê-lo. Se um servidor DNS não sabe o endereço IP, ele perguntará a outro servidor DNS. Uma organização precisa monitorar a reputação de seu domínio, incluindo seu endereço IP, para ajudar a se proteger contra domínios externos maliciosos.
DNS spoofing (envenenamento de cache de DNS)	Ataque no qual dados falsos são introduzidos no cache de resolução DNS - o banco de dados temporário no sistema operacional de um computador que registra visitas recentes a sites e outros domínios da Internet. Esses ataques de veneno exploram uma fraqueza no software DNS que faz com que os servidores DNS redirecionem o tráfego de um domínio específico para o computador do invasor.
Sequestro de domínio	Quando um invasor obtém, por engano, o controle das informações de DNS de um alvo, ele pode fazer alterações não autorizadas.
Localizador uniforme de recursos (URL)	Um identificador único para localizar um recurso específico na Internet. O redirecionamento de uma URL geralmente acontece para fins legítimos.

Ataques de camada 2

Os atacantes frequentemente se aproveitam das vulnerabilidades na segurança da camada dois.

Alguns exemplos de ataques são:

Spoofing
- Falsificação de endereço MAC
- falsificação ARP
- Spoofing de IP

Inundação de MAC
- Isso compromete os dados transmitidos para um dispositivo. Um invasor inunda a rede com endereços MAC falsos, comprometendo a segurança do switch de rede.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ataques Man-in-the-Middle e Man-in-the-Mobile

Os invasores podem interceptar ou modificar as comunicações entre dois dispositivos para roubar informações ou se passar por um dos dispositivos.

MitM (Man-in-the-Middle)

- Isso ocorre quando um criminoso cibernético assume o controle de um dispositivo sem o conhecimento do usuário.
- Com esse nível de acesso, um invasor pode interceptar, manipular e retransmitir informações falsas entre o remetente e o destino pretendido.

MitMO (Man-in-the-Mobile)

- Uma variação de MitMO é um tipo de ataque usado para assumir o controle do dispositivo móvel de um usuário.
- Quando infectado, o dispositivo móvel instrui a exfiltrar informações confidenciais do usuário e enviá-las aos invasores.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ataques de Dia Zero

- Ele explora vulnerabilidades de software antes que se tornem conhecidas ou antes que o fornecedor de software as divulgue.
- Uma rede é altamente vulnerável a ataques entre o momento em que uma vulnerabilidade é descoberta (hora zero) e o momento em que o fornecedor de software desenvolve e lança uma correção para essa vulnerabilidade.
- A defesa contra esses ataques rápidos exige que os profissionais de segurança de rede adotem uma visão mais sofisticada e holística de qualquer arquitetura de rede.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Keyboard Logging

- Isso se refere a gravar ou registrar cada tecla pressionada no teclado de um computador.
- Os cibercriminosos registram as teclas pressionadas por meio de software instalado em um sistema de computador ou por meio de dispositivos de hardware que são fisicamente conectados a um computador, e configuram o software de keylogger para enviar o arquivo de registro para o criminoso.
- Por ter registrado todas as teclas pressionadas, esse arquivo de registro pode revelar nomes de usuário, senhas, sites visitados e outras informações confidenciais.
- Muitos pacotes anti-spyware podem detectar e remover keyloggers não autorizados.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Defesa contra ataques

As organizações podem tomar várias medidas para se defender contra vários ataques. Isso inclui:

- Configure os firewalls para remover quaisquer pacotes de fora da rede com endereços indicando que eles se originaram de dentro da rede.
- Verifique se as correções e atualizações estão atualizadas.
- Distribuir a carga de trabalho nos sistemas de servidor.
- Os dispositivos de rede usam pacotes ICMP para enviar mensagens de erro e de controle Para evitar ataques de DoS e DDoS, as empresas podem bloquear pacotes externos de ICMP com seus firewalls.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

1.4 Ataques a dispositivos móveis e sem fio

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Grayware e Smishing

Grayware (Programas Cinzentos)

- Qualquer aplicativo não desejado que se comporta de maneira irritante ou indesejável.

- E, embora o grayware não tenha nenhum malware reconhecível, ele ainda pode representar um risco para o usuário, por exemplo, acompanhando a sua localização ou disponibilizando publicidade indesejável.

Serviço de mensagens curtas phishing ou SMiShing

- Outra tática usada pelos invasores é enganá-lo.

- Mensagens de texto falsas solicitam que você acesse um site mal-intencionado ou ligue para um número de telefone fraudulento, o que pode resultar no download de malware no dispositivo ou no compartilhamento de informações pessoais.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Access points não autorizados

Um access point não autorizado é um access point sem fio instalado em uma rede segura sem autorização explícita.

Algumas maneiras de instalar um ponto de acesso não autorizado são:

- Um invasor geralmente usa táticas de engenharia social para obter acesso físico à infraestrutura de rede de uma empresa e instalar o access point não autorizado.
- O ponto de acesso pode ser configurado como um dispositivo de interceptação para capturar suas informações de login.
- Um ataque de "evil twin" descreve uma situação em que o ponto de acesso do atacante é configurado para parecer uma opção de conexão melhor. Depois de se conectar ao ponto de acesso maligno, o invasor pode analisar o tráfego da rede e executar ataques MitM.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Bloqueio de Radiofrequência

- Os sinais sem fio são suscetíveis a interferência eletromagnética (EMI), interferência de radiofrequência (RFI) e até mesmo a raios ou ruídos de luzes fluorescentes.
- Os invasores podem aproveitar esse fato bloqueando deliberadamente a transmissão de uma estação de rádio ou satélite para impedir que um sinal sem fio chegue à estação receptora.
- Para obter sucesso em bloquear o sinal, a frequência, modulação e potência do dispositivo de interferência de radiofrequência (RF jammer) precisam ser iguais aos do dispositivo que o atacante deseja perturbar.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Bluejacking e Bluesnarfing

Devido ao alcance limitado do Bluetooth, o invasor deve estar dentro do alcance do alvo.

Aqui estão algumas maneiras pelas quais eles podem explorar o dispositivo de um alvo sem o conhecimento deles:

- O Bluejacking usa a tecnologia Bluetooth sem fio para enviar mensagens não autorizadas ou imagens chocantes para outro dispositivo Bluetooth.

- O bluesnarfing ocorre quando um invasor copia informações, como e-mails e listas de contatos, de um dispositivo de destino usando uma conexão Bluetooth.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ataques Contra Protocolos Wi-Fi

Wired Equivalent Privacy (WEP) e Wi-Fi Protected Access (WPA) são protocolos de segurança projetados para proteger redes sem fio.

- O WEP foi desenvolvido para fornecer uma WLAN com um nível de proteção criptografando os dados
- O WEP usava uma chave para criptografia, mas o WEP não tinha provisão para gerenciamento de chaves, dando aos criminosos acesso a uma grande quantidade de dados de tráfego.
- Para resolver isso e substituir o WEP, o WPA e o WPA2 foram desenvolvidos como protocolos de segurança aprimorados.
- Ao contrário do WEP, um invasor não pode recuperar a chave de criptografia do WPA2 observando o tráfego de rede.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Defesa de Wi-Fi e Dispositivos Móveis

Existem várias etapas que organizações e usuários precisam seguir para se defender contra ataques de dispositivos móveis e sem fio:

- Aproveite os recursos básicos de segurança sem fio, como autenticação e criptografia, alterando as configurações padrão.
- Restrinja o posicionamento de access point colocando esses dispositivos fora do firewall ou dentro de uma zona desmilitarizada - uma rede de perímetro que protege a LAN de uma empresa contra dispositivos não confiáveis.
- Use ferramentas WLAN como NetStumbler para detectar pontos de acesso não autorizados ou estações de trabalho não autorizadas.
- Desenvolva uma política para acesso de convidado à rede Wi-Fi de uma empresa.
- Os funcionários de uma empresa devem usar uma VPN de acesso remoto para acesso à WLAN.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

1.5 Ataques à aplicativos

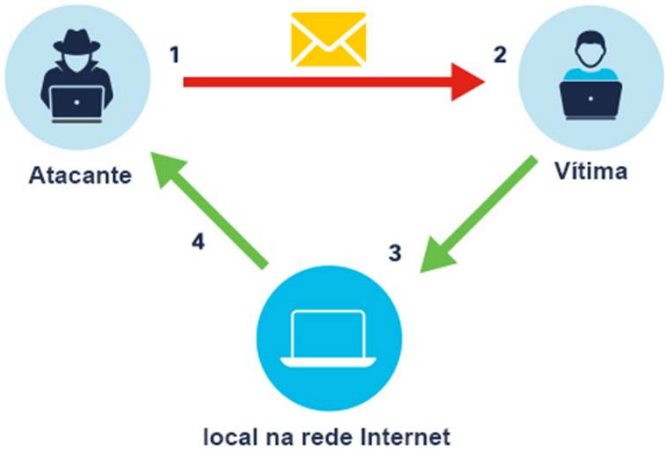
© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ataques a aplicativos

Scripting através de sites

Cross-site scripting (XSS) é uma vulnerabilidade comum encontrada em muitos aplicativos da web. Funciona assim:

- Os criminosos digitais exploram a vulnerabilidade XSS ao injetar scripts que contêm código mal-intencionado em uma página da Web.
- A página da Web é acessada pela vítima, e os scripts mal-intencionados passam inadvertidamente para o navegador.
- O script malicioso pode acessar quaisquer cookies, tokens de sessão ou outras informações sensíveis sobre o usuário, que são enviadas de volta para o cibercriminoso.
- Munido dessas informações, o criminoso digital pode se passar por um usuário.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ataques a aplicativos

Injeção de código

- Os ataques de injeção exploram vulnerabilidades em bancos de dados, como a Linguagem de Consulta Estruturada (SQL) ou a Linguagem de Marcação Extensível (XML), que são utilizadas por sites modernos para armazenar e gerenciar dados.

- Alguns tipos comuns de ataques de injeção são:

Ataque de injeção de XML	Ele pode corromper os dados no banco de dados XML e ameaçar a segurança do site. Ele funciona interferindo no processamento de dados XML ou consulta inserida por um usuário em um aplicativo. Os criminosos cibernéticos podem manipular essa consulta programando-a de acordo com suas necessidades.
Ataque de injeção de SQL	Os criminosos cibernéticos podem realizar esse ataque em sites ou em qualquer banco de dados SQL inserindo uma instrução SQL maliciosa em um campo de entrada. Aproveita uma vulnerabilidade em que o aplicativo não filtra corretamente os dados inseridos pelo usuário em caracteres de uma declaração SQL.
Ataque de injeção de DLL	A injeção de DLL permite que um criminoso digital engane um aplicativo para chamar um arquivo DLL mal-intencionado, que é executado como parte do processo de destino.
Ataque de injeção de LDAP	O LDAP é um protocolo aberto para autenticar o acesso do usuário aos serviços de diretório. Este ataque explora vulnerabilidades de validação de entrada injetando e executando consultas em servidores LDAP, oferecendo aos criminosos cibernéticos a oportunidade de extrair informações confidenciais do diretório LDAP de uma organização.

Ataques a aplicativos

Buffer Overflow

- Os buffers são áreas de memórias alocadas a um aplicativo.
- Um estouro de buffer ocorre quando os dados são gravados além dos limites de um buffer. Ao alterar os dados além dos limites de um buffer, o aplicativo pode acessar a memória alocada para outros processos.
- Isso pode levar à queda do sistema, comprometimento de dados ou fornecer o escalonamento de privilégios.
- Essas falhas de memória também podem oferecer aos invasores controle total sobre o dispositivo de um alvo.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Execuções de código remoto

- A execução remota de código permite que um cibercriminoso aproveite as vulnerabilidades do aplicativo para executar qualquer comando com os privilégios do usuário que executa o aplicativo no dispositivo de destino.
- A elevação de privilégios explora um bug, falha de projeto ou má configuração em um sistema operacional ou aplicativo de software para acessar recursos normalmente restritos.
- "The Metasploit Project" é um projeto de segurança de computadores que fornece informações sobre vulnerabilidades de segurança e auxilia em testes de penetração.
- Entre as ferramentas desenvolvidas, eles criaram o Metasploit Framework, que pode ser usado para criar e executar códigos de exploração em um alvo remoto.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Outros ataques de aplicativos

- Cada informação que um invasor recebe sobre um sistema ou aplicativo específico pode ser usada como uma arma valiosa para iniciar um ataque perigoso.
- Alguns outros tipos de ataques de aplicativos são:

Cross-site request forgery (CSRF)	Isso descreve a exploração maliciosa de um site onde comandos não autorizados são enviados a partir do navegador de um usuário para um aplicativo web confiável.
Ataque de condição de corrida (time of check – TOC ou time of use – TOU)	Esse ataque ocorre quando um sistema de computação projetado para lidar com tarefas em uma sequência específica é forçado a executar duas ou mais operações simultaneamente.
Ataque de tratamento de entrada inadequado	Os dados inseridos por um usuário que não é validado corretamente podem afetar o fluxo de dados de um programa e causar vulnerabilidades críticas em sistemas e aplicativos que resultam em estouro de buffer ou ataques de injeção de SQL.
Ataque de tratamento de erros	Os invasores podem usar mensagens de erro para extrair informações específicas, como nomes de host de sistemas internos e diretórios ou arquivos que existem em um determinado servidor Web, bem como nomes de bancos de dados, tabelas e campos que podem ser usados para criar ataques de injeção de SQL.

Outros ataques de aplicativos (cont.)

Ataque à interface de programação de aplicativos (API)	Uma API fornece uma resposta do usuário para um sistema e envia a resposta do sistema de volta para o usuário. Um ataque de API ocorre quando um criminoso digital abusa de um endpoint de API.
ataques de repetição	Isso descreve uma situação em que uma transmissão de dados válida é repetida ou retardada de forma mal-intencionada ou fraudulenta por um invasor, que intercepta, altera e reenvia os dados para que o destinatário faça o que quiser.
Ataque transversal de diretório	A travessia de diretório ocorre quando um atacante lê arquivos no servidor web fora do diretório do site. Um invasor pode usar essas informações para baixar arquivos de configuração do servidor que contêm informações confidenciais, expor potencialmente mais vulnerabilidades do servidor ou até mesmo assumir o controle do servidor!
Ataques de exaustão de recursos	Esses ataques são exploits de segurança de computadores que travam, paralisam ou interferem em um programa ou sistema específico. Em vez de sobrecarregar a largura de banda de rede como um ataque de DoS, os ataques de exaustão de recursos sobrecarregam os recursos de hardware disponíveis no servidor de destino.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Defesa contra ataques de aplicativo

Você pode tomar várias medidas para se defender contra um ataque de aplicativo.

Alguns deles são:

- A primeira defesa contra um ataque de aplicativo é escrever um código sólido.
- Prática prudente de programação envolve tratar e validar todas as entradas de fora de uma função como se fosse hostil.
- Mantenha todo o software, incluindo sistemas operacionais e aplicativos, atualizado e não ignore as solicitações de atualização. Nem todos os programas são atualizados automaticamente.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ataques a aplicativos

Spam

- Spam (lixo eletrônico) é um e-mail não solicitado e, na maioria dos casos, é um método de publicidade.
- Muitos spams são enviados em massa por computadores infectados por vírus ou worms — e frequentemente contêm links maliciosos, malware ou conteúdo enganoso que tem como objetivo enganar os destinatários para revelar informações sensíveis.
- Quase todos os provedores de e-mail filtram spam, mas ainda consomem largura de banda. E mesmo se você tiver recursos de segurança implementados, alguns spams ainda podem chegar até você.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Spam (cont.)

Alguns indicadores de spam:

- O e-mail não tem assunto.
- O e-mail solicita que você atualize os detalhes da sua conta.
- O texto do e-mail tem erros de ortografia ou uma pontuação estranha.
- Os links dentro do e-mail são longos e criptografados.
- O e-mail parece correspondência de uma empresa legítima, mas há pequenas diferenças - ou contém informações que não parecem relevantes para você.
- O e-mail solicita que você abra um anexo, geralmente com urgência.

Se você receber um e-mail contendo um ou mais indicadores, você não deve abrir o e-mail ou quaisquer anexos.

Muitas empresas têm uma política de e-mail que exige que os funcionários relatem o recebimento desse tipo de e-mail à equipe de segurança digital para investigação adicional. Em caso de dúvida, sempre informe.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ataques a aplicativos

Phishing

Phishing é uma forma de atividade fraudulenta frequentemente usada para roubar informações pessoais.

Phishing

- Isso ocorre quando um usuário é contatado por e-mail, mensagem instantânea - ou de qualquer outra forma - por alguém se passando por uma pessoa ou organização legítima.

- A intenção é induzir o destinatário a instalar malware em seu dispositivo ou compartilhar informações pessoais, como credenciais de login ou informações financeiras.

Spear phishing

- Um ataque altamente direcionado, o spear phishing envia e-mails personalizados para uma pessoa específica com base em informações que o atacante conhece sobre ela, como seus interesses, preferências, atividades e projetos de trabalho.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ataques a aplicativos

Vishing, Pharming e Whaling

Os criminosos usam uma ampla variedade de técnicas para tentar obter acesso às suas informações pessoais.

Alguns de seus golpes comuns são:

- Vishing: Esse tipo de ataque envolve criminosos que utilizam tecnologia de comunicação por voz para incentivar os usuários a divulgar informações, como detalhes de cartão de crédito.

- Farming (Falsificação): Esse ataque direciona intencionalmente os usuários para uma versão falsa de um site oficial.

- Whaling (Pesca de baleias): Um ataque de phishing direciona indivíduos de alto perfil, como altos executivos de uma organização, políticos e celebridades.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Defesa contra ataques ao e-mail e navegador

Algumas das ações importantes que você pode tomar para se defender contra ataques de e-mail e navegadores:

É difícil parar o spam, mas existem maneiras de reduzir seus efeitos:

- A maioria dos provedores de serviços de Internet (ISPs) filtra o spam antes que ele chegue à caixa de entrada do usuário.
- Muitos programas antivírus e de software de e-mail detectam e removem automaticamente spam perigoso de uma caixa de entrada de e-mail.
- As organizações devem educar os funcionários sobre os perigos dos emails não solicitados e conscientizá-los sobre os riscos de abrir anexos.
- Sempre varra anexos de e-mail, antes de abri-los.

Torne-se um membro do Grupo de Trabalho Anti-Phishing (APWG). É uma associação internacional de empresas focada na eliminação de fraudes e roubo de identidade resultantes de phishing e falsificação de e-mail.

Todo o software deve ser mantido atualizado, com as últimas correções de segurança, para se proteger contra vulnerabilidades conhecidas.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ataques a aplicativos

Tem mais...

- Alguns outros ataques comuns que os cibercriminosos podem lançar são:

Ataques físicos	São ações intencionais e ofensivas usadas para destruir, expor, alterar, desabilitar, roubar ou obter acesso não autorizado à infraestrutura ou hardware de uma organização.
Ataques adversos à inteligência artificial	O aprendizado de máquina é um método de automação que permite que os dispositivos realizem análises e executem tarefas sem serem especificamente programados para isso. Isso usa modelos matemáticos para prever resultados. No entanto, esses modelos dependem dos dados inseridos. Se os dados estiverem infectados, poderão ter um impacto negativo no resultado previsto. Os invasores podem aproveitar isso para realizar ataques contra algoritmos de aprendizagem de máquina.
Ataques à cadeia de fornecimento	Muitas empresas interagem com terceiros para gerenciar seus sistemas ou comprar componentes e software. As empresas podem até depender de peças ou componentes de fontes estrangeiras. Os atacantes frequentemente encontram maneiras de interceptar essas cadeias de suprimentos.
Ataques na nuvem	Em vez de desenvolver sistemas em suas próprias instalações, cada vez mais organizações estão migrando para a computação em nuvem. Os invasores estão constantemente aproveitando formas de explorar dados confidenciais armazenados na nuvem, bem como aplicações, plataformas e infraestrutura baseada em nuvem, como vimos com SaaS, PaaS e IaaS.

Resumo de ameaças, vulnerabilidades e ataques de segurança cibernética

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Resumo de ameaças, vulnerabilidades e ataques de segurança cibernética

O que aprendi neste módulo?

- Um domínio de ameaça é uma área de controle, autoridade ou proteção que os invasores podem explorar para obter acesso a um sistema.
- As ameaças cibernéticas são classificadas como ameaças internas e externas. Isso inclui ataques e erros de software, sabotagem, erros humanos, roubo, falhas de hardware, interrupção de serviços públicos e desastres naturais.
- A engenharia social é uma estratégia não técnica que tenta manipular indivíduos para realizar ações específicas ou divulgar informações confidenciais.
- Malware é qualquer código que pode ser usado para roubar dados, contornar o controle de acesso ou causar danos ou comprometer um sistema.
- Grayware é um aplicativo indesejado que se comporta de maneira irritante ou indesejável. Para se defender contra ataques a dispositivos sem fio e móveis: altere as configurações padrão.
- Os ataques de injeção de código incluem XML, SQL, DLL e LDAP. Escreva um código sólido para se defender contra um ataque de aplicativo.
- Use um software antivírus para se defender contra ataques de e-mail e navegadores.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Módulo 1

Termos e comandos

- Cross-Site Scripting (XSS)
- Software como Serviço (SaaS)
- Plataforma como SERVIÇO (PaaS)
- Infraestrutura como Serviço (IaaS)
- Ameaça persistente avançada (APT - Advanced Persistent Threat)
- Programa de ferramenta administrativa remota (RAT)
- Common Vulnerabilities and Exposures (CVE):
- Indicador de comprometimento (IOC)
- teia escura
- Structured Threat Information Expression (STIX)
- Trusted Automated Exchange of Indicator Information (TAXII)
- ataque de dia zero
- Malware
- Grayware (Programas Cinzentos)

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco



Módulo 2: Protegendo Redes

Segurança de endpoint

Objetivos do Módulo

Título do módulo: Protegendo Redes

Objetivo do Módulo: Explicar os princípios de segurança de redes.

Título do Tópico	Objetivo do Tópico
Situação Atual	Explicar as ameaças, as vulnerabilidades e os ataques que ocorrem nos vários domínios.
Quem está atacando nossa rede?	Explicar como as ameaças à rede evoluíram.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

2.1 Situação Atual

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Situação Atual

Vídeo - Anatomia de um Ataque

Este vídeo mostra uma amostra do que os profissionais de segurança cibernética fazem. O arquiteto de segurança da Cisco, Matt Carling, oferece o ponto de vista do defensor e por que uma abordagem de camada de "defesa em profundidade" é a melhor.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Situação Atual

As redes são alvos

- As redes de computadores estão rotineiramente sob ataque.
- A Kapersky mantém a exibição interativa do Mapa em Tempo Real de Ameaças Cibernéticas dos ataques de rede atuais.
- Os dados do ataque são enviados pelos produtos de segurança de rede Kapersky implantados em todo o mundo
- Muitas ferramentas semelhantes estão disponíveis na internet e podem ser encontradas pesquisando mapas de ameaças cibernéticas.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Situação Atual

Razões para a Segurança da Rede

- A segurança da rede está diretamente relacionada à continuidade dos negócios de uma organização.
- As violações de segurança de rede podem interromper o comércio eletrônico, causar a perda de dados comerciais, ameaçar a privacidade das pessoas e comprometer a integridade das informações.
- Essas violações podem resultar em perda de receita para empresas, roubo de propriedade intelectual, ações judiciais e até ameaçar a segurança pública.
- Manter uma rede segura garante a segurança dos usuários da rede e protege os interesses comerciais.
- Manter uma rede segura requer vigilância por parte dos profissionais de segurança de rede de uma organização.
- Muitas ferramentas ajudam os administradores de rede a adaptar, desenvolver e implementar técnicas de mitigação de ameaças. Dois exemplos são
  - Site do Cisco Talos Intelligence Group
  - Equipe de resposta a incidentes de segurança do produto (PSIRT) da Cisco

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Situação Atual

Vetores de Ataques de Rede

- Um vetor de ataque é um caminho pelo qual um atacante poder obter acesso a um servidor, equipamento ou rede.

- Os vetores de ataque são originários de dentro ou de fora da rede corporativa.
  - Um usuário interno, como um funcionário, pode acidentalmente ou intencionalmente:
    - Roubar e copiar dados confidenciais para mídia removível, email, software de mensagens e outras mídias.
    - Comprometer servidores internos ou dispositivos de infraestrutura de rede.
    - Desconectar uma conexão de rede crítica e cause uma interrupção na rede.
    - Conectar uma unidade USB infectada a um sistema de computador corporativo.
  - Ameaças internas têm o potencial de causar danos mais significativos do que as ameaças externas.

- Profissionais de segurança de rede devem implementar ferramentas e aplicar técnicas para mitigar ameaças externas e internas.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Situação Atual

Perda de Dados

Termo	Definição
E-mail/Redes sociais	O vetor mais comum para a perda de dados inclui o software de sistema de mensagens instantâneas e sites de mídia social. Por exemplo, e-mail ou mensagens instantâneas interceptadas podem ser capturados e revelam informações confidenciais.
Dispositivos não Criptografados	Um laptop corporativo roubado normalmente contém dados organizacionais confidenciais. As ameaças internas têm o potencial de causar danos mais significativos do que as externas, o ladrão pode recuperar dados pessoais valiosos se os dados não forem armazenados usando ameaças de algoritmo de criptografia.
Dispositivos de Armazenamento em nuvem	Salvar dados na nuvem tem muitos benefícios potenciais. Dados confidenciais podem ser perdidos se o acesso à nuvem for comprometido devido a configurações de segurança fracas.
Mídia removível	Um risco é que um funcionário possa realizar uma transferência não autorizada de dados para uma unidade USB. Outro risco é a perda de uma unidade USB contendo dados corporativos valiosos.
Cópia Impressa	Os dados corporativos devem ser descartados completamente. Os dados confidenciais devem ser fragmentados quando não forem mais necessários. Caso contrário, um ladrão pode recuperar relatórios descartados e obter informações valiosas.
Controle de acesso inadequado	Senhas são a primeira linha de defesa Senhas ou senhas fracas que foram comprometidas podem fornecer a um agente de ameaças acesso fácil aos dados corporativos.

Situação Atual

Packet Tracer - Investigue um cenário de ameaças

Nesta atividade do Packet Tracer, você completará os seguintes objetivos:

- Parte 1: Investigar a barra de ferramentas inferior
- Parte 2: Investigar dispositivos em um armário de fiação
- Parte 3: Conecte dispositivos finais a dispositivos de rede
- Parte 4: Instalar um roteador de backup
- Parte 5: Configurar um nome de host
- Parte 6: Explore o Resto da Rede

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

2.2 Quem está atacando nossa rede?

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Quem está atacando nossa rede?

Ameaça, Vulnerabilidade e Risco

Estamos sob ataque e os invasores desejam acessar nossos ativos (dados, propriedade intelectual, servidores, computadores, smartphones, tablets e muito mais).

Termo	Explicação
Ameaça	Um perigo potencial para um ativo, como dados ou a própria rede.
Vulnerabilidade	Uma fraqueza em um sistema ou em seu projeto que uma ameaça pode explorar
Superfície de Ataque	Uma superfície de ataque é a soma total das vulnerabilidades em um determinado sistema que é acessível a um invasor. A superfície de ataque descreve diferentes pontos em que um invasor pode entrar em um sistema e onde ele pode obter dados do sistema.
Exploit	O mecanismo que é usado para alavancar uma vulnerabilidade para comprometer um ativo. As explorações podem ser remotas ou locais. Uma exploração remota funciona na rede sem acesso prévio ao sistema de destino. O invasor não precisa de uma conta no sistema final para explorar a vulnerabilidade. Em uma exploração local, o agente da ameaça tem algum acesso administrativo ou de usuário ao sistema final. Uma exploração local não significa necessariamente que o invasor tenha acesso físico ao sistema final.
Risco	A probabilidade de que uma ameaça particular explore uma vulnerabilidade específica de um ativo e resulte em uma consequência indesejável.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ameaça, Vulnerabilidade e Risco (Cont.)

Existem quatro maneiras comuns de gerenciar riscos:

Estratégia de gestão de riscos	Explicação
Aceitação de riscos	Isso ocorre quando o custo das opções de gerenciamento de risco supera o custo do próprio risco. O risco é aceito, e nenhuma ação é tomada.
Prevenção de riscos	Isso significa evitar qualquer exposição ao risco, eliminando a atividade ou o dispositivo que apresenta o perigo. A remoção de uma atividade para evitar riscos e possíveis benefícios do treinamento também são perdidos.
Redução de Risco	Isso reduz a exposição ao risco ou o impacto do risco ao tomar medidas para diminuir o risco. É a estratégia de mitigação de riscos mais utilizada. Essa estratégia requer uma avaliação cuidadosa dos custos de perda, da estratégia de mitigação e dos benefícios obtidos com a operação ou atividade que está em risco.
Transferência de risco	Parte ou todo o risco é transferido para um terceiro voluntário, como uma companhia de seguros.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Quem está Atacando nossa Rede?

Hacker vs. Agente de Ameaça

O termo "hacker" tem uma variedade de significados:

- Um programador inteligente capaz de desenvolver novos programas e codificar alterações em programas existentes para torná-los mais eficientes.
- Um profissional de rede que usa habilidades sofisticadas de programação para garantir que as redes não sejam vulneráveis a ataques.
- Uma pessoa que tenta obter acesso não autorizado a dispositivos na internet.
- Um indivíduo que executa programas para impedir ou retardar o acesso à rede para muitos usuários, ou corromper ou apagar dados em servidores.

Um vetor de ataque é um caminho pelo qual um atacante poder obter acesso a um servidor, equipamento ou rede.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Hacker vs. Ator de Ameaças (Cont.)

Hacker de chapéu branco, hacker de chapéu preto e hacker de chapéu cinza:

- Hackers White Hat são hackers éticos que usam suas habilidades de programação para propósitos bons, éticos e legais. Eles podem realizar testes de penetração de rede na tentativa de comprometer redes e sistemas, usando seu conhecimento de sistemas de segurança de computador para descobrir vulnerabilidades de rede.
- Hackers Gray Hat são indivíduos que cometem crimes e fazem coisas possivelmente antiéticas, mas não para ganho pessoal ou para causar danos. Um exemplo seria alguém que compromete uma rede sem permissão e, em seguida, divulga publicamente a vulnerabilidade.
- Os hackers Black Hat são criminosos antiéticos que violam a segurança do computador e da rede para ganho pessoal ou por motivos maliciosos, como ataques a redes. Os hackers Black Hat exploram vulnerabilidades para comprometer os sistemas de computador e rede.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Quem está Atacando nossa Rede?

Evolução dos Atores de Ameaças

Atores de Ameaças	Explicação
Script kiddies	Script kiddies surgiram na década de 1990 e se refere a adolescentes ou atores de ameaças inexperientes executando scripts, ferramentas e explorações existentes para causar danos, mas normalmente sem fins lucrativos.
Corretores de Vulnerabilidades	Os corretores de vulnerabilidade normalmente se referem a hackers Grey Hat que tentam descobrir exploits e relatá-los aos fornecedores, às vezes por prêmios ou recompensas.
Hacktivistas	Hacktivistas é um termo que se refere a hackers Grey Hat que se manifestam e protestam contra diferentes ideias políticas e sociais. Os hacktivistas protestam publicamente contra organizações ou governos, publicando artigos, vídeos, vazando informações confidenciais e realizando ataques DDoS (Denial of Service, Negação de serviço).
Cibercriminosos	Cibercriminoso é um termo para hackers black hat que são autônomos ou trabalham para grandes organizações de crimes cibernéticos. Cibercriminosos roubam bilhões de dólares de consumidores e empresas a cada ano.
Patrocinados pelo Estado	Os hackers patrocinados pelo Estado são atores de ameaças que roubam segredos do governo, coletam informações e sabotam redes de governos estrangeiros, grupos terroristas e corporações. A maioria dos países do mundo participam, em algum grau, em ataques de hackers patrocinados pelo estado. Dependendo da perspectiva de uma pessoa, estes são hackers white hat ou black hat.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Quem está Atacando nossa Rede?

Cibercriminosos

- Os cibercriminosos são atores de ameaça que estão motivados a ganhar dinheiro usando todos os meios necessários.
- Embora às vezes os cibercriminosos trabalhem de forma independente, eles são mais frequentemente financiados e patrocinados por organizações criminosas.
- Os cibercriminosos operam em no submundo onde compram, vendem e comercializam explorações e ferramentas.
- Eles também compram e vendem as informações pessoais e propriedade intelectual que roubam das vítimas.
- Os cibercriminosos visam pequenas empresas e consumidores, bem como grandes empresas e indústrias.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Quem está Atacando nossa Rede?

Tarefas de Cibersegurança

- Os atores de ameaças visam os dispositivos finais vulneráveis de usuários domésticos, empresas de pequeno a médio porte e grandes organizações públicas e privadas.
- Para tornar a Internet e as redes mais protegidas e mais seguras, nós devemos de desenvolver uma boa consciência da segurança cibernética.
- Cibersegurança é uma responsabilidade compartilhada que todos os usuários devem praticar
- As organizações devem agir e proteger seus ativos, usuários e clientes. Eles devem desenvolver e praticar tarefas de cibersegurança como as listadas na figura.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Indicadores de Ameaças Cibernéticas

- Muitos ataques de rede podem ser evitados compartilhando informações sobre indicadores de comprometimento (COI).
- Os IOCs podem ser recursos que identificam arquivos de malware, endereços IP de servidores que são usados em ataques, nomes de arquivos e alterações características feitas no software final do sistema, entre outros.
- Os IOCs ajudam o pessoal de segurança cibernética a identificar o que aconteceu em um ataque e desenvolver defesas contra o ataque.
- Os indicadores de ataque (IOA) se concentram mais na motivação por trás de um ataque e nos meios potenciais pelos quais os atores da ameaça têm, ou irão comprometer as vulnerabilidades para obter acesso aos ativos.
- Os IOAs estão preocupadas com as estratégias usadas pelos atacantes. Por esse motivo, os IOAs podem ajudar a gerar uma abordagem de segurança proativa em vez de responder a uma única ameaça.
- A defesa contra uma estratégia pode prevenir ataques futuros que utilizem a mesma estratégia ou uma estratégia semelhante.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Quem está Atacando nossa Rede?

Compartilhamento de ameaças e criação de conscientização de cibersegurança

- Os governos estão agora promovendo ativamente a segurança cibernética. A Agência de Infraestrutura e Segurança Cibernética dos EUA (CISA) está liderando esforços para automatizar o compartilhamento de informações de segurança cibernética com organizações públicas e privadas sem nenhum custo.
- A CISA usa um sistema denominado Compartilhamento Automático de Indicador (AIS). O AIS permite o compartilhamento de indicadores de ataque entre o governo dos EUA e o setor privado assim que as ameaças são verificadas.
- A CISA e a National Cyber Security Alliance (NCSA) promovem a segurança cibernética a todos os usuários.
- A CISA e a NCSA têm uma campanha anual todo mês de outubro chamada “Mês Nacional de Conscientização sobre Segurança Cibernética” (NCASM). Esta campanha promove e aumenta a conscientização sobre segurança cibernética.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Compartilhamento de Ameaças e Conscientização sobre Segurança Cibernética (Cont.)

- A CISA e a NCSA têm uma campanha anual todo mês de outubro chamada “Mês Nacional de Conscientização sobre Segurança Cibernética” (NCASM). A campanha fornece material sobre uma grande variedade de tópicos de segurança, incluindo:

  - Segurança das Redes Sociais
  - Atualizando configurações de privacidade
  - Reconhecimento da segurança de aplicativos de dispositivos
  - Manter o software atualizado
  - Compras online seguras
  - Segurança Wi-Fi
  - Protegendo os dados do cliente

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

2.3 Resumo de Segurança de Redes

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Resumo Protegendo Redes

O que aprendi neste Módulo?

- A segurança da rede está diretamente relacionada à continuidade dos negócios de uma organização.
- As violações de segurança de rede podem interromper o comércio eletrônico, causar a perda de dados comerciais, ameaçar a privacidade das pessoas e comprometer a integridade das informações.
- Muitas ferramentas estão disponíveis para ajudar os administradores de rede a adaptar, desenvolver e implementar técnicas de mitigação de ameaças, incluindo o Cisco Talos Intelligence Group.
- Um vetor de ataque é um caminho pelo qual um atacante poder obter acesso a um servidor, equipamento ou rede.
- A gestão de riscos é o processo que equilibra os custos operacionais de provisão de medidas de proteção com os ganhos obtidos através da proteção do ativo.
- Hacker é um termo usado para descrever um ator de ameaça. Os atores de ameaças incluem crianças de script, corretores de vulnerabilidade, hacktivistas, criminosos cibernéticos e hackers patrocinados pelo Estado.
- Muitos ataques de rede podem ser evitados compartilhando informações sobre IOCs. Muitos governos estão promovendo a segurança cibernética. CISA e NCSA são exemplos de tais organizações.

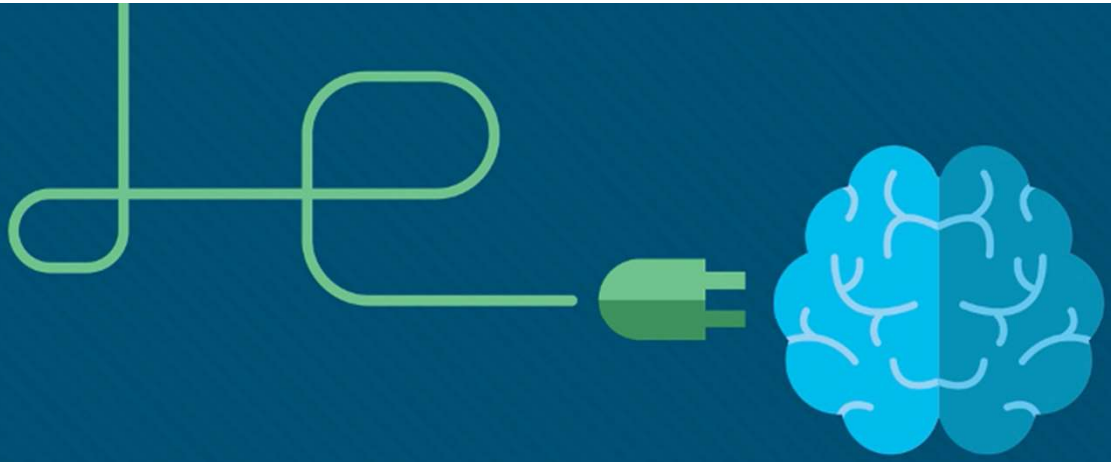
© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Módulo 2

Novos termos e comandos

- Grupo de inteligência do Cisco Talos
- Equipe de resposta a incidentes de segurança do produto (PSIRT) da Cisco
- Vetor de ataque (Attack vector)
- Hacker White hat , hacker Black hat e hacker Grey hat
- Script kiddies, Corretores de vulnerabilidades, Hacktivistas, Cibercriminosos e Hackers patrocinados pelo Estado
- Agência de Segurança e Infraestrutura Cibernética (CISA)
- Compartilhamento Automatizado de Indicadores (AIS)
- Indicadores de ataque (IOA)
- A CISA e a National Cyber Security Alliance (NCSA)
- The European Union Agency for Cybersecurity (ENISA)

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco



Módulo 3: Ataque à Base



Segurança de endpoint

Objetivos do Módulo

Título do Módulo: Atacando a Base

Objetivo do Módulo: Explicar como as vulnerabilidades do TCP/IP permitem ataques à rede.

Título do Tópico	Objetivo do Tópico
Detalhes de PDU IP	Explicar a estrutura de cabeçalho IPv4 e IPv6.
Vulnerabilidades de IP	Explicar como as vulnerabilidades de IP possibilitam ataques de rede.
Vulnerabilidades TCP e UDP	Explicar como as vulnerabilidades de TCP e UDP possibilitam ataques de rede.

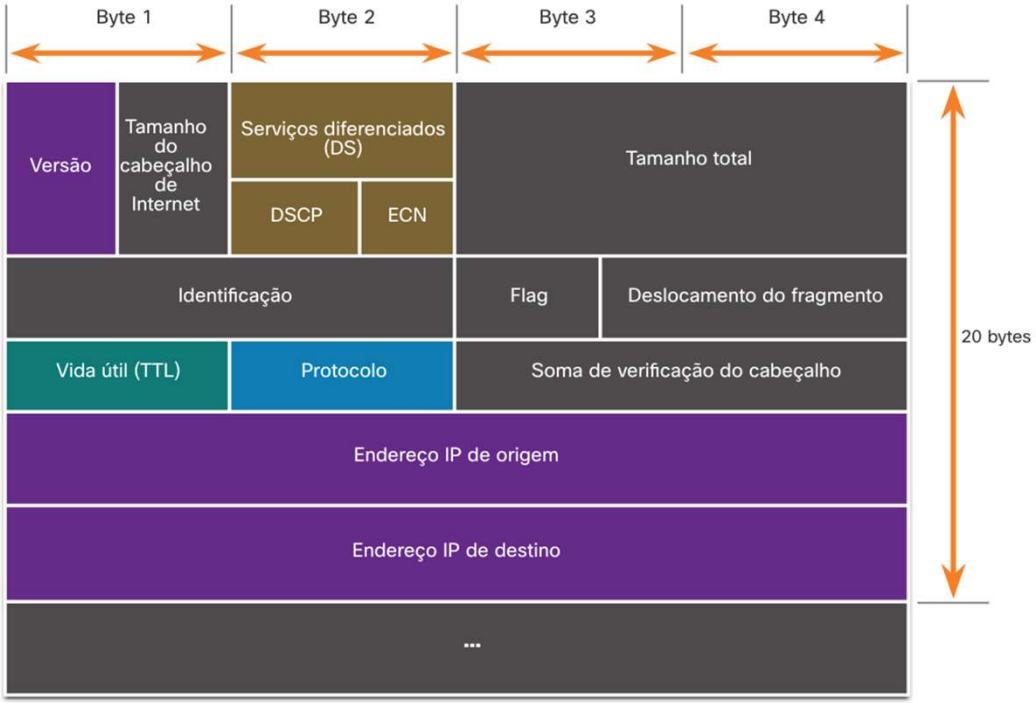
© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

3.1 Detalhes da PDU IP

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Detalhes da PDU IP

IPv4 e IPv6



O IP foi projetado como um protocolo sem conexão de Camada 3.

- Entrega pacotes do host ao destino através de um sistema interconectado de redes.
- NÃO projetado para rastrear e gerenciar o fluxo de pacotes.
- Se necessário, isto é realizado principalmente pelo TCP na Camada 4

O IP não valida se o endereço IP de origem contido em um pacote realmente veio dessa origem.

- Atores de ameaças podem enviar pacotes usando um endereço IP de origem falsificado e adulterar outros campos no cabeçalho IP para realizar seus ataques.
- Os analistas de segurança devem entender os diferentes campos nos cabeçalhos IPv4 e IPv6.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Detalhes da PDU IP

O cabeçalho do pacote IPv4

Campo de cabeçalho IPv4	Descrição
Versão	Ele contém um valor binário de 4 bits definido como 0100 que identifica isso como um pacote IPv4.
Comprimento do cabeçalho da Internet	Um campo de 4 bits contendo 20 bytes é o comprimento mínimo do cabeçalho IP.
Serviços diferenciados ou DiffServ (DS)	O campo DS é um campo de 8 bits usado para determinar a prioridade de cada pacote. Os seis bits mais significativos do campo DiffServ são o DSCP (Ponto de código de serviços diferenciados). Os dois últimos bits são os bits de notificação de congestionamento explícito (ECN).
Comprimento total	Especifique o comprimento do pacote IP (cabeçalho IP + dados do usuário). O campo de comprimento total é de 2 bytes, portanto, o tamanho máximo de um pacote IP é de 65.535 bytes, mas na prática, os pacotes são muito menores.
Deslocamento de identificação, flag e fragmento	À medida que um pacote IP se move pela Internet, talvez seja necessário cruzar uma rota que não possa lidar com o tamanho do pacote. O pacote será dividido, ou fragmentado, em pacotes menores e remontado posteriormente. Esses campos são usados para fragmentar e remontar pacotes.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Detalhes da PDU IP

O Cabeçalho do Pacote IPv4 (Cont.)

Campo de cabeçalho IPv4	Descrição
Tempo de Vida (TTL)	Valor binário de 8 bits que limita o tempo de vida de um pacote. O remetente do pacote define o valor TTL inicial, que é diminuído em um cada vez que um roteador processa o pacote. Se o campo TTL for decrementado até zero, o roteador descartará o pacote e enviará uma mensagem ICMP de tempo excedido para o endereço IP de origem.
Protocolo	Ele identifica o protocolo do próximo nível. O valor binário de 8 bits indica o tipo de carga de dados que o pacote está carregando, o que permite que a camada de rede transfira os dados para o protocolo apropriado das camadas superiores.
Cabeçalho checksum	Um valor calculado com base no conteúdo do cabeçalho IP determina quaisquer erros introduzidos na transmissão.
Endereço IPv4 Origem	Contém um valor binário de 32 bits que representa o endereço IPv4 de origem do pacote. O endereço de origem IPv 4 é sempre um endereço unicast.
Endereço IPv4 de destino	Contém um valor binário de 32 bits que representa o endereço IPv4 de destino do pacote.
Opções e Preenchimento	Este é um campo que varia em comprimento de 0 a um múltiplo de 32 bits. Se os valores de opção não forem um múltiplo de 32 bits, 0s serão adicionados ou preenchidos para garantir que este campo contenha um múltiplo de 32 bits.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Detalhes da PDU IP

Vídeo - Exemplo de cabeçalhos IPv4 no Wireshark

Este vídeo aborda o seguinte:

- Clique em Reproduzir na figura para ver uma demonstração do exame de cabeçalhos IPv4 em uma captura do Wireshark.
- As informações da camada de rede em uma captura de pacote Wireshark
- Identifique o endereço IP de origem, versão, comprimento do cabeçalho, campo DS, flags e TTL em cada pacote IPv4.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Detalhes da PDU IP

O cabeçalho do pacote IPv6

Campo de cabeçalho IPv6	Descrição
Versão	Este campo contém um valor binário de 4 bits definido como 0110 que o identifica como um pacote IPv6.
Classe de tráfego	Este campo de 8 bits é equivalente ao campo IPv4 Differentiated Services (DS).
Rótulo de fluxo	Este campo de 20 bits sugere que todos os pacotes com o mesmo rótulo de fluxo recebem o mesmo tipo de tratamento pelos roteadores.
Tamanho da carga	Este campo de 16 bits indica o comprimento da porção de dados ou carga útil do pacote IPv6.
Próximo cabeçalho	Este campo de 8 bits é equivalente ao campo do protocolo IPv4. Ele exibe o tipo de carga de dados que o pacote está carregando, permitindo que a camada de rede transfira os dados para o protocolo apropriado das camadas superiores.
Limite de saltos	Este campo de 8 bits substitui o campo TTL IPv4. Esse valor é subtraído por um valor de 1 por cada roteador que encaminha o pacote. Quando o contador chega a 0, o pacote é descartado e uma mensagem ICMPv6 de Tempo Excedido é encaminhada ao host emissor, indicando que o pacote não atingiu seu destino por causa do limite de saltos.
Endereço IPv6 origem	Este campo de 128 bits identifica o endereço IPv6 do host de envio.
Endereço IPv6 destino	Este campo de 128 bits identifica o endereço IPv6 do host receptor.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Detalhes da PDU IP

Vídeo - Exemplo de cabeçalhos IPv6 no Wireshark

Este vídeo aborda o seguinte:

- Investigue um cenário de ameaças e três vulnerabilidades que podem ser exploradas por agentes de ameaças
- Explorar uma vulnerabilidade resultante de um dispositivo que não está configurado corretamente com as práticas recomendadas de segurança

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

3.2 Vulnerabilidades de IP

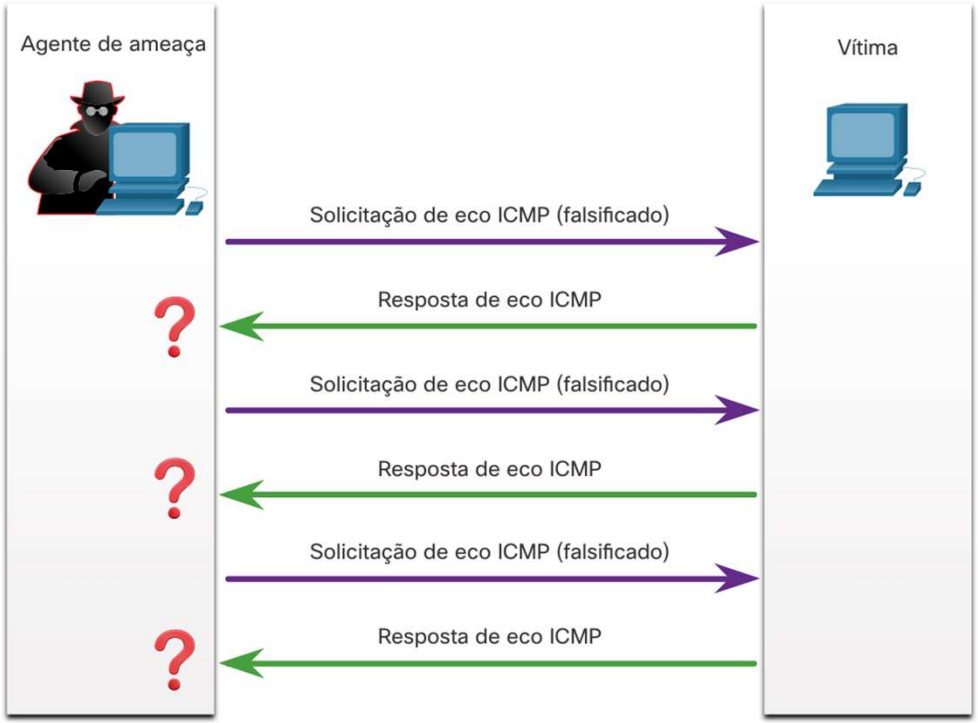
© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Vulnerabilidades de IP

Ataques IP	Descrição
Ataques ICMP	Atores de ameaças usam pacotes de eco ICMP (pings) para descobrir sub-redes e hosts em uma rede protegida, para gerar ataques DoS flood e para alterar tabelas de roteamento de host.
Ataques de negação de serviço (DoS)	Os atores da ameaça tentam impedir que usuários legítimos acessem informações ou serviços.
Ataques de negação de serviço distribuída (DDoS)	Semelhante a um ataque DoS, mas apresenta um ataque simultâneo e coordenado de várias máquinas de origem.
Ataque de Falsificação de Endereços	Os atores da ameaça falsificam o endereço IP de origem na tentativa de executar falsificação cega ou não cega.
Ataque man-in-the-middle (MiTM)	Os agentes de ameaças se posicionam entre uma fonte e um destino para monitorar, capturar e controlar de forma transparente a comunicação. Eles poderiam simplesmente espiar inspecionando os pacotes capturados ou alterando os pacotes e encaminhando-os ao seu destino original.
sequestro de sessão	Os atores da ameaça obtêm acesso à rede física e, em seguida, usam um ataque MiTM para sequestrar uma sessão.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ataques ICMP



O ICMP carrega mensagens de diagnóstico e relata condições de erro quando rotas, hosts e portas não estão disponíveis.

- Mensagens são geradas pelos dispositivos quando ocorre um erro de rede ou uma interrupção.
- O comando ping é uma mensagem ICMP gerada pelo usuário, chamada de solicitação de eco, u sada para verificar a conectividade com um destino.

Os agentes de ameaças usam o ICMP para ataques de reconhecimento e varredura.

- Isso permite que eles lancem ataques de coleta de informações para mapear uma topologia de rede, descobrir quais hosts estão ativos (acessíveis), identificar o sistema operacional do host (impressão digital do sistema operacional) e determinar o estado de um firewall.

Os atores de ameaças também usam ICMP para ataques DoS e DDoS, conforme mostrado no ataque de inundação ICMP na figura.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ataques ICMP (cont.)

Mensagem ICMP	Descrição
ICMP solicitação de eco (echo request) e resposta do eco (echo reply)	Executa verificação de host e ataques DoS.
ICMP inacessível	Executa reconhecimento de rede e ataques de varredura.
Resposta da máscara ICMP	Mapeia uma rede IP interna.
ICMP redireciona	Atrai um host de destino para enviar todo o tráfego por meio de um dispositivo comprometido e cria um ataque MiTM.
Descoberta de rotas ICMP	Injeta entradas de rota falsas na tabela de roteamento de um host de destino.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

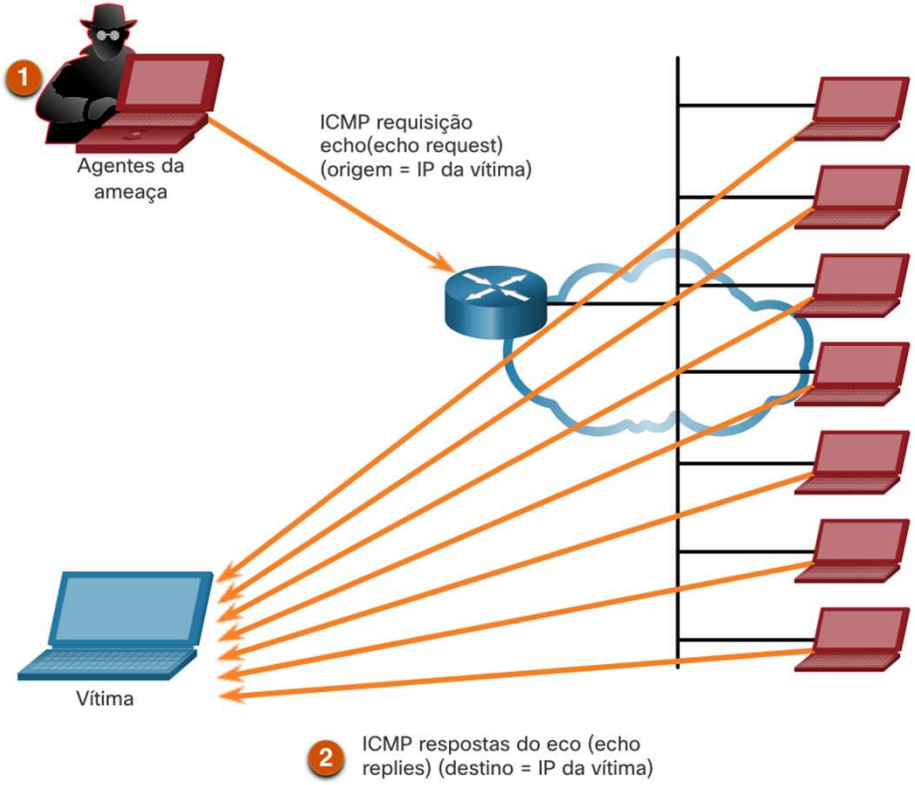
Vídeo - Ataques de amplificação, reflexão e falsificação

Este vídeo aborda o seguinte:

- Explica o ataque de amplificação, reflexão e falsificação
- Identifica e aborda a diferença entre ataques de falsificação não cega e falsificação cega

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ataques de amplificação e reflexão



- Os agentes de ameaças geralmente usam técnicas de amplificação e reflexão para criar ataques de negação de serviço (DoS).
- O exemplo na figura ilustra como uma técnica de amplificação e reflexão chamada ataque Smurf é usada para sobrecarregar um host alvo.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ataque de Falsificação de Endereços

Os ataques de falsificação de endereço IP ocorrem quando um agente de ameaça cria pacotes com informações de endereço IP de origem falsa para ocultar a identidade do remetente ou se passar por outro usuário legítimo.

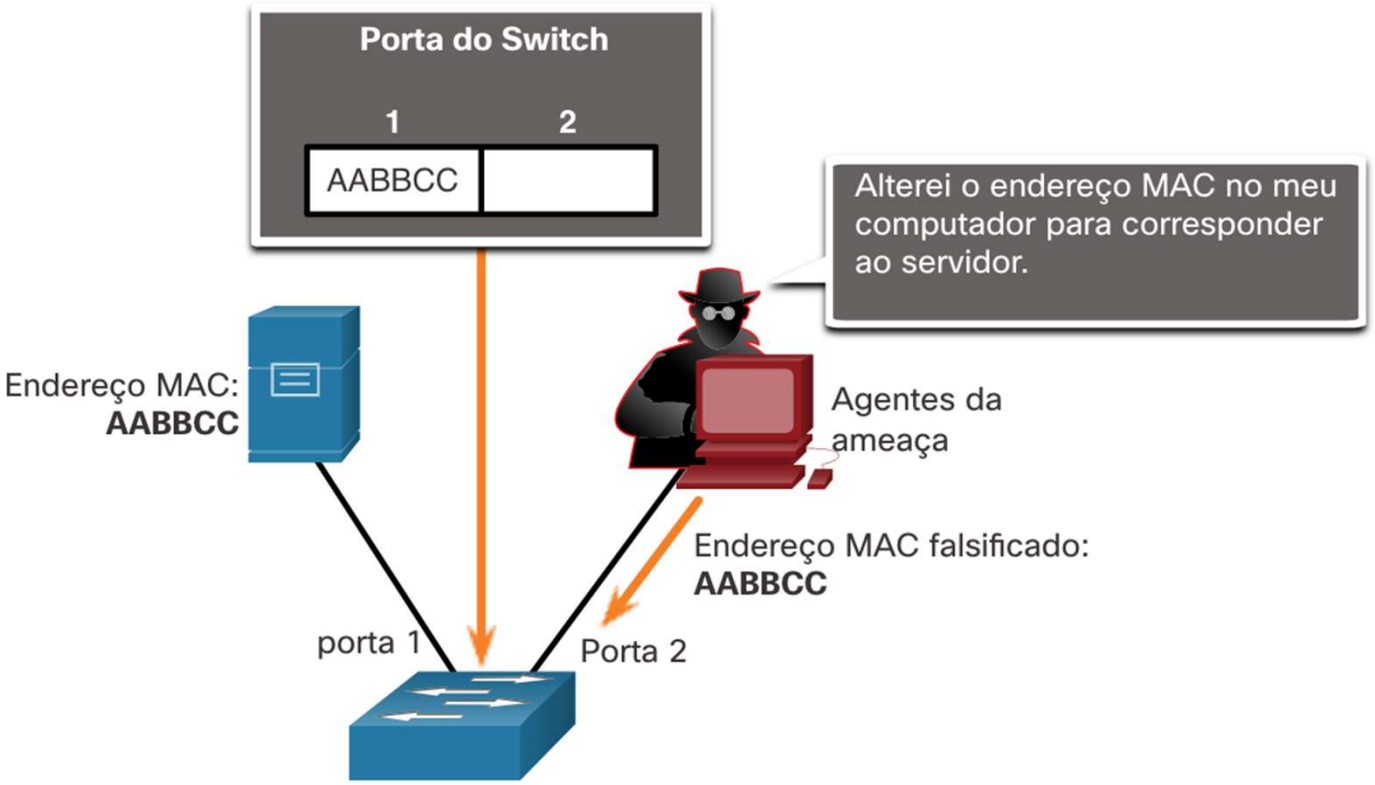
Os ataques de falsificação podem ser cegos ou não cegos:

- Falsificação não cega - O agente da ameaça pode ver o tráfego que está sendo enviado entre o host e o destino. O agente de ameaça usa a falsificação não cega para inspecionar o pacote de resposta da vítima alvo.
- Falsificação cega - O agente da ameaça não pode ver o tráfego que está sendo enviado entre o host e o destino. A falsificação cega é usada em ataques de negação de serviço.

Os ataques de falsificação de endereço MAC são usados quando os atores de ameaças têm acesso à rede interna. Os agentes de ameaças alteram o endereço MAC de seu host para corresponder a outro endereço MAC conhecido de um host de destino.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ataque de Falsificação de Endereços (Cont.)



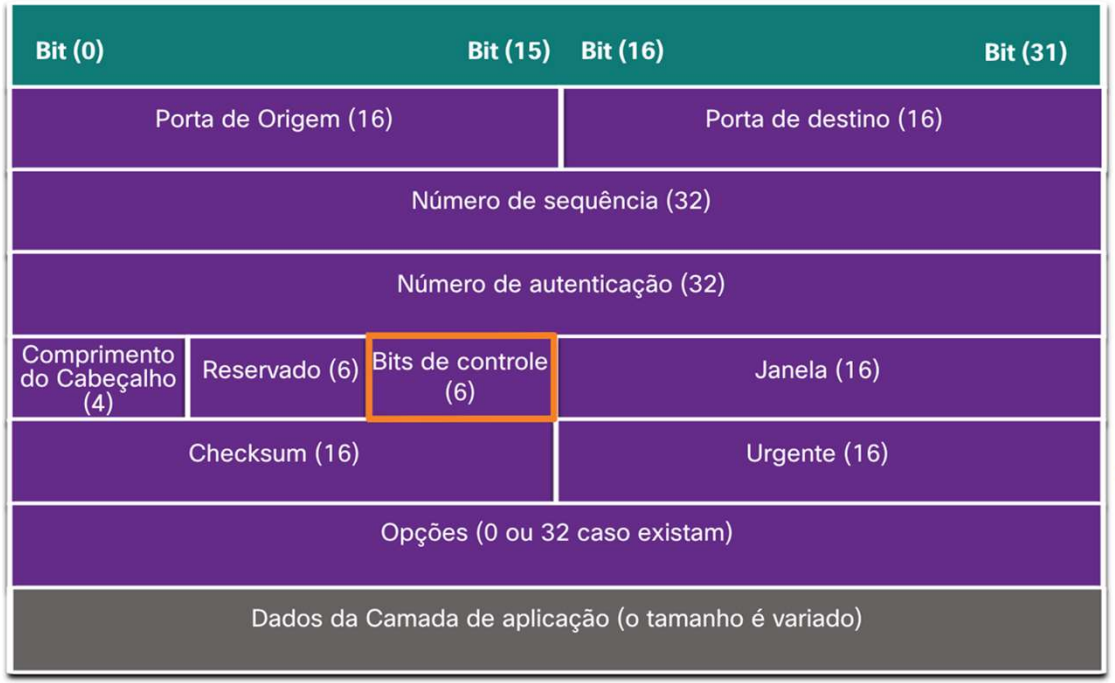
- O switch substitui a entrada atual da tabela CAM e atribui o endereço MAC à nova porta, como mostrado na figura.
- Em seguida, encaminha os quadros destinados ao host de destino para o host atacante.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

3.3 Vulnerabilidades de TCP e UDP

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Cabeçalho do segmento TCP



- As informações do segmento TCP aparecem imediatamente após o cabeçalho IP.
- Os campos do segmento TCP e as flags para o campo Bits de controle são exibidos na figura.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Serviços TCP

O TCP fornece estes serviços:

Entrega Confiável

- TCP incorpora reconhecimentos para garantir a entrega, em vez de depender de protocolos de camada superior para detectar e resolver erros.
- Se uma confirmação não for recebida à tempo, o remetente retransmitirá os dados.
- Exigir reconhecimentos dos dados recebidos pode causar atrasos substanciais.

Controle de fluxo

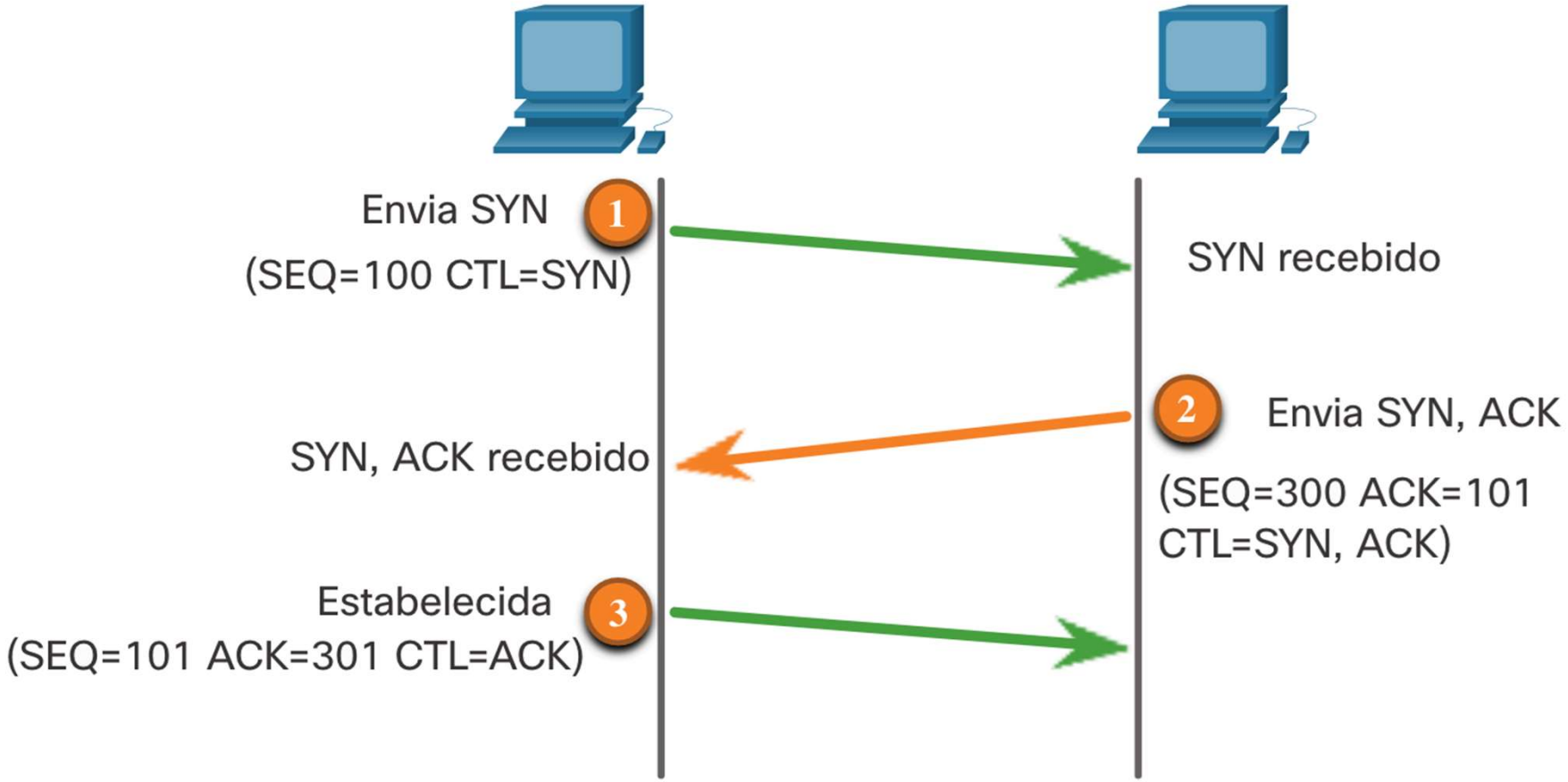
- TCP implementa controle de fluxo para resolver esse problema. Em vez de reconhecer um segmento por vez, vários segmentos podem ser reconhecidos simultaneamente.

Comunicação com estado

- A comunicação com monitoração de estado TCP entre duas partes ocorre durante o handshake TCP de três vias.
- Antes que os dados possam ser transferidos usando TCP, um handshake de três vias abre a conexão TCP.
- Se ambos os lados concordarem com a conexão TCP, os dados poderão ser enviados e recebidos por ambas as partes usando o TCP.

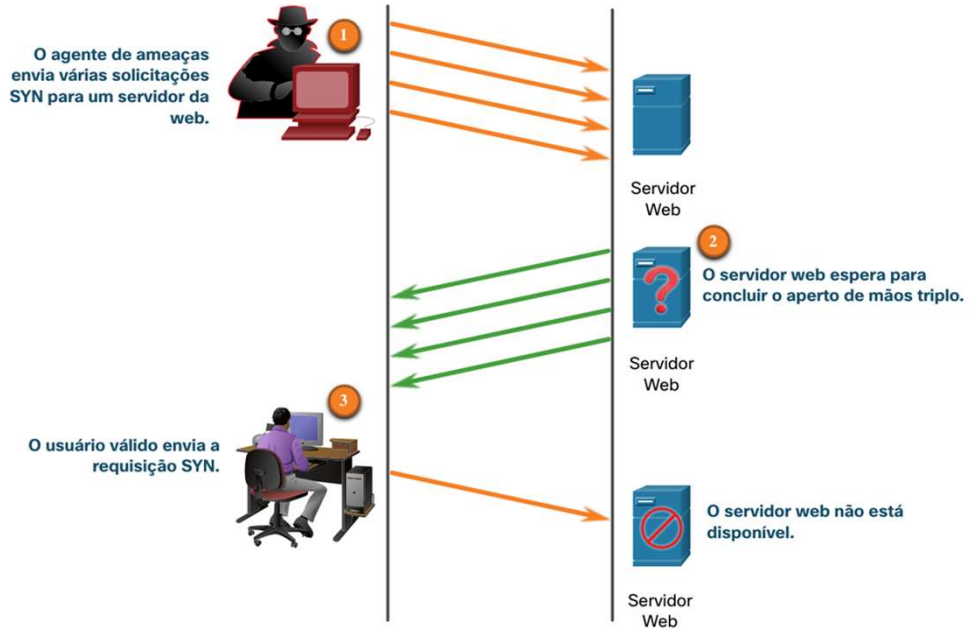
© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Serviços TCP (Cont.)



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ataques TCP



O ataque de inundação SYN TCP explora o handshake triplo do TCP.

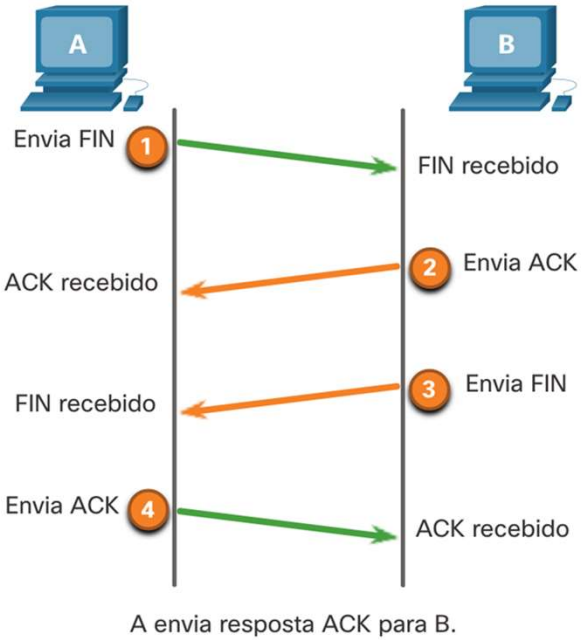
- O agente da ameaça envia pacotes de solicitação de sessão TCP SYN com um endereço IP de origem falsificado aleatoriamente para um destino.
- O dispositivo de destino responde com um pacote TCP SYN-ACK ao endereço IP falsificado e aguarda um pacote TCP ACK.
- Essas respostas nunca chegam.
- Eventualmente, o host de destino nega usuários legítimos porque está sobrecarregado com conexões TCP semi-abertas.

Ataque de Redefinição de TCP

- Ele encerra as comunicações TCP entre dois hosts. TCP usa uma troca de quatro vias (four-way) para fechar a conexão TCP usando um par de segmentos FIN e ACK de cada extremidade da conexão TCP.
- Uma conexão TCP termina abruptamente quando recebe um bit RST, que interrompe a conexão TCP e informa o host receptor para parar de usar a conexão TCP imediatamente.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ataques TCP (Cont.)



O encerramento de uma sessão TCP usa o seguinte processo de troca de quatro vias:

1. Quando o cliente não tem mais dados para enviar no fluxo, ele envia um segmento com um flag FIN ligado.
- O servidor envia ACK para confirmar o recebimento de FIN , então encerra a sessão do cliente para o servidor.
1. O servidor envia um FIN ao cliente para encerrar a sessão do servidor-para-cliente.
2. O cliente responde com um ACK para reconhecer o FIN do servidor.

Sequestro de sessão TCP

- Um ator de ameaça assume o controle de um host já autenticado à medida que se comunica com o alvo.
- O agente de ameaça deve falsificar o endereço IP de um dos hosts, prever o próximo número de sequência e enviar um ACK para o outro host.
- Se for bem-sucedido, o agente da ameaça poderá enviar, mas não receber, dados do dispositivo de destino.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

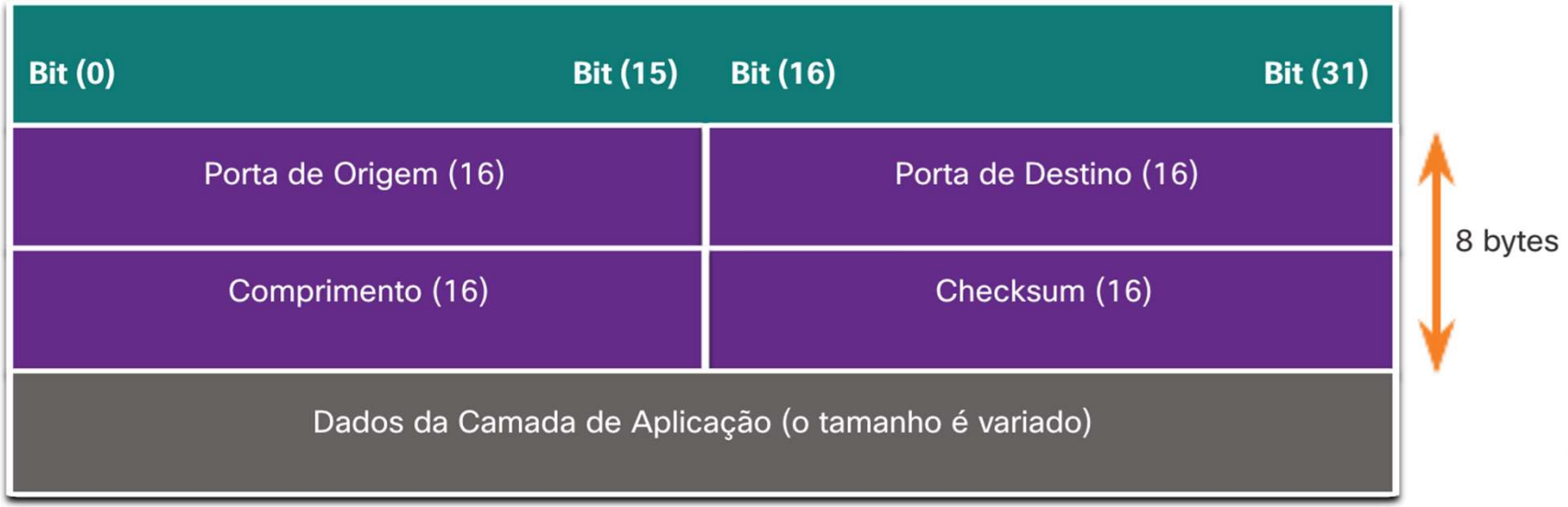
Operação e Cabeçalho do segmento UDP

- UDP é comumente usado por DNS, DHCP, TFTP, NFS e SNMP.
- É usado com aplicações em tempo real, como streaming de mídia ou VoIP.
- UDP é um protocolo de camada de transporte não orientado à conexão.
- Ele tem uma sobrecarga muito mais baixa que o TCP, porque não é orientado a conexão e não oferece retransmissão, sequenciamento e mecanismos de controle de fluxo sofisticados que fornecem confiabilidade.
- A estrutura de segmentos UDP é muito menor que a estrutura de segmentos TCP.
- **Nota**: o UDP divide dados em datagramas. No entanto, o termo genérico “segmento” é comumente usado

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Operação e Cabeçalho do segmento UDP (Cont.)

- Embora UDP seja normalmente chamado de não confiável, em contraste com a confiabilidade do TCP, isso não significa que os aplicativos que usam UDP são sempre não confiáveis, nem significa que o UDP é um protocolo inferior.
- Isso simplesmente significa que essas funções não são fornecidas pelo protocolo da camada de transporte e devem ser implementadas em outros locais, se houver necessidade.
- A baixa sobrecarga do UDP o torna muito interessante para protocolos que efetuam transações simples de requisição e resposta.
- Por exemplo, usar TCP para o DHCP geraria tráfego de rede desnecessário. Se nenhuma resposta for recebida, o dispositivo reenvia a solicitação.



cisco
cial da Cisco

Ataques UDP

Qualquer criptografia não protege o UDP. A criptografia pode ser adicionada ao UDP, mas não está disponível por padrão.

- A falta de criptografia significa que qualquer pessoa pode ver o tráfego, alterá-lo e enviá-lo ao seu destino.
- Alterar os dados no tráfego alterará a soma de verificação (checksum) de 16 bits, mas o checksum é opcional e nem sempre é usado.
- Quando o checksum é usado, o agente de ameaça pode criar um novo checksum com base na nova carga de dados e registrá-lo no cabeçalho como um novo checksum.
- O dispositivo de destino descobrirá que o checksum corresponde aos dados sem perceber que são dados alterados. Esse tipo de ataque não é amplamente utilizado.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ataques UDP (Cont.)

Ataques de inundação UDP

- Um ataque de inundação UDP consome todos os recursos em uma rede.
- O agente de ameaça deve usar uma ferramenta como UDP Unicorn ou Low Orbit Ion Cannon.
- Essas ferramentas enviam uma inundação de pacotes UDP, geralmente de um host falsificado, para um servidor na sub-rede.
- O programa varrerá todas as portas conhecidas para encontrar portas fechadas, fazendo com que o servidor responda com uma mensagem de porta ICMP inacessível.
- Como há muitas portas fechadas no servidor, isso cria tráfego no segmento, que consome a maior parte da largura de banda. O resultado é muito semelhante a um ataque de negação de serviço (DoS).

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

3.4 Resumo do ataque à base

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Resumo de Atacando a Base

O que aprendi neste módulo?

- O IP é um protocolo sem conexão de Camada 3. O cabeçalho IPv4 consiste em vários campos e o cabeçalho IPv6 contém menos campos.
- Diferentes tipos de ataques têm como alvo o IP, como ataques ICMP, ataques DoS, ataques DDoS, ataques de falsificação de endereço, ataques Man-in-the-middle (MiTM) e seqüestro de sessão.
- O ICMP carrega mensagens de diagnóstico e relata condições de erro quando rotas, hosts e portas não estão disponíveis.
- Atores de ameaças usam ICMP para ataques de reconhecimento e varredura e ataques DoS e DDoS.
- Os agentes de ameaças geralmente usam técnicas de amplificação e reflexão para criar ataques de negação de serviço (DoS).
- Eles também usam ataques de esgotamento de recursos para consumir os recursos de um host de destino para travar ou consumir os recursos da rede.
- Os ataques de falsificação de endereço IP ocorrem quando um agente de ameaça cria pacotes com informações de endereço IP de origem falsa para ocultar a identidade do remetente ou se passar por outro usuário legítimo.
- Os ataques de falsificação de endereços podem ser falsificação não cega para sequestrar uma sessão ou falsificação cega para criar um ataque DoS. Os ataques de falsificação de endereços MAC são implantados quando os agentes de ameaças têm acesso à rede interna.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Resumo Atacando a Base

O que aprendi neste módulo? (Cont.)

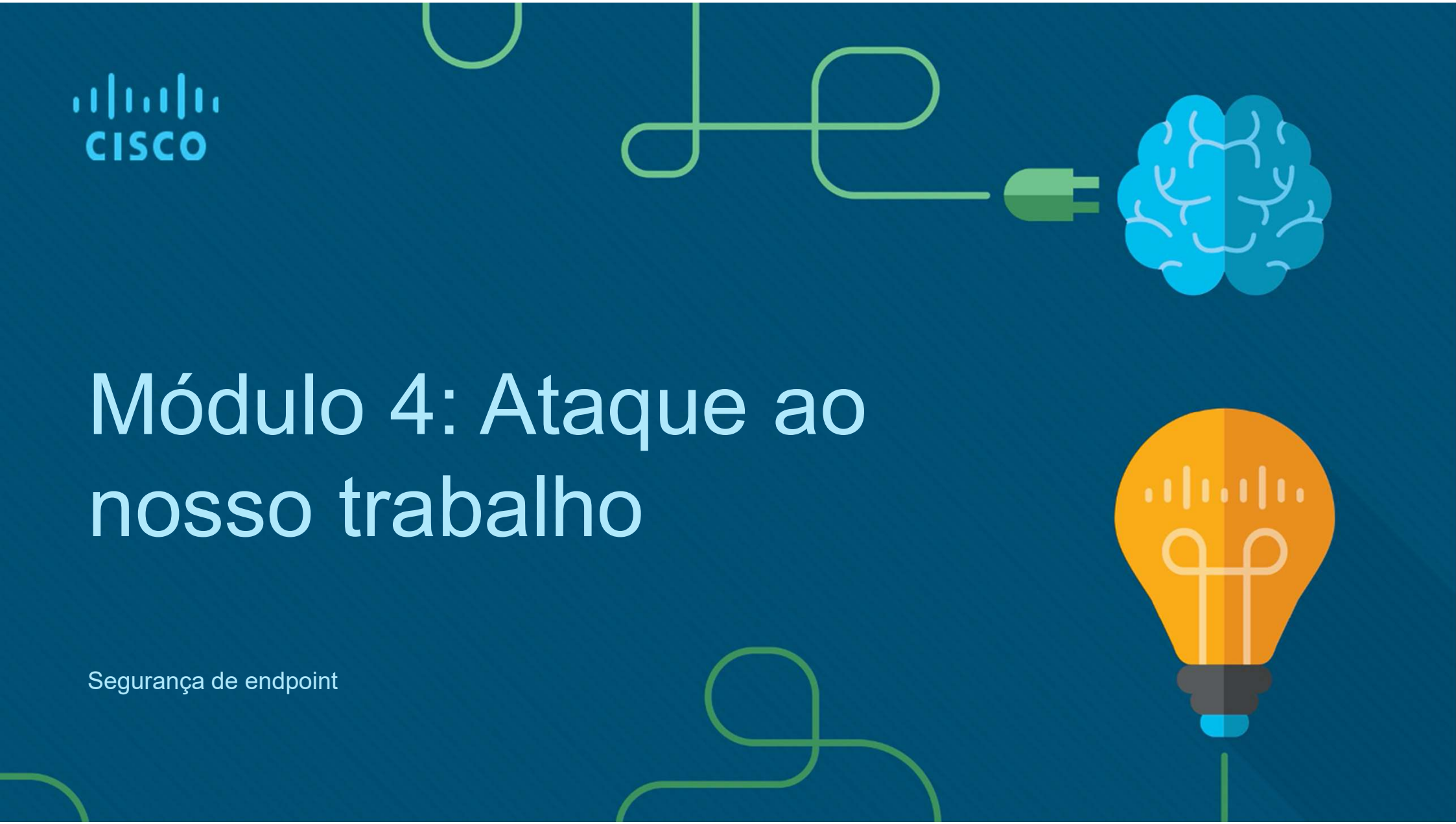
- As informações do segmento TCP e do datagrama UDP aparecem imediatamente após o cabeçalho IP.
- O TCP fornece entrega confiável, controle de fluxo e comunicação com estado.
- A comunicação com monitoração de estado TCP entre duas partes ocorre durante o handshake TCP de três vias.
- Atores de ameaças podem conduzir ataques relacionados a TCP, como varreduras de porta TCP, ataques de inundação TCP SYN, ataques de redefinição de TCP e ataques de sequestro de sessão TCP.
- O segmento UDP (ou seja, datagrama) é muito menor que o segmento TCP, tornando-o desejável para uso por protocolos que fazem transações simples de solicitação e resposta, como DNS, DHCP, SNMP e outros.
- Os atores de ameaças podem conduzir ataques de inundação UDP que varrem todas as portas UDP conhecidas em um servidor tentando encontrar portas fechadas. As ações do agente de ameaças podem criar uma situação de DoS.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Módulo 3:

Novos termos e Comandos

- Serviços diferenciados ou DiffServ (DS)
- Sequestro de Sessão
- Spoofing Não Cego
- Spoofing Cego
- Tempo de Vida (TTL)
- Network Time Protocol (NTP)



Módulo 4: Ataque ao nosso trabalho

Segurança de endpoint

Objetivos do módulo

Título do módulo: Atacando o que Fazemos
Objetivo do módulo: Recomendar medidas para mitigar as ameaças.

Título do Tópico	Objetivo do Tópico
Serviços IP	Explicar as vulnerabilidades do serviço IP.
Serviços Corporativos	Explique como as vulnerabilidades de aplicativos de rede permitem ataques de rede
Mitigando Ataques Comuns à Rede	Recomendar medidas básicas de mitigação de ameaças.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

4.1 Serviços IP

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Vulnerabilidades ARP

Os hosts transmitem uma solicitação ARP para outros hosts no segmento de rede para determinar o endereço MAC de um host com um endereço IP específico. O host com o endereço IP correspondente na solicitação ARP envia uma resposta ARP.

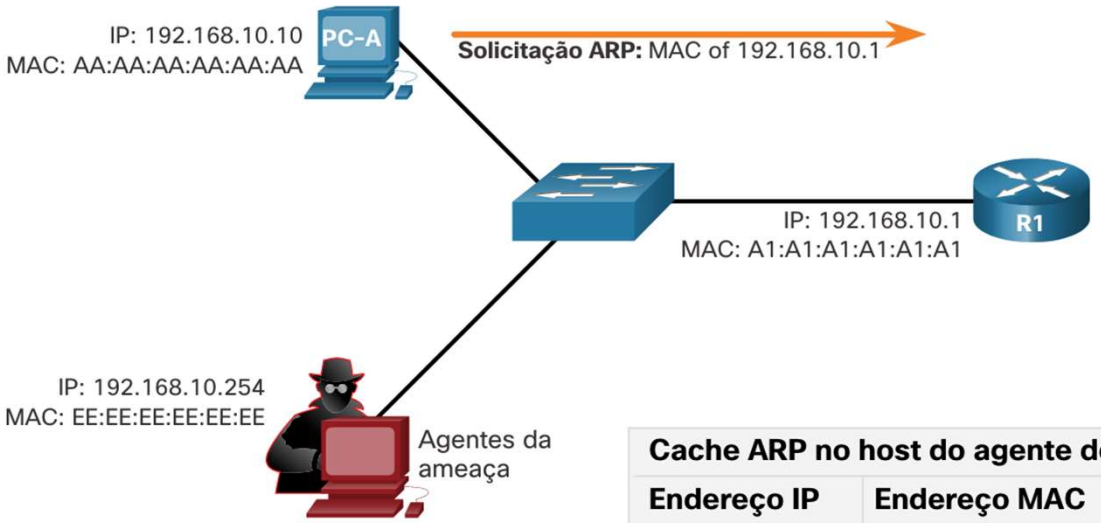
Qualquer cliente pode enviar uma resposta ARP não solicitada denominada "ARP gratuito".

- Quando um host envia um ARP gratuito, outros hosts na sub-rede armazenam o endereço MAC e o endereço IP contidos no ARP gratuito em suas tabelas ARP.
- Qualquer host pode reivindicar ser o proprietário de qualquer IP/MAC que escolher.
- Atores de ameaças podem envenenar o cache ARP de dispositivos na rede local, criando um ataque MiTM para redirecionar o tráfego.
- O objetivo é associar o endereço MAC do ator de ameaça ao endereço IP do gateway padrão nos caches ARP dos hosts no segmento LAN.
- Ele posiciona o agente da ameaça entre a vítima e todos os outros sistemas fora da sub-rede local.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Envenenamento de cache ARP.

ARP Cache no PC-A	
Endereço IP	**Endereço MAC**
192.168.10.1	????



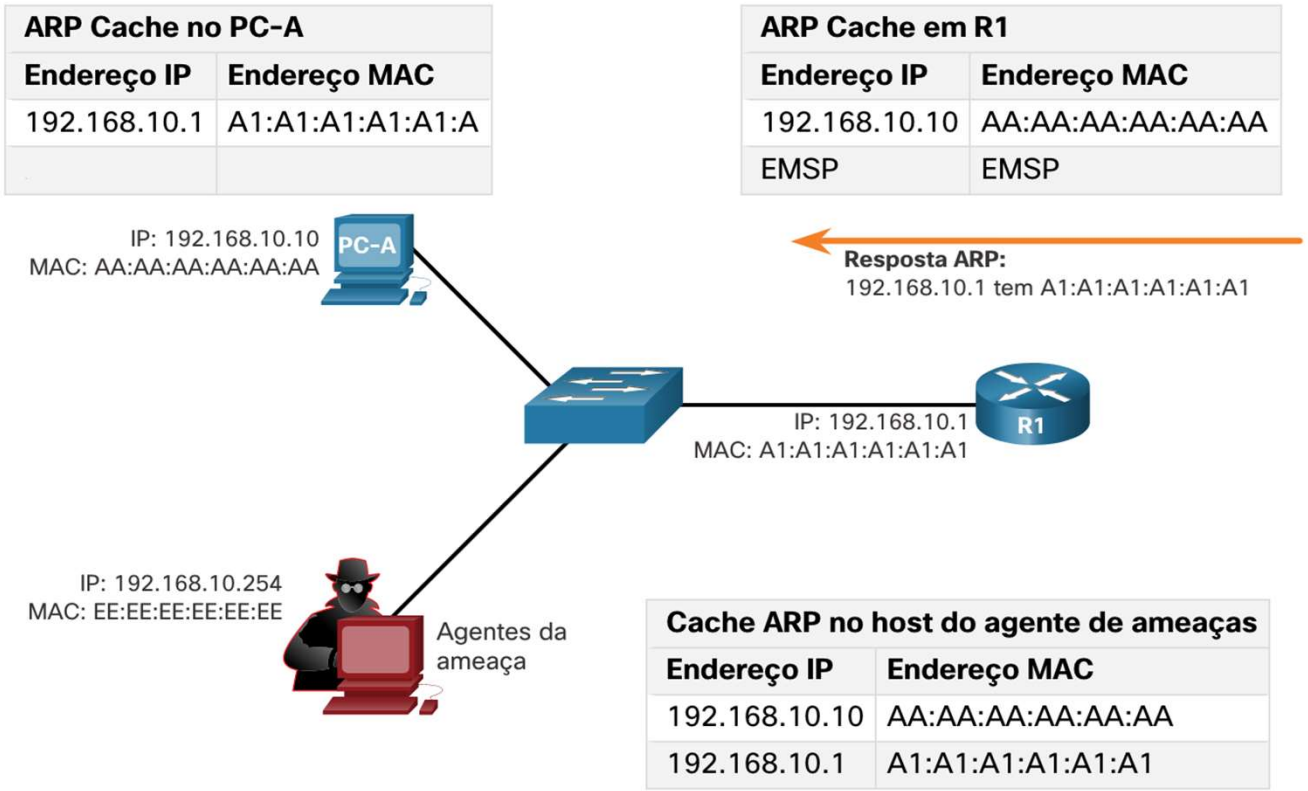
Cache ARP no host do agente de ameaças	
Endereço IP	**Endereço MAC**
192.168.10.10	AA:AA:AA:AA:AA:AA
192.168.10.1	A1:A1:A1:A1:A1:A1

Requisição ARP

- A figura mostra como o envenenamento de cache do ARP funciona.
- PC-A requer o endereço MAC do seu gateway padrão (R1); então, ele envia uma solicitação ARP para o endereço MAC 192.168.10.1.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Envenenamento de cache ARP (cont.)



Resposta ARP

- Nesta figura, R1 atualiza seu cache ARP com os endereços IP e MAC do PC-A.
- R1 envia uma resposta ARP para PC-A, que então atualiza seu cache ARP com os endereços IP e MAC de R1.

Respostas gratuitas de ARP falsas

- O envenenamento passivo de ARP ocorre quando agentes de ameaças roubam informações confidenciais.
- O envenenamento por ARP ativo ocorre quando agentes de ameaças modificam dados em trânsito ou injetam dados maliciosos.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Serviços IP

Ataquesde DNS

Um resolvedor aberto de DNS responde a consultas de clientes fora de seu domínio administrativo e é vulnerável a várias atividades maliciosas descritas na tabela.

Vulnerabilidades de resolvedor de DNS	Descrição
Ataques de envenenamento de cache DNS	Os agentes de ameaças enviam informações falsificadas e falsificadas de recursos de registro (RR) para um resolvedor de DNS, redirecionando os usuários de sites legítimos para sites mal-intencionados. Ataques de envenenamento de cache de DNS podem ser usados para informar o resolvedor de DNS para usar um servidor de nomes mal-intencionado que está fornecendo informações RR para atividades mal-intencionadas.
Ataques de amplificação e reflexão de DNS	Os agentes de ameaças usam ataques DoS ou DDoS em resolvedores abertos do DNS para aumentar o volume de ataques e ocultar a verdadeira fonte de um ataque. Os agentes de ameaças enviam mensagens DNS para os resolvedores abertos usando o endereço IP de um host de destino. Esses ataques são possíveis porque o resolvedor aberto responderá às perguntas de qualquer pessoa que faça uma pergunta.
Ataques de utilização de recursos DNS	Os ataques DoS consomem todos os recursos disponíveis para afetar negativamente as operações do resolvedor aberto de DNS. O impacto de um ataque DoS pode exigir que o resolvedor aberto de DNS seja reinicializado ou que os serviços sejam interrompidos e reiniciados.

Ataques de DNS (cont.)

Os agentes de ameaças também usam as técnicas **furtivas de DNS**descritas na tabela para realizar seus ataques.

técnicas furtivas de DNS	Descrição
Fluxo Rápido	Os atores de ameaças usam essa técnica para ocultar seus sites de entrega de phishing e malware atrás de uma rede que muda rapidamente de hosts DNS comprometidos. Os endereços IP do DNS são alterados continuamente em minutos. As redes de bots geralmente empregam técnicas do Fast Flux para impedir a detecção eficaz de servidores mal-intencionados.
Fluxo de IP duplo	Os atores de ameaças usam essa técnica para alterar rapidamente o nome do host para os mapeamentos de endereço IP e também para alterar o servidor de nomes autoritativo. Isso aumenta a dificuldade de identificar a fonte do ataque.
Algoritmos de geração de domínio	Os atores de ameaças usam essa técnica em malware para gerar aleatoriamente nomes de domínio que podem ser usados como pontos de encontro para seus servidores de comando e controle (C&C).

DNS Domain shadowing envolve o agente da ameaça reunindo credenciais de conta de domínio para criar silenciosamente vários subdomínios a serem usados durante os ataques que normalmente apontam para servidores mal-intencionados sem alertar o proprietário real do domínio pai.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Tunelamento DNS

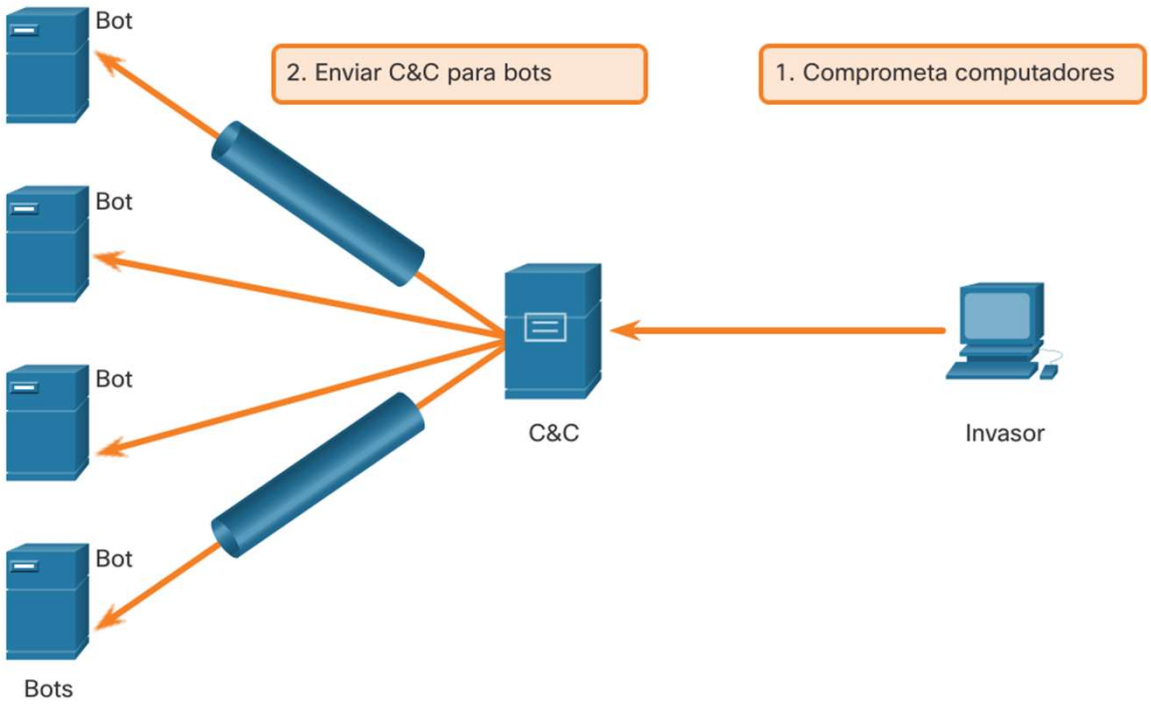
Os botnets usam o protocolo DNS para espalhar malware ou lançar ataques DDoS e phishing. Os analistas de segurança devem implementar uma solução para bloquear as comunicações de saída dos hosts infectados para detectar quando um invasor está usando o túnel DNS.

Um ataque de tunelamento DNS usando TXT funciona assim:

- Os dados são divididos em vários blocos codificados.
- Cada pedaço é colocado em um rótulo de nome de domínio de nível inferior na consulta DNS.
- Como não há resposta do DNS local ou em rede para a consulta, a solicitação é enviada aos servidores DNS recursivos do ISP.
- O serviço DNS recursivo encaminhará a consulta para o servidor de nomes autorizado do invasor.
- O processo é repetido até que todas as consultas contendo os chunks sejam enviadas.
- Quando o servidor de nomes autoritativo do invasor recebe as consultas DNS dos dispositivos infectados, ele envia respostas para cada consulta DNS, que contém os comandos encapsulados e codificados.
- O malware no host comprometido recombina os pedaços e executa os comandos ocultos.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

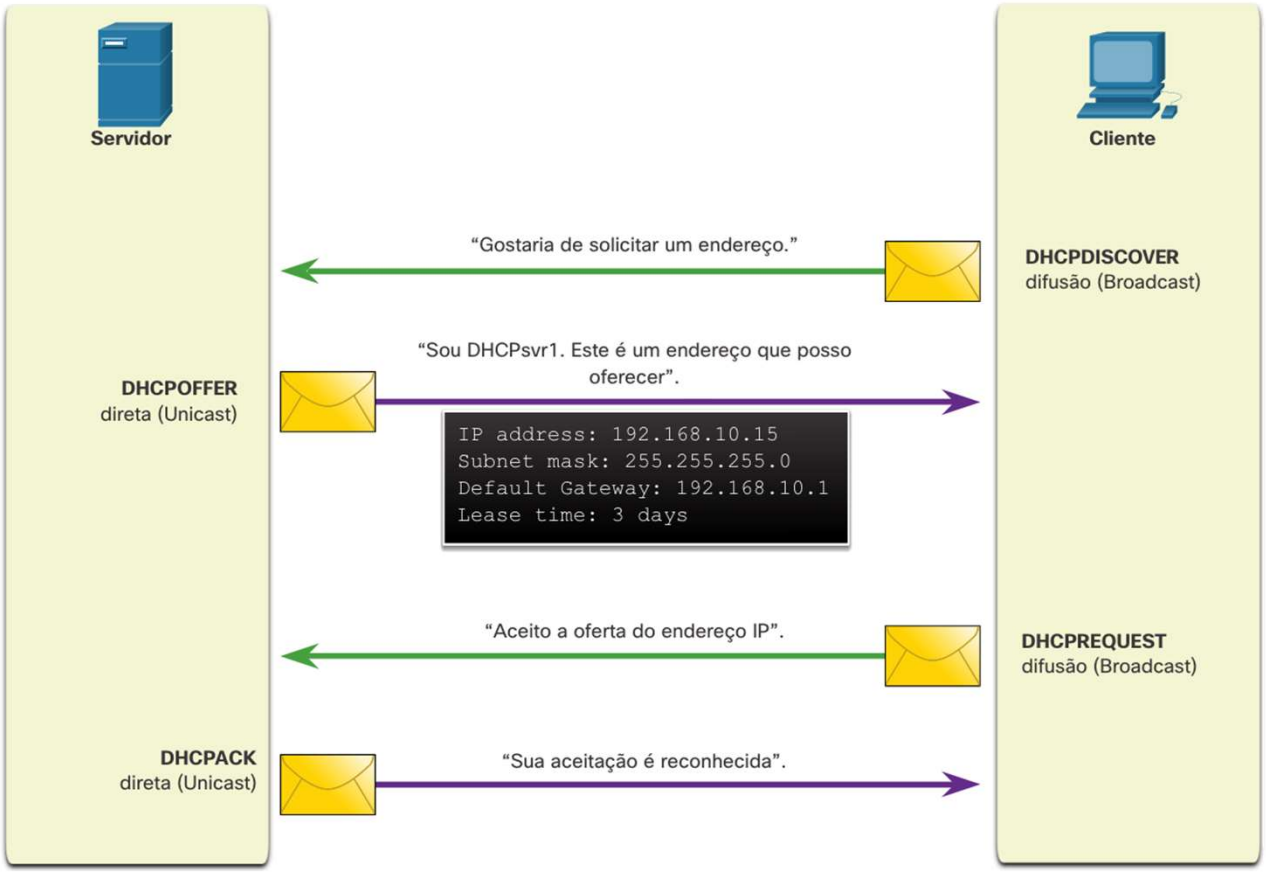
Tunelamento DNS (cont.)



- Um filtro que inspeciona o tráfego DNS deve ser usado para interromper o tunelamento DNS.
- Preste atenção especial às consultas DNS que são mais longas do que a média, ou aquelas que têm um nome de domínio suspeito.
- As soluções de segurança de DNS, como o Cisco Umbrella, bloqueiam grande parte do tráfego do tunelamento DNS identificando domínios suspeitos.
- Domínios associados a serviços DNS dinâmicos devem ser considerados altamente suspeitos.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Serviços IP
DHCP



- Os servidores DHCP fornecem dinamicamente informações de configuração de IP aos clientes.
- A figura mostra a sequência típica de uma troca de mensagens DHCP entre cliente e servidor.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ataques à DHCP

Ocorre quando um servidor DHCP não autorizado está conectado à rede e fornece parâmetros de configuração de IP falsos para clientes legítimos.

Um servidor não autorizado pode fornecer uma variedade de informações enganosas:

- **Gateway padrão incorreto - o** ator de ameaça fornece um gateway inválido ou o endereço IP de seu host para criar um ataque MiTM. Isso pode não ser totalmente detectado, pois o invasor intercepta o fluxo de dados pela rede.
- **Servidor DNS errado** - O agente de ameaças fornece um endereço de servidor DNS incorreto, apontando o usuário para um site malicioso.
- **Endereço IP errado** - O agente de ameaças fornece um endereço IP inválido, um endereço IP de gateway padrão inválido ou ambos. O agente de ameaça cria um ataque de negação de serviço no cliente DHCP.

Suponha que um agente de ameaça tenha conectado com êxito um servidor DHCP não autorizado a uma porta de switch na mesma sub-rede que os clientes de destino. O objetivo do servidor não autorizado é fornecer aos clientes informações falsas de configuração de IP.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ataques DHCP (cont.)

As etapas em um ataque de falsificação de DHCP são:

Etapas	Descrição
1. Cliente transmite mensagens de descoberta DHCP	Um cliente legítimo se conecta à rede e requer parâmetros de configuração IP. O cliente transmite uma solicitação de descoberta de DHCP procurando uma resposta de um servidor DHCP. Um servidor DHCP legítimo e um servidor invasor recebem a mensagem.
2. Servidores DHCP respondem com ofertas	Como os servidores DHCP legítimos e o não autorizado, respondem com parâmetros de configuração de IP válidos. O cliente responde à primeira oferta recebida.
3. Cliente aceita solicitação DHCP não autorizada	O cliente recebeu a oferta não autorizada primeiro. Ele transmite uma solicitação DHCP, aceitando os parâmetros do servidor não autorizado. Cada servidor legítimo e não autorizado recebem a solicitação.
4. DHCP não autorizado confirma a solicitação	No entanto, apenas o servidor invasor envia uma resposta ao cliente para reconhecer sua solicitação. O servidor legítimo para de se comunicar com o cliente porque a solicitação já foi confirmada.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Serviços IP

Laboratório - Explore o tráfego DNS

Neste laboratório, você completará os seguintes objetivos:

- Capture o tráfego DNS
- Explore o tráfego de consulta DNS
- Explore o tráfego de resposta do DNS

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

4.2 Serviços corporativos

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

HTTP e HTTPS

Os estágios comuns de um típico ataque na web são:

- A vítima visita inconscientemente uma página web que foi comprometida por malware.
- A página Web comprometida redireciona o usuário, muitas vezes através de muitos servidores comprometidos, para um site contendo código malicioso.
- Quando o usuário visita este site com código malicioso, um kit de exploração verifica o software em execução no computador da vítima, incluindo o sistema operacional, Java ou Flash player, procurando uma exploração via software.
- Depois de identificar um pacote de software vulnerável em execução no computador da vítima, o kit de exploração entra em contato com o servidor do kit de exploração para baixar código que pode usar a vulnerabilidade para executar código mal-intencionado no computador da vítima.
- Depois que o computador da vítima é comprometido, ele se conecta ao servidor de malware e baixa uma carga útil (malware ou um serviço de download de arquivos que baixa outro malware).
- O último pacote de malware é executado no computador da vítima.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

HTTP e HTTPS (cont.)

Os logs de conexão do servidor geralmente podem revelar informações sobre o tipo de varredura ou ataque. Os diferentes tipos de códigos de status de conexão estão listados aqui:

- **1xx Informativa** - Esta é uma resposta provisória, consistindo apenas na Linha de Status e cabeçalhos opcionais. É encerrado por uma linha vazia. Não há cabeçalhos necessários para esta classe de código de status. Servidores NÃO DEVE enviar uma resposta 1xx para um cliente HTTP/1.0, exceto em condições experimentais.
- **2xx Sucesso** - A solicitação do cliente foi recebida, compreendida e aceita com êxito.
- **3xx** Redirecionamento — Outras ações devem ser tomadas pelo agente do usuário para atender a solicitação. Um cliente DEVE detectar loops de redirecionamento infinitos, porque esses loops geram tráfego de rede para cada redirecionamento.
- **4xx** Erro de cliente — Para casos em que o cliente parece ter errado. Exceto quando responder a uma solicitação HEAD, o servidor DEVE incluir uma entidade contendo uma explicação da situação, e se ela é temporária. Agentes de usuário DEVE exibir qualquer entidade incluída para o usuário.
- **5xx** Erro de Servidor - Isso é para casos em que o servidor está ciente de que errou ou não pode executar a solicitação. Exceto quando responder a uma solicitação HEAD, o servidor DEVE incluir uma entidade contendo uma explicação da situação de erro, e se ela é temporária. Agentes de usuário DEVE exibir qualquer entidade incluída para o usuário.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Explorações HTTP comuns

IFrames maliciosos

- iFrames maliciosos são frequentemente usados por agentes de ameaças.
- É um elemento HTML que permite ao navegador carregar outra página da Web de outra fonte.
- Os atores de ameaças comprometem um servidor da Web e modificam páginas da Web adicionando HTML para o iFrame malicioso.Ele pode então ser usado para fornecer uma exploração maliciosa, como publicidade de spam, um kit de exploração e outros malwares.

Amortecimento HTTP 302

- Atores de ameaças atacam usando o código de status de resposta HTTP 302 Encontrado para redirecionar o navegador da Web do usuário para um novo local.
- O navegador acredita que o novo local é a URL fornecida no cabeçalho e é convidado a solicitar essa nova URL.
- Esta função de redirecionamento pode ser usada várias vezes até que o navegador finalmente chegue na página que contém o exploit.
- Os redirecionamentos podem ser difíceis de detectar, pois redirecionamentos legítimos ocorrem com frequência na rede.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Exploits comuns de HTTP (cont.)

Sombreamento de domínio

- Para atacar, o agente da ameaça deve primeiro comprometer um domínio e, em seguida, criar vários subdomínios desse domínio.
- Logons de registro de domínio sequestrados são então usados para criar muitos subdomínios necessários para ataques.
- Mesmo que os subdomínios sejam domínios maliciosos, mais podem ser feitos a partir do domínio pai.
- A sequência a seguir é normalmente usada por atores de ameaça:
    1. Um site fica comprometido.
    2. O amortecimento HTTP 302 é usado para enviar o navegador para sites maliciosos.
    3. O sombreamento de domínio é usado para direcionar o navegador para um servidor comprometido.
    4. Uma página inicial do kit de exploração é acessada.
    5. Downloads de malware da página inicial do kit de exploração.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Serviços Corporativos

E-mail

À medida que o nível de uso de e-mail aumenta, a segurança se torna uma prioridade maior. Hoje, as mensagens HTML são acessadas a partir de muitos dispositivos diferentes que muitas vezes não são protegidos pelo firewall da empresa. HTML permite mais ataques devido à quantidade de acesso que às vezes pode ignorar diferentes camadas de segurança.

Veja a seguir exemplos de ameaças de email:

- **Ataques** baseados em anexos - atores de ameaças incorporam conteúdo malicioso em arquivos de negócios, como um e-mail do departamento de TI.
- **Falsificação** de e-mails - Os atores de ameaças criam mensagens de e-mail com um endereço de remetente falsificado que visa enganar o destinatário a fornecer dinheiro ou informações confidenciais.
- **E-mail** spam - Os agentes de ameaças enviam e-mails não solicitados contendo anúncios ou ficheiros maliciosos.
- **Servidor** de retransmissão de email aberto — os atores de ameaças aproveitam os servidores corporativos configurados incorretamente como retransmissores de email abertos para enviar grandes volumes de spam ou malware para usuários desavisados.
- **Homoglifos** — os atores de ameaças podem usar caracteres de texto muito semelhantes ou até mesmo idênticos aos caracteres de texto legítimos.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

E-mail (cont.)

Assim como qualquer outro serviço que escuta uma porta para conexões de entrada, os servidores SMTP também podem ter vulnerabilidades.

Algumas ações para ajudar a proteger contra ameaças incluem:

- Mantenha o software SMTP atualizado com patches e atualizações de software e segurança.
- Implemente contramedidas para evitar que os agentes de ameaças concluam sua tarefa de enganar o usuário final.
- Use um dispositivo de segurança específico para e-mail, como o Cisco Email Security Appliance, para ajudar a detectar e bloquear muitos tipos conhecidos de ameaças, como phishing, spam e malware.
- Ensine o usuário final a reconhecer spam, tentativas de phishing, links e URLs suspeitos, homóglifos e a nunca abrir anexos suspeitos.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Bancos de dados expostos pela Web

Os aplicativos da Web geralmente se conectam a um banco de dados relacional para acessar dados confidenciais.

Injeção de código

- Os invasores executam comandos no sistema operacional de um servidor da web por meio de um aplicativo da web vulnerável.

Injeção de SQL

- Os agentes de ameaças usam injeções SQL para violar o banco de dados relacional, criar consultas SQL mal-intencionadas e obter dados confidenciais do banco de dados relacional.
- SQL Injection é um dos ataques de banco de dados mais comuns.

Os analistas de segurança devem ser capazes de reconhecer consultas SQL suspeitas para detectar se o banco de dados relacional foi submetido a ataques de injeção SQL.

Os analistas de segurança precisam ser capazes de determinar qual ID de usuário foi usado pelo agente da ameaça para fazer login e, em seguida, identificar qualquer informação ou outro acesso que o agente da ameaça possa ter aproveitado após um login bem-sucedido.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Scriptingdo lado do cliente

Cross-Site Scripting (XSS)

O XSS ocorre quando as páginas da Web executadas no lado do cliente, em seu próprio navegador da Web, são injetadas com scripts maliciosos.

Dois tipos principais de XSS:

- **Armazenado (persistente)** - Isso é armazenado permanentemente no servidor infectado e é recebido por todos os visitantes da página infectada.
- **Refletido (não persistente)** - Isso requer apenas que o script malicioso esteja em um link e os visitantes devem clicar no link infectado para serem infectados.

Para prevenir ou reduzir ataques XSS:

- Certifique-se de que os desenvolvedores de aplicativos da Web estejam cientes das vulnerabilidades XSS e de como evitá-las.
- Use uma implementação IPS para detectar e evitar scripts mal-intencionados.
- Use um proxy da Web para bloquear sites mal-intencionados.
- Use um serviço como o Cisco Umbrella para impedir que os usuários naveguem para sites conhecidos por serem mal-intencionados.
- Ensine os usuários finais a identificar ataques de phishing e notificar o pessoal da infosec quando suspeitarem de algo relacionado à segurança.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Serviços Corporativos

Laboratório – Instalação de uma máquina virtual em um computador pessoal

Objetivos:

Parte 1: Preparação de um computador para virtualização
Parte 2: Importe uma máquina virtual para o inventário do VirtualBox

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Serviços Corporativos

Laboratório - Atacando um banco de dados MySQL

Neste laboratório, você verá um arquivo PCAP de um ataque anterior contra um banco de dados SQL.

- Parte 1: Abra o Wireshark e carregue o arquivo PCAP.
- Parte 2: Veja o Ataque de Injeção SQL.
- Parte 3: O Ataque de Injeção SQL continua...
- Parte 4: O Ataque de Injeção SQL fornece informações do sistema.
- Parte 5: O Ataque de Injeção SQL e Informações da Tabela
- Parte 6: O Ataque de Injeção SQL Conclui.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Serviços Corporativos

Laboratório - Leitura de logs do servidor

Neste laboratório, você completará os seguintes objetivos:

- Lendo Arquivos de Log com **cat**, **more** e **less**
- Arquivos de log e Syslog
- Arquivos de log e **journalctl**

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

4.3 Mitigação de Ataques Comuns à Rede

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Defendendo a Rede

Vigilância constante e educação contínua são necessários para defender sua rede contra ataques.

As melhores práticas para proteger uma rede são:

- Desenvolva uma política de segurança escrita para a empresa.
- Eduque os funcionários sobre os riscos de engenharia social e desenvolva estratégias para validar identidades por telefone, por e-mail ou pessoalmente.
- Controle o acesso físico aos sistemas.
- Use senhas fortes e altere-as com frequência.
- Criptografar e proteger por senha dados sensíveis.
- Implemente hardware e software de segurança, como firewalls, dispositivos IPS, dispositivos VPN, software antivírus e filtragem de conteúdo.
- Realize backups e teste os arquivos de backup regularmente.
- Desligue os serviços e portas desnecessários.
- Mantenha as correções atualizadas, instalando-as semanais ou diariamente, se possível, para evitar ataques de escalonamento de transbordamento e privilégio.
- Execute auditorias de segurança para testar a rede.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Mitigando Malware

Malware, incluindo vírus, worms e cavalos de Tróia, pode causar sérios problemas em redes e dispositivos finais.

Os administradores de rede têm vários meios (ou contramedidas) para mitigar esses ataques:

Software antivírus

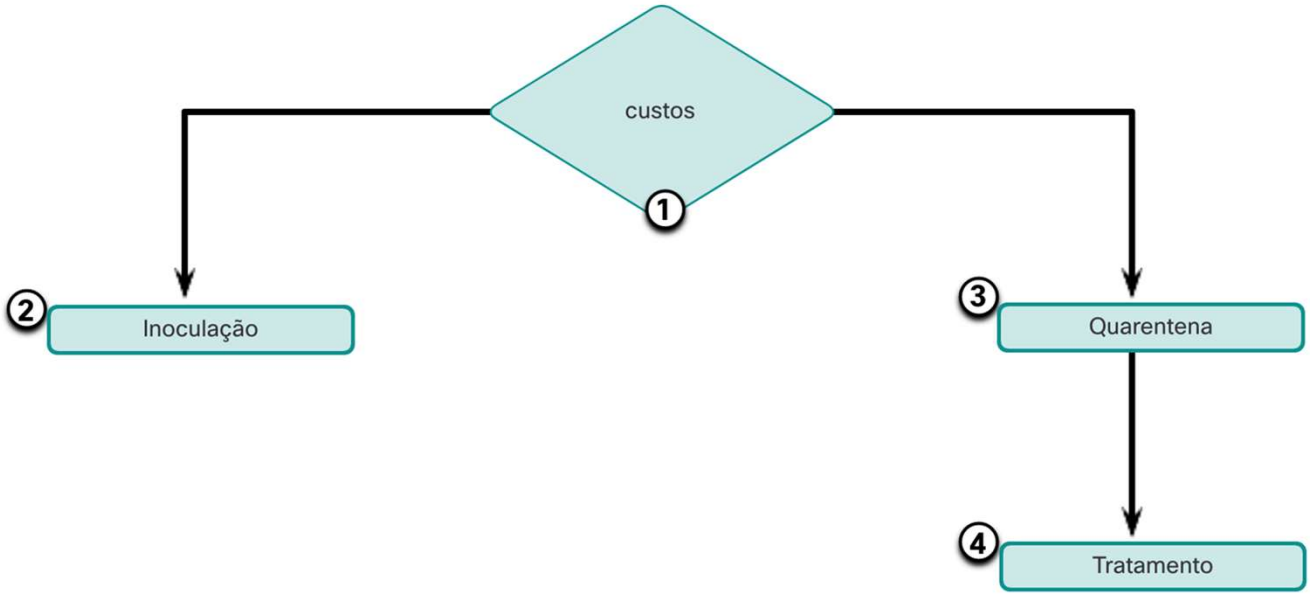
- Ele ajuda a impedir que os hosts sejam infectados e espalhem códigos maliciosos, detectando e eliminando vírus.
- Eles não impedem a entrada de vírus na rede, portanto, um profissional de segurança de rede deve estar ciente dos principais vírus e acompanhar as atualizações de segurança.

Impedir que arquivos de malware entrem na rede

- Os dispositivos de segurança no perímetro da rede podem identificar e remover arquivos de malware conhecidos com base em seus indicadores de comprometimento.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Mitigando Worms.



- Worms são mais baseados em rede do que vírus.
- A mitigação de worm requer diligência e coordenação por parte dos profissionais de segurança de rede.
- Como mostrado na figura, a resposta a um ataque de vermes pode ser dividida em quatro fases: contenção, inoculação, quarentena e tratamento.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Mitigação de worms (cont.)

Fase	Resposta
1. Custos	A fase de contenção envolve limitar a propagação de uma infecção por worms para áreas da rede que já estão afetadas. Isso requer compartimentação e segmentação da rede para abrandar ou parar o worm e evitar que hosts atualmente infectados segmentem e infectem outros sistemas. A contenção requer o uso de ACLs de saída e entrada em roteadores e firewalls em pontos de controle dentro da rede.
2. Inoculação	A fase de inoculação ocorre paralelamente ou após a fase de contenção. Durante a fase de inoculação, todos os sistemas não infectados são corrigidos com o patch de fornecedor apropriado. O processo de inoculação priva ainda mais o worm de quaisquer alvos disponíveis.
3. Quarentena	A fase de quarentena envolve rastrear e identificar máquinas infectadas dentro das áreas contidas e desconectá-las, bloquear ou removê-las. Isto isola estes sistemas adequadamente para a fase de tratamento.
4. Tratamento	A fase de tratamento envolve a desinfecção ativa dos sistemas infectados. Isso pode envolver encerrar o processo do worm, remover arquivos modificados ou configurações do sistema introduzidos pelo worm e corrigir a vulnerabilidade que o worm usou para explorar o sistema. Alternativamente, em casos mais graves, o sistema pode precisar ser reinstalado para garantir que o worm e seus subprodutos sejam removidos.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Mitigando Ataques de Reconhecimento

- Os ataques de reconhecimento são tipicamente o precursor de outros ataques que têm a intenção de obter acesso não autorizado a uma rede ou interromper a funcionalidade da rede.

- Uma variedade de tecnologias e dispositivos podem ser usados para monitorar esse tipo de atividade e gerar um alarme.

- Cisco ASA fornece prevenção de intrusão em um dispositivo standalone. Além disso, os roteadores corporativos, como os Cisco Integrated Services Routers (ISR), oferecem suporte à prevenção contra invasões na rede com software adicional.

- Os ataques de reconhecimento podem ser mitigados de várias maneiras, incluindo o seguinte:
  - Autenticação de implementação para garantir o acesso adequado.
  - Usando a criptografia para renderizar os ataques do Sniffer do pacote.
  - Usando ferramentas anti-sniffer para detectar ataques de sniffer de pacotes.
  - Implementando uma infraestrutura comutada.
  - Usando um firewall e IPS.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Mitigação de ataques de reconhecimento (cont.)

- O software anti-sniffer e as ferramentas de hardware detectam mudanças no tempo de resposta dos hosts para determinar se os hosts estão processando mais tráfego do que suas próprias cargas de tráfego indicariam.
- Embora isso não elimine a ameaça, como parte de um sistema geral de mitigação, pode reduzir o número de instâncias de ameaça.
- A criptografia também é eficaz para mitigar ataques de sniffer de pacotes. Se o tráfego é criptografado, usar um sniffer de pacote é de pouca utilidade porque os dados capturados não são legíveis.
- É impossível mitigar a varredura de portas, mas usar um IPS e firewall pode limitar as informações que podem ser descobertas com um scanner de portas.
- As varreduras do ping podem ser interrompidas se o ICMP echo e o echo-reply forem desligados nos roteadores de borda; No entanto, quando esses serviços estão desativados, os dados de diagnóstico de rede são perdidos.
- Além disso, as varreduras de porta podem ser executadas sem varreduras de ping completas. As varreduras simplesmente levam mais tempo porque os endereços IP inativos também são verificados.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Mitigando Ataques de Acesso

- Técnicas para mitigar ataques de acesso: segurança de senha forte, princípio de confiança mínima, criptografia e aplicação de patches de sistema operacional e aplicativos.

- Um número surpreendente de ataques de acesso é realizado através de simples adivinhação de senha ou ataques de dicionário de força bruta contra senhas.Para se defender contra isso, crie e imponha uma política de autenticação forte.

    - **Use senhas fortes** - Elas têm pelo menos oito caracteres e contêm letras maiúsculas, minúsculas, números e caracteres especiais.
    - **Desabilitar contas após um número especificado de logins malsucedidos** - Isso ajuda a evitar tentativas contínuas de senha.

- A rede também deve ser projetada usando o princípio da confiança mínima. Isso significa que os sistemas não devem usar um ao outro desnecessariamente.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Mitigação de ataques de acesso (cont.)

- A criptografia é um componente crítico de qualquer rede segura moderna.Quanto mais o tráfego for criptografado, menos oportunidades que os hackers têm para interceptar dados com ataques man-in-the-middle.
- O uso de protocolos de autenticação criptografados ou hash, juntamente com uma política de senha forte, reduz consideravelmente a probabilidade de ataques de acesso bem-sucedidos.
- Eduque os funcionários sobre os riscos de engenharia social e desenvolva estratégias para validar identidades por telefone, por e-mail ou pessoalmente.
- A autenticação multifator (MFA) tornou-se cada vez mais comum e requer dois ou mais meios independentes de verificação.
- Ataques de acesso podem ser detectados revisando logs, utilização de largura de banda e cargas de processo.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Mitigação de Ataques DoS

- Para minimizar o número de ataques DoS, um pacote de software de utilização de rede deve estar sempre em execução e exigido pela política de segurança de rede da organização.
- Os ataques DoS podem levar a problemas nos segmentos de rede dos computadores que estão sendo atacados.
- Historicamente, os ataques DoS foram originados de endereços falsificados.
- Os roteadores e switches Cisco oferecem suporte a várias tecnologias anti-spoofing, como port security, DHCP snooping, IP Source Guard, Dynamic Address Resolution Protocol (DAI) Inspection, e access control lists (ACLs).

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Mitigando Ataques Comuns à Rede

Laboratório - Recomendar medidas de mitigação de ameaças

Neste laboratório, você completará os seguintes objetivos:

- Parte 1: Analisar um Incidente em uma Produtora de Vídeo
- Parte 2: Analisar um Incidente em uma Empresa Varejista

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

4.4 Resumo do ataque ao nosso trabalho

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Resumo do ataque ao que fazemos

O que aprendi neste módulo?

- O protocolo DNS define um serviço automatizado que combina nomes de recursos com o endereço de host IP numérico necessário. Um ARP gratuito é uma resposta ARP não solicitada que pode ser enviada por qualquer cliente.
- Um ataque de spoofing de DHCP ocorre quando um servidor DHCP invasor está conectado à rede e fornece falsos parâmetros de configuração IP aos clientes legítimos.
- Ataques de injeção de código e injeção de SQL exploram campos de entrada validados insuficientemente para enviar comandos a bancos de dados ou outros aplicativos para obter acesso a informações privadas.
- Os ataques XSS (Cross-Site Scripting) ocorrem quando os navegadores executam scripts mal-intencionados no cliente e fornecem aos agentes da ameaça acesso a informações confidenciais no host local.
- O software antivírus é o principal meio de mitigar ataques de vírus e cavalos de Tróia.
- A resposta ao ataque do worm pode ser dividida em quatro fases: contenção, inoculação, quarentena e tratamento.
- A mitigação de ataques de reconhecimento pode incluir autenticação de acesso, criptografia e o uso de ferramentas anti-sniffer, firewalls e IPS.
- As melhores práticas de segurança de rede podem incluir a educação dos funcionários, o uso de senhas e criptografias fortes, teste de arquivos de backup, desligamentos desnecessários de serviços e portas, atualização de patches e realização de auditorias de segurança.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Módulo 4:

Novos termos e comandos

- Envenenamento de cache ARP.
- Ataques de DNS Open Resolver
- Ataques DNS Stealth
- Ataques de sombreamento de domínio DNS
- Ataques de tunelamento de DNS
- Fast Flux
- Double IP Flux
- Algoritmos de Geração de Domínio
- Ataque de falsificação de DHCP
- Mensagem de Descoberta DHCP
- Tráfego DNS
- Tráfego de consulta de DNS
- Tráfego de resposta DNS
- Serviços Corporativos
- HTTPS
- Informativo 1xx
- Redirecionamento bem-sucedido 3xx
- Erro do cliente 4xx
- Erro do servidor 5xx
- Open Web Application Security Project (OWASP)
- IFrames maliciosos
- HTTP 302 Cushioning
- Sombreamento de domínio
- Ataques baseados em anexos
- Open mail relay
- Homoglifos
- Scripting do lado do cliente



Módulo 5: Comunicação de Rede Sem Fio (Wireless)



Material do instrutor

Segurança de endpoint

Materiais do instrutor - Guia de planejamento do módulo 5

Esta apresentação de PowerPoint é dividida em duas partes:

- Guia de planejamento do Instrutor
  - Informações para ajudá-lo a se familiarizar com o módulo
  - Material didático
- Apresentação para aulas
  - Slides opcionais que você pode usar em sala de aula
  - Começa no slide 9

Observação: Remova o Guia de planejamento desta apresentação antes de compartilhar com outra pessoa.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

O Que Esperar Neste Módulo

Para facilitar o aprendizado, os seguintes recursos da interface do usuário podem ser incluídos neste módulo:

Recurso	Descrição
Avatar	Um personagem virtual, representando um especialista no assunto, acrescenta informações contextuais adicionais às habilidades que os alunos aprenderam e os ajuda a ligar os pontos, fazendo perguntas de reflexão aberta.
Animações	Expor os alunos a novas competências e conceitos.
Vídeos	Exponha os alunos a novas habilidades e conceitos.
Verifique seu entendimento	Per topic online quiz to help learners gauge content understanding.
Atividades Interativas	Uma variedade de formatos para ajudar os alunos a avaliar a compreensão do conteúdo.
Verificador de Sintaxe	Pequenas simulações que expõem os alunos à linha de comando da Cisco para praticar habilidades de configuração.
Atividade do PT	Atividades de simulação e modelagem projetadas para explorar, adquirir, reforçar e expandir habilidades.

O Que Esperar Neste Módulo (Cont.)

Para facilitar o aprendizado, os seguintes recursos da interface do usuário podem ser incluídos neste módulo:

Recurso	Descrição
Laboratórios Práticos	Laboratórios projetados para trabalhar com equipamentos físicos.
Testes de módulo	Autoavaliações que integram conceitos e habilidades aprendidas ao longo da série de tópicos apresentados no módulo.
Resumo do módulo	Recapitula brevemente o conteúdo do módulo.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Verifique seu entendimento

- As atividades Verifique sua compreensão são projetadas para permitir que os alunos determinem rapidamente se entendem o conteúdo e podem prosseguir ou se precisam revisar
- As atividades Verifique sua compreensão ***não*** afetam as notas dos estudantes
- Não há slides separados para essas atividades no PPT. Elas estão listadas na área de anotações do slide que aparece antes dessas atividades.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Módulo 5: Atividades

Quais atividades estão associadas a este módulo?

Nº da página	Atividade de	Nome da atividade	Opcional?
5.1.1	Vídeo	Vídeo - Operação WLAN	Recomendada
5.1.7	Verifique seu entendimento	Verifique sua compreensão — Etapas no processo de cliente e AP	Recomendada
5.1.9	Verifique Sua Compreensão	Verifique sua compreensão - Identifique o dispositivo LAN	Recomendada
5.2.1	Vídeo	Vídeo - Ameaças à WLAN	Recomendada
5.2.6	Verifique sua Compreensão	Verifique sua Compreensão - Ameaças à WLAN	Recomendada
5.3.1	Vídeo	Vídeo - WLANs seguras	Recomendada
5.3.9	Verifique sua Compreensão	Verifique sua compreensão - WLANs seguras	Recomendada
5.3.10	Atividade do PT	Packet Tracer – Configuração de segurança básica para redes sem fio	Recomendada
5.3.11	Atividade do PT	Packet Tracer – Solução de problemas de uma conexão sem fio	Recomendada

Senha do Activity Wizard: PT_csp11

Módulo 5: Práticas recomendadas

Antes de ensinar o Módulo 5, o instrutor deve:

- Revise as atividades e avaliações para este módulo.
- Tente incluir o máximo de perguntas possível para manter os alunos envolvidos durante a apresentação em sala de aula.

Tópico 5.1

- Peça à turma para assistir ao vídeo 5.1.1 sobre a operação de WLAN.
- Explique as diferenças entre LANs com fio e LANs sem fio.
- Descrever o método CSMA/CA e apontar as diferenças com o método CSMA/CD.
- Explique como os clientes sem fio se associam a um AP ou roteador sem fio.

Tópico 5.2

- Recomende aos alunos que assistam ao vídeo 5.2.1 sobre ameaças de WLAN.
- Peça aos alunos que dêem exemplos de ameaças às redes sem fio.
- Explique os tipos de ataques sem fio e dê exemplos no mundo real.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Módulo 5: Melhores Práticas (Cont.)

Tópico 5.3

- Peça à turma para assistir ao vídeo 5.3.1 sobre segurança de WLANs.
- Explique cada técnica para WLANs seguras: ocultação de SSID, filtragem de endereços MAC, métodos de autenticação e métodos de criptografia.
- Apresente o método AAA para WLANs corporativas seguras usando o servidor RADIUS.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco



Módulo 5: Comunicação de Rede Sem Fio (Wireless)

Segurança de endpoint

Objetivos do Módulo

Título do Módulo: Comunicação de Rede Sem Fio

Objetivo do Módulo: Solucionar problemas de uma rede sem fio**.**

Título do Tópico	Objetivo do Tópico
Comunicações sem fio	Explicar como os dispositivos sem fio viabilizam a comunicação de rede.
Ameaças de WLAN	Descrever ameaças à WLAN.
WLANs seguras	Solucionar problemas em uma conexão sem fio.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

5.1 Comunicações Sem Fio

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Comunicações sem fio

Vídeo - Operação WLAN

Este vídeo aborda o seguinte:

- Modo Infraestrutura
- Modo Ad Hoc
- Tethering (Vínculo)
- Conjunto de Serviços Básicos (BSS)
- Conjunto de Serviços Estendidos (ESS)
- Estutura do quadro 802.11
- Acesso múltiplo com detecção de operadora com prevenção de colisão (CSMA/CA)
- Clientes Sem Fio e Associação de APs
- Modo de Descoberta Passiva e Ativa

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

LANs sem fio versus com fio

A tabela resume as diferenças entre LANs sem fio e com fio.

Característica	802.11 LAN sem fio	802.3 LANs Ethernet com fio
Camada Física	Radiofrequência (RF)	cabos físicos
Acesso à mídia	prevenção de colisão	detecção de colisão
Disponibilidade	qualquer pessoa com uma placa de rede sem fio ao alcance de um ponto de acesso	conexão de cabo físico necessária
Interferência de sinal	sim	mínima
Regulamentações	diferentes regulamentos por país	O padrão IEEE dita

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Estutura do quadro 802.11

Todos os quadros da camada 2 consistem em um cabeçalho, carga útil e seção de sequência de verificação de quadro (FCS). O formato de quadro 802.11 é semelhante ao formato de quadro Ethernet, exceto pelo fato de conter mais campos.

- Controle do quadro - ele identifica o tipo de quadro sem fio e contém subcampos para versão do protocolo, tipo de quadro, tipo de endereço, gerenciamento de energia e configurações de segurança.
- Duração - normalmente é usado para indicar a duração restante necessária para receber a próxima transmissão de quadro.
- Endereço 1- Geralmente contém o endereço MAC do dispositivo sem fio ou AP receptor.E
- Endereço 2 - Geralmente contém o endereço MAC do dispositivo sem fio ou AP de transmissão.
- Endereço3 - Às vezes, isso contém o endereço MAC do destino, como a interface do roteador (gateway padrão) à qual o ponto de acesso está conectado.
- Controle de sequencia - Ele contém informações para controlar o seqüenciamento e os quadros fragmentados.
- Endereço4 - Isso geralmente está ausente porque é usado apenas no modo ad hoc.
- Carga útil - contém os dados para transmissão.
- FCS - é usado para controle de erro da camada 2.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

CSMA/CA

As WLANs são configurações de mídia compartilhada half-duplex. Isso cria um problema porque um cliente sem fio não pode ouvir enquanto está enviando, o que torna impossível detectar uma colisão.

Para resolver esse problema, as WLANs usam CSMA/CA como método para determinar como e quando enviar dados na rede. Um cliente sem fio faz o seguinte:

1. Escuta o canal (portadora) para ver se não detecta nenhum outro tráfego no canal (ocioso).
2. Envia uma mensagem pronta para enviar (RTS) para o ponto de acesso para solicitar acesso dedicado à rede.
3. Recebe uma mensagem clara para enviar (CTS) do ponto de acesso que concede acesso ao envio.
4. Se o cliente sem fio não receber uma mensagem CTS, ele aguardará um período aleatório antes de reiniciar o processo.
5. Depois de receber o CTS, ele transmite os dados.
6. Todas as transmissões são confirmadas. Se um cliente sem fio não receber uma confirmação, ele assume uma colisão e reinicia o processo.

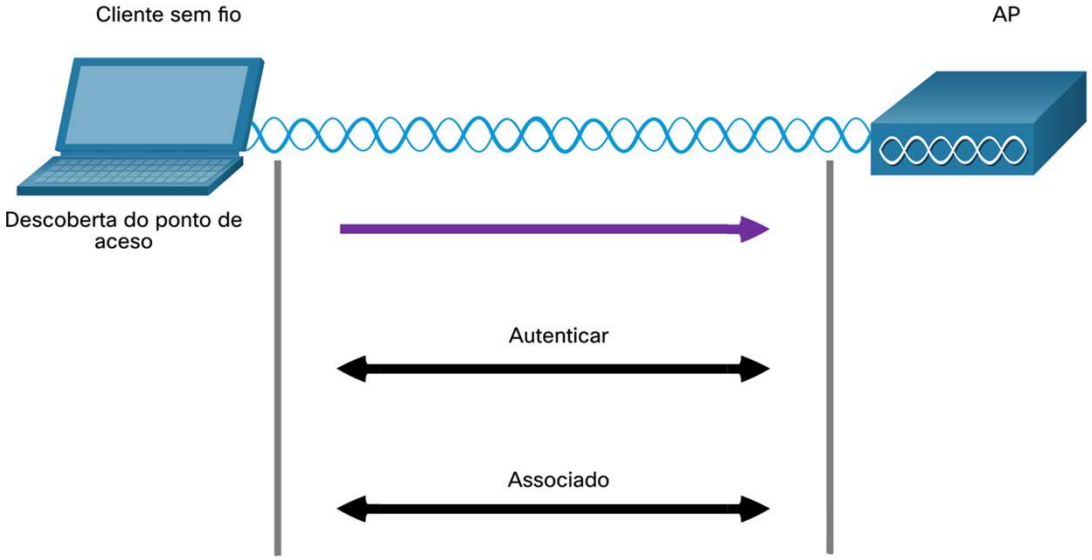
© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Clientes Sem Fio e Associação de APs

Para que os dispositivos sem fio se comuniquem através de uma rede, eles devem primeiro se associar a um Ponto de acesso ou roteador sem fio. Uma parte importante do processo 802.11 é descobrir uma WLAN e subsequentemente conectar-se a ela.

Os dispositivos sem fio concluem o seguinte processo de três estágios:

- Descobrir novo AP sem fio.
- Autenticar-se no AP
- Associar no AP



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Clientes Sem Fio e Associação de APs

Um cliente sem fio e um AP devem concordar com parâmetros específicos que devem ser configurados no AP e posteriormente no cliente para permitir a negociação de uma associação bem-sucedida.

- SSID - ele aparece na lista de redes sem fio disponíveis em um cliente.
- Senha - é exigido do cliente sem fio para autenticar no AP.
- Modo de rede - Refere-se aos padrões WLAN 802.11a/b/g/n/ac/ad.
- Modo de Segurança - Refere-se às configurações dos parâmetros de segurança, como WEP, WPA ou WPA2.
- Configurações de canal - Refere-se às bandas de frequência usadas para transmitir dados sem fio.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Modo de Descoberta Passiva e Ativa

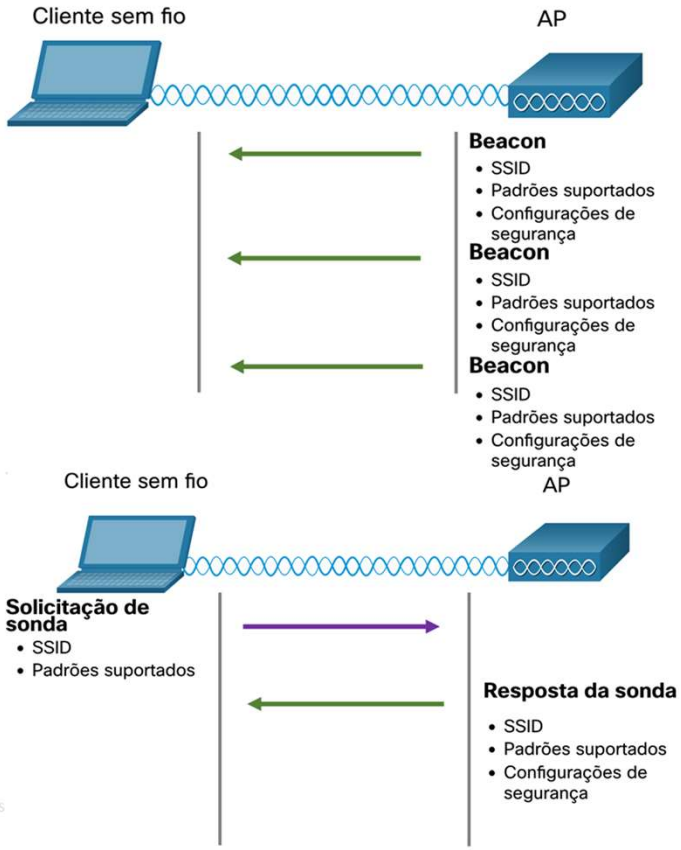
Os dispositivos sem fio devem descobrir e conectar-se a um ponto de acesso ou roteador sem fio. Os clientes sem fio se conectam ao ponto de acesso usando um processo de verificação (verificação). Este processo pode ser passivo ou ativo.

Modo passivo

- O AP anuncia abertamente seu serviço enviando periodicamente quadros beacon contendo o SSID, padrões suportados e configurações de segurança.

Modo ativo

- Os clientes sem fio devem saber o nome do SSID e i niciar o processo transmitindo um quadro de solicitação de sondagem (probe) em vários canais.
- Os pontos de acesso configurados com o SSID enviarão uma resposta do probe que inclui o SSID, os padrões suportados e as configurações de segurança.



© 2020 Cis

Dispositivos sem fio - AP, LWAP e WLC

- Roteadores sem fio domésticos e de pequenas empresas integram as funções de um roteador, switch e access point em um único dispositivo.
- Todas as funções de controle e gerenciamento dos APs em uma rede podem ser centralizadas em um Wireless LAN Controller (WLC).
- Ao usar uma WLC, os APs não atuam mais de forma autônoma, mas atuam como APs leves (LWAPs).
- Os LWAPs apenas encaminham dados entre a LAN sem fio e a WLC.
- Um grande benefício da centralização das funções de gerenciamento de AP na WLC é a configuração simplificada e o monitoramento de vários pontos de acesso (APS)



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

5.2 Ameaças WLAN

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Vídeo - Ameaças à WLAN

Este vídeo aborda o seguinte:

- Interceptação de dados
- Intruso em redes sem fio
- Ataques de Negação de Serviço (DoS)
- APs invasores

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Visão geral da segurança sem fio

Com uma placa de rede sem fio e o conhecimento de técnicas de cracking, um invasor pode não precisar entrar fisicamente no local de trabalho para obter acesso a uma WLAN.

As redes sem fio são especificamente suscetíveis a várias ameaças, incluindo:

- Interceptação de dados - Os dados sem fio devem ser criptografados para evitar que sejam lidos por pessoas que estejam "bisbilhotando".
- Intrusos em redes sem fio - Usuários não autorizados que tentam acessar recursos de rede podem ser impedidos por meio de técnicas eficazes de autenticação.
- Ataques de Negação de Serviço (DoS) - O acesso aos serviços WLAN pode ser comprometido tanto acidentalmente quanto de forma maliciosa.
- APs nao autorizados - Os pontos de acesso não autorizados instalados por um usuário bem-intencionado ou para fins maliciosos podem ser detectados usando o software de gerenciamento.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ameaças à WLAN

Ataques DoS

Os ataques de DoS sem fio podem ser o resultado de:

- Dispositivos configurados incorretamente - Erros de configuração podem desabilitar a WLAN.
- Um usuário malicioso interfere intencionalmente na comunicação sem fio - Seu objetivo é desabilitar completamente a rede sem fio ou a ponto de nenhum dispositivo legítimo poder acessar o meio.
- Interferência acidental - WLANs são suscetíveis a interferência de outros dispositivos sem fio (fornos de micro-ondas, telefones sem fio, babás eletrônicas) A banda de 2,4 GHz é mais propensa a interferências do que a banda de 5 GHz.

Para minimizar o risco de um ataque de negação de serviço devido a dispositivos mal configurados e ataques maliciosos, proteja todos os dispositivos, mantenha as senhas seguras, crie backups e garanta que todas as alterações na configuração sejam incorporadas fora do horário comercial.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Access points não autorizados

Um ponto de acesso não autorizado é um ponto de acesso ou roteador sem fio que foi conectado a uma rede corporativa sem autorização explícita e contra a política corporativa.

Qualquer pessoa com acesso às instalações pode instalar um roteador sem fio barato que pode potencialmente permitir o acesso a um recurso de rede seguro.

O AP não autorizado conectado pode ser usado por um invasor para capturar endereços MAC, capturar pacotes de dados, obter acesso a recursos de rede ou iniciar um ataque man-in-the-middle.

Um hotspot de rede pessoal também pode ser usado como um ponto de acesso não autorizado.

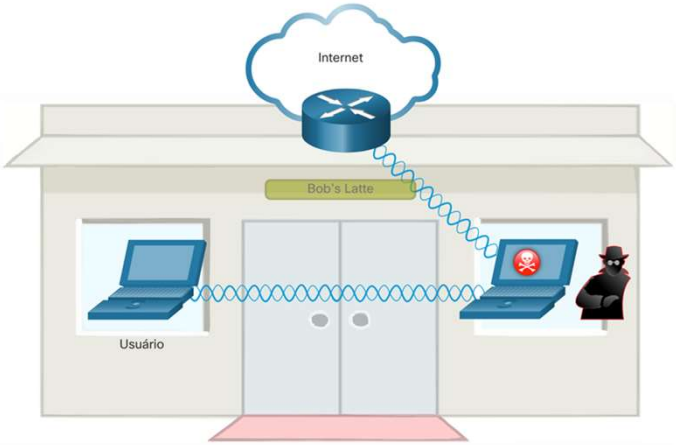
Para impedir a instalação de pontos de acesso não autorizados, as organizações devem configurar WLCs com políticas de pontos de acesso não autorizados e usar o software de monitoramento para monitorar ativamente o espectro de rádio para pontos de acesso não autorizados.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ameaças à WLAN

Ataque Man- in-the-middle

- O hacker está posicionado entre duas entidades legítimas para ler ou modificar os dados que passam entre as duas partes.
- Ataque: "Evil twin A": um invasor introduz um AP não autorizado e o configura com o mesmo SSID de um AP legítimo.
- Os clientes sem fio que tentam se conectar a uma WLAN verão dois APs oferecendo acesso sem fio. Aqueles perto do ponto de acesso não autorizado encontram o sinal mais forte e provavelmente se associam a ele.
- O tráfego do usuário é agora enviado para o AP não autorizado que captura os dados e os encaminha para o AP legítimo.
- O tráfego de retorno do ponto de acesso legítimo é enviado ao ponto de acesso não autorizado, capturado e depois encaminhado ao usuário inocente.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

5.3 WLANs seguras

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Vídeo - WLANs Seguras

Este vídeo aborda o seguinte:

- Ocultação do SSID
- Filtragem de endereços MAC
- Sistemas de autenticação e criptografia (autenticação aberta e autenticação de chave compartilhada)

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ocultação do SSID e filtragem de endereço MAC

Para lidar com as ameaças de impedir invasores sem fio e proteger dados, dois recursos de segurança anteriores foram usados e ainda estão disponíveis na maioria dos roteadores e pontos de acesso: camuflagem SSID e filtragem de endereço MAC.

Ocultação do SSID

- Os pontos de acesso e alguns roteadores sem fio permitem que o quadro de sinalização SSID seja desativado.
- Os clientes sem fio devem configurar manualmente o SSID para se conectar à rede.

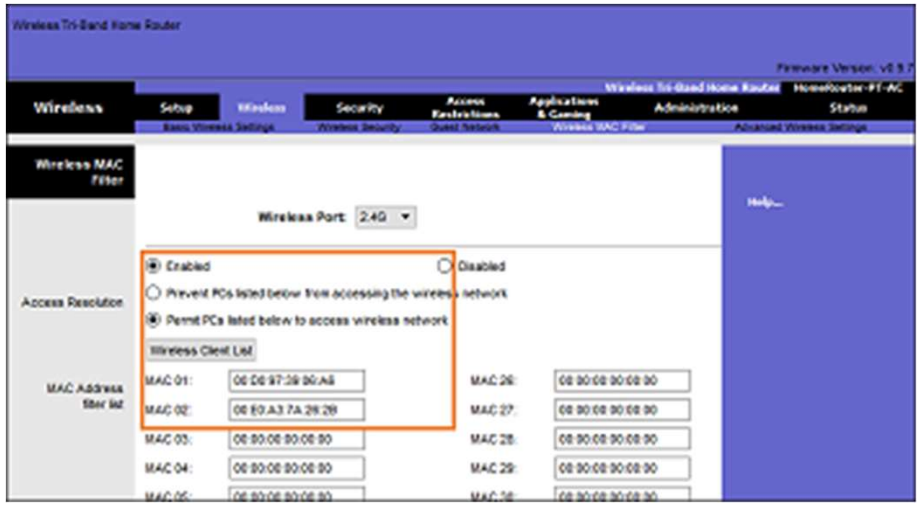


© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ocultação do SSID e filtragem de endereço MAC (Cont.)

Filtragem de endereços MAC

- Um administrador pode permitir ou negar manualmente o acesso sem fio dos clientes com base em seu endereço físico de hardware MAC.
- Na figura, o roteador está configurado para permitir dois endereços MAC. Dispositivos com endereços MAC diferentes não poderão ingressar na WLAN de 2,4 GHz.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Métodos de Autenticação Original 802.11

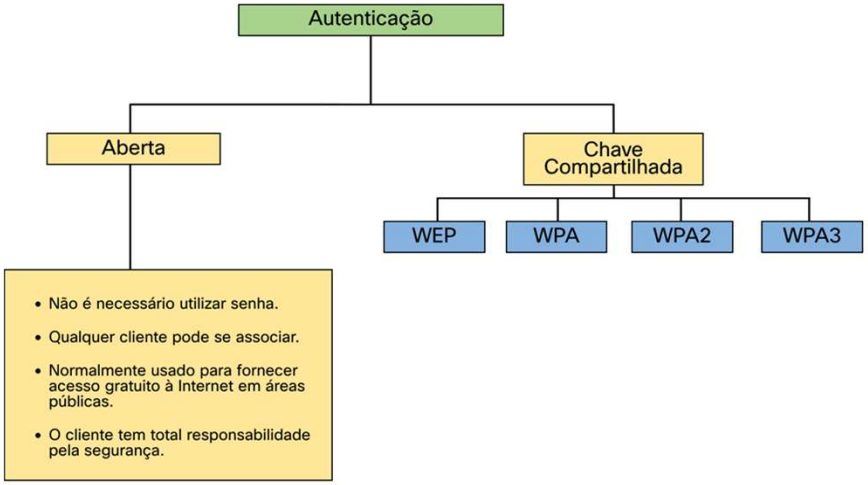
Os SSIDs são facilmente descobertos mesmo se os APs não os transmitirem e os endereços MAC podem ser falsificados.

A melhor maneira de proteger uma rede sem fio é usar sistemas de autenticação e criptografia.

Dois tipos de autenticação foram introduzidos com o padrão 802.11 original:

- Autenticação de sistema aberto - Qualquer cliente sem fio pode se conectar facilmente e só deve ser usado quando a segurança não for motivo de preocupação.

- A autenticação de chave compartilhada - fornece mecanismos como WEP, WPA, WPA2 e WPA3 para autenticar e criptografar dados entre um cliente sem fio e um ponto de acesso (AP).



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Métodos de autenticação de chave compartilhada

Existem quatro técnicas de autenticação de chave compartilhada disponíveis. Até que a disponibilidade dos dispositivos WPA3 se torne onipresente, as redes sem fio devem usar o padrão WPA2.

Método de autenticação	Descrição
WEP (Wired Equivalent Privacy)	A especificação 802.11 original projetada para proteger os dados usando o método de criptografia Rivest Cipher 4 (RC4) com uma chave estática. No entanto, a chave nunca muda ao trocar pacotes. Isso facilita a invasão O WEP não é mais recomendado e nunca deve ser usado.
WPA (Wi-Fi Protected Access)	Um padrão da Wi-Fi Alliance que usa WEP, mas protege os dados com o algoritmo de criptografia TKIP (Temporal Key Integrity Protocol) muito mais forte. O TKIP muda a chave para cada pacote, dificultando o trabalho dos hackers.
WPA2	O WPA2 é o padrão atual do setor para proteger redes sem fio. Usa a criptografia AES (Advanced Encryption Standard - Padrão de Criptografia Avançada). O AES é considerado atualmente o protocolo de criptografia mais forte.
WPA3	A próxima geração de segurança Wi-Fi, os dispositivos habilitados para WPA3 usam os métodos de segurança mais recentes, não permitem protocolos legados desatualizados e exigem o uso de quadros de gerenciamento protegidos (PMF). No entanto, os dispositivos com WPA3 ainda não estão disponíveis.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Autenticando um usuário doméstico

Os roteadores domésticos geralmente têm duas opções para autenticação: WPA e WPA2 (mais seguro). Dois métodos de autenticação WPA2 são:

Pessoal

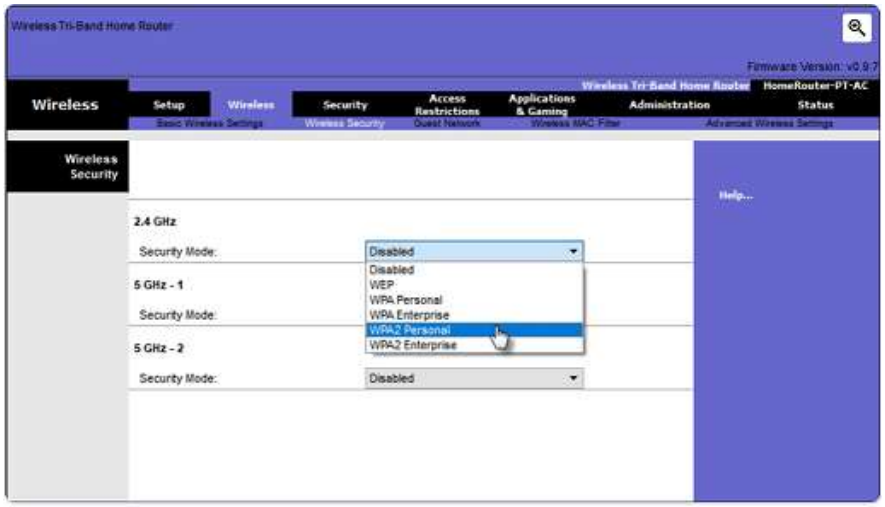
- Destinado a redes domésticas ou de pequenos escritórios, os usuários autenticam-se usando uma chave pré-compartilhada (PSK).

- Os clientes sem fio se autenticam com o roteador sem fio usando uma senha pré-compartilhada.

Corporativo

- Destinado a redes corporativas, mas requer um servidor de autenticação RADIUS (Remote Authentication Dial-In User Service).

- O dispositivo deve ser autenticado pelo servidor RADIUS e, em seguida, os usuários devem autenticar usando o protocolo de autenticação extensível (EAP) padrão 802.1X.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Métodos de criptografia

Os padrões WPA e WPA2 usam os seguintes protocolos de criptografia:

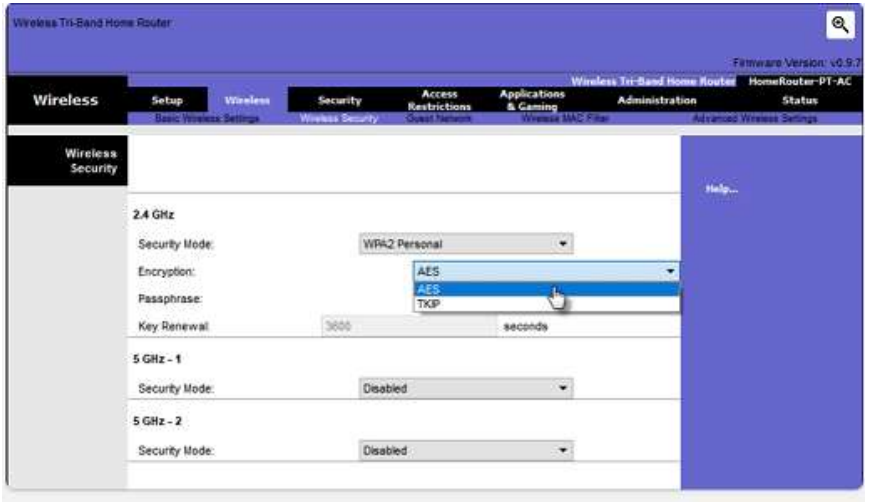
TKIP (Temporal Key Integrity Protocol)

- Ele é usado pelo WPA e fornece suporte para equipamentos WLAN herdados, abordando as falhas originais associadas à criptografia WEP.

AES (Advanced Encryption Standard)

- Ele é usado pelo WPA2 e é o método preferido porque é um método de criptografia muito mais forte.

- Ele usa o Modo de Cifra de Contador com o Protocolo de Código de Autenticação de Mensagem em Cadeia de Blocos (CCMP - Chaining Message Authentication Code Protocol) que permite que os hosts de destino reconheçam se os bits criptografados e não criptografados foram alterados.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Autenticação no modo Enterprise (Corporativo)

Em redes com requisitos de segurança mais rígidos, é necessária uma autenticação ou login adicional para conceder acesso a clientes sem fio.

A escolha do modo de segurança Enterprise requer um servidor RADIUS Authentication, Authorization, and Accounting (AAA).



- Endereço IP do servidor RADIUS - Este é o endereço acessível do servidor RADIUS.
- Números de porta UDP - As portas UDP oficialmente designadas são 1812 para autenticação RADIUS e 1813 para contabilidade RADIUS, mas também podem operar usando as portas UDP 1645 e 1646, como mostrado na figura.
- Chave compartilhada - Usada para autenticar o ponto de acesso (AP) com o servidor RADIUS.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

WLANs seguras

WPA3

No momento da redação deste artigo, os dispositivos que suportam autenticação WPA3 não estavam disponíveis. No entanto, o WPA2 não é mais considerado seguro.

WPA3, se disponível, é o método de autenticação 802.11 recomendado.

O WPA3 inclui quatro recursos:

- WPA3-Personal (Pessoal)
- WPA3-Enterprise (Corporativo)
- Redes abertas
- Integração da Internet das Coisas (IoT)

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Packet Tracer - Configuração de segurança básica para redes sem fio

Neste Packet tracer, você fará o seguinte:

Configure a segurança básica para redes sem fio usando WPA2 Personal.

- Verifique a conectividade.
- Configure a segurança básica para redes sem fio.
- Atualize as configurações da rede sem fio no laptop.
- Verifique a conectividade.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Packet Tracer - Solucionar problemas em uma Conexão Wireless

Neste Packet tracer, você fará o seguinte:

- Solucionar problemas em uma conexão sem fio.
- Identificar falhas em uma rede sem fio.
- Corrija dispositivos mal configurados em uma rede sem fio.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

5.4 Resumo da Comunicação da Rede Sem Fio

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Resumo da comunicação de rede sem fio

O que aprendi neste módulo?

- Os dispositivos de rede sem fio se conectam a um ponto de acesso ou roteador sem fio usando o f ormato de quadro 802.11 que é semelhante ao formato de quadro Ethernet, mas com campos adicionais.
- WLANs usam CSMA/CA como o método para determinar como e quando enviar dados na rede.
- Os APs podem ser configurados de forma autônoma (individualmente) ou usando uma WLC para simplificar a configuração e o monitoramento de vários pontos de acesso.
- As redes sem fio são suscetíveis a ameaças, incluindo: interceptação de dados, invasores sem fio, ataques de negação de serviço e pontos de acesso não autorizados.
- Um ponto de acesso não autorizado é um ponto de acesso ou roteador sem fio que foi conectado a uma rede corporativa sem autorização explícita.
- Em um ataque MITM, o atacante é posicionado entre duas entidades legítimas para ler ou modificar os dados que passam entre as duas partes.
- Existem quatro técnicas de autenticação de chave compartilhada disponíveis: WEP, WPA, WPA2 e WPA3.
- Os roteadores domésticos geralmente têm duas opções para autenticação: WPA e WPA2 (mais seguro).

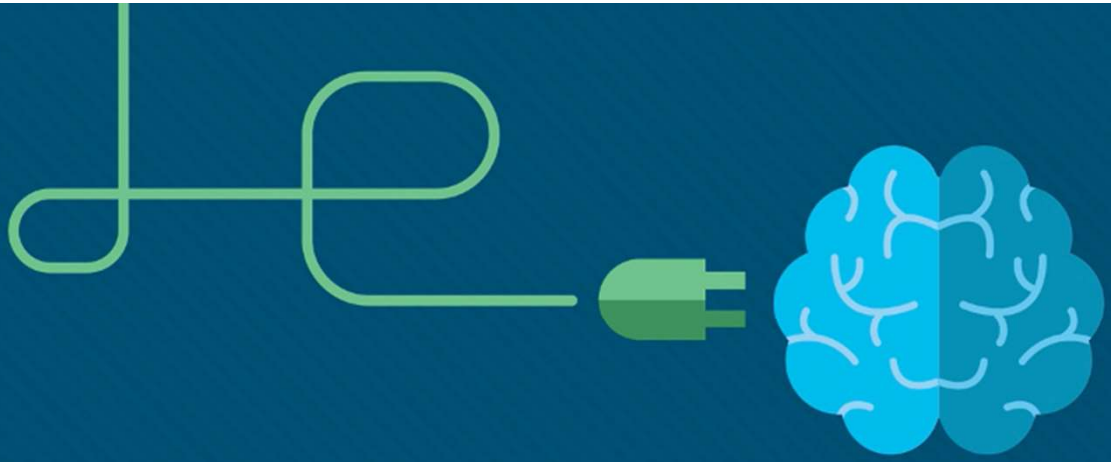
© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Módulo 5.

Termos e comandos

- Carrier Sense Multiple Access with Collision Avoidance (CSMA/CA)
- AP leve (LWAP)
- Controladora de Rede local sem fio (WLC)
- Ponto de acesso sem fio (WAP)
- AP desonesto
- AP gêmeo do mal (evil twin AP)
- Ocultação do SSID
- Filtragem de endereços MAC
- Autenticação de chave compartilhada
- Protocolo de autenticação extensível (EAP)
- Remote Authentication Dial-In User Service (RADIUS)
- TKIP (Temporal Key Integrity Protocol)
- AES (Advanced Encryption Standard)

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco



Módulo 6: Infraestrutura de Segurança de Rede



Segurança de endpoint

Objetivos do módulo

Título do módulo: Infraestrutura de segurança**de rede**

Objetivo do Módulo: Explicar como os dispositivos e serviços são usados para aumentar a segurança da rede.

Título do Tópico	Objetivo do Tópico
Dispositivos de segurança	Explicar como os dispositivos especializados são usados para aprimorar a segurança da rede.
Serviços de segurança	Explicar como os serviços de rede melhoram a segurança da rede.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

6.1 Dispositivos de segurança

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Vídeo - Dispositivos de Segurança

Este vídeo aborda o seguinte:

- Os switches do grupo de trabalho fornecem segurança de porta, inspeção ARP dinâmica (DAI) e DHCP Snooping.
- Os switches multicamadas fornecem firewalls de Camada 3 e Camada 4.
- Os pontos de acesso sem fio fornecem autenticação WPA2.
- Os firewalls de proxy da Web, e-mail e SSL inspecionam o tráfego.
- Os sistemas de detecção de intrusão (IDS) detectam ataques.
- Um ASA fornece firewall de camada 7 e sistema de prevenção de intrusão (IPS) em linha.
- O Cisco Talos fornece inteligência global sobre ameaças.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Firewalls

Um firewall é um sistema ou grupo de sistemas que aplica uma política de controle de acesso entre redes.

Propriedades comuns do firewall:

- Os firewalls são resistentes a ataques de rede.
- Firewalls são o único ponto de trânsito entre redes corporativas internas e redes externas porque todo o tráfego flui através do firewall.
- Firewalls reforçam a política de controle de acesso.

Benefícios do firewall

- Eles impedem a exposição de hosts, recursos e aplicações sensíveis a usuários não confiáveis.
- Eles sanitizam o fluxo do protocolo, o que impede a exploração de falhas no protocolo.
- Eles bloqueiam dados maliciosos de servidores e clientes.
- Eles reduzem a complexidade do gerenciamento de segurança descarregando a maior parte do controle de acesso à rede para alguns firewalls na rede.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Firewalls (cont.)

Um firewall é um sistema ou grupo de sistemas que aplica uma política de controle de acesso entre redes.

Limitações do firewall:

- Um firewall mal configurado pode ter sérias conseqüências para a rede, como se tornar um único ponto de falha.
- Os dados de muitos aplicativos não podem ser transmitidos por firewalls com segurança.
- Os usuários podem procurar proativamente maneiras de contornar o firewall para receber material bloqueado, o que expõe a rede a possíveis ataques.
- O desempenho da rede pode diminuir.
- O tráfego não autorizado pode ser encapsulado ou escondido como tráfego legítimo através do firewall.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

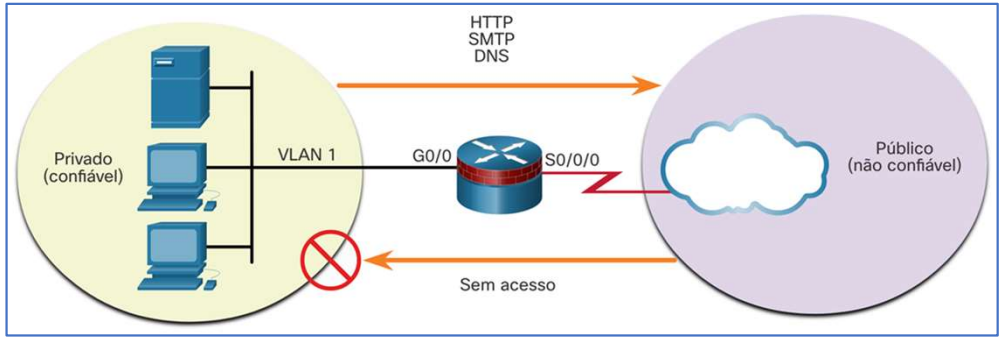
Arquiteturas de segurança comuns

O design do firewall é principalmente sobre interfaces de dispositivo que permitem ou negam tráfego com base na origem, no destino e no tipo de tráfego. Três projetos comuns de firewall são:

Privado e Público

A rede pública (ou rede externa) não é confiável e a rede privada (ou rede interna) é confiável. Normalmente, um firewall com duas interfaces é configurado da seguinte forma:

- O tráfego proveniente da rede privada é permitido e inspecionado à medida que viaja em direção à rede pública. É permitido o tráfego inspecionado que retorna da rede pública e associado ao tráfego originado da rede privada.
- O tráfego originado da rede pública e que viaja para a rede privada geralmente é bloqueado.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

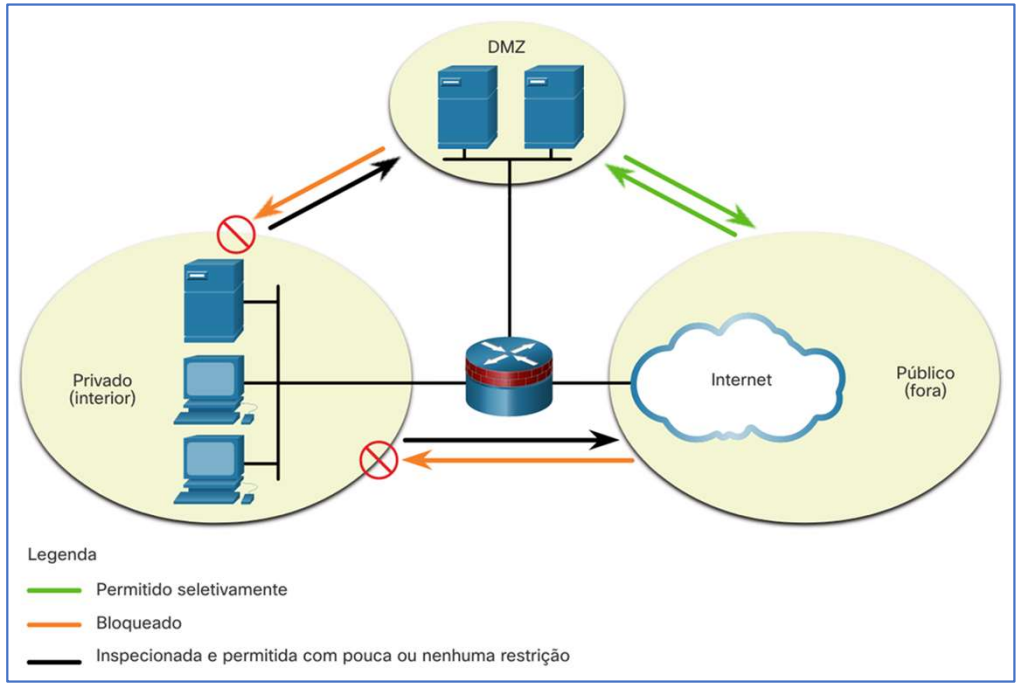
Arquiteturas de segurança comuns (cont.)

Zona Desmilitarizada (DMZ)

Um projeto de firewall onde normalmente há uma interface interna conectada à rede privada, uma interface externa conectada à rede pública e uma interface DMZ.

Configuração típica de firewall DMZ:

- O tráfego proveniente da rede privada é permitido e inspecionado à medida que viaja em direção à rede pública. É permitido o tráfego inspecionado que retorna da rede pública e associado ao tráfego originado da rede privada.
- O tráfego originado da rede pública e que viaja para a rede privada geralmente é bloqueado.



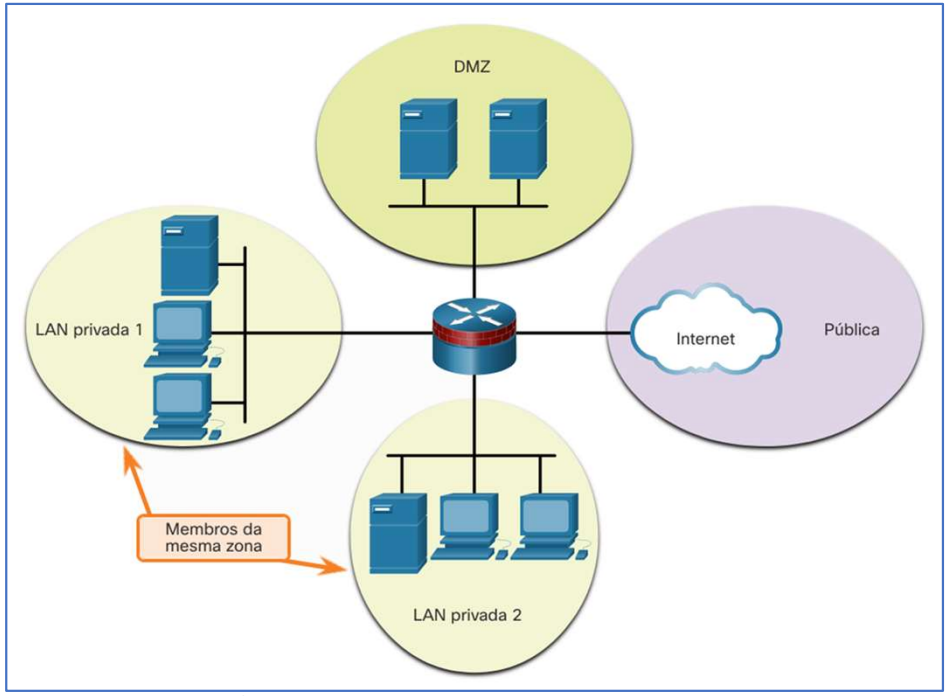
© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Arquiteturas de segurança comuns (cont.)

Firewalls de política baseados em zona (ZPFs)

ZPFs usam zonas para fornecer flexibilidade adicional. Uma zona é um grupo de uma ou mais interfaces que têm funções ou recursos semelhantes. As zonas são usadas para especificar onde uma regra ou política de firewall do Cisco IOS deve ser aplicada.

- As políticas de segurança para LAN 1 e LAN 2 são semelhantes e podem ser agrupadas em uma zona para firewall.
- O tráfego entre interfaces na mesma zona não está sujeito a nenhuma política e passa livremente.
- Todo o tráfego de zona a zona é bloqueado e, para permitir o tráfego entre as zonas, uma política que permita ou inspecione o tráfego deve ser configurada.
- A única exceção a esta política padrão **deny any** é a zona própria do roteador.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Descrições de tipo de firewall

Quatro tipos comuns de firewalls são:

Tipo de firewall	Recursos de firewall
Firewall de filtragem de pacotes (sem estado)	Os firewalls de filtragem de pacotes geralmente fazem parte de um firewall de roteador, que permite ou nega tráfego com base nas informações da Camada 3 e da Camada 4. Eles são firewalls sem estado (stateless)
Firewall com monitoração de estado	Os firewalls stateful fornecem filtragem de pacotes stateful usando informações de conexão mantidas em uma tabela de estado. Ele analisa o tráfego na camada OSI 3 a 5.
Firewall de gateway de aplicativo	Um firewall de gateway de aplicativo (firewall proxy) filtra informações nas camadas 3, 4, 5 e 7 do modelo OSI. A maior parte do controle e filtragem do firewall é feita em software.
Firewalls de próxima geração	Os firewalls de próxima geração (NGFW) vão além dos firewalls dinâmicos, fornecendo prevenção integrada contra invasões, reconhecimento e controle de aplicativos, caminhos de atualização para incluir futuros feeds de informações e técnicas para lidar com ameaças de segurança em evolução.

Descrições dos tipos de firewall (cont.)

Outros métodos de implementação de firewalls incluem:

- **Firewall baseado em host (servidor e pessoal)** - Um PC ou servidor com software de firewall em execução.
- **Firewall transparente** - Filtra o tráfego IP entre um par de interfaces em modo bridge.
- **Firewall híbrido** - Uma combinação dos vários tipos de firewalls.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Dispositivos de prevenção e detecção de intrusão

Características comuns do sistema de detecção de intrusão (IDS) e sistema de prevenção de intrusão (IPS):

- Ambas as tecnologias são implantadas como sensores na forma de vários dispositivos diferentes:
  - Um roteador configurado com o software Cisco IOS IPS
  - Um dispositivo projetado especificamente para fornecer serviços IDS ou IPS dedicados
  - Um módulo de rede instalado em um dispositivo de segurança adaptável (ASA), switch ou roteador

- Ambas as tecnologias usam assinaturas para detectar padrões de uso indevido no tráfego de rede. Uma assinatura é um conjunto de regras que um IDS ou IPS usa para detectar atividades maliciosas.

- Ambos podem detectar padrões atômicos (pacote único) ou padrões compostos (pacote múltiplo).

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Vantagens e desvantagens de IDS e IPS

Solução	Vantagens	Desvantagens
IDS	• Sem impacto na rede (latência, variação) • Sem impacto na rede se houver uma falha no sensor • Sem impacto na rede se houver sobrecarga do sensor	• Ação de resposta não pode parar pacotes de gatilho • Ajuste correto necessário para ações de resposta • Mais vulnerável a técnicas de evasão de segurança de rede
IPS	• Interrompe pacotes de gatilho • Pode usar técnicas de normalização de fluxo	• Problemas de sensor podem afetar o tráfego de rede • A sobrecarga do sensor afeta a rede • Algum impacto na rede (latência, tremulação)

Considerações de implantação

- Tanto um IPS quanto um IDS podem ser implantados; eles podem se complementar.
- Decidir qual implementação usar se baseia nos objetivos de segurança da organização, conforme indicado em sua política de segurança de rede.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Tipos de IPS

Existem dois tipos principais de IPS disponíveis: IPs (HIPS) baseados em host e baseados em rede.

IPS baseado em host (HIPS)

- HIPS é um software instalado em um host para monitorar e analisar atividades suspeitas.
- O HIPS pode monitorar atividades anormais e impedir que o host execute comandos que não correspondam ao comportamento típico.
- O tráfego de rede também pode ser monitorado para impedir que o host participe de um ataque de negação de serviço (DoS) ou faça parte de uma sessão de FTP ilícita.

Vantagens do HIPS	Desvantagens do HIPS
• Fornece proteção específica para um sistema operacional host • Fornece proteção em nível de aplicativo e sistema operacional • Protege o host depois que a mensagem é descriptografada	• Dependente do sistema operacional • Deve ser instalado em todos os hosts

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Tipos de IPS (cont.)

Existem dois tipos principais de IPS disponíveis: IPs (HIPS) baseados em host e baseados em rede.

IPS baseado em rede

- Um IPS baseado em rede pode ser implementado usando um dispositivo IPS dedicado ou não dedicado.
- As implementações de IPS baseadas em rede são um componente crítico da prevenção de intrusões.
- Existem soluções IDS/IPS baseadas em host, mas elas devem ser integradas a uma implementação IPS baseada em rede para garantir uma arquitetura de segurança robusta.
- Os sensores detectam atividades maliciosas e não autorizadas em tempo real e podem agir quando necessário.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Dispositivos de segurança especializados

Há uma variedade de dispositivos de segurança especializados disponíveis. Três exemplos são:

Dispositivo	Explicação
Cisco Advanced Malware Protection (AMP)	• Uma solução de proteção e análise de malware avançada de classe empresarial • Fornece proteção abrangente contra malware para organizações antes, durante e depois de um ataque • Acessa a inteligência de segurança coletiva do Cisco Talos Security Intelligence and Research Group
Cisco Web Security Appliance (WSA)	• Um gateway da Web seguro que combina proteções líderes para ajudar as organizações a enfrentar os desafios crescentes de proteção e controle do tráfego da Web • Protege a rede bloqueando automaticamente sites arriscados e testando sites desconhecidos antes de permitir que os usuários acessem • Fornece proteção contra malware, visibilidade e controle de aplicativos, controles de política de uso aceitável, relatórios perspicazes e mobilidade segura
Cisco Email Security Appliance (ESA)	• Defende sistemas de e-mail de missão crítica • Constantemente atualizado por feeds em tempo real do Cisco Talos • Os recursos incluem bloqueio de spam, proteção avançada contra malware e controle de mensagens enviadas

6.2 Serviços de segurança

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Vídeo - Serviços de Segurança

Este vídeo abordará o seguinte:

- Sistema de detecção de invasão (IDS)
- Analisador de porta comutada (SPAN – Switched Port Analyzer)
- Syslog
- Autenticação, Autorização, and Contabilidade (AAA)
- NetFlow
- SNMP

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Controle de tráfego com ACLs

Uma lista de controle de acesso (ACL) é uma série de comandos que controlam se um dispositivo encaminha ou descarta pacotes com base nas informações encontradas no cabeçalho do pacote. As ACLs executam as seguintes tarefas:

- Eles limitam o tráfego da rede para aumentar o desempenho da rede.
- Eles fornecem controle de fluxo de tráfego.
- Elas fornecem um nível básico de segurança para acesso à rede.
- Elas filtram o tráfego com base no tipo de tráfego.
- Elas examinam hosts para permitir ou negar acesso aos serviços de rede.

Além da permissão ou negação de tráfego, as ACLs podem ser usadas selecionando tipos de tráfego que serão analisados, enviados ou processados de outras formas.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

ACLs: recursos importantes

Dois tipos de ACLs Cisco IPv4 são padrão e estendidos.

As ACLs padrão podem ser usadas para permitir ou negar tráfego somente dos endereços IPv4 origem. O destino do pacote e as portas envolvidas não são avaliados.

As ACLs estendidas filtram pacotes IPv4 com base em vários atributos que incluem:

- Tipo de protocolo
- Endereço IPv4 origem
- Endereço IPv4 destino
- Portas TCP ou UDP origem
- Portas TCP ou UDP destino
- Informações opcionais do tipo de protocolo para o melhor controle

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

ACLs: recursos importantes (cont.)

- As ACLs padrão e estendidas podem ser criadas usando-se um número ou um nome para identificar a ACL e sua lista de instruções.

- Ao configurar o registro de ACL, uma mensagem ACL pode ser gerada e registrada quando o tráfego atende aos critérios de permissão ou negação definidos na ACL.

- As ACLs Cisco também podem ser configuradas para permitir apenas tráfego TCP que tenha um conjunto de bits ACK ou RST, de modo que apenas o tráfego de uma sessão TCP estabelecida seja permitido. Isso pode ser usado para negar qualquer tráfego TCP de fora da rede que está tentando estabelecer uma nova sessão TCP.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Serviços de segurança

Packet Tracer - demonstração da ACL

Nesta atividade do Packet Tracer, você atingirá os seguintes objetivos:

- Parte 1: Verificar a conectividade local e testar a lista de controle de acesso
- Parte 2: Remover a lista de controle de acesso e repetir o teste

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Serviços de segurança

SNMP

- O protocolo SNMP (Simple Network Management Protocol) permite que os administradores gerenciem dispositivos finais como servidores, estações de trabalho, roteadores, switches e dispositivos de segurança em uma rede IP.
- Permite que os administradores de rede monitorem o desempenho da rede, encontrem e resolvam os problemas da rede e planejem o crescimento da rede.
- O sistema SNMP consiste em dois elementos:
  - Gerenciador SNMP que executa o software de gerenciamento SNMP.
  - Agentes SNMP que são os nós que estão sendo monitorados e gerenciados.
- O Management Information Base (MIB) é um banco de dados dos agentes que armazena dados e estatísticas operacionais sobre o dispositivo.
- O gerenciador de SNMP faz parte de um sistema de gerenciamento de rede (NMS).
- O gerenciador SNMP pode coletar informações de um agente SNMP usando a ação “get” e pode alterar as configurações em um agente usando a ação “set”.
- Além disso, os agentes SNMP podem encaminhar informações diretamente para um gerenciador de rede usando “traps”.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Serviços de segurança

NetFlow

- Uma tecnologia Cisco IOS que fornece estatísticas sobre pacotes que fluem através de um roteador Cisco ou switch multicamada.
- O NetFlow fornece dados para permitir monitoramento de rede e segurança, planejamento de rede, análise de tráfego para incluir identificação de gargalos de rede e contabilidade IP para fins de faturamento.
- A tecnologia NetFlow distingue os fluxos de pacotes usando uma combinação de sete campos:
  - Endereço IP de origem
  - Endereço IP de destino
  - Número da porta de origem
  - Número da porta de destino
  - Tipo de protocolo da camada 3
  - Marcação de tipo de serviço (ToS)
  - Interface lógica de entrada

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Espelhamento de porta

- **Limitação do analisador de pacotes (sniffer de pacotes ou sniffer de tráfego)** - porque os switches de rede podem isolar o tráfego, sniffers de tráfego ou outros monitores de rede, como IDS, não podem acessar todo o tráfego em um segmento de rede.

- **O espelhamento** de portas é um recurso que permite que um switch faça cópias duplicadas do tráfego que passa por um switch e, em seguida, enviá-lo para fora uma porta com um monitor de rede conectado. O tráfego original é encaminhado da maneira usual.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Serviços de segurança

Servidores Syslog

- Quando determinados eventos ocorrem em uma rede, os dispositivos de rede têm mecanismos confiáveis para notificar o administrador com mensagens de sistema detalhadas.
- Os administradores de rede têm várias opções para armazenar, interpretar e exibir essas mensagens e para serem alertados sobre essas mensagens.
- O protocolo Syslog é o método mais comum de acessar as mensagens do sistema.

- O serviço de logging de syslog oferece três funções principais:
  - A capacidade de coletar informações de registro para monitorar e solucionar problemas
  - A capacidade de selecionar o tipo de informações de registro que são capturadas
  - A capacidade de especificar o destino das mensagens syslog capturadas

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Serviços de segurança

NTP

- Network Time Protocol (NTP) é importante para sincronizar a hora em todos os dispositivos na rede. Quando a hora não está sincronizada entre os dispositivos, será impossível determinar a ordem dos eventos que ocorreram em diferentes partes da rede.

- Conforme a rede cresce, torna-se cada vez mais difícil garantir que todos os dispositivos da infraestrutura operem com horário sincronizado.

- Uma solução para manter a configuração de hora sincronizada é configurar o Network Time Protocol (NTP).

- O protocolo NTP permite que os roteadores na rede sincronizem suas configurações de horário com um servidor NTP.

- Um grupo de clientes NTP que obtém informações de data e hora de uma única fonte tem configurações de hora mais consistentes.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

NTP (cont.)

As redes NTP usam um sistema hierárquico de fontes de horário. Cada nível desse sistema hierárquico é denominado stratum.

Os servidores NTP são organizados em três níveis conhecidos como estratos:

- **Stratum 0** - Uma rede NTP obtém o tempo de fontes de tempo confiáveis. Essas fontes, também conhecidas como dispositivos de stratum 0, são dispositivos de pontualidade de alta precisão, com pouco ou nenhum atraso associado a eles.
- **Stratum 1** - Os dispositivos do Stratum 1 estão diretamente conectados às fontes de tempo autorizadas. Eles atuam como o principal padrão de horário da rede.
- **Stratum 2 e estratos inferiores** - Os servidores estrato 2 são conectados aos dispositivos estrato 1 por meio de conexões de rede. Os dispositivos do stratum 2, como os clientes NTP, sincronizam a hora usando os pacotes NTP dos servidores do stratum 1. Eles também podem atuar como servidores dos dispositivos do stratum 3.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Serviços de segurança

Servidores AAA

Três funções de segurança independentes fornecidas pela estrutura arquitetônica AAA são autenticação, autorização e contabilidade.

AAA Fornece	Descrição
Autenticação	• Os usuários e administradores devem provar quem são. • A autenticação pode ser estabelecida usando combinações de nome de usuário e senha, perguntas e respostas de desafio, tokens e outros métodos. • A autenticação AAA fornece uma maneira centralizada de controlar o acesso à rede.
Autorização	• Após a autenticação do usuário, os serviços de autorização determinam quais recursos o usuário pode acessar e quais operações ele tem permissão para executar.
Accounting (Contabilidade)	• O accounting registra o que o usuário faz, incluindo o que é acessado, a quantidade de tempo em que o recurso é acessado e todas as alterações efetuadas. • O accounting rastreia como os recursos de rede são usados.

Servidores AAA (cont.)

Terminal Access Controller Access-Control System Plus (TACACS+) e Remote Authentication Dial-In User Service (RADIUS) são protocolos de autenticação usados para comunicação com servidores AAA.

	TACACS+	RADIUS
Funcionalidade	Separa o AAA de acordo com a arquitetura AAA, permitindo a modularidade da implementação do servidor de segurança	Combina autenticação e autorização, mas separa a contabilidade, permitindo menos flexibilidade na implementação do que o TACACS+
Padrão	Principalmente com suporte Cisco	Padrão aberto/RFC
Transporte	TCP	UDP
Protocolo CHAP	Desafio bidirecional e resposta conforme usado no Challenge Handshake Authentication Protocol (CHAP)	Desafio unidirecional e resposta do servidor de segurança RADIUS para o cliente RADIUS
Confidencialidade	Pacote inteiro criptografado	Senha criptografada
Personalização	Fornece autorização de comandos do roteador por usuário ou por grupo	Não tem opção para autorizar comandos de roteador por usuário ou por grupo
Accounting	Limitado	Extensivo

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Serviços de segurança

VPN

- Uma rede virtual privada (VPN) é uma rede privada criada em uma rede pública, geralmente a Internet. A VPN usa conexões virtuais que são roteadas pela Internet da organização para o site remoto.
- Uma VPN conecta dois terminais, como um escritório remoto a um escritório central, por meio de uma rede pública, para formar uma conexão lógica. As conexões lógicas podem ser feitas na Camada 2 ou na Camada 3.
- Uma VPN é privada, pois o tráfego é criptografado para manter os dados confidenciais enquanto são transportados pela rede pública.
- Exemplos comuns de VPNs de Camada 3 são GRE, MPLS (Multiprotocol Label Switching) e IPsec.
- As VPNs de camada 3 podem ser conexões de site ponto a ponto, como GRE e IPsec, ou podem estabelecer qualquer conectividade para muitos sites usando MPLS.
- As VPNs são normalmente implantadas em uma topologia site a site para conectar sites centrais com locais remotos com segurança. Eles também são implantados em uma topologia de acesso remoto para fornecer acesso remoto seguro a usuários externos que viajam ou trabalham de casa.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

6.3 Resumo da infraestrutura de segurança de rede

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Resumo da infraestrutura de segurança de rede

O que aprendi neste módulo?

Dispositivos de segurança

- Existem vários tipos diferentes de firewalls, incluindo filtragem de pacotes (sem estado), firewall de inspeção com estado, gateway de aplicativo (proxy) e firewalls de última geração.
- O design do firewall é principalmente sobre interfaces de dispositivo que permitem ou negam tráfego com base na origem, no destino e no tipo de tráfego.
- Os sistemas de prevenção de intrusões (IPS) e os sistemas de detecção de intrusões (IDS) são usados para detectar potenciais riscos de segurança e alertar/parar tráfego inseguro.
- O IDS/IPS pode ser implementado como baseado em host ou em rede.
- Dispositivos de segurança especializados incluem Cisco Advanced Malware Protection (AMP), Cisco Web Security Appliance (WSA) e Cisco Email Security Appliance (WSA).
- Esses appliances de segurança utilizam os serviços do Cisco Talos Security Intelligence and Research Group.
- O Talos detecta e correlaciona ameaças em tempo real usando a maior rede de detecção de ameaças do mundo.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Resumo da infraestrutura de segurança de rede

O que aprendi neste módulo? (continuação)

Serviços de segurança

- ACLs são uma série de instruções que controlam se um dispositivo encaminha ou descarta pacotes com base nas informações encontradas no cabeçalho do pacote.
- O NTP sincroniza a hora do sistema em todos os dispositivos na rede para garantir um carimbo de data/hora preciso e consistente das mensagens do sistema.
- Os servidores Syslog compilam e fornecem acesso às mensagens do sistema geradas pelos dispositivos de rede.
- O SNMP permite que os administradores de rede monitorem e gerenciem o desempenho da rede, localizem e resolvam problemas de rede e planejem o crescimento da rede.
- O NetFlow fornece estatísticas sobre os pacotes que estão fluindo através de um roteador Cisco ou switch multicamadas.
- O espelhamento de porta é um recurso que permite que um switch faça cópias duplicadas do tráfego que está passando pelo switch e, em seguida, enviá-lo por uma porta que tenha um monitor de rede conectado.
- O AAA é uma estrutura para configurar serviços de autenticação, autorização e contabilidade do usuário. O AAA normalmente usa um servidor TACACS+ ou RADIUS para esse fim.
- VPNs são redes privadas criadas entre dois pontos de extremidade em uma rede pública.

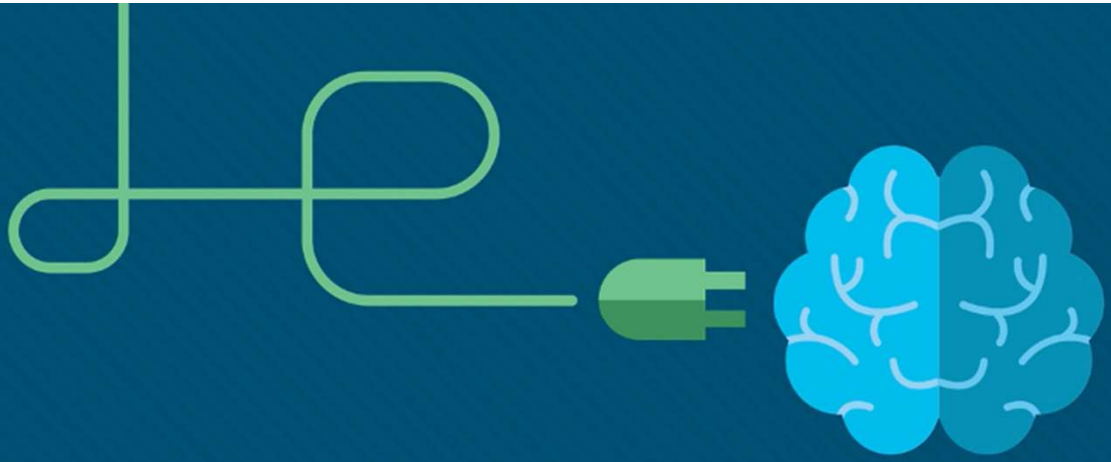
© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Módulo 6.

Novos termos e comandos

• Zona Desmilitarizada • Firewalls de política baseados em zona • Firewall de filtragem de pacotes (sem estado) • Firewall com monitoração de estado • Firewall de gateway de aplicativo • Firewall de última geração • Firewall baseado em host (servidor e pessoal) • Firewall transparente • Firewall Híbrido • Sistema de Detecção de Intrusão (IDS) • Cisco Advanced Malware Protection (AMP) • Cisco Web Security Appliance (WSA) • Cisco Email Security Appliance (ESA) • Access Control List (ACL) • ACLs padrão • ACLs estendidas	• Protocolo de Gerenciamento Simples de Rede (SNMP) • Management Information Base (MIB) • NetFlow • Espelhamento de portas • Syslog • Estrutura arquitetônica AAA • Terminal Access Controller Access-Control System Plus (TACACS+) • Remote Authentication Dial-In User Service (RADIUS) • Encapsulamento de roteamento genérico (GRE – Generic Routing Encapsulation) • Multiprotocol Label Switching (MPLS) • IPsec

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco



Módulo 7: O sistema operacional Windows



Segurança de endpoint

Objetivos do Módulo

Título do Módulo: O Sistema Operacional Windows
Objetivo do Módulo: Usar ferramentas administrativas do Windows.

Título do Tópico	Objetivo do Tópico
Histórico do Windows	Descrever a história do sistema operacional Windows.
Arquitetura e operações do Windows	Explicar a arquitetura do Windows e sua operação.
Configuração e monitoramento do Windows	Usar as ferramentas administrativas do Windows para configurar, monitorar e gerenciar os recursos do sistema.
Segurança do Windows	Explicar como o Windows pode permanecer seguro.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

7.1 A história do Windows

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Histórico do Windows

Sistema operacional de disco

```
Starting MS-DOS...
HIMEM is testing extended memory... done.
C:\> C:\DOS\SMARTDRV.EXE /X
C:\> dir
Volume in drive C is MS-DOS_6
Volume Serial Number is 4006-6939
Directory of C:\
DOS         <DIR>         05-06-17  1:09p
COMMAND  COM       54,645 05-31-94  6:22a
WINA20   386        9,349 05-31-94  6:22a
CONFIG   SYS           71 05-06-17  1:10p
AUTOEXEC BAT           78 05-06-17  1:10p
        5 file(s)         64,143 bytes
                  517,021,696 bytes free
C:\>
```

Os primeiros computadores não tinham dispositivos de armazenamento modernos, como discos rígidos, unidades ópticas ou armazenamento flash. Os primeiros métodos de armazenamento usavam cartões perfurados, fita de papel, fita magnética e até cassetes de áudio.

Disquetes e armazenamento em disco rígido exigem software para ler, gravar e gerenciar os dados que eles armazenam. O sistema operacional de disco (DOS) é um sistema operacional que o computador usa para habilitar esses dispositivos de armazenamento de dados para ler e gravar arquivos.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Histórico do Windows

Sistema operacional de disco (Cont)

- A Microsoft comprou o DOS e desenvolveu o MS-DOS.
- Com o MS-DOS, o computador tinha um conhecimento básico de trabalho de como acessar a unidade de disco e carregar os arquivos do sistema operacional diretamente do disco como parte do processo de inicialização.
- As versões anteriores do Windows consistiam em uma interface gráfica do usuário (GUI) que executava o MS-DOS.
- Para experimentar um pouco do que era trabalhar no MS-DOS, abra uma janela de comando digitando **cmd** na Pesquisa do Windows e pressionando **Enter**.
  - A tabela lista alguns comandos que você pode usar.
  - Digite **help** seguido pelo comando para saber mais sobre o comando.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Histórico do Windows

Sistema operacional de disco (Cont)

Comando MS-DOS	Descrição
dir	Mostra uma lista de todos os arquivos no diretório atual (pasta)
cd *diretório*	Altera o diretório para o diretório indicado
cd ..	Muda o diretório para o diretório acima do diretório atual
cd \	Muda o diretório para o diretório raiz (geralmente C:)
copy *origem destino*	Copia arquivos para outro local
del *nome do arquivo*	Exclui um ou mais arquivos.
find	Procura texto em arquivos
mkdir *diretório*	Cria um novo diretório.
ren *nome_antigo novo_nome*	Renomeia um arquivo
help	Exibe todos os comandos que podem ser usados, com uma breve descrição
help *comando*	Exibe a ajuda extensa para o comando indicado

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Histórico do Windows

Versões do Windows

- Desde 1993, houve mais de 20 lançamentos do Windows que são baseados no sistema operacional NT.
  - A maioria dessas versões era para uso pelo público em geral e pelas empresas devido à segurança de arquivos oferecida pelo sistema de arquivos usado pelo sistema operacional NT.

- A partir do Windows XP, uma edição de 64 bits estava disponível.
- Ele tinha um espaço de endereço de 64 bits em vez de um espaço de endereço de 32 bits.
  - Em geral, computadores e sistemas operacionais de 64 bits são compatíveis com programas mais antigos de 32 bits, mas programas de 64 bits não podem ser executados em hardware mais antigo de 32 bits.

- Com cada versão subsequente do Windows, o sistema operacional tornou-se mais refinado ao incorporar mais recursos.
  - O Windows 7 foi oferecido com seis edições diferentes, o Windows 8 com até cinco e o Windows 10 com oito edições diferentes!

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Histórico do Windows

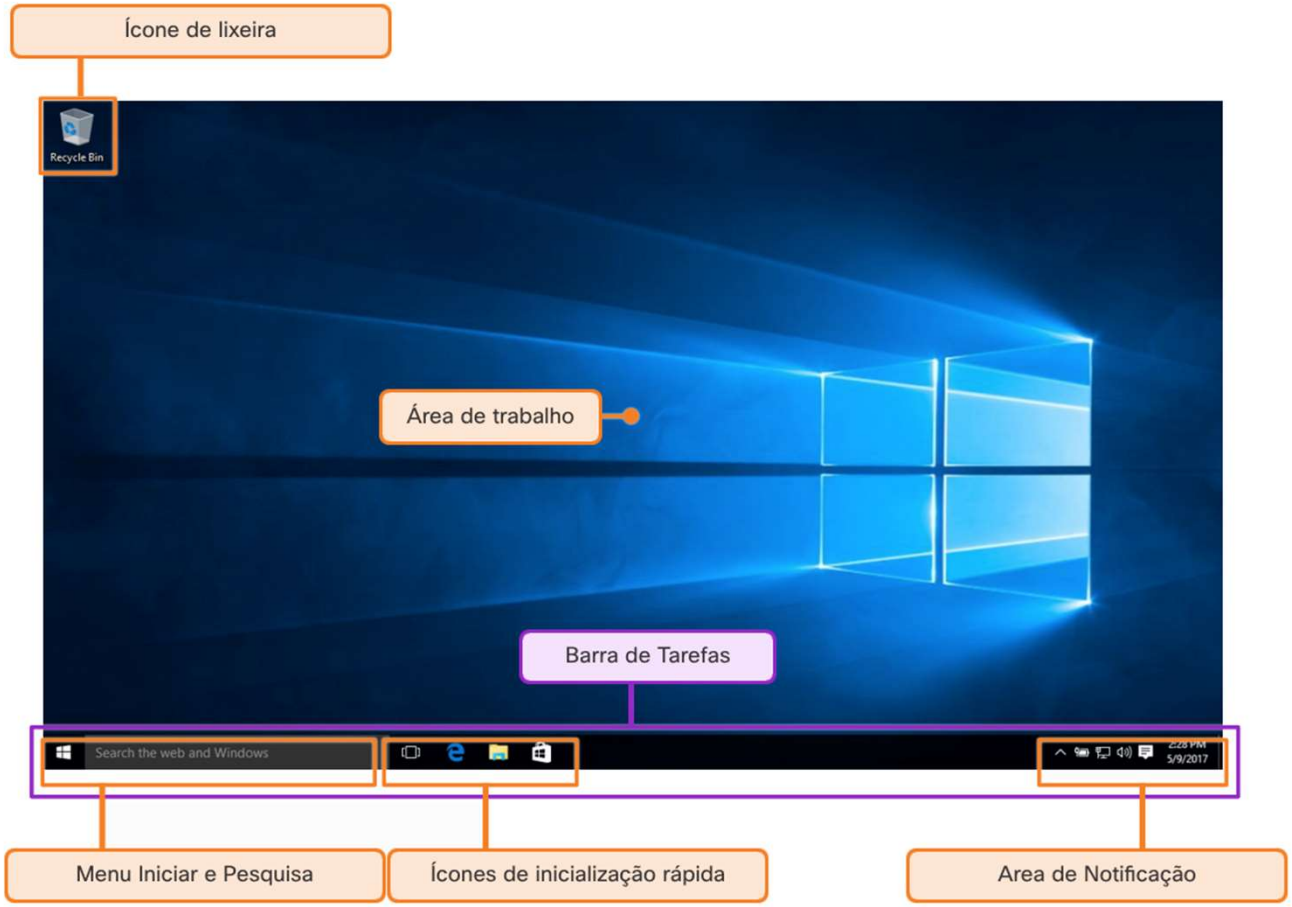
Versões do Windows (Cont.)

SO	Versões
Windows 7	Starter, Home Basic, Home Premium, Professional, Enterprise, Ultimate
Windows Server 2008 R2	Foundation, Standard, Enterprise, Datacenter, Web Server, HPC Server, Itanium-Based Systems
Windows Home Server 2011	Nenhum
Windows 8	Windows 8, Windows 8 Pro, Windows 8 Enterprise, Windows RT
Windows Server 2012	Foundation, Essentials, Standard, Datacenter
Windows 8.1	Windows 8.1, Windows 8.1 Pro, Windows 8.1 Enterprise, Windows RT 8.1
Windows Server 2012 R2	Foundation, Essentials, Standard, Datacenter
Windows 10	Home, Pro, Pro Education, Enterprise, Education, IoT Core, Mobile, Mobile Enterprise
Windows Server 2016	Essentials, Standard, Datacenter, Multipoint Premium Server, Storage Server, Hyper-V Server

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Histórico do Windows

GUI do Windows

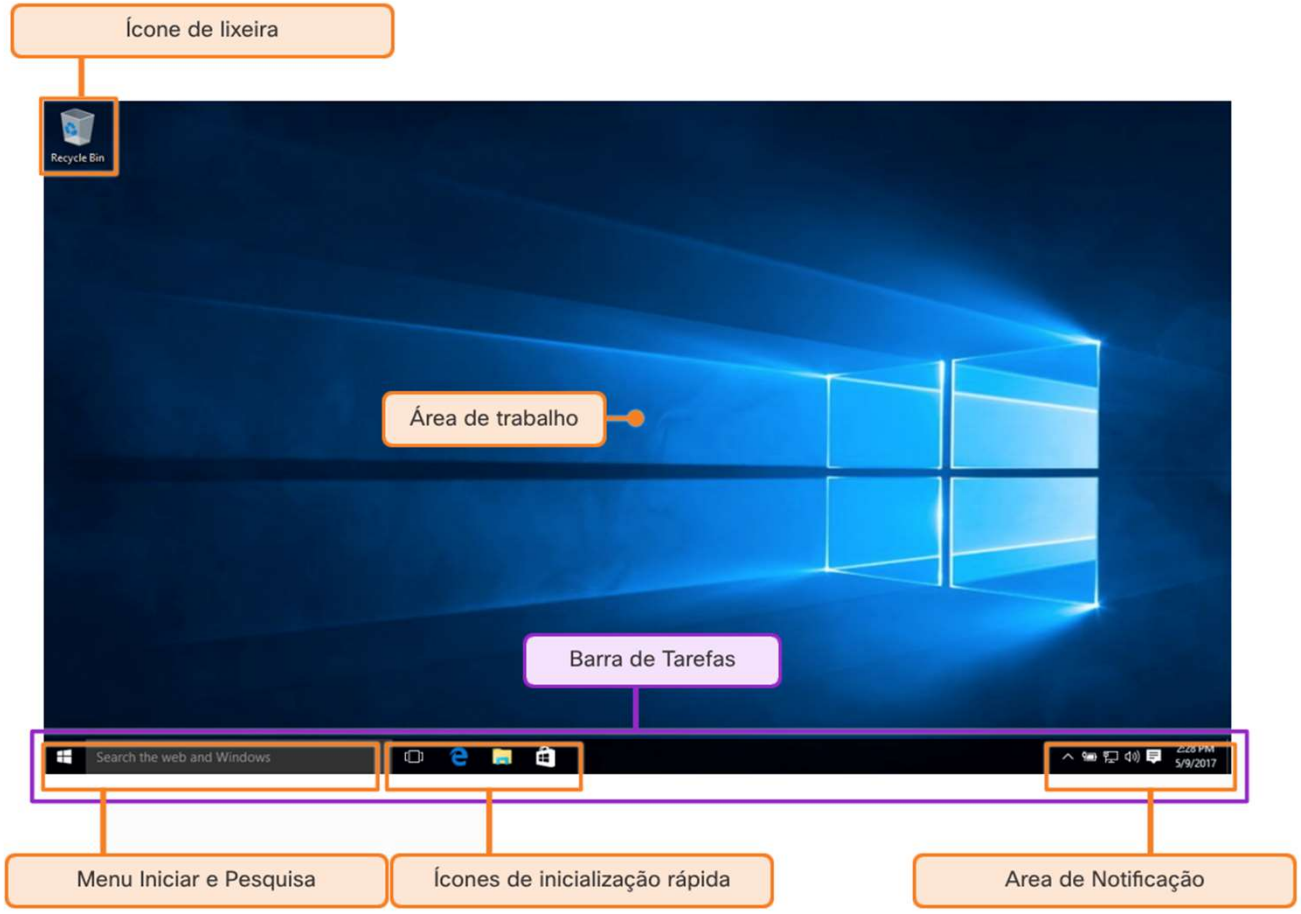


O Windows tem uma interface gráfica do usuário (GUI) para que os usuários trabalhem com arquivos de dados e software. A GUI tem uma área principal que é conhecida como Área de Trabalho, mostrada na figura.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Histórico do Windows

GUI do Windows (Cont.)

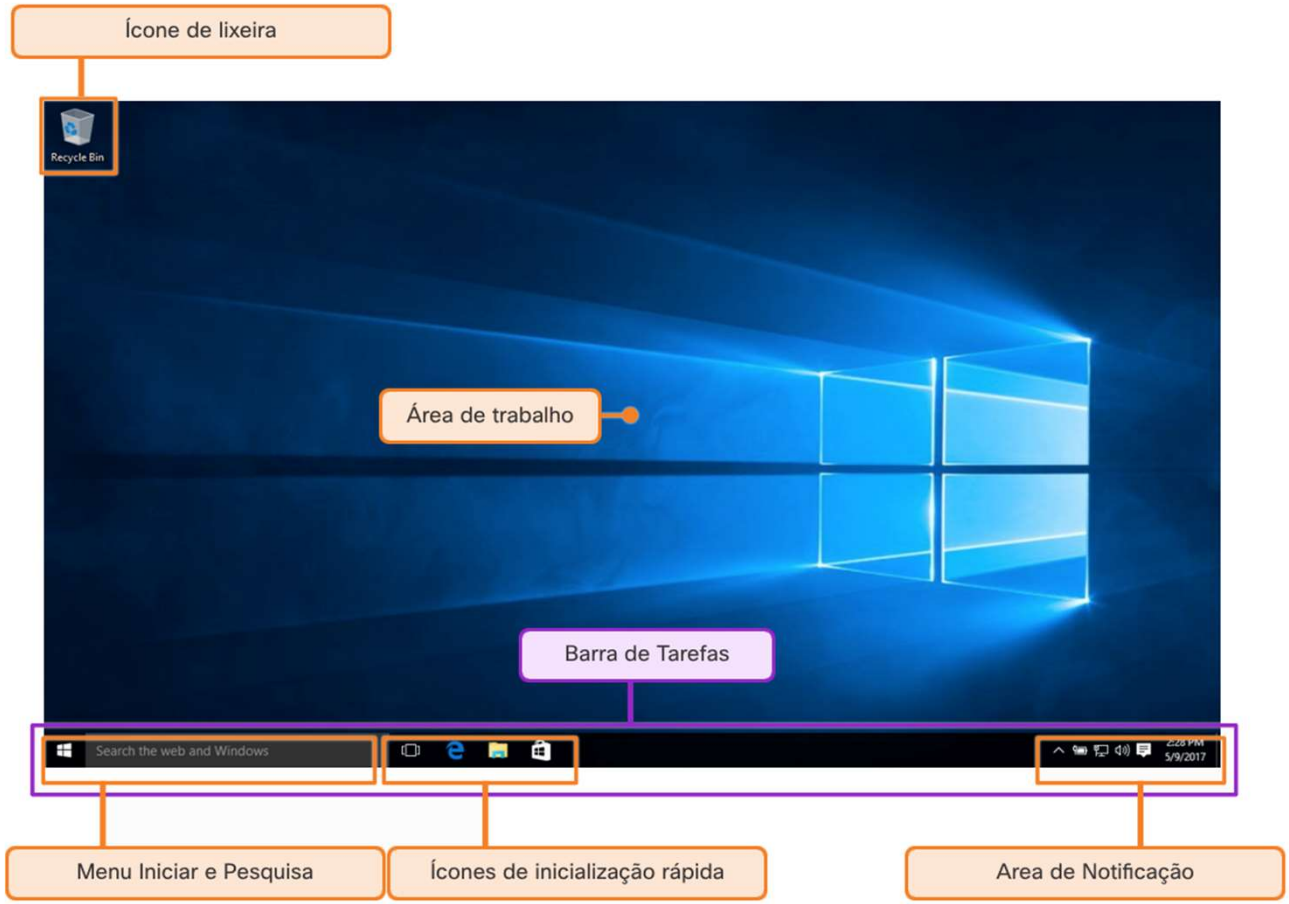


- A área de trabalho pode ser personalizada com várias cores e imagens de fundo.
- O Windows suporta vários usuários, para que cada usuário possa personalizar a Área de Trabalho ao seu gosto.
- A Área de Trabalho pode armazenar arquivos, pastas, atalhos para locais e programas e aplicativos.
- A área de trabalho também tem um ícone de lixeira, onde os arquivos são armazenados quando o usuário os exclui.
- Os arquivos podem ser restaurados da lixeira ou a lixeira pode ser esvaziada de arquivos, o que realmente os exclui.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Histórico do Windows

GUI do Windows (Cont.)

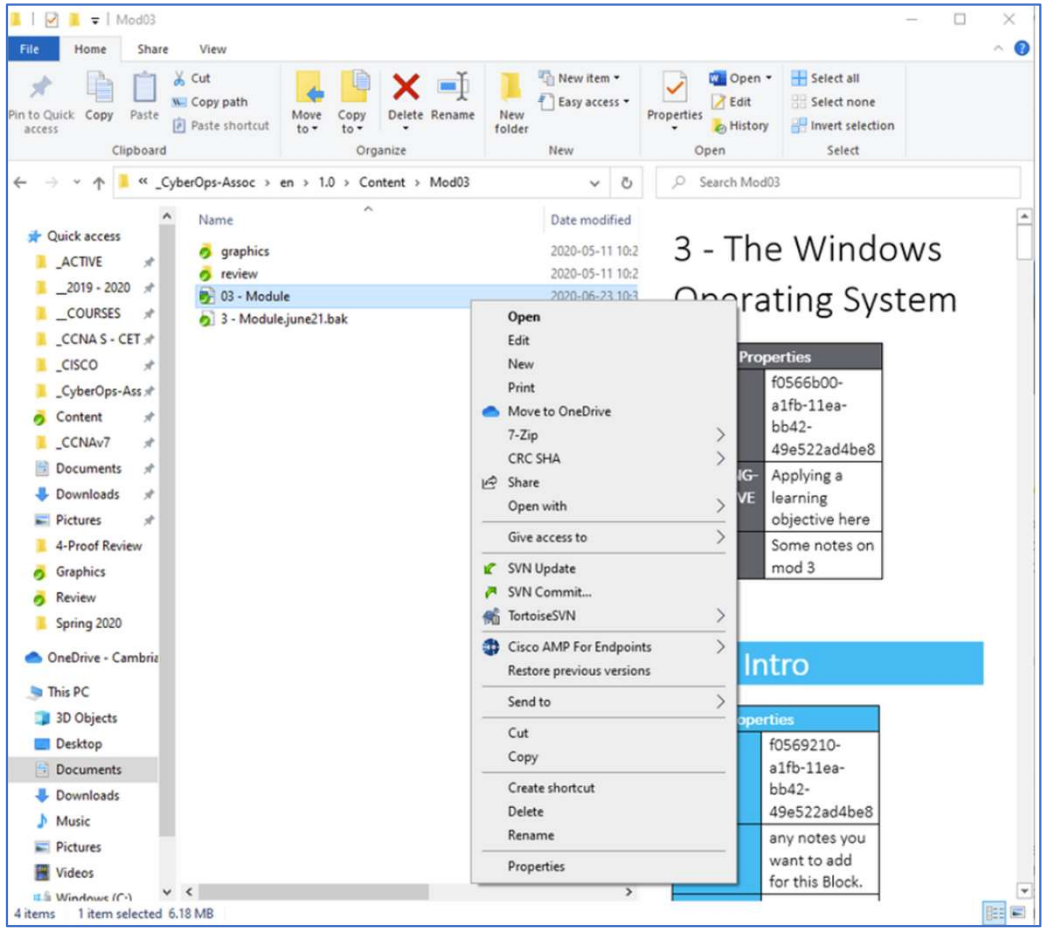


- A Barra de Tarefas tem três áreas que são usadas para diferentes fins.
- Menu Início - usado para acessar todos os programas instalados, opções de configuração e o recurso de pesquisa.
- Barra de Tarefas - usuários colocam ícones de inicialização rápida que executam programas específicos ou abrem pastas específicas quando clicam.
- Área de notificação - mostra a funcionalidade de muitos programas e recursos diferentes.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Histórico do Windows

GUI do Windows (Cont.)



Clicando com o botão direito do mouse em um ícone trará funções adicionais que podem ser usadas.

Esta lista é conhecida como um Menu de Contexto, mostrado na figura.

Há Menus de Contexto para os ícones na área de notificação, para ícones de inicialização rápida, ícones de configuração do sistema e para arquivos e pastas.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Histórico do Windows

Vulnerabilidades do Sistema Operacional

- Os sistemas operacionais consistem em milhões de linhas de código. O software instalado também pode conter milhões de linhas de código. Com todo esse código vem vulnerabilidades.
- Uma vulnerabilidade é alguma falha ou fraqueza que pode ser explorada por um invasor para reduzir a viabilidade das informações de um computador.
- Para tirar proveito de uma vulnerabilidade do sistema operacional, o invasor deve usar uma técnica ou uma ferramenta para explorar a vulnerabilidade.
- O invasor pode então usar a vulnerabilidade para fazer com que o computador atue de forma fora do design pretendido.
- Em geral, o objetivo é obter controle não autorizado do computador, alterar permissões ou manipular ou roubar dados.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Histórico do Windows

Vulnerabilidades do Sistema Operacional (Cont;)

Algumas recomendações comuns de Segurança do SO Windows.

Recomendação	Descrição
Proteção contra vírus ou malware	• Por padrão, o Windows usa o Windows Defender para proteção contra malware. • O Windows Defender fornece um conjunto de ferramentas de proteção incorporadas ao sistema. • Se o Windows Defender estiver desativado, o sistema ficará mais vulnerável a ataques e malware.
Serviços desconhecidos ou não gerenciados	• Há muitos serviços que funcionam nos bastidores. • É importante certificar-se de que cada serviço é identificável e seguro. • Com um serviço desconhecido em execução em segundo plano, o computador pode ficar vulnerável a ataques.
Criptografia	• Quando os dados não são criptografados, eles podem ser facilmente coletados e explorados. • Isso não é importante apenas para computadores desktop, mas especialmente dispositivos móveis.
Política de segurança	• Uma boa política de segurança deve ser configurada e seguida. • Muitas configurações no controle de Diretiva de Segurança do Windows podem impedir ataques.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Histórico do Windows

Vulnerabilidades do Sistema Operacional (Cont.)

Algumas recomendações comuns de Segurança do SO Windows incluem:

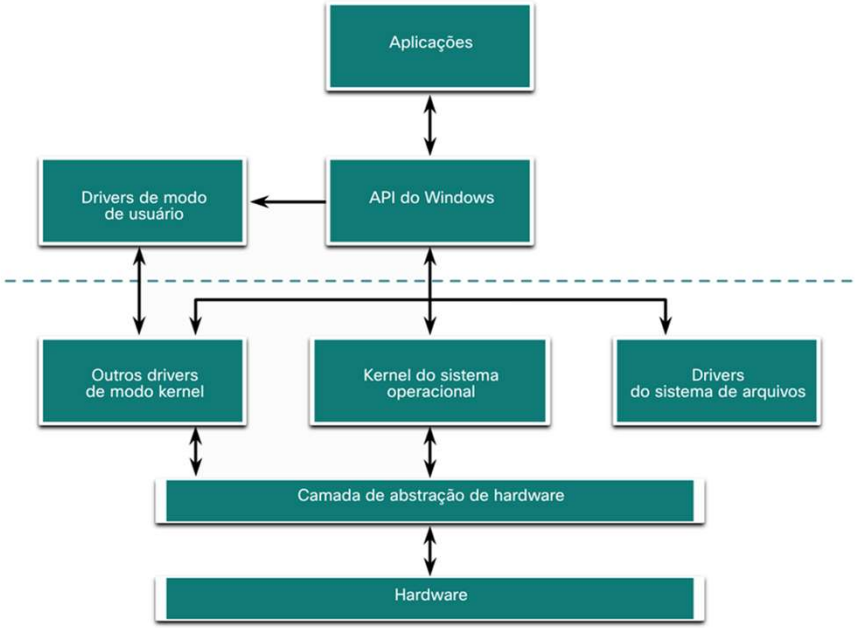
Recomendação	Descrição
Firewall	• Por padrão, o Windows usa o Firewall do Windows para limitar a comunicação com dispositivos na rede. • Com o tempo, as regras podem não se aplicar mais. • Por exemplo, uma porta pode ser deixada aberta que não deve mais estar prontamente disponível. • É importante revisar periodicamente as configurações do firewall para garantir que as regras ainda são aplicáveis e remover as que não se aplicam mais.
Permissões de arquivo e compartilhamento	• Essas permissões devem ser definidas corretamente. • É fácil dar ao grupo “Todos” Controle Total, mas isso permite que todas as pessoas façam o que quiserem com todos os arquivos. • É melhor fornecer a cada usuário ou grupo as permissões mínimas necessárias para todos os arquivos e pastas.
Senha fraca ou sem senha	• Muitas pessoas escolhem senhas fracas ou não usam nenhuma senha. • É especialmente importante certificar-se de que todas as contas, especialmente a conta de Administrador, têm uma senha muito forte.
Login como Administrador	• Quando um usuário faz logon como administrador, qualquer programa executado terá os privilégios dessa conta. • É melhor fazer login como um Usuário Padrão e usar apenas a senha de administrador para realizar determinadas tarefas.

7.2 Arquitetura e operações do Windows

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Camada de abstração de hardware

Computadores Windows usam muitos tipos diferentes de hardware. O sistema operacional pode ser instalado em um computador comprado ou em um computador que é montado pelo usuário. Quando o sistema operacional está instalado, ele deve ser isolado das diferenças no hardware. A arquitetura básica do Windows é mostrada na figura.



afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Camada de Abstração de Hardware (Cont.)

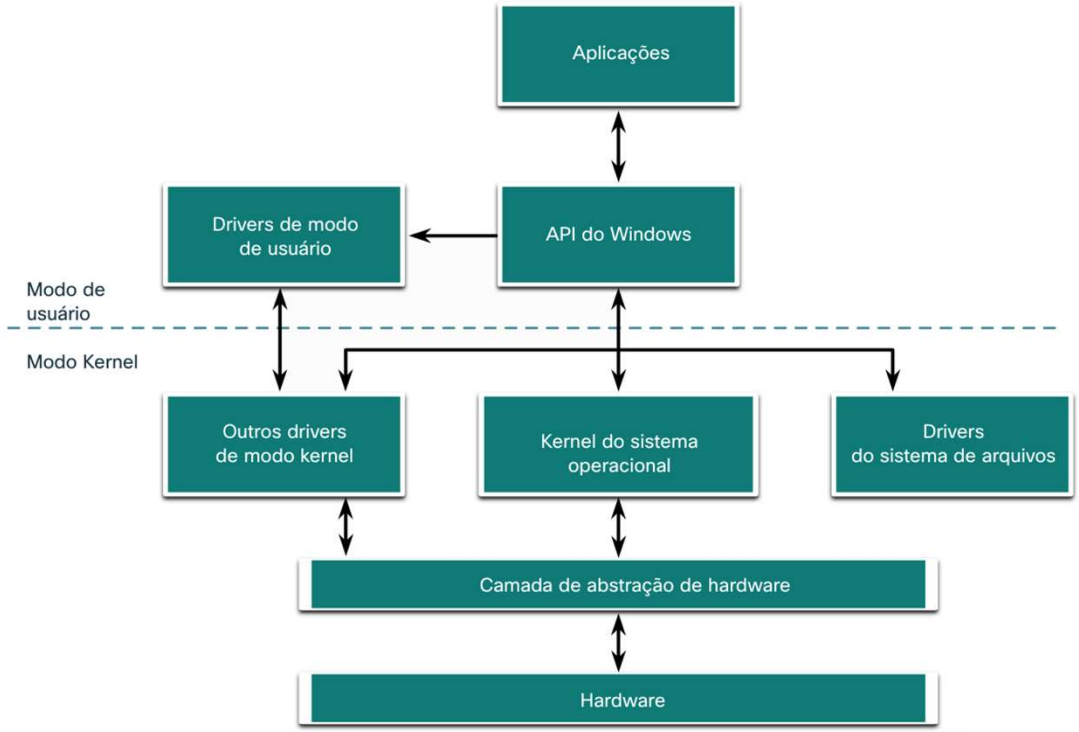
Uma camada de abstração de hardware (HAL) é um software que lida com toda a comunicação entre o hardware e o kernel. O kernel é o núcleo do sistema operacional e tem controle sobre todo o computador. Ele lida com todas as solicitações de entrada e saída, memória e todos os periféricos conectados ao computador.

Em alguns casos, o kernel ainda se comunica diretamente com o hardware, portanto não é completamente independente do HAL. O HAL também precisa do kernel para executar algumas funções.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Modo de usuário e modo kernel

Conforme identificado na figura, existem dois modos diferentes em que uma CPU opera quando o computador tem o Windows instalado: o modo de usuário e o modo kernel.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Modo de usuário e modo kernel (Cont.)

- Os aplicativos instalados são executados no modo de usuário e o código do sistema operacional é executado no modo kernel.
- O código que está sendo executado no modo kernel tem acesso irrestrito ao hardware subjacente e é capaz de executar qualquer instrução de CPU.
- O código do modo kernel também pode referenciar qualquer endereço de memória diretamente.
- O código executado no modo kernel usa o mesmo espaço de endereço e não tem isolamento do sistema operacional.
- Quando o código de modo de usuário é executado, ele é concedido seu próprio espaço de endereço restrito pelo kernel, juntamente com um processo criado especificamente para o aplicativo.
- A razão para essa funcionalidade é principalmente para impedir que aplicativos alterem o código do sistema operacional que está sendo executado ao mesmo tempo.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Sistemas de arquivos Windows

Sistema de Arquivos Windows	Descrição
exFAT	• Este é um sistema de arquivos simples suportado por muitos sistemas operacionais diferentes. • O FAT tem limitações para o número de partições, tamanhos de partições e tamanhos de arquivo que pode resolver, portanto, não é mais usado para discos rígidos (HDs) ou unidades de estado sólido (SSDs). • Tanto o FAT16 quanto o FAT32 estão disponíveis para uso, sendo o FAT32 o mais comum porque tem muito menos restrições do que o FAT16.
Sistema de Arquivos Hierárquico Plus (HFS+)	• Este sistema de arquivos é usado em computadores MAC OS X e permite nomes de arquivos, tamanhos de arquivo e tamanhos de partição muito mais longos do que os sistemas de arquivos anteriores. • Embora não seja suportado pelo Windows sem software especial, o Windows é capaz de ler dados de partições HFS+.
Sistema de arquivos estendido (EXT)	• Este sistema de arquivos é usado com computadores baseados em Linux. • Embora não seja suportado pelo Windows, o Windows é capaz de ler dados de partições EXT com software especial.
New Technology File System (NTFS)	• Este é o sistema de arquivos mais comumente usado ao instalar o Windows. Todas as versões do Windows e Linux suportam NTFS. • Computadores Mac-OS X só podem ler uma partição NTFS. Eles são capazes de gravar em uma partição NTFS depois de instalar drivers especiais.

Sistemas de arquivos Windows (Cont.)

O NTFS é o sistema de arquivos mais utilizado para Windows por muitas razões.

- Suporta arquivos e partições muito grandes e é muito compatível com outros sistemas operacionais.
- Muito confiável e oferece suporte a recursos de recuperação.
- Suporta muitos recursos de segurança

Antes que um dispositivo de armazenamento, como um disco, possa ser usado, ele deve ser formatado com um sistema de arquivos. Por sua vez, antes que um sistema de arquivos possa ser colocado em prática em um dispositivo de armazenamento, o dispositivo precisa ser particionado.

- Um disco rígido é dividido em áreas denominadas partições.
- Cada partição é uma unidade lógica de armazenamento que pode ser formatada para armazenar informações, como arquivos de dados ou de aplicações.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Sistemas de arquivos Windows (Cont.)

A formatação NTFS cria estruturas importantes no disco para armazenamento de arquivos e tabelas para gravar os locais dos arquivos:

- **Setor de inicialização da partição** - São os primeiros 16 setores da unidade. Ele contém o local da tabela de arquivos mestre (MFT). Os últimos 16 setores contêm uma cópia do setor de inicialização.
- **Master File Table (MFT)** - Esta tabela contém os locais de todos os arquivos e diretórios na partição , incluindo atributos de arquivo, como informações de segurança e carimbos de data/hora.
- **Arquivos de sistema** - São arquivos ocultos que armazenam informações sobre outros volumes e atributos de arquivo.
- **Área do Arquivo** - A área principal da partição onde os arquivos e diretórios são armazenados.

Nota: Ao formatar uma partição, os dados anteriores ainda podem ser recuperados porque nem todos os dados são completamente removidos. O espaço livre pode ser examinado e os arquivos podem ser recuperados, o que pode comprometer a segurança. Recomenda-se executar um apagamento seguro em uma unidade que está sendo reutilizada. O apagamento seguro grava dados em toda a unidade várias vezes para garantir que não haja dados restantes.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Fluxos de dados alternativos

```
C:\ADS> echo "Alternate Data Here" > Testfile.txt:ADS
C:\ADS> dir
 Volume in drive C is Windows
 Volume Serial Number is A606-CB1B
 Directory of C:\ADS
2020-04-28  04:01 PM    <DIR>          .
2020-04-28  04:01 PM    <DIR>          ..
2020-04-28  04:01 PM                 0 Testfile.txt
               1 File(s)              0 bytes
               2 Dir(s)  43,509,571,584 bytes free
C:\ADS> more < Testfile.txt:ADS
"Alternate Data Here"
C:\ADS> dir /r
 Volume in drive C is Windows
 Volume Serial Number is A606-CB1B
 Directory of C:\ADS
2020-04-28  04:01 PM    <DIR>          .
2020-04-28  04:01 PM    <DIR>          ..
2020-04-28  04:01 PM                 0 Testfile.txt
                                    24 Testfile.txt:ADS:$DATA
               1 File(s)              0 bytes
               2 Dir(s)  43,509,624,832 bytes free
C:\ADS>
```

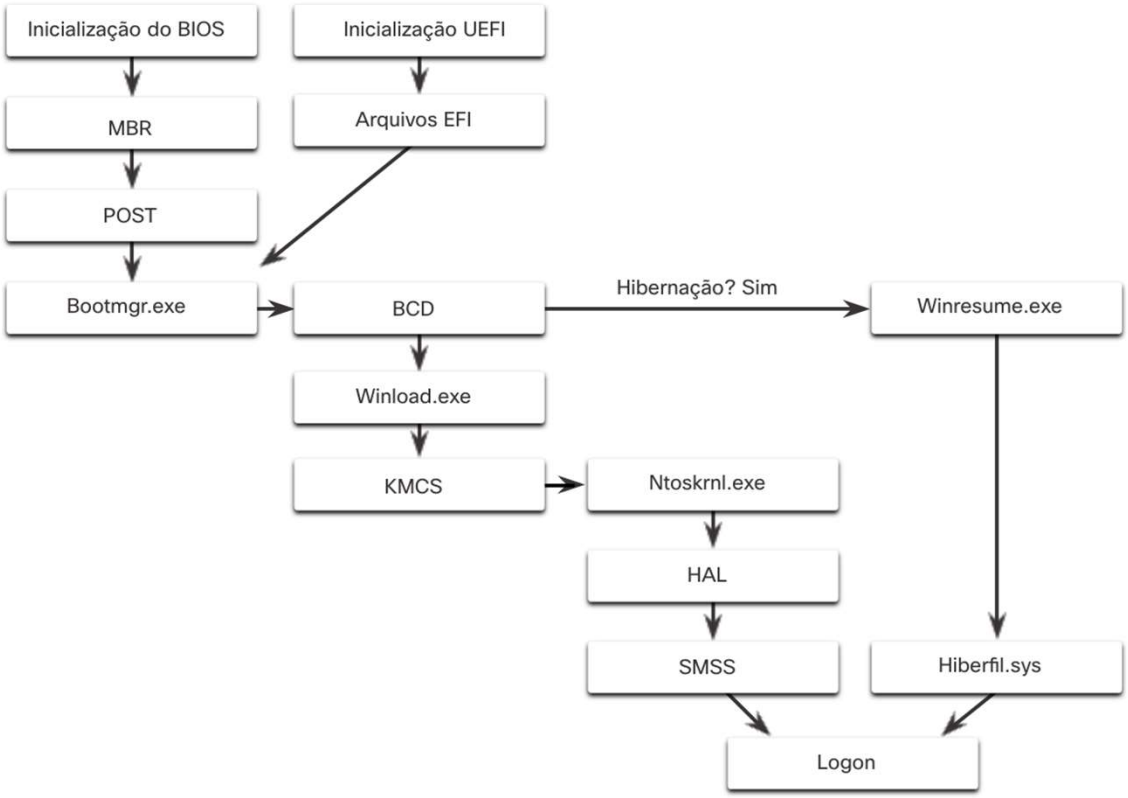
NTFS armazena arquivos como uma série de atributos, como o nome do arquivo ou um carimbo de data/hora. Os dados que o arquivo contém são armazenados no atributo $DATA, e é conhecido como um fluxo de dados. Usando NTFS, você pode conectar fluxos de dados alternativos (ADSs) ao arquivo.

No sistema de arquivos NTFS, um arquivo com um ADS é identificado após o nome do arquivo e dois pontos, por exemplo,Testfile.txt:ADS. Este nome de arquivo indica que um ADS está associado ao arquivo chamado Testfile.txt. Um exemplo de ADS é mostrado na saída do comando.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Processo de Inicialização do Windows

Muitas ações ocorrem entre o momento em que o botão liga/desliga do computador é pressionado e o Windows está totalmente carregado, como mostrado na figura. Isso é conhecido como o processo de inicialização do Windows.



direitos reservados. Documento confidencial da Cisco

Processo de Inicialização do Windows (Cont.)

Existem dois tipos de firmware de computador:

- **Sistema básico de entrada-saída (BIOS)** - O firmware do BIOS foi criado no início da década de 1980 e funciona da mesma forma que quando foi criado. À medida que os computadores evoluíram, tornou-se difícil para o firmware do BIOS suportar todos os novos recursos solicitados pelos usuários.

- **UEFI (Unified Extensible Firmware Interface)** - O UEFI foi projetado para substituir o BIOS e suportar os novos recursos.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Processo de Inicialização do Windows (Cont.)

Processo de inicialização do firmware do BIOS:

- O processo começa com a fase de inicialização do BIOS - é quando os dispositivos de hardware são inicializados e um autoteste de inicialização (POST) é executado para garantir que esses dispositivos estejam se comunicando.
- Quando o disco do sistema é descoberto, o POST termina.
- A última instrução no POST é procurar o registro mestre de inicialização (MBR).
- A MBR contém um pequeno programa que é responsável por localizar e carregar o sistema operacional.
- O BIOS executa esse código e o sistema operacional começa a carregar.

Processo de inicialização do firmware UEFI:

- O UEFI inicializa carregando arquivos de programa EFI, armazenados como arquivos.efi em uma partição de disco especial, conhecida como EFI System Partition (ESP).

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Processo de Inicialização do Windows (Cont.)

Processo de inicialização para BIOS ou UEFI após a localização de uma instalação válida do Windows:

- O arquivo Bootmgr.exe é executado.
- Bootmgr.exe l ê o banco de dados de configuração de inicialização (BCD).
  - O BCD contém qualquer código adicional necessário para iniciar o computador, juntamente com uma indicação de se o computador está saindo da hibernação ou se este é um arranque a frio.
- Se o computador estiver saindo da hibernação, o processo de inicialização c ontinuará com o Winresume.exe.
  - Isso permite que o computador leia o arquivo Hiberfil.sys que contém o estado do computador quando foi colocado em hibernação.
- Se o computador estiver sendo inicializado a partir de um início a frio, o arquivoWinload.exeserá carregado.
  - O arquivo Winload.exe cria um registro da configuração de hardware no registro.
  - O registro é um registro de todas as configurações, opções, hardware e software do computador.
- Depois que os drivers forem examinados, o Winload.exe executa o Ntoskrnl.exe , que inicia o kernel do Windows e configura o HAL.
- O Subsistema do Gestor de Sessões (SMSS) lê o registro para criar o ambiente do utilizador, iniciar o serviço Winlogon e preparar a área de trabalho de cada utilizador à medida que inicia sessão.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Inicialização do Windows

- Há dois itens de registro importantes que são usados para iniciar automaticamente aplicativos e serviços:
  - **HKEY_LOCAL_MACHINE** - Vários aspectos da configuração do Windows são armazenados nesta chave, incluindo informações sobre serviços que iniciam com cada inicialização.
  - **HKEY_CURRENT_USER** - Vários aspectos relacionados ao usuário logado são armazenados nesta chave, incluindo informações sobre serviços que iniciam somente quando o usuário faz logon no computador.

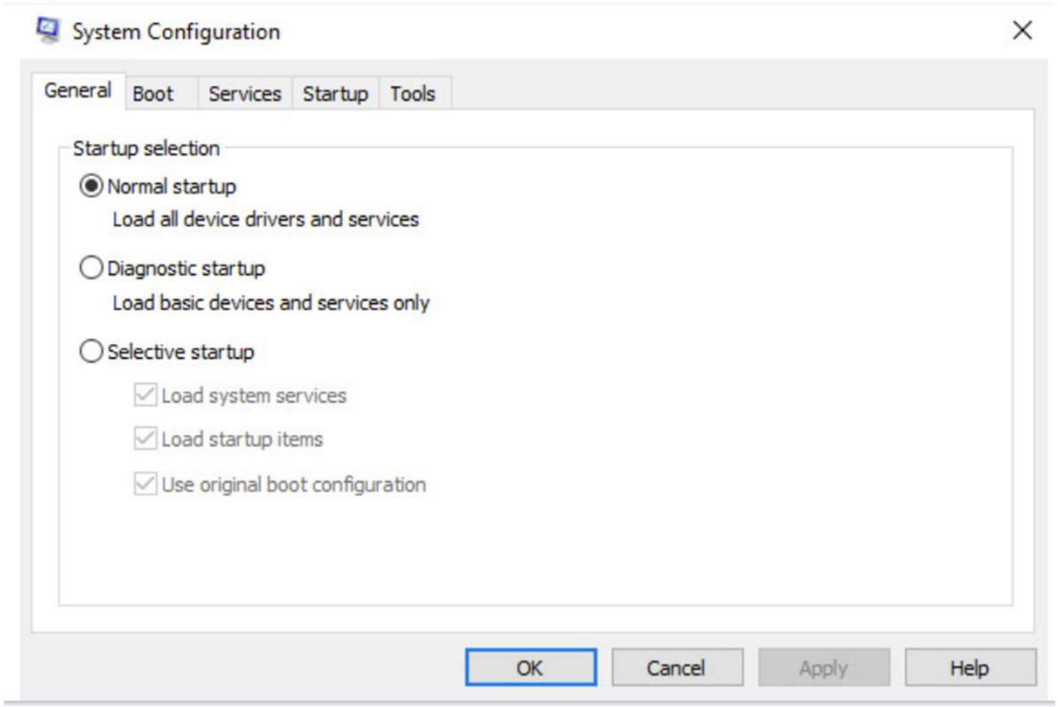
- Entradas diferentes nesses locais de registro definem quais serviços e aplicativos serão iniciados, conforme indicado pelo tipo de entrada.

- Esses tipos incluem Run, RunOnce, RunServices, RunServicesOnce e Userinit.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Inicialização do Windows (Cont.)

A ferramenta Msconfig abre a janela de Configuração do sistema. Existem cinco guias que contêm as opções de configuração: **Geral, Inicialização, Serviços, Inicialização e Ferramentas.**

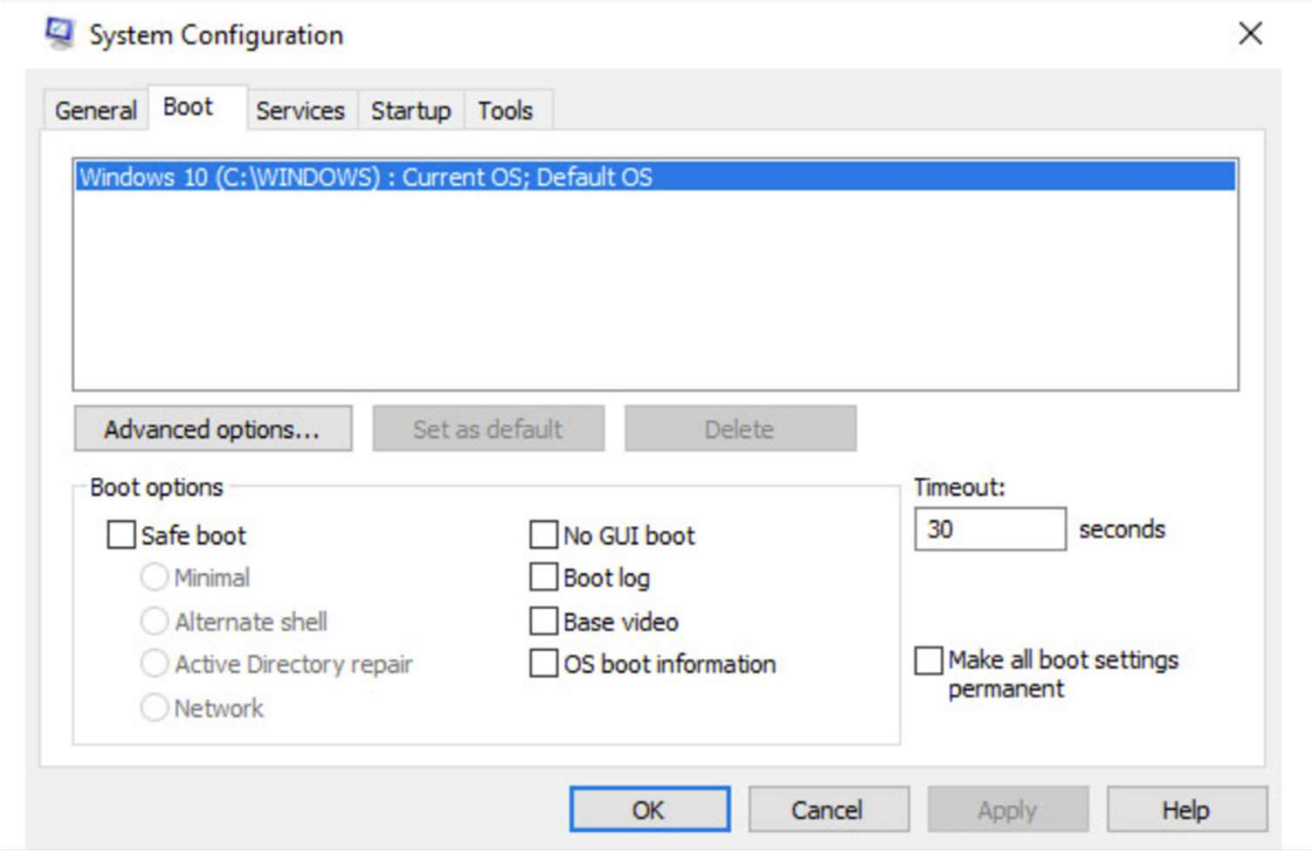


Geral: Três tipos de inicialização diferentes podem ser escolhidos aqui**:**

- Normal carrega todos os drivers e serviços.
- Diagnóstico carrega apenas drivers e serviços básicos.
- Seletivo permite que o usuário escolha o que carregar na inicialização.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Inicialização do Windows (Cont.)

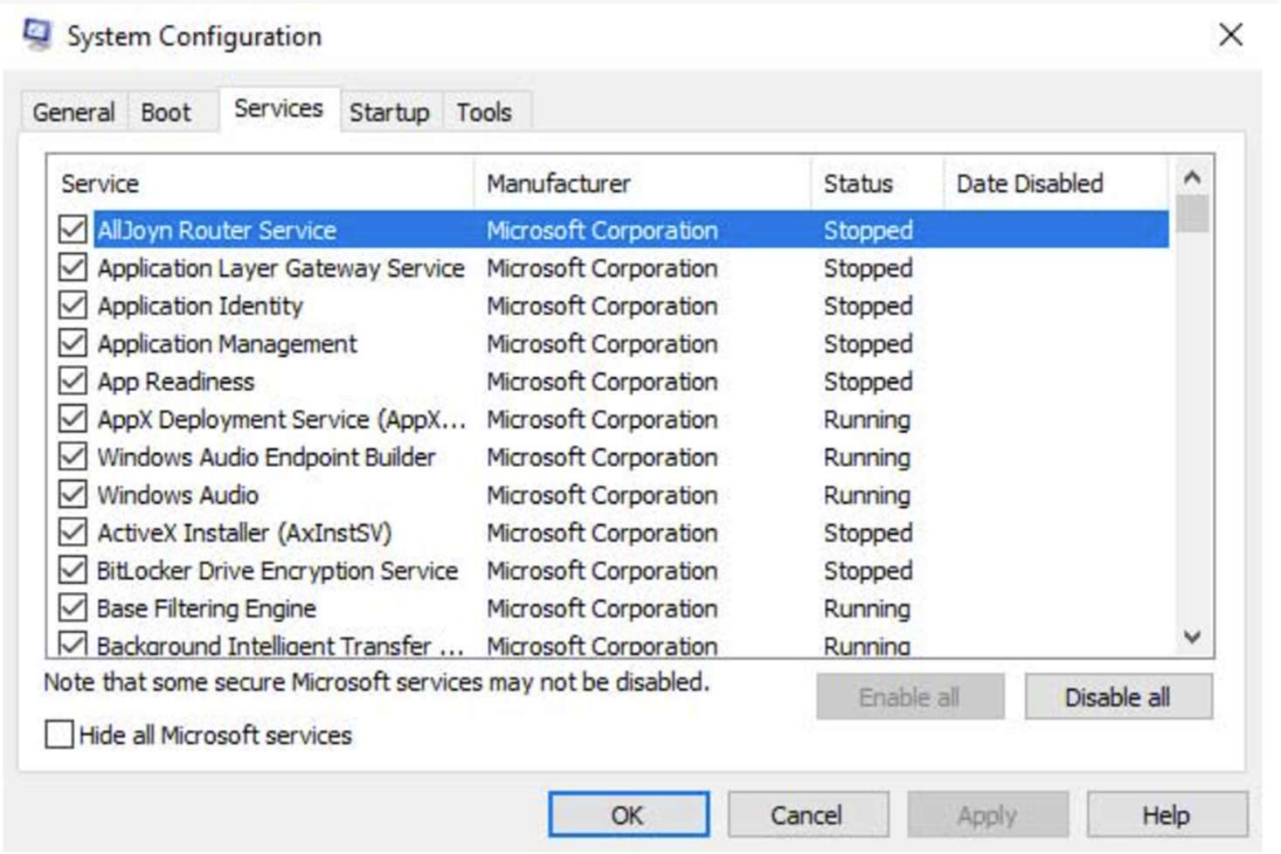


Boot: Qualquer sistema operacional instalado pode ser escolhido aqui para iniciar.

Existem também opções para a inicialização segura, que é usada para solucionar problemas de inicialização.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

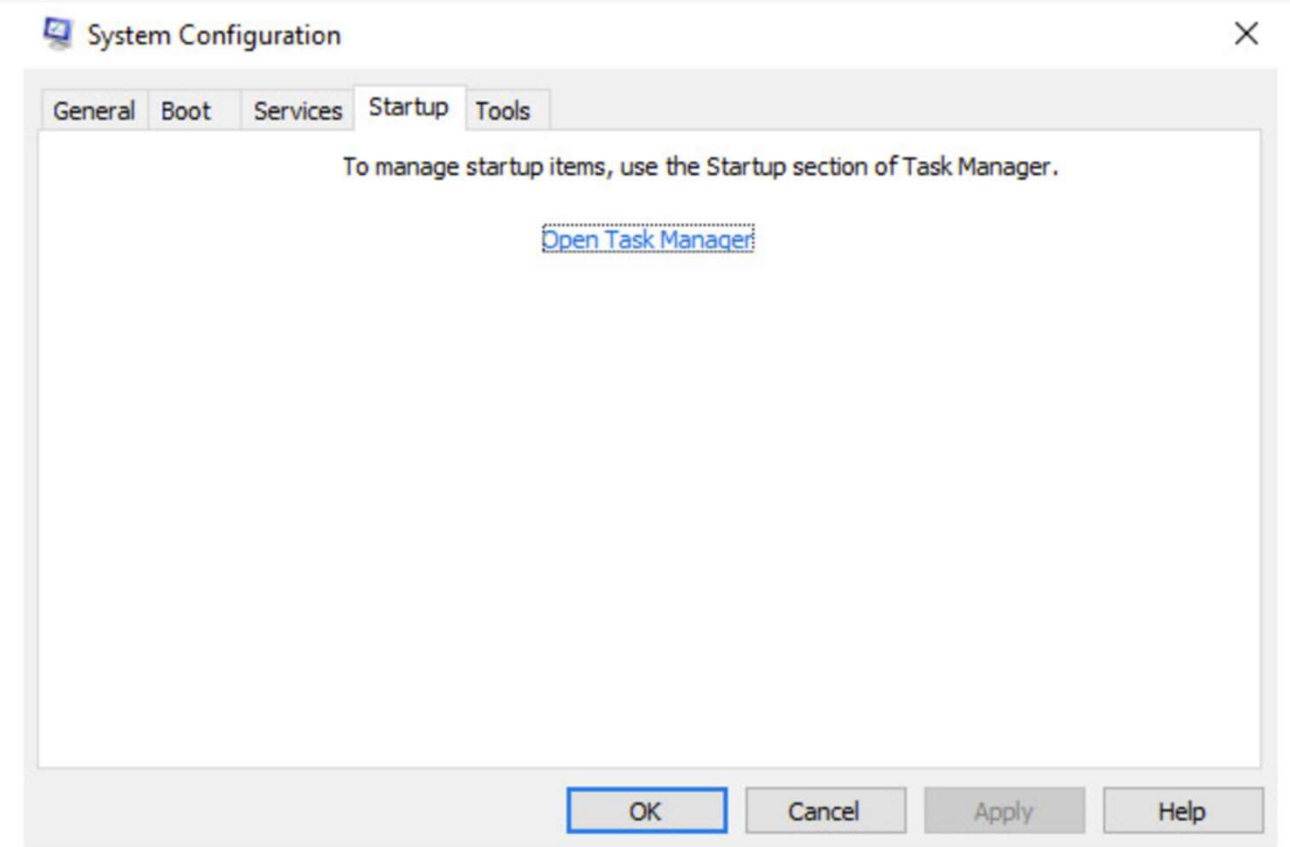
Inicialização do Windows (Cont.)



Serviços: Todos os serviços instalados estão listados aqui para que possam ser escolhidos para iniciar na inicialização.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

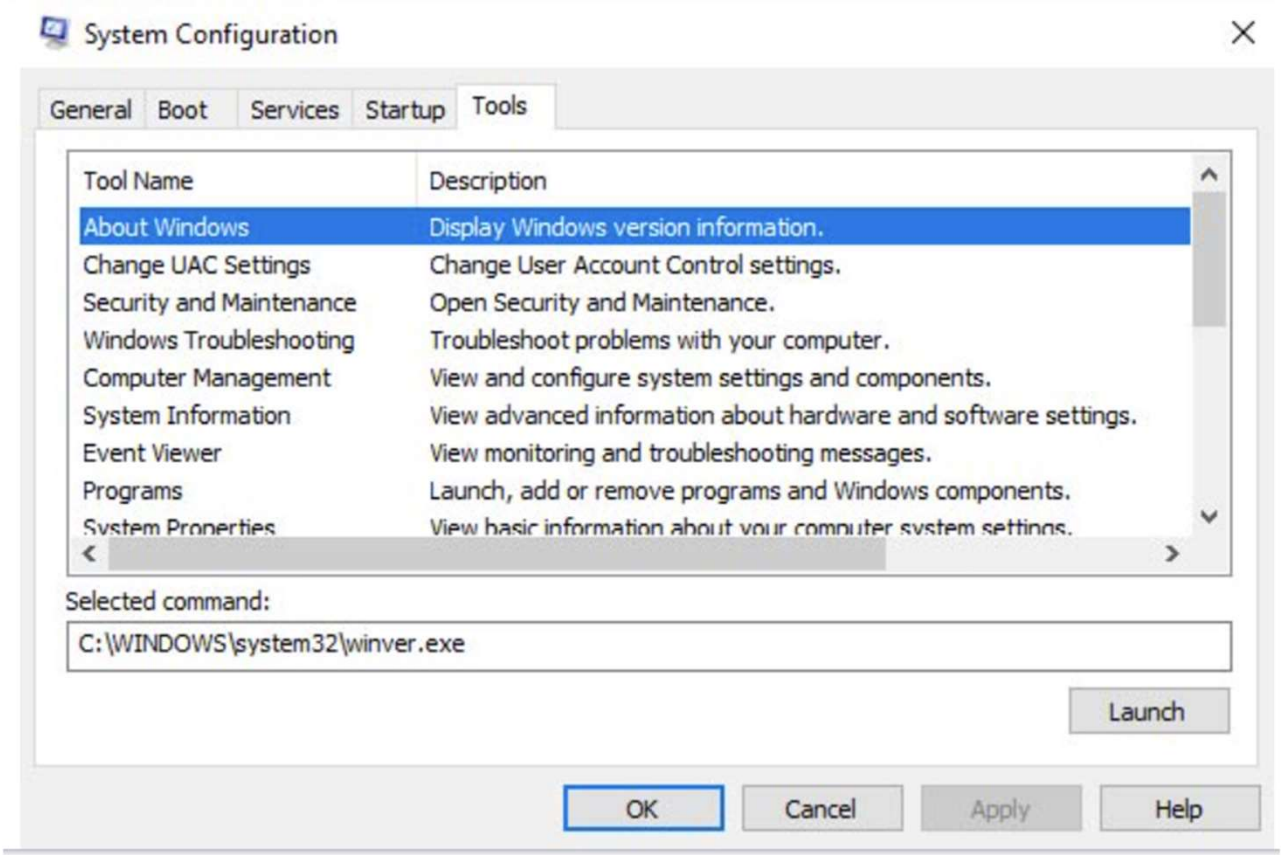
Inicialização do Windows (Cont.)



Inicialização: Todos os aplicativos e serviços configurados para iniciar automaticamente na inicialização podem ser ativados ou desabilitados abrindo o gerenciador de tarefas a partir desta guia.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Inicialização do Windows (Cont.)



Ferramentas: Muitas ferramentas comuns do sistema operacional podem ser iniciadas diretamente a partir desta guia.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Desligamento do Windows

- É sempre melhor executar um desligamento adequado para desligar o computador.
  - Arquivos que são deixados abertos, serviços que são fechados fora de ordem e aplicativos que travam podem ser danificados se a energia for desligada sem primeiro informar o sistema operacional.
  - Durante o desligamento, o computador fechará os aplicativos do modo de usuário primeiro, seguido pelos processos do modo kernel.

- Existem várias maneiras de desligar um computador Windows: opções de energia do menu Iniciar, o comando shutdown da linha de comando e usando Ctrl+Alt+Delete e clicando no ícone de energia.

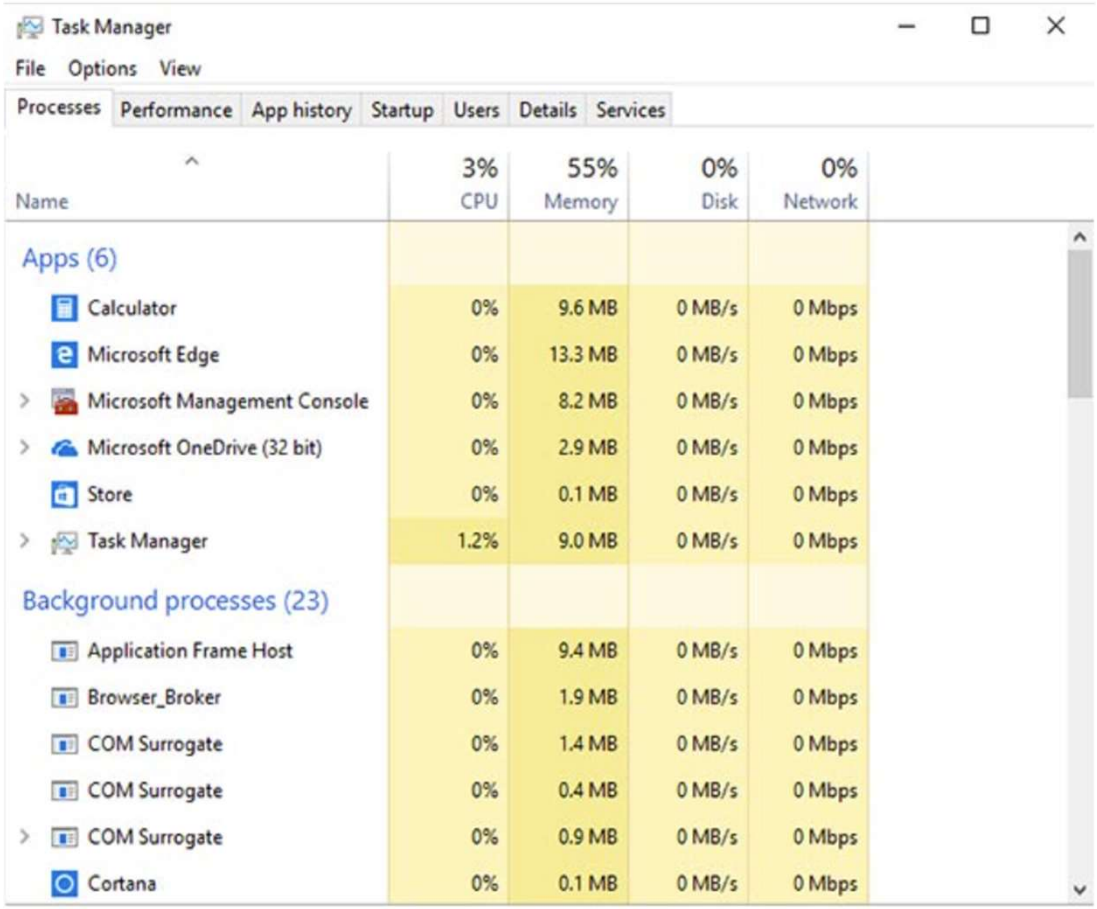
Três opções para desligar o computador incluem:

- **Desligar** (Shutdown) - Desliga o computador.
- **Reiniciar** (Restart) - Reinicia o computador (desliga e liga).
- **Hibernar** (Hibernate) - Registra o estado atual do computador e do ambiente do usuário e o armazena em um arquivo. A hibernação permite que os usuários retomem exatamente de onde pararam muito rapidamente, com todos os seus arquivos e programas ainda abertos.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Arquitetura e operações do Windows

Processos, Threads e Serviços



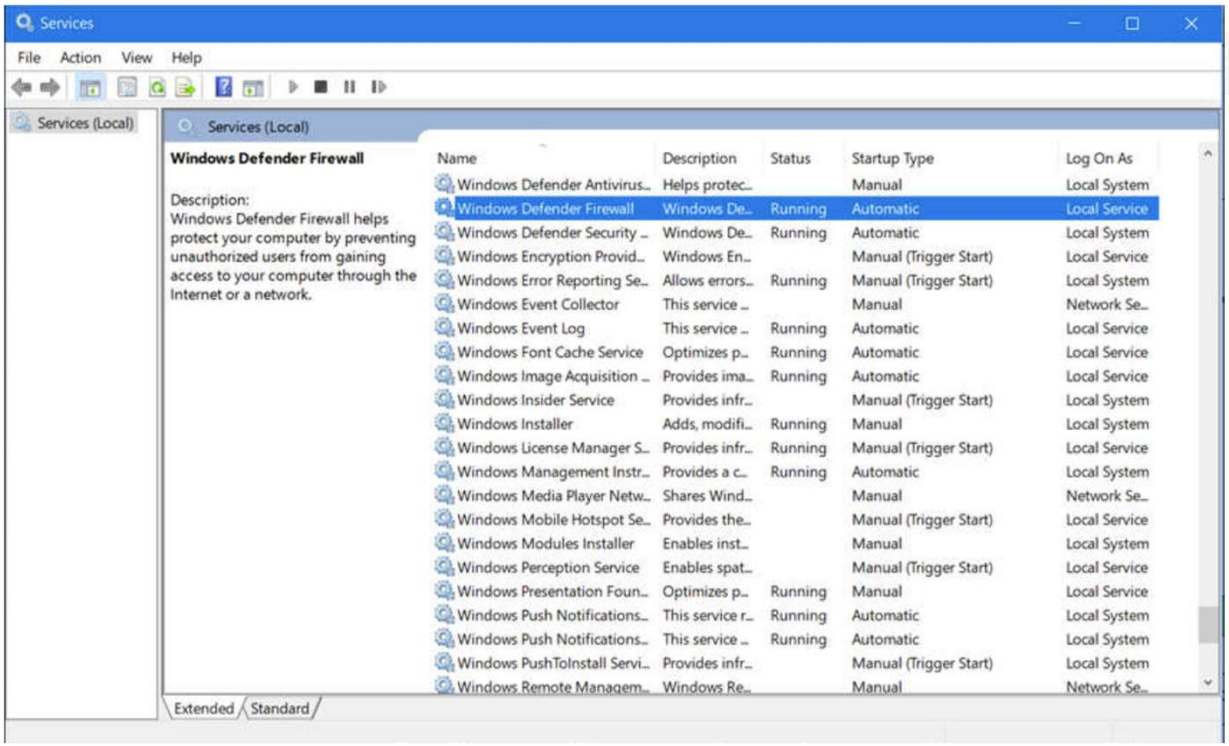
Um aplicativo do Windows é composto de processos. O aplicativo pode ter um ou muitos processos dedicados a ele. Um processo é qualquer programa em execução no momento.

Cada processo que é executado é composto de pelo menos um thread. Um thread é uma parte do processo que pode ser executado. O processador executa cálculos na thread.

Para configurar processos do Windows, procure o Gerenciador de Tarefas.A guia Processos do Gerenciador de Tarefas é mostrada na figura.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Processos, Threads e Serviços



As threads dedicados a um processo estão contidos no mesmo espaço de endereço. Isso impede a corrupção de outros processos Como Windows é multitarefas, várias threads podem ser executados ao mesmo tempo.

Alguns dos processos executados pelo Windows são serviços. Os serviços fornecem funcionalidade de longa execução, como sem fio ou acesso a um servidor FTP.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

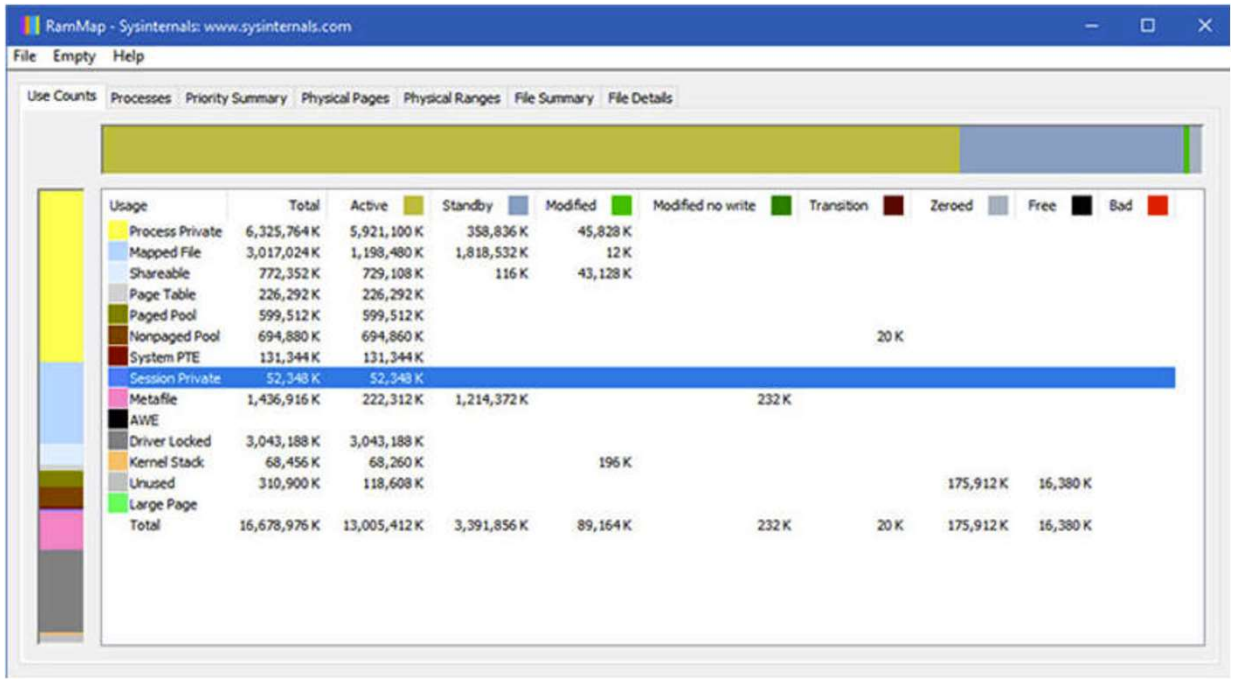
Alocação e identificadores de memória

- Um computador funciona armazenando instruções na RAM até que a CPU os processe.
- O espaço de endereço virtual para um processo é o conjunto de endereços virtuais que o processo pode usar.
  - Cada processo em um computador Windows de 32 bits suporta um espaço de endereço virtual que permite endereçar até 4 gigabytes.
  - Cada processo num computador Windows de 64 bits suporta um espaço de endereço virtual de 8 terabytes.

- Cada processo de espaço do usuário é executado em um espaço de endereço privado, separado de outros processos de espaço do usuário.
  - Quando o processo de espaço do usuário precisa acessar recursos do kernel, ele deve usar um identificador de processo.
  - O identificador do processo fornece o acesso necessário ao processo do espaço do usuário sem uma conexão direta com o recurso do kernel.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Alocação e Identificadores de memória (Cont.)



Uma ferramenta poderosa para visualizar a alocação de memória é RAMMap, que é mostrado na figura.

RAMMap fornece uma riqueza de informações sobre como o Windows alocou memória do sistema para o kernel, processos, drivers e aplicativos.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

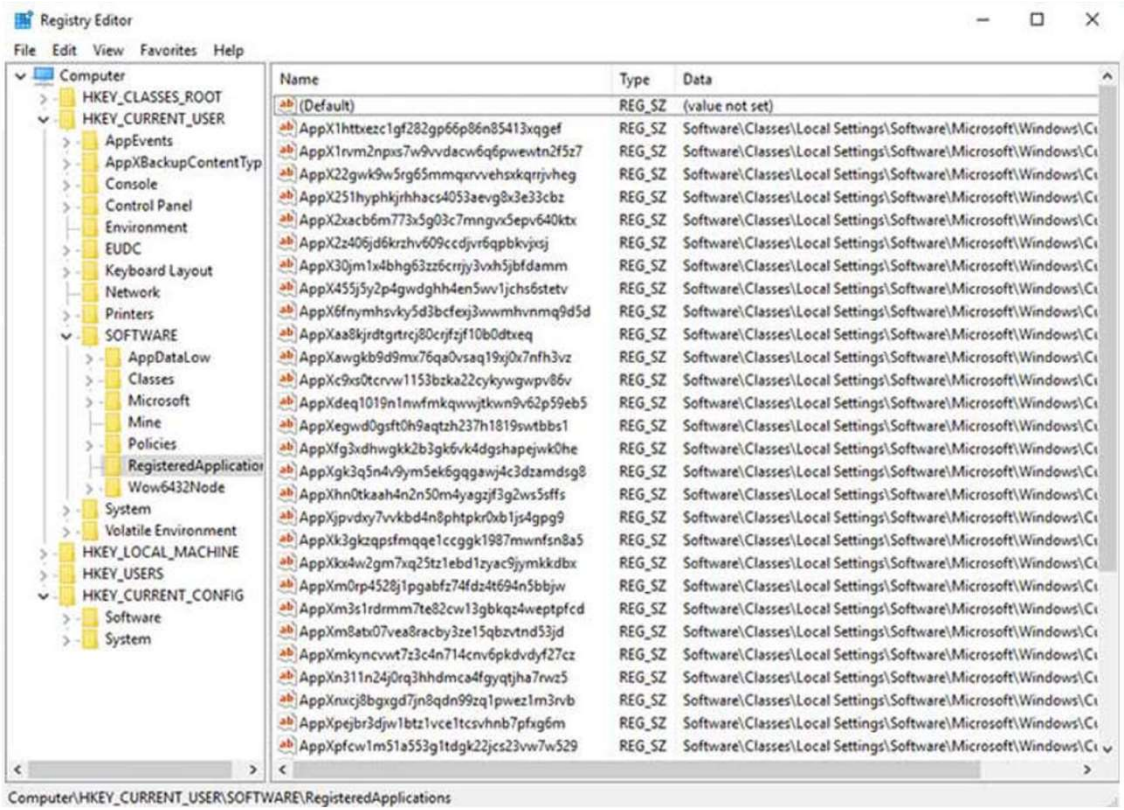
O Registro do Windows

O Windows armazena informações sobre hardware, aplicativos, usuários e configurações do sistema em um banco de dados grande conhecido como Registro. As formas como esses objetos interagem também são registradas, como quais arquivos um aplicativo abre e todos os detalhes de propriedade de pastas e aplicativos. O registro é um banco de dados hierárquico onde o nível mais alto é conhecido como um ramo, abaixo que existem chaves, seguido por subchaves. Os valores armazenam dados e são armazenados nas chaves e subchaves. Uma chave do Registro pode ter até 512 níveis de profundidade.

Hive do Registro	Descrição
HKEY_CURRENT_USER (HKCU)	Contém informações sobre o usuário conectado no momento.
HKEY_USERS (HKU)	Contém informações relativas a todas as contas de usuário no host.
HKEY_CLASSES_ROOT (HKCR)	Contém informações sobre registros OLE (vinculação e incorporação de objetos). OLE permite que os usuários incorporem objetos de outros aplicativos (como uma planilha) em um único documento (como um documento do Word).
HKEY_LOCAL_MACHINE (HKLM)	Contém informações relacionadas ao sistema.
HKEY_CURRENT_CONFIG (HKCC)	Contém informações sobre o perfil de hardware atual.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

O Registro do Windows (Cont.)



Novas seções (hives) não podem ser criadas. As chaves do Registro e os valores nas seções podem ser criados, modificados ou excluídos por uma conta com privilégios administrativos.

Como mostrado na figura,
af erramenta **regedit.exe** usada para modificar o registro. Tenha muito cuidado ao usar esta ferramenta. Alterações menores no registro podem ter efeitos maciços ou mesmo catastróficos.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

O Registro do Windows (Cont.)

- Use o painel esquerdo para navegar nas seções (hives) e na estrutura abaixo dele e use o painel direito para ver o conteúdo do item realçado no painel esquerdo.

- As chaves do Registro podem conter uma subchave ou um valor. Os diferentes valores que as chaves podem conter são os seguintes:
  - **REG_BINARY** - Números ou valores booleanos
  - **REG_DWORD** - Números maiores que 32 bits ou dados brutos
  - **REG_SZ** - Valores de string

- Como o registro contém quase toda infomação do sistema operacional e do usuário, é essencial garantir que ele não seja comprometido.
  - Aplicativos potencialmente mal-intencionados podem adicionar chaves do Registro para que elas sejam iniciadas quando o computador for iniciado.

- O registro também contém a atividade que um usuário executa durante o uso diário normal do computador.
  - Isso inclui o histórico de dispositivos de hardware, todos os dispositivos que foram conectados ao computador, incluindo o nome, o fabricante e o número de série.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Laboratório - Explorando Processos, Threads, Identificadores e Registro do Windows

Neste laboratório, você explorará os processos, threads e identificadores usando o Process Explorer no SysInternals Suite. Você também usará o Registro do Windows para alterar uma configuração.

Parte 1: Explorando Processos
Parte 2: Explorando Threads e Identificadores
Parte 3: Explorando o Registro do Windows

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

7.3 Configuração e monitoramento do Windows

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Executar como Administrador

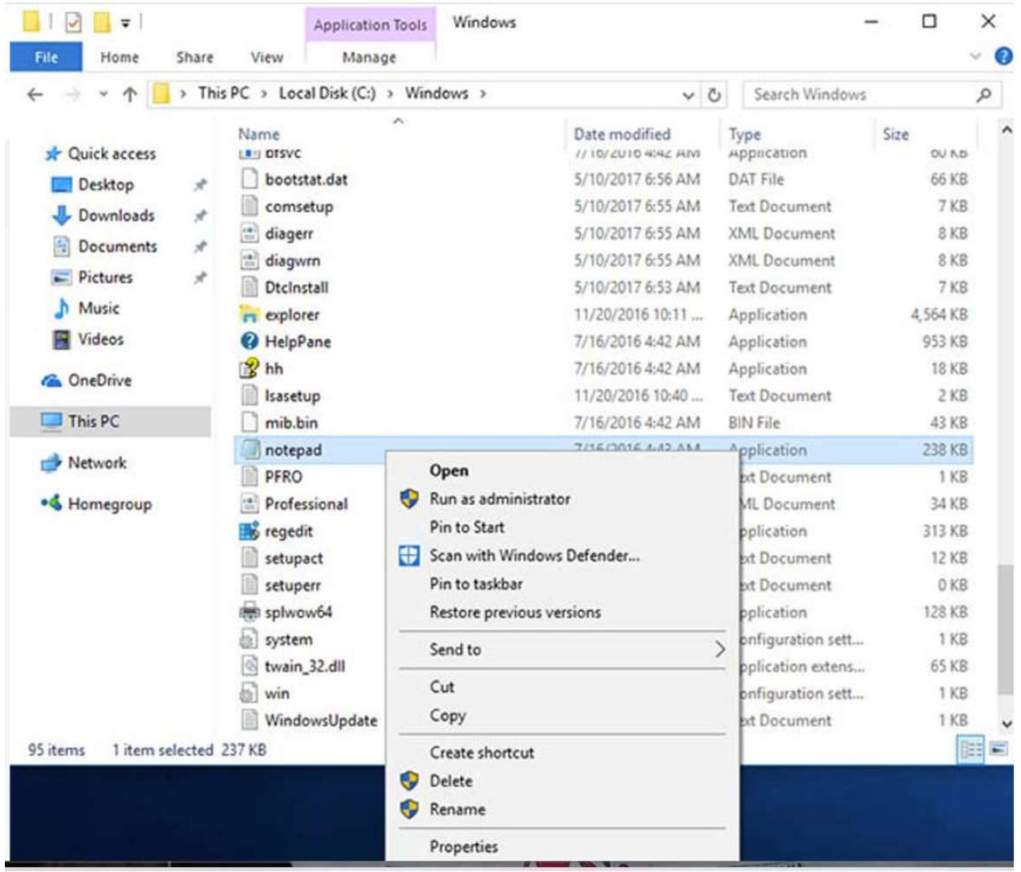
Como prática recomendada de segurança, não é aconselhável fazer logon no Windows usando a conta de Administrador ou uma conta com privilégios administrativos.

- Isso ocorre porque qualquer programa que é executado enquanto conectado com esses privilégios herdará privilégios administrativos.
- O malware que tem privilégios administrativos tem acesso total a todos os arquivos e pastas no computador.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Executar como Administrador (Cont.)

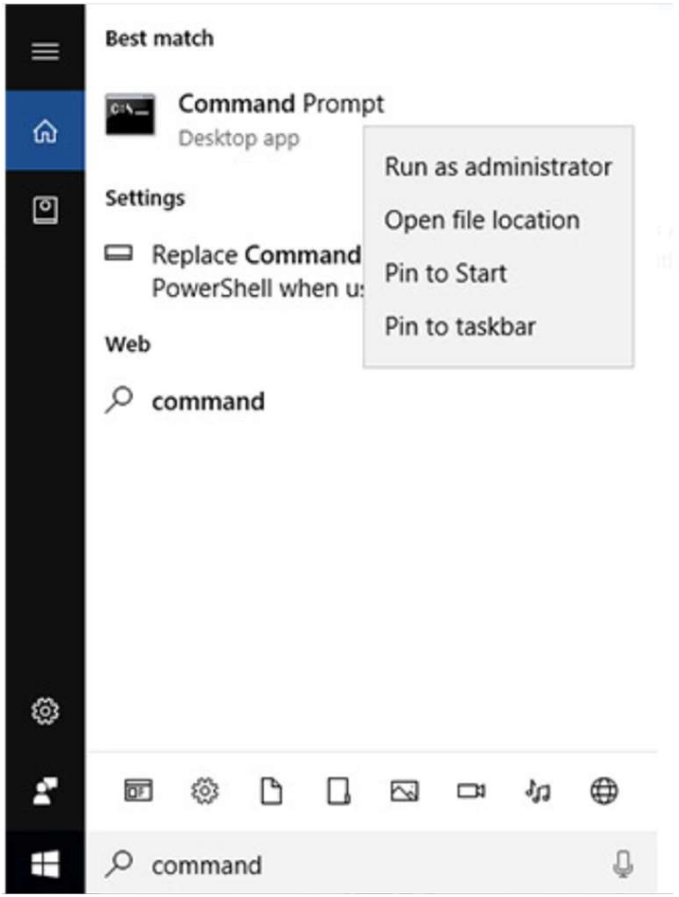
Às vezes, é necessário executar ou instalar software que requer os privilégios do Administrador. Para conseguir isso, existem duas maneiras diferentes de instalá-lo.



Administrador: Clique com o botão direito do mouse o comando no Windows File Explorer e escolha Executar como administrador no menu de contexto.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Executar como Administrador (Cont.)



Prompt de Comando do Administrador:
Clique com o botão direito do mouse o comando no Windows File Explorer e escolha Executar como administrador no menu de contexto.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Usuários e Domínios Locais

- Quando inicia um novo computador pela primeira vez ou instala o Windows, será pedido para criar uma conta de usuário (usuário local)
  - Esta contém todas as configurações de personalização, permissões de acesso, locais de arquivos e muitos outros dados específicos do usuário.

- Como prática recomendada de segurança, não habilite a conta Administrador e não conceda privilégios administrativos aos usuários padrão.

- A conta Convidados não deve ser ativada.

- Para facilitar a administração de usuários, o Windows usa grupos.
  - Um grupo terá um nome e um conjunto específico de permissões associadas a ele.
  - Quando um usuário é colocado em um grupo, as permissões desse grupo são dadas a esse usuário.

- O Windows também pode usar domínios para definir permissões.
  - Um domínio é um tipo de serviço de rede onde todos os usuários, grupos, computadores, periféricos e configurações de segurança são armazenados e controlados por um banco de dados.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

CLI e PowerShell

- A interface de linha de comando (CLI) do Windows pode ser usada para executar programas, navegar no sistema de arquivos e gerenciar arquivos e pastas.
- Para abrir a CLI do Windows, procure **cmd.exe** e clique no programa.

O prompt exibe o local atual dentro do sistema de arquivos. Algumas coisas para lembrar:

- Os nomes de arquivo e caminhos não diferenciam maiúsculas de minúsculas, por padrão.
- Os dispositivos de armazenamento recebem uma letra para referência. A letra da unidade é seguida por dois pontos e barra invertida (\) Isso indica a raiz, ou o nível mais alto, do dispositivo.
- Comandos que têm opções opcionais usam a barra (/) para delinear entre o comando e a opção switch.
- Você pode usar a teclaTabpara completar automaticamente comandos quando diretórios ou arquivos são referenciados.
- O Windows mantém um histórico dos comandos inseridos durante uma sessão da CLI. Acesse comandos inseridos anteriormente usando as teclas de seta para cima e para baixo.
- Para alternar entre dispositivos de armazenamento, digite a letra do dispositivo, seguida de dois pontos epressione Enter.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

CLI e PowerShell (Cont)

- A CLI não pode funcionar junto com o núcleo do Windows ou a GUI.
- Windows PowerShell pode ser usado para criar scripts para automatizar tarefas que a CLI normal não consegue automatizar.

Estes são os tipos de comandos que o PowerShell pode executar:

- **cmdlets** - Esses comandos executam uma ação e retornam uma saída ou objeto para o próximo comando que será executado.
- **Scripts do PowerShell** - São arquivos comextensão .ps1 que contêm comandos do PowerShell que são executados.
- **Funções do PowerShell** - são pedaços de código que podem ser referenciados em um script.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

CLI e PowerShell (Cont.)

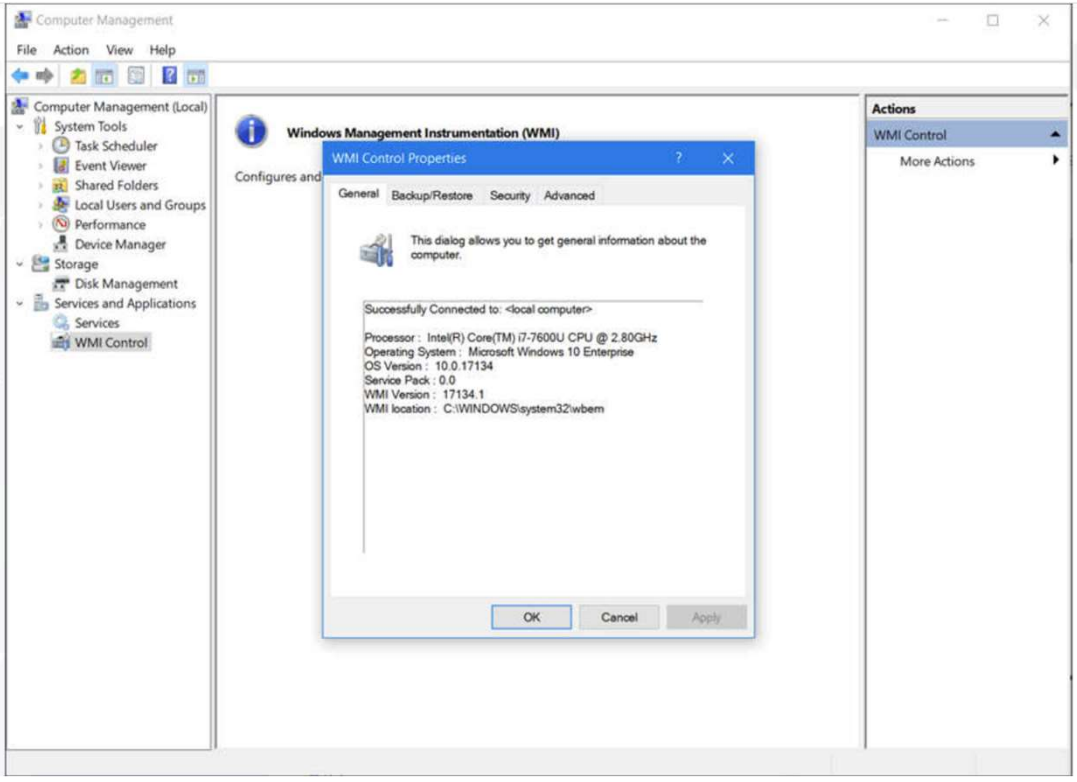
```
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.
Try the new cross-platform PowerShell https://aka.ms/pscore6
PS C:\WINDOWS\system32> help
TOPIC
    Windows PowerShell Help System
SHORT DESCRIPTION
    Displays help about Windows PowerShell cmdlets and concepts.
LONG DESCRIPTION
    Windows PowerShell Help describes Windows PowerShell cmdlets,
    functions, scripts, and modules, and explains concepts, including
    the elements of the Windows PowerShell language.
    Windows PowerShell does not include help files, but you can read the
    help topics online, or use the Update-Help cmdlet to download help files
    to your computer and then use the Get-Help cmdlet to display the help
    topics at the command line.
    You can also use the Update-Help cmdlet to download updated help files
    as they are released so that your local help content is never obsolete.
    Without help files, Get-Help displays auto-generated help for cmdlets,
    functions, and scripts.
  ONLINE HELP
    You can find help for Windows PowerShell online in the TechNet Library
    beginning at http://go.microsoft.com/fwlink/?LinkID=108518.
```

Há quatro níveis de ajuda no Windows PowerShell:

- **get-help** *PS command* - Exibe ajuda básica para um comando
- **get-help** *PS command [-examples]* - Exibe ajuda básica para um comando com exemplos
- **get-help** *PS command [-detailed]* - Exibe ajuda detalhada para um comando com exemplos
- **get-help** *PS command [-full]* - Exibe todas as informações de ajuda para um comando com exemplos mais detalhados

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Instrumentação de Gerenciamento do Windows



A Instrumentação de Gerenciamento do Windows (WMI) é usada para gerenciar computadores remotos. Ele pode recuperar informações sobre componentes de computador, estatísticas de hardware e software e monitorar a integridade de computadores remotos.

Para abrir o controle WMI no Painel de Controle, clique duas vezes em **Ferramentas Administrativas > Gerenciamento do Computador**para abrir a janela Gerenciamento do Computador, expanda a árvore **Serviços e Aplicativos** e clique com o botão direito do mouse no **ícone Controle WMI > Propriedades**.

A janela Propriedades de Controle WMI é mostrada na figura.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Instrumentação de Gerenciamento do Windows (Cont.)

Estas são as quatro guias na janela Propriedades de Controle WMI:

- **Geral** - Informações resumidas sobre o computador local e o WMI
- **Backup/Restaurar** - Permite o backup manual das estatísticas coletadas pelo WMI
- **Segurança** - Configurações para configurar quem tem acesso a diferentes estatísticas WMI
- **Avançado** - Configurações para configurar o namespace padrão para WMI

- Alguns ataques hoje usam o WMI para se conectar a sistemas remotos, modificar o registro e executar comandos.
- O WMI ajuda-os a evitar a detecção porque é tráfego comum, na maioria das vezes confiável pelos dispositivos de segurança de rede e os comandos WMI remotos geralmente não deixam evidências no host remoto.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

O comando net

```
C:\> net help
The syntax of this command is:
NET HELP
command
     -or-
NET command /HELP
  Commands available are:
  NET ACCOUNTS             NET HELPMSG              NET STATISTICS
  NET COMPUTER             NET LOCALGROUP           NET STOP
  NET CONFIG               NET PAUSE                NET TIME
  NET CONTINUE             NET SESSION              NET USE
  NET FILE                 NET SHARE                NET USER
  NET GROUP                NET START                NET VIEW
  NET HELP
  NET HELP NAMES explains different types of names in NET HELP syntax lines.
  NET HELP SERVICES lists some of the services you can start.
  NET HELP SYNTAX explains how to read NET HELP syntax lines.
  NET HELP command | MORE displays Help one screen at a time.
C:\>
```

- Um comando importante é o comando **net**, que é usado na administração e manutenção do SO.
- O comando **net** suporta muitos subcomandos que seguem o comando **net** e podem ser combinados com opções para focar em uma saída específica.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

O comando net (Cont.)

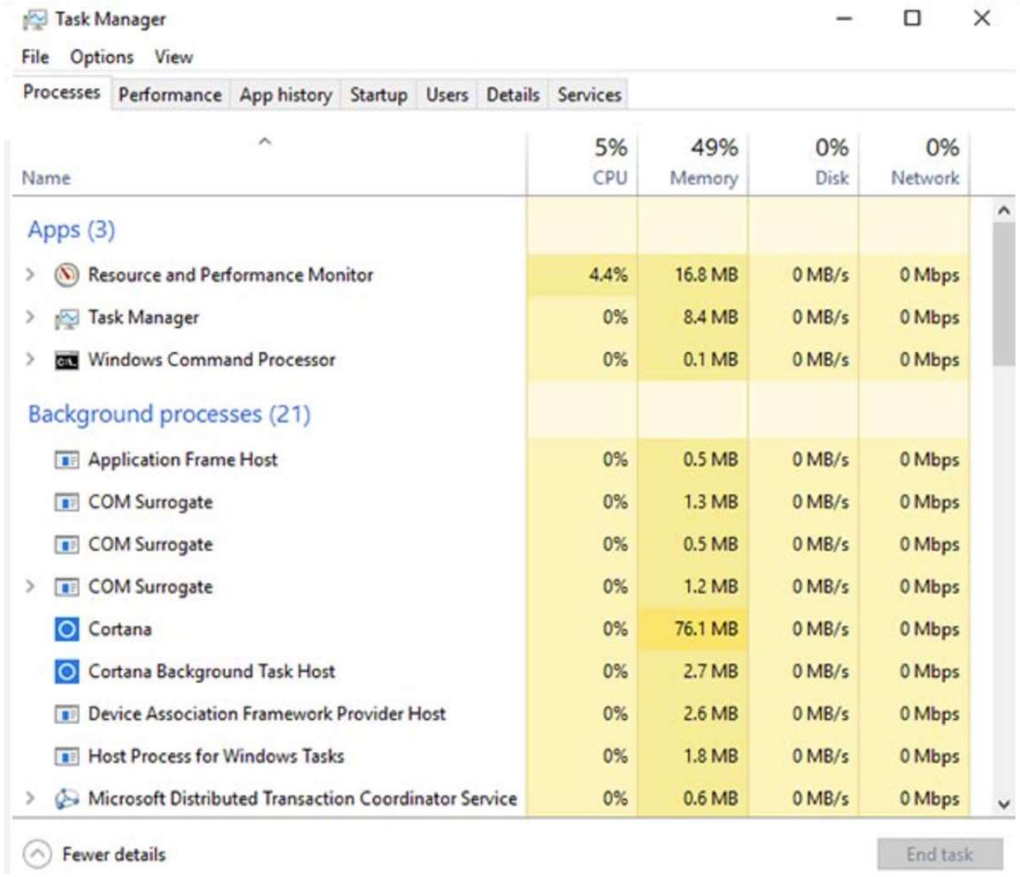
Comandos net comuns

Comando	Descrição
net accounts	Define os requisitos de senha e logon para usuários
net session	Lista ou desconecta sessões entre um computador e outros computadores na rede
net share	Cria, remove ou gerencia recursos compartilhados
net start	Inicia um serviço de rede ou lista os serviços de rede em execução
net stop	Para um serviço de rede
net use	Conecta, desconecta e exibe informações sobre recursos de rede compartilhados
net view	Mostra uma lista de computadores e dispositivos de rede na rede

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Configuração e monitoramento do Windows

Gerenciador de tarefas e Monitor de recursos



Existem duas ferramentas muito importantes e úteis para ajudar um administrador a compreender os vários aplicativos, serviços e processos diferentes que estão sendo executados em um computador Windows.

Gerenciador de Tarefas

O Gerenciador de Tarefas, que é mostrado na figura, fornece muitas informações sobre o software em execução e o desempenho geral do computador.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Gerenciador de tarefas e Monitor de recursos (Cont.)

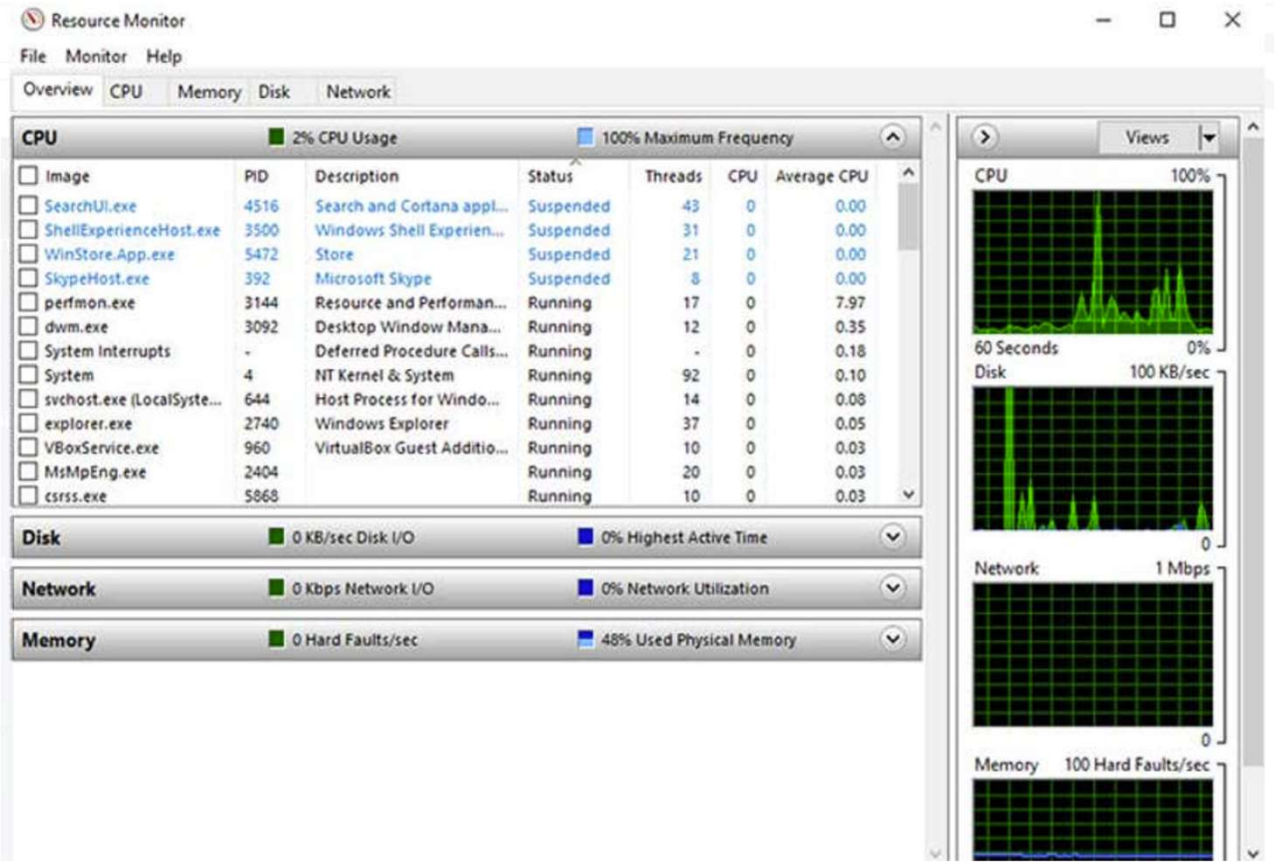
Guias do gerenciador de tarefas	Descrição
Processos	• Lista todos os programas e processos que estão em execução no momento. • Exibe a utilização da CPU, da memória, do disco e da rede de cada processo. • As propriedades de um processo podem ser examinadas ou encerradas se ele não estiver se comportando corretamente ou tiver parado.
Desempenho	• Uma exibição de todas as estatísticas de desempenho fornece uma visão geral útil do desempenho da CPU, memória, disco e rede. • Clicar em cada item no painel esquerdo irá mostrar estatísticas detalhadas desse item no painel direito.
Histórico do aplicativo	• O uso de recursos por aplicativo ao longo do tempo fornece informações sobre aplicativos que estão consumindo mais recursos do que deveriam. • Clique em Opções e Mostrar histórico de todos os processos para ver o histórico de todos os processos executados desde que o computador foi iniciado.
Startup	• Todos os aplicativos e serviços que iniciam quando o computador é inicializado são mostrados nesta guia. • Para desativar o início de um programa na inicialização, clique com o botão direito do mouse no item e escolha Desativar.

Gerenciador de tarefas e Monitor de recursos (Cont.)

Guias do gerenciador de tarefas	Descrição
Usuários	• Todos os usuários que estão conectados ao computador são mostrados nesta guia. • Também são mostrados todos os recursos que os aplicativos e processos de cada usuário estão usando. • Nesta guia, um administrador pode desconectar um usuário do computador.
Detalhes	• Semelhante à guia Processos, essa guia fornece opções de gerenciamento adicionais para processos, como definir uma prioridade para que o processador dedique mais ou menos tempo a um processo. • A afinidade da CPU também pode ser definida, o que determina qual núcleo ou CPU um programa usará. • Além disso, um recurso útil chamado Analisar cadeia de espera mostra qualquer processo para o qual outro processo está aguardando. • Esse recurso ajuda a determinar se um processo está simplesmente aguardando ou está parado.
Serviços	• Todos os serviços que são carregados são mostrados nesta guia. • O ID do processo (PID) e uma breve descrição também são mostrados juntamente com o status de Executando ou Parado. • Na parte inferior, há um botão para abrir o console Serviços que fornece gerenciamento adicional de serviços.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Gerenciador de tarefas e Monitor de recursos (Cont.)



Quando forem necessárias informações mais detalhadas sobre o uso de recursos, você poderá usar o **Monitor de Recursos**, conforme mostrado na figura.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Configuração e monitoramento do Windows

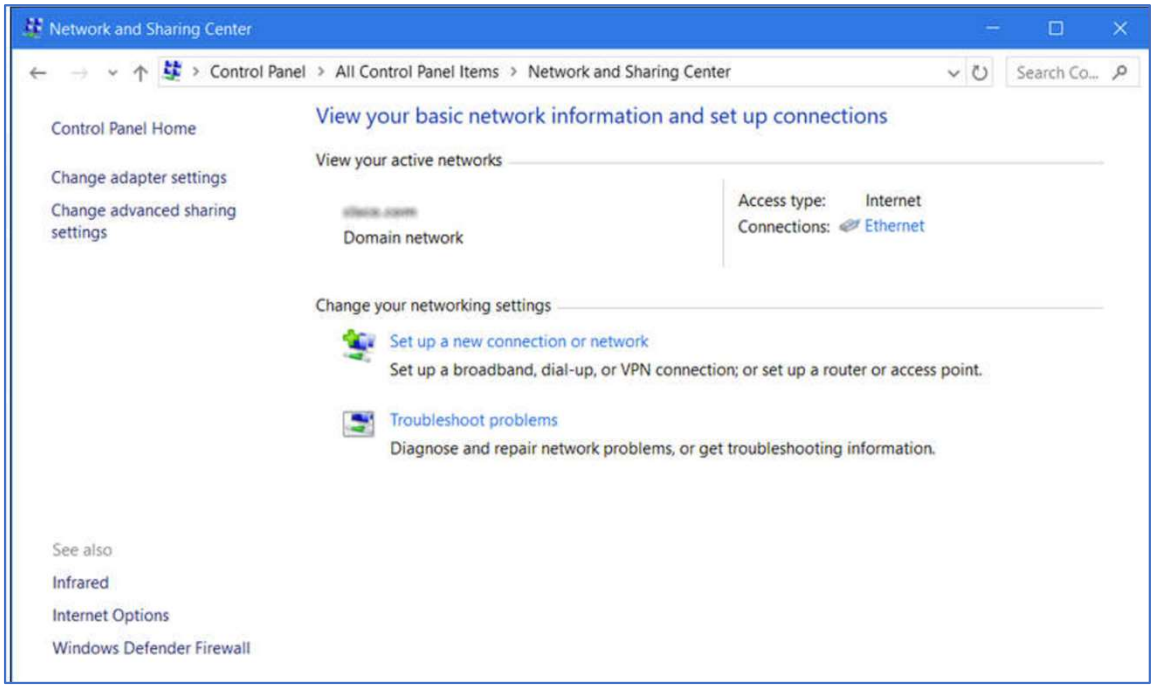
Gerenciador de tarefas e Monitor de recursos (Cont.)

O Monitor de recursos pode ajudar a encontrar a origem do problema quando o computador está agindo de forma irregular.

Guias do Monitor de Recursos	Descrição
Resumo	• A guia exibe o uso geral de cada recurso.
CPU	• O PID, o número de threads, qual CPU o processo está usando e o uso médio da CPU de cada processo é mostrado. • Informações adicionais sobre quaisquer serviços em que o processo se baseia e os identificadores e módulos associados podem ser vistas expandindo as linhas inferiores.
Memória	• Todas as informações estatísticas sobre como cada processo usa memória é mostrada nesta guia. • Além disso, uma visão geral do uso de toda a RAM é mostrada abaixo da linha Processos.
Disco	• Todos os processos que estão usando um disco são mostrados nesta guia, com estatísticas de leitura/gravação e uma visão geral de cada dispositivo de armazenamento.
Rede	• Todos os processos que estão usando a rede são mostrados nesta guia, com estatísticas de leitura/gravação. • Mais importante ainda, as conexões TCP atuais são mostradas, juntamente com todas as portas que estão escutando. • Esta guia é muito útil ao tentar determinar quais aplicativos e processos estão se comunicando pela rede. • Permite saber se um processo não autorizado está acessando a rede, ouvindo uma comunicação e o endereço com o qual está se comunicando.

Configuração e monitoramento do Windows

Redes



- Um dos recursos mais importantes de qualquer sistema operacional é a capacidade do computador se conectar a uma rede.
- Sem esse recurso, não há acesso aos recursos de rede ou à internet.
- Para configurar as propriedades de rede do Windows e testar as configurações de rede, o **Centro de Rede e Compartilhamento** é usado.
- Essa exibição mostra se há acesso à Internet e se a rede é privada, pública ou convidada.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Rede (cont.)

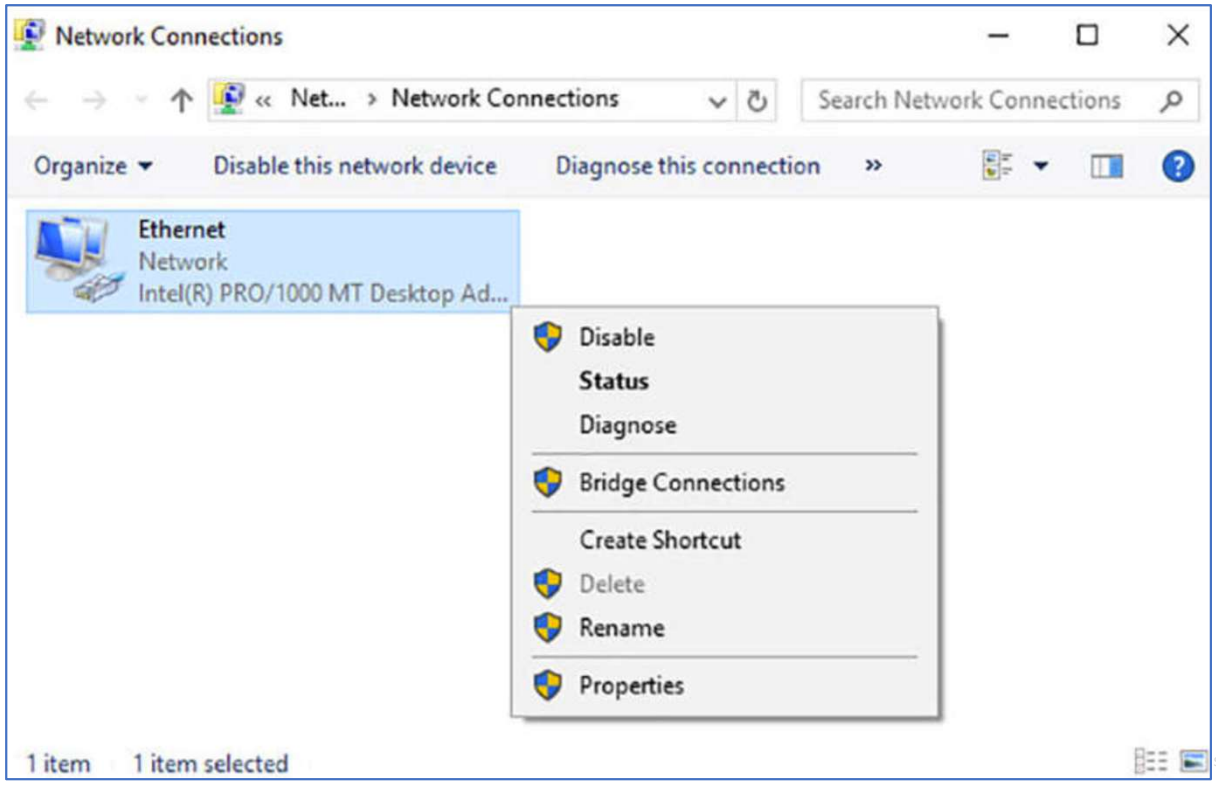
Alterar as configurações do adaptador

- Para configurar um adaptador de rede, escolha Alterar configurações do adaptador no Centro de Rede e Compartilhamento para mostrar todas as conexões de rede disponíveis.
- Selecione o adaptador que você deseja configurar.
- Neste caso, alteramos um adaptador Ethernet para adquirir seu endereço IPv4 automaticamente da rede.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

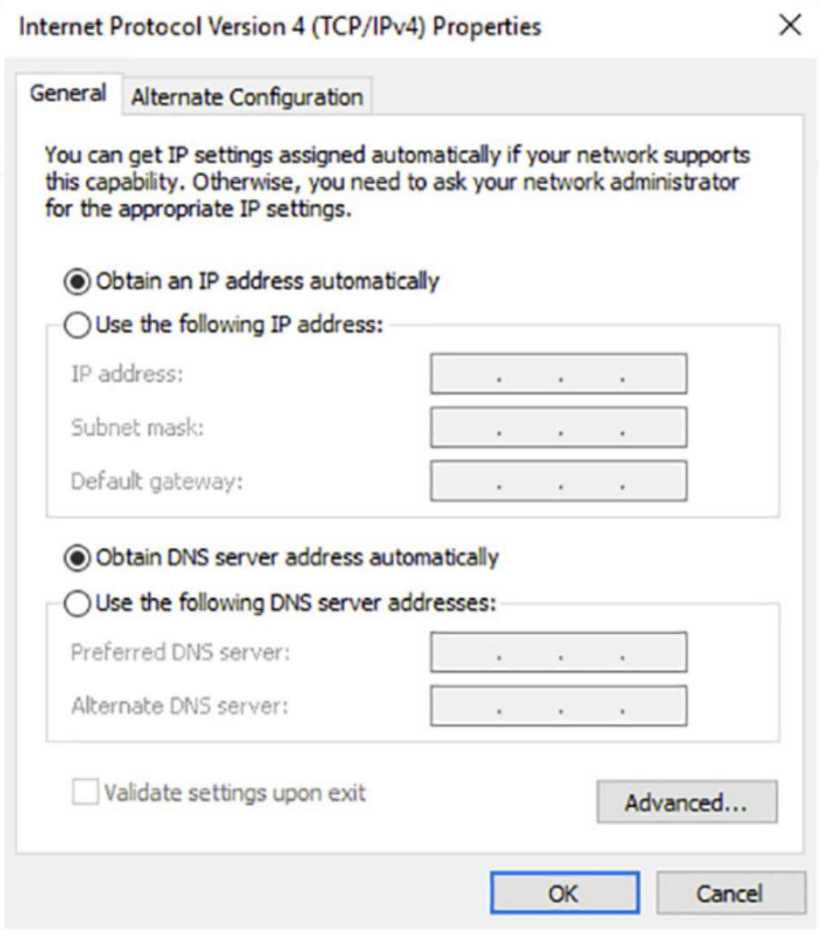
Rede (Cont.)

Acesso a Propriedades do Adaptador: Clique com o botão direito do mouse no adaptador que deseja configurar e escolha Propriedades, conforme mostrado na figura.



suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Rede (Cont.)



Acessar Propriedades TCP/IPV4

Esta conexão utiliza os seguintes itens: Protocolo **Internet Protocol Version 4 (TCP/IPv4)** ou **Internet Protocol Version 6 (TCP/IPv6)** , dependendo da versão que pretende utilizar. Na figura, IPv4 está sendo selecionado.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Rede (Cont.)

nslookup e netstat

- O Sistema de Nomes de Domínio (DNS) também deve ser testado porque é essencial encontrar o endereço dos hosts traduzindo-o a partir de um nome, como uma URL.
- Use o comando **nslookup** para testar o DNS.
- Digite **nslookup cisco.com** no prompt de comando para localizar o endereço do servidor Web Cisco.

```
C:\Users\USER>netstat

Active Connections

  Proto     Local Address         Foreign Address     State
  TCP     127.0.0.1:3030        USER-VGFFA:58652   ESTABLISHED
  TCP     127.0.0.1:3030        USER-VGFFA:62114   ESTABLISHED
  TCP     &127.0.0.1:3030       USER-VGFFA:62480   TIME_WAIT
  TCP     127.0.0.1:3030        USER-VGFFA:62481   TIME_WAIT
  TCP     127.0.0.1:3030        USER-VGFFA:62484   TIME_WAIT
```

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

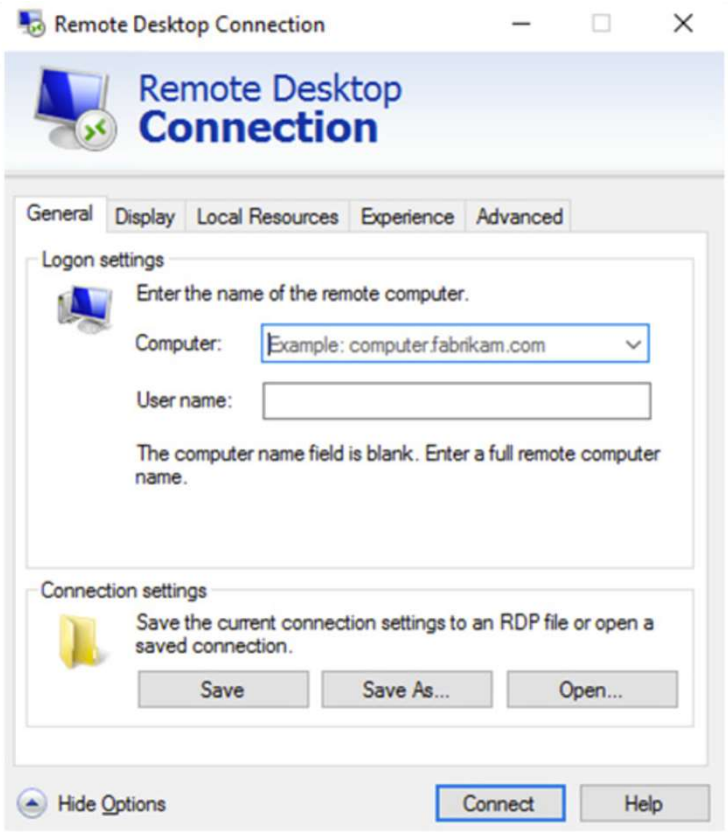
Acessando recursos de rede

- O Windows usa a rede para muitos aplicativos diferentes, como serviços da Web, de email e de arquivo. A Microsoft ajudou no desenvolvimento do protocolo SMB (Server Message Block) para compartilhar recursos de rede.
  - O SMB é usado principalmente para acessar arquivos em hosts remotos.
  - O formato UNC (Universal Naming Convention) é usado para conectar a recursos como, por exemplo: \\servername\sharename\file.
  - servername é o servidor que está hospedando o recurso.
  - sharename é a raiz da pasta no sistema de arquivos no host remoto
  - arquivo é o recurso que o host local está tentando encontrar

- Ao compartilhar recursos na rede, a área do sistema de arquivos que será compartilhada precisará ser identificada.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Acessando Recursos de Rede (Cont.)



- Para se conectar a um compartilhamento, digite o UNC do compartilhamento no Windows File Explorer
- Você será solicitado a fornecer credenciais para acessar o recurso.
- Você pode fazer login em um host remoto para fazer alterações de configuração, instalar software ou solucionar um problema.
  - No Windows, esse recurso usa o protocolo RDP (Remote Desktop Protocol).
  - Para iniciar o RDP e conectar-se a um computador remoto, procure área de trabalho remota e clique no aplicativo. **A janela Conexão de área de trabalho remota é mostrada na figura.**
  - RDP foi projetado para permitir que usuários remotos controlem hosts individuais, ele é um alvo natural para atores de ameaças.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Servidor Windows

- A maioria das instalações do Windows são executadas como instalações de área de trabalho em desktops e laptops.
- Há outra edição do Windows que é usada principalmente em data centers chamados Windows Server.
  - Esta é uma família de produtos Microsoft que começou com o Windows Server 2003.
  - O Windows Server hospeda muitos serviços diferentes e pode desempenhar funções diferentes dentro de uma empresa.

Estes são alguns dos serviços que o Windows Server fornece:

- **Serviços de rede** - DNS, DHCP, serviços de terminal, controlador de rede e virtualização de rede Hyper-V
- **Serviços de arquivo** - SMB, NFS e DFS
- **Serviços Web :** FTP, HTTP e HTTPS
- **Gerenciamento** - Política de grupo e controle de serviços de domínio do Active Directory

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Configuração e monitoramento do Windows

Laboratório – Criação de Contas de Usuário

Neste laboratório, você criará e modificará contas de usuário no Windows.

- Parte 1: Criando uma nova conta de usuário local
- Parte 2: Revisando Propriedades da Conta de Usuário
- Parte 3: Modificando Contas de Usuário Local

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Laboratório - Usando o Windows PowerShell

Neste laboratório, você explorará algumas das funções do PowerShell.

- Parte 1: Acesse o console do PowerShell.
- Parte 2: Explore comandos do Prompt de Comando e do PowerShell.
- Parte 3: Explore cmdlets.
- Parte 4: Explore o comando netstat usando o PowerShell.
- Parte 5: Esvazie a lixeira usando o PowerShell.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Configuração e monitoramento do Windows

Laboratório - Gerenciador de Tarefas do Windows

Neste laboratório, você vai explorar o Gerenciador de Tarefas e administrar processos nele.

- Parte 1: Trabalhando na guia Processos
- Parte 2: Trabalhando na guia Serviços
- Parte 3: Trabalhando na guia Desempenho

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Laboratório - Monitorar e gerenciar recursos do sistema no Windows

Neste laboratório, você usará ferramentas administrativas para monitorar e gerenciar os recursos do sistema Windows.

- Parte 1: Iniciando e interrompendo o serviço de roteamento e acesso remoto
- Parte 2: Trabalhando no Utilitário de Gerenciamento do Computador
- Parte 3: Configurando Ferramentas Administrativas

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

7.4 Segurança do Windows

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Segurança do Windows

O Comando netstat

- Quando o malware está presente em um computador, ele geralmente abre portas de comunicação no host para enviar e receber dados. O comando **netstat** pode ser usado para procurar conexões de entrada ou saída não autorizadas. Quando usado sozinho, o comando **netstat** exibirá todas as conexões TCP ativas.

- Examinando essas conexões, é possível determinar quais dos programas estão escutando conexões que não estão autorizadas. Quando um programa é suspeito de ser malware, uma pequena pesquisa pode ser realizada para determinar sua legitimidade. A partir daí, o processo pode ser encerrado com o Gerenciador de Tarefas, e o software de remoção de malware pode ser usado para limpar o computador.

- Para facilitar esse processo, você pode vincular as conexões aos processos em execução que as criaram no Gerenciador de Tarefas. Para fazer isso, abra um prompt de comando com privilégios administrativos e digite o comando **netstat -abno** , conforme mostrado na saída do comando no próximo slide

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

O comando netstat (Cont.)

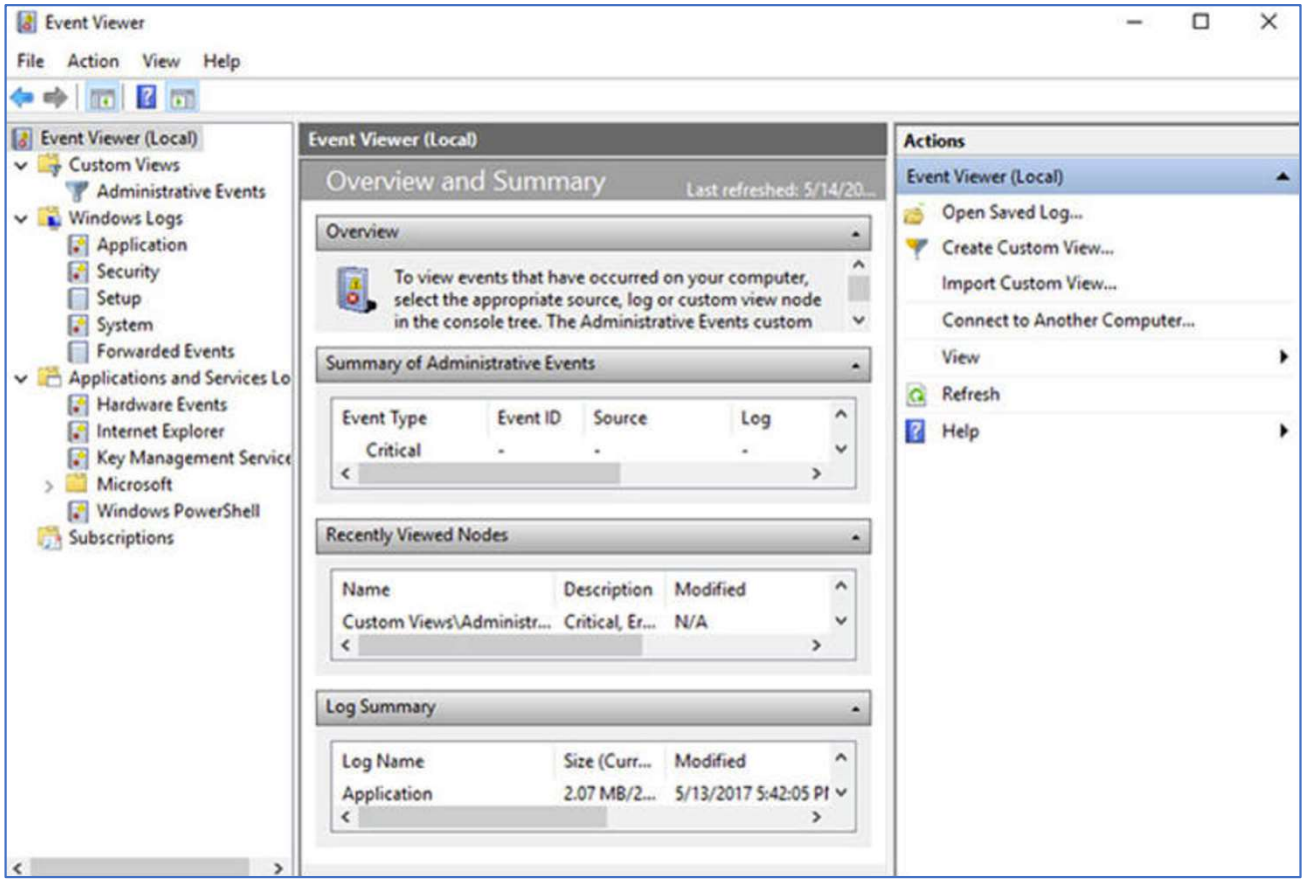
```
Microsoft Windows [Version 10.0.18363.720]
(c) 2019 Microsoft Corporation. All rights reserved.
C:\WINDOWS\system32> netstat -abno
Active Connections
  Proto  Local Address          Foreign Address        State           PID
  TCP    0.0.0.0:80             0.0.0.0:0              LISTENING       4
 Can not obtain ownership information
  TCP    0.0.0.0:135            0.0.0.0:0              LISTENING       952
  RpcSs
 [svchost.exe]
  TCP    0.0.0.0:445            0.0.0.0:0              LISTENING       4
 Can not obtain ownership information
  TCP    0.0.0.0:623            0.0.0.0:0              LISTENING       14660
 [LMS.exe]
  TCP    0.0.0.0:3389           0.0.0.0:0              LISTENING       1396
  TermService
 [svchost.exe]
  TCP    0.0.0.0:5040           0.0.0.0:0              LISTENING       9792
  CDPSvc
 [svchost.exe]
  TCP    0.0.0.0:5357           0.0.0.0:0              LISTENING       4
 Can not obtain ownership information
  TCP    0.0.0.0:5593           0.0.0.0:0              LISTENING       4
```

- Examinando as conexões TCP ativas, um analista deve ser capaz de determinar se há algum programa suspeito que esteja escutando conexões de entrada no host.
- O processo pode ser rastreado no Gerenciador de Tarefas do Windows e cancelado.
- Se mais de um processo estiver listado com o mesmo nome, use o PID para localizar o processo correto.
- Para exibir os PIDs dos processos no Gerenciador de Tarefas, abra o Gerenciador de **Tarefas**, clique com o botão direito do mouse no cabeçalho da tabela e selecione **PID**.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Segurança do Windows

Visualizador de Eventos



- O Visualizador de Eventos do Windows registra o histórico de eventos de aplicativos, segurança e sistema.
- Esses arquivos de log são uma valiosa ferramenta de solução de problemas porque fornecem informações para identificar um problema.
- Para abrir o Visualizador de Eventos, procure-o e clique no ícone do programa, conforme mostrado na figura.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Visualizador de Eventos (Cont.)

- O Windows inclui duas categorias de logs de eventos:
  - Registros do Windows
  - Registros de aplicativos e serviços

- Os eventos exibidos nesses logs possuem dados de:
  - nível: informação, aviso, erro ou crítico
  - data e hora em que o evento ocorreu
  - origem do evento e um ID relacionado a esse tipo de evento

- Os logs de eventos de segurança são encontrados em Logs do Windows.
- Eles usam IDs de evento para identificar o tipo de evento.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

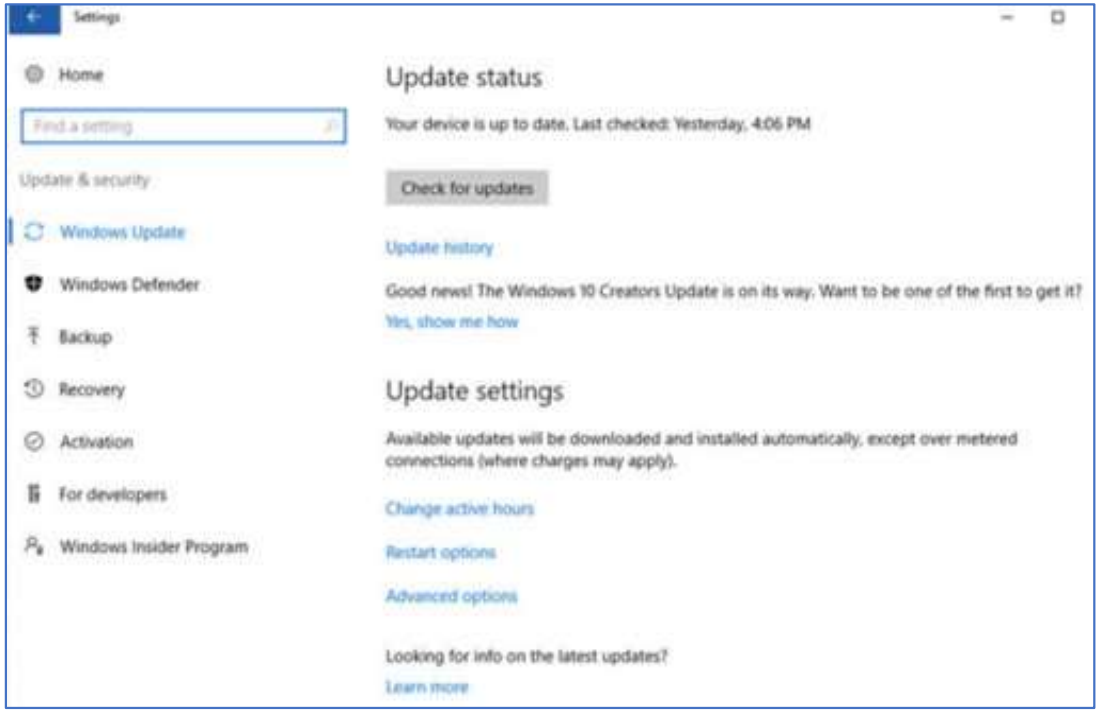
Configurações do Windows Update (Atualizações do Windows)

- Os invasores estão constantemente produzindo novas maneiras de comprometer computadores e explorar códigos maliciosos.
- A Microsoft está sempre tentando ficar à frente dos invasores, portanto, certifique-se sempre de que o Windows esteja atualizado com os service packs e patches de segurança mais recentes.
- Os patches são atualizações de código que os fabricantes fornecem para evitar que um vírus ou um worm recém-descoberto façam um ataque bem-sucedido.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Segurança do Windows

Gerenciamento de Atualizações do Windows



- O Windows verifica, regularmente, o site Windows Update, por atualizações de alta prioridade e que podem ajudar a proteger o computador contra as mais recentes ameaças de segurança.
  - Essas atualizações incluem atualizações de segurança, atualizações críticas e service packs.
  - O status da atualização (Update), mostrado na figura, permite que você verifique as atualizações manualmente e veja o histórico de atualizações do computador.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Segurança do Windows

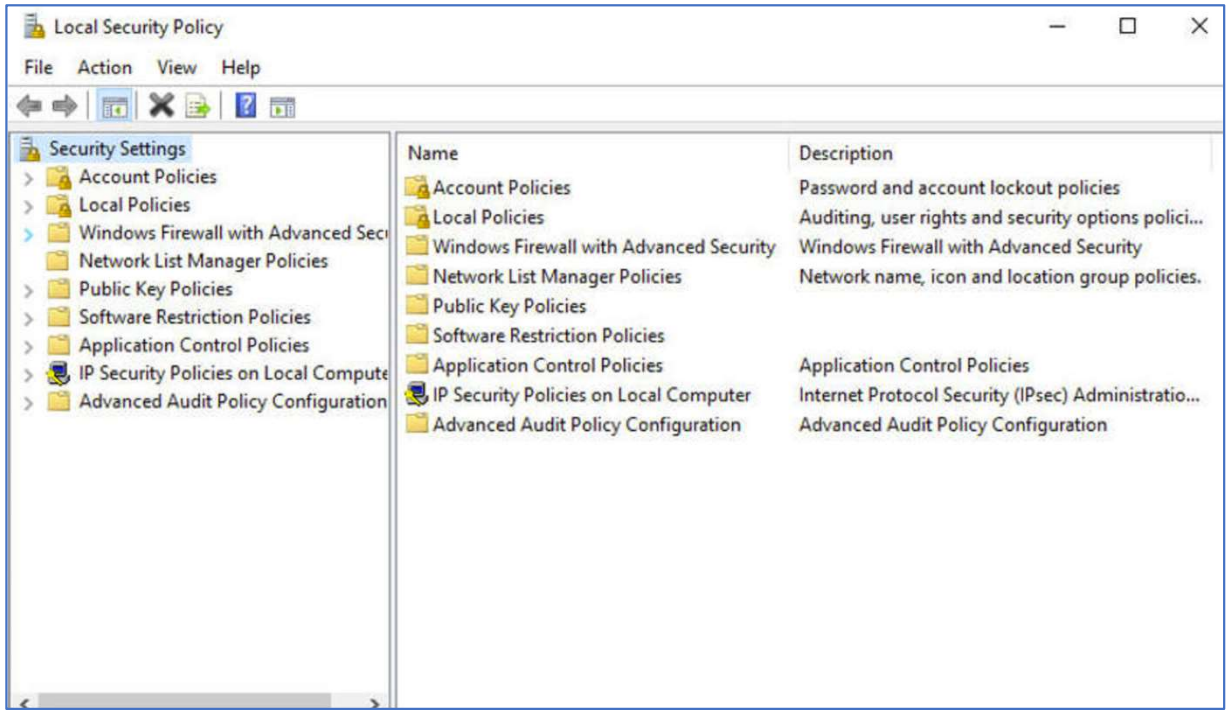
Ferramenta de Política de Segurança Local

- Uma política de segurança é um conjunto de objetivos que garante a segurança de uma rede, dos dados e dos sistemas de computador em uma organização.

- A política de segurança é um documento em constante desenvolvimento, baseado em mudanças na tecnologia, nos negócios e nas necessidades dos funcionários.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Política de Segurança Local (Cont.)



- O Active Directory é configurado com Domínios em um Windows Server.
- O administrador configura uma Política de Segurança de Domínio que se aplica a todos os computadores que ingressam no domínio.
- As políticas de conta são definidas automaticamente quando um usuário efetua login em um computador que é membro de um domínio.
- A Política de Segurança Local do Windows, mostrada **na figura**, pode ser usada para computadores autônomos que não fazem parte de um domínio do Active Directory .

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Política de Segurança Local (Cont.)

- As diretrizes de senha são um componente importante de uma política de segurança.
- As senhas ajudam a evitar roubo de dados e atos mal-intencionados.
- Use a Diretiva de Bloqueio de Conta em Diretivas de Conta, para impedir tentativas de login por força bruta.
- Uma política de segurança deve conter uma regra sobre a necessidade de se bloquear um computador, quando a proteção de tela for iniciada.
- Se a política de segurança local em cada computador autônomo for a mesma, use o recurso Exportar política.
- O miniaplicativo Diretiva de Segurança Local contém muitas outras configurações de segurança que se aplicam especificamente ao computador local.
    - Você pode configurar Direitos de Usuário, Regras de Firewall e até mesmo a capacidade de restringir os arquivos que os usuários ou grupos têm permissão para executar com o AppLocker.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Segurança do Windows

Windows Defender

Malware inclui vírus, worms, cavalos de Troia, keyloggers, spyware, e adware. Eles são projetados para invadir a privacidade, roubar informações, danificar o computador ou corromper dados. É importante que você proteja os computadores e dispositivos móveis com software antimalware de qualidade. Estão disponíveis os seguintes tipos de programas antimalware:

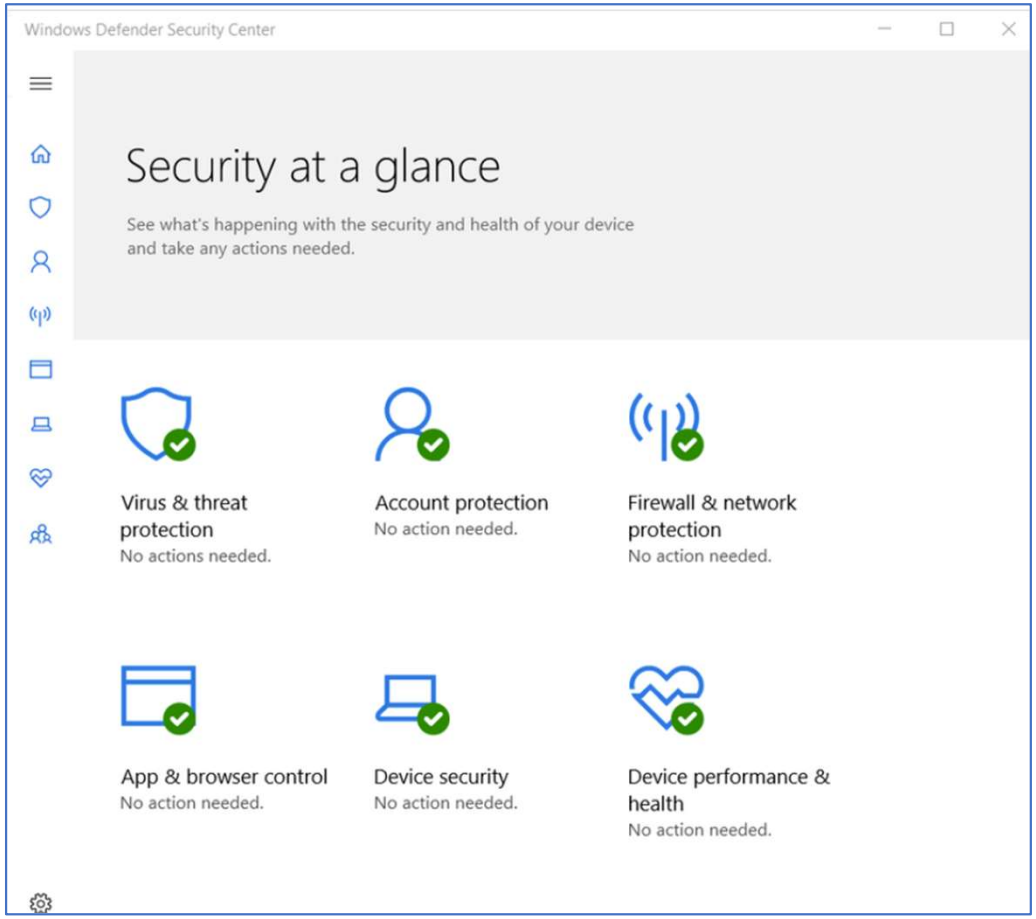
Programas anti-malware	Descrição
Proteção antivírus	Este programa monitora continuamente a presença de vírus. Quando um vírus é detectado, o usuário é avisado e o programa tenta colocar o vírus em quarentena ou excluí-lo.
Proteção contra adware	Este programa procura continuamente por programas que exibam publicidade em seu computador.
Proteção contra phishing	Este programa bloqueia os endereços IP de sites de phishing conhecidos e avisa o usuário sobre sites suspeitos.
Proteção contra spyware	Este programa verifica keyloggers e outros spywares.
Verificação de fontes confiáveis / não confiáveis	Este programa avisa sobre programas inseguros prestes a serem instalados ou sites inseguros antes de serem visitados.

Pode ser necessário usar vários programas diferentes e fazer várias varreduras para remover completamente todos os softwares mal-intencionados. Execute apenas um programa de proteção contra malware por vez.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Segurança do Windows

Windows Defender (Cont.)



- Várias empresas de segurança confiáveis, como McAfee, Symantec e Kaspersky, oferecem proteção completa contra malware para computadores e dispositivos móveis.
- O Windows possui proteção interna contra vírus e spyware chamada Windows Defender, como mostrado na figura.
- O Windows Defender está ativado por padrão para fornecer proteção em tempo real contra infecções.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Segurança do Windows

Firewall do Windows Defender

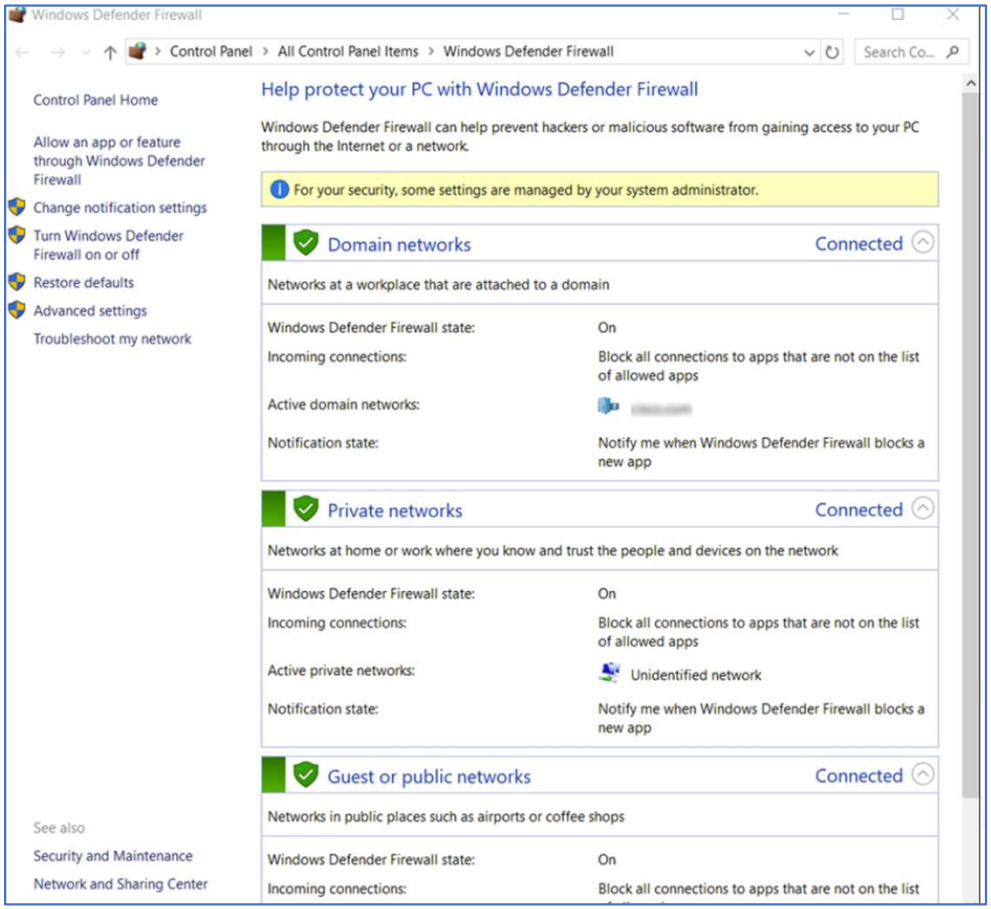
- Um firewall nega, seletivamente, o tráfego a um computador ou a um segmento de rede.

- Os firewalls trabalham, geralmente, abrindo e fechando as portas usadas por vários aplicativos.
  - Ao abrir apenas as portas necessárias em um firewall, você está implementando uma política de segurança restritiva.
  - Qualquer pacote não explicitamente permitido é negado.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Segurança do Windows

Firewall Windows Defender (Cont.)



- Para permitir o acesso ao programa através do Firewall Windows Defender, procure por **Painel de Controle**. Em **Sistemas e Segurança**, localize o **Firewall Windows Defender**. Clique em Permitir **um aplicativo ou recurso por meio do Firewall do Windows Defender**, conforme mostrado na figura.

- Para usar um firewall por software diferente, você precisará desativar o firewall do Windows. Para desativar o Firewall do Windows, clique **em Ativar ou desativar o Firewall** do Windows.

- Muitas configurações adicionais podem ser encontradas em **Configurações** avançadas.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

7.5 Resumo do Sistema Operacional Windows

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Resumo Sistema Operacional Windows

O que aprendi neste módulo?

Histórico do Windows

- A Microsoft desenvolveu o MS-DOS como uma interface de linha de comando (CLI) para acessar a unidade de disco e carregar os arquivos do sistema operacional.
- As versões modernas do Windows controlam diretamente o computador e seu hardware e oferecem suporte a vários processos de usuário.
- Os usuários usam uma GUI do Windows para trabalhar com arquivos de dados e software.
    - A GUI tem uma área principal conhecida como Área de Trabalho e uma Barra de Tarefas situada abaixo da área de trabalho.
        - A Barra de Tarefas inclui o menu Iniciar, ícones de inicialização rápida e uma área de notificação. O Windows tem muitas vulnerabilidades.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

O que aprendi neste módulo? (Continuação)

Arquitetura e operações do Windows

- O Windows consiste em uma camada de abstração de hardware (HAL); software que lida com toda a comunicação entre o hardware e o kernel.
  - O kernel tem controle sobre todo o computador e lida com solicitações de entrada e saída, memória e todos os periféricos conectados ao computador.
- O Windows suporta vários sistemas de arquivos diferentes, mas o NTFS é o mais utilizado.
  - Os volumes NTFS incluem o setor de inicialização de partição, tabela de arquivos mestre, arquivos de sistema e a área de arquivo.
- Um computador funciona armazenando instruções na RAM até que a CPU os processe.
  - Cada processo em um computador Windows de 32 bits suporta um espaço de endereço virtual que permite endereçar até 4 gigabytes.
  - Cada processo num computador Windows de 64 bits suporta um espaço de endereço virtual de até 8 terabytes.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

O que aprendi neste módulo? (continuação)

Configuração e monitoramento do Windows

- Por segurança, não é aconselhável fazer logon no Windows usando a conta de administrador.
  - Não dê privilégios administrativos aos usuários padrão.
  - Não habilite a conta de convidados.
- Você pode usar a CLI ou o Windows PowerShell para executar comandos.
- O PowerShell pode ser usado para criar scripts para automatizar tarefas que a CLI normal não consegue automatizar.
- A Instrumentação de Gerenciamento do Windows (WMI) é usada para gerenciar computadores remotos.
- O Gerenciador de Tarefas fornece muitas informações sobre o que está sendo executado e o desempenho geral do computador.
- O Monitor de Recursos fornece informações mais detalhadas sobre o uso de recursos.
- O Centro de Rede e Compartilhamento é utilizado para configurar as propriedades de rede do Windows e testar as definições de rede.
- O protocolo SMB (Server Message Block) é usado para compartilhar recursos de rede, como arquivos em hosts remotos.
- O formato UNC (Universal Naming Convention) é usado para se conectar a recursos.
- O Windows Server é uma edição do Windows que é usada principalmente em data centers.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

O que aprendi neste módulo? (continuação)

Segurança do Windows

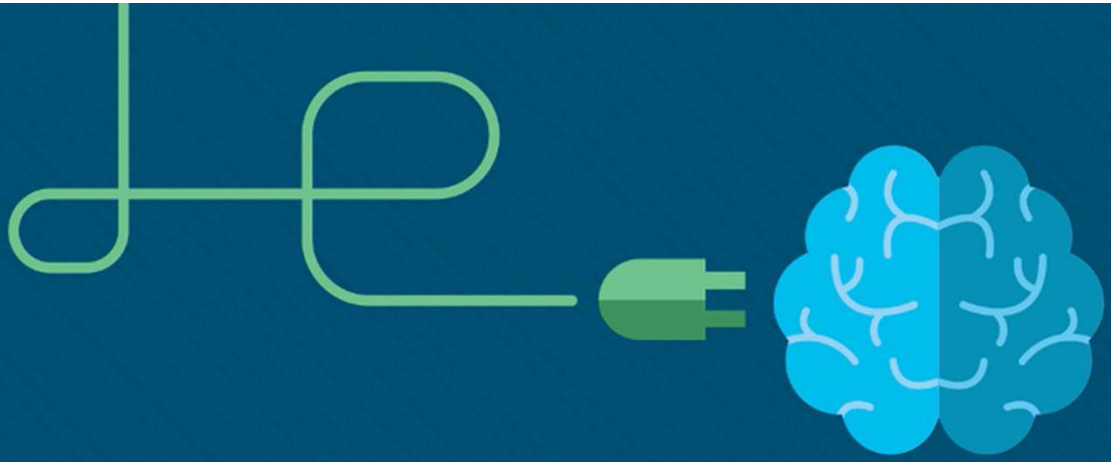
- O malware pode abrir portas de comunicação para se comunicar e espalhar.
- O comandonetstatdo Windows exibe todas as portas de comunicação abertas em um computador e também pode exibir os processos de software associados às portas.
  - Isso permite que softwares potencialmente mal-intencionados desconhecidos sejam identificados e desativados.
- O Visualizador de Eventos do Windows fornece acesso a vários eventos registrados em relação à operação de um computador.
- O registro do Windows registra eventos de aplicativos e serviços do Windows.
  - Os níveis de gravidade de eventos registrados variam por meio das informações, advertência, erro ou níveis críticos.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Módulo 7:

Novos termos e comandos

- Sistema Operacional de Disco
- Interface gráfica do usuário (GUI)
- Barra de Tarefas
- Menu Iniciar
- Vulnerabilidades do Sistema Operacional
- Firewall
- Criptografia
- Proteção contra malware
- Camada de Abstração de Hardware (HAL)
- Modo Usuário
- Modo Kernel
- NTFS
- Setor de Inicialização da Partição
- Tabela Mestre de Arquivos (MFT)
- Política de Segurança Local
- Arquivos do sistema
- Área de arquivo
- Fluxos de dados alternativos (ADS)
- Processo de Inicialização do Windows
- Basic Input-Output System (Sistema básico de Entrada-Saída - BIOS)
- Unified Extensible Firmware Interface (UEFI)
- Banco de Dados de Configuração de Inicialização (BCD).
- Subsistema do Gerenciador de Sessões (SMSS)
- HKEY_CURRENT_USER
- HKEY_LOCAL_MACHINE
- RAMMap
- Registro do Windows
- App Locker
- REG_BINARY
- REG_DWORD
- REG_SZ
- Prompt de comando do administrador
- Domínio
- CLI e PowerShell
- Instrumentação de Gerenciamento do Windows
- Gerenciador de Tarefas
- Acesso a Propriedades do Adaptador
- Acesso a Propriedades TCP/IPV4
- Nslookup
- Netstat
- Bloco de Mensagens do Servidor (SMB)
- Remote Desktop Protocol (RDP)



Módulo 8: Resumo do Linux



Segurança de endpoint

Objetivos do Módulo

Título do Módulo: Visão geral do Linux

Objetivo do Módulo:Implementar segurança básica do Linux.

Título do Tópico	Objetivo do Tópico
Conceitos Básicos do Linux	Explicar por que as habilidades do Linux são essenciais para o monitoramento e a investigação de segurança de rede.
Trabalhando no Linux Shell	Usar o Linux Shell para manipular arquivos de texto.
Servidores e clientes Linux	Usar a linha de comando do Linux para identificar os servidores que estão sendo executados em um computador.
Administração Básica do Servidor	Usar os comandos para localizar e monitorar os arquivos de log.
O sistema de arquivos Linux	Usar os comandos para gerenciar o sistema de arquivos e as permissões do Linux.
Trabalhando na GUI do Linux	Explicar os componentes básicos da GUI do Linux.
Trabalhando em um host Linux	Usar ferramentas para detectar malware em um host do Linux.

8.1 Noções básicas do Linux

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Conceitos Básicos do Linux

O que é Linux?

- O Linux é um sistema operacional criado em 1991 que é código aberto, rápido, confiável e pequeno.
- Ele requer muito poucos recursos de hardware para ser executado e é altamente personalizável.
- Ao contrário do Windows e Mac OS X, ele foi criado, e atualmente é mantido por, uma comunidade de programadores.
- Ele foi projetado para ser conectado à rede, o que torna muito mais simples escrever e usar aplicativos baseados em rede.
- Qualquer pessoa ou empresa pode obter o código-fonte do kernel, inspecioná-lo, modificá-lo e recompilá-lo à vontade.
- Eles também estão autorizados a redistribuir o programa com ou sem encargos.
- istribuição Linux (distro) é o termo usado para descrever pacotes criados por diferentes organizações e inclui o kernel do Linux com ferramentas e pacotes de software personalizados.
- Exemplos de distribuições incluem: Debian, Red Hat, Ubuntu, CentOS e SUSE.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

O valor do Linux

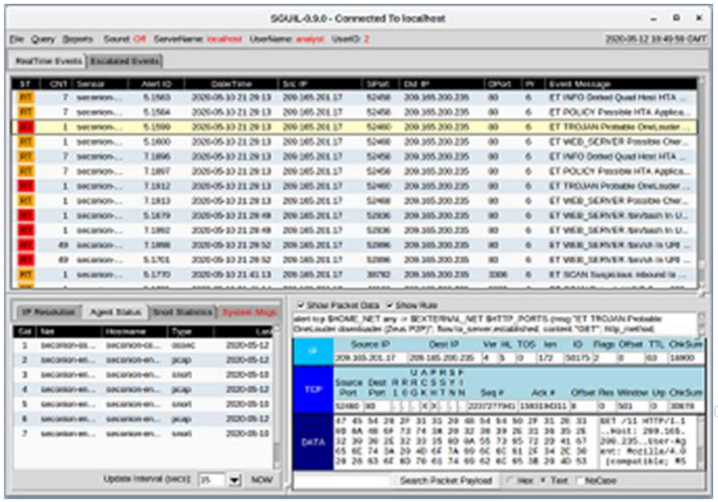
O Linux é frequentemente o sistema operacional escolhido no Centro de Operações de Segurança (SOC). Algumas das razões para escolher o Linux:

- Linux é open source - Qualquer pessoa pode adquirir Linux gratuitamente e modificá-lo para atender a necessidades específicas.
- A CLI do Linux é muito poderosa - GUI torna muitas tarefas mais fáceis de executar, ela adiciona complexidade e requer mais recursos de computador para executar. CLI permite que os analistas executem tarefas diretamente em um terminal e remotamente.
- O usuário tem mais controle sobre o sistema operacional - O usuário administrador no Linux (usuário root ou superusuário) tem poder absoluto sobre o computador. O usuário root pode modificar qualquer aspecto do computador com algumas teclas pressionadas.
- Permite um melhor controle da comunicação de rede - Como o sistema operacional pode ser ajustado em praticamente todos os aspectos, é uma ótima plataforma para criar aplicativos de rede.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Linux no SOC

- Todo o sistema operacional pode ser adaptado para se tornar a plataforma de análise de segurança perfeita.
- Administradores podem adicionar apenas os pacotes necessários ao sistema operacional, tornando-o simples e eficiente.
- Ferramentas de software específicas podem ser instaladas e configuradas para funcionar em conjunto, permitindo que os administradores criem um computador personalizado que se encaixe perfeitamente no fluxo de trabalho de um SOC.
- A figura mostra o Sguil, que é o console do analista de segurança cibernética em uma versão especial do Linux chamada Security Onion.
- O Security Onion é um conjunto de ferramentas de código aberto que trabalham juntas para análisede segurança de rede.



020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Linux no SOC (Cont.)

As ferramentas frequentemente encontradas em um SOC são:

Ferramenta	Explicação
Software de captura de pacotes de rede	Esta é uma ferramenta crucial para observar e entender cada detalhe de uma transação de rede. Wireshark é uma ferramenta popular de captura de pacotes.
Ferramentas de análise de malware	Elas permitem que os analistas executem e observem com segurança a execução de malware sem o risco de comprometer o sistema subjacente.
Sistemas de detecção de intrusão (IDSs)	Eles são usadas para monitoramento e inspeção de tráfego em tempo real. Se qualquer aspecto do tráfego atualmente em fluxo corresponder a qualquer uma das regras estabelecidas, uma ação predefinida será executada.
Firewalls	Este software é usado para especificar, com base em regras predefinidas, se o tráfego tem permissão para entrar ou sair de uma rede ou dispositivo.
Gerenciadores de log	Como uma rede pode gerar um número muito grande de entradas de log, o software do gerenciador de logs é empregado para facilitar o monitoramento de log.
Segurança das informações e gerenciamento de eventos (SIEM)	Os SIEMs fornecem análise em tempo real de alertas e entradas de log geradas por dispositivos de rede, como IDSs e firewalls.
Sistemas de emissão de bilhetes	A atribuição de tíquetes de tarefa, edição e gravação é feita através de um sistema de gerenciamento de tíquetes.

Ferramentas Linux

- Além das ferramentas específicas de SOC, os computadores Linux que são usados no SOC geralmente contêm ferramentas de teste de penetração.
- Um teste de penetração (Pentesting) é o processo de procurar vulnerabilidades em uma rede ou computador atacando-o.
- Geradores de pacotes, scanners de porta e explorações de prova de conceito são exemplos de ferramentas Pentesting.
- Kali Linux é uma distribuição Linux que agrupa muitas ferramentas de penetração juntas em uma única distribuição Linux. Ela contém uma grande variedade de ferramentas.
- A figura mostra uma captura de tela do Kali Linux.



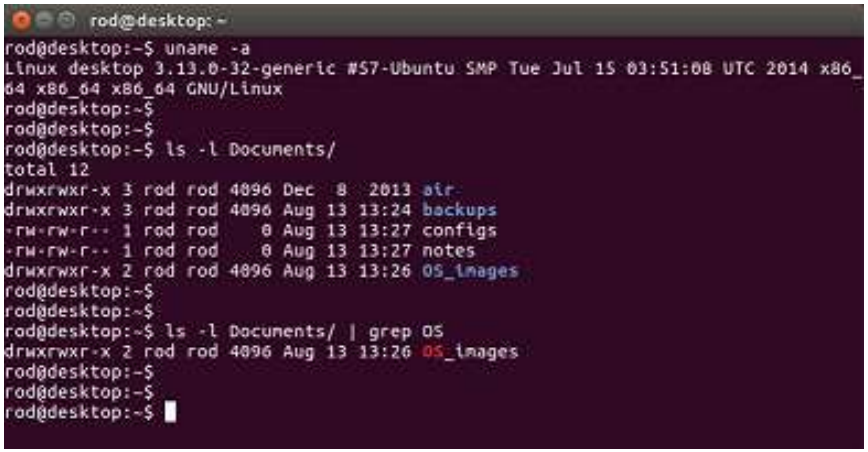
© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

8.2 Como trabalhar no Shell do Linux

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

O Shell do Linux

- No Linux, o usuário se comunica com o SO usando a CLI ou a GUI (padrão)
- Isso oculta a CLI do usuário. Uma maneira de acessar a CLI a partir da GUI é por meio de um aplicativo de emulador de terminal. Esses aplicativos fornecem acesso de usuário à CLI.
- No Linux, emuladores de terminal populares são Terminator, eterm, xterm, konsole e gnome-terminal.
- A figura mostra o gnome-terminal, um emulador de terminal Linux popular.
- Os termos shell, console, janela do console, terminal da CLI e janela do terminal são frequentemente usados de forma intercambiável.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Trabalhando no Shell do Linux

Comandos básicos

Os comandos do Linux são programas armazenados no disco e criados para executar uma tarefa específica. Quando um usuário digita um comando, o shell deve encontrá-lo no disco antes que ele possa ser executado.

A tabela lista comandos básicos do Linux e suas funções.

Comando	Descrição
mv	Move ou renomeia arquivos e diretórios
chmod	Modifica as permissões de arquivos
chown	Altera o dono de um arquivo
dd	Copia os dados de uma entrada para uma saída
pwd	Exibe o nome do diretório atual
ps	Lista os processos em execução no momento no sistema.
su	Simula um login como outro usuário ou para se tornar um superusuário
sudo	Executa um comando como um superusuário, por padrão, ou outro usuário nomeado

Comandos básicos (Cont.)

Comando	Descrição
grep	Usado para pesquisar cadeias de caracteres específicas em um arquivo ou outras saídas de comando.
ifconfig	Usado para exibir ou configurar informações relacionadas à placa de rede. Se emitido sem parâmetros, o ifconfig exibirá a configuração atual da (s) placa (s) de rede.
apt-obter	Usado para instalar, configurar e remover pacotes no Debian e seus derivados.
iwconfig	Usado para exibir ou configurar informações relacionadas à placa de rede sem fio.
shutdown	Usado para desligar o sistema, shutdown pode ser instruído para executar várias tarefas relacionadas ao desligamento.
passwd	Usado para alterar a senha.
cat	Usado para listar o conteúdo de um arquivo e espera o nome do arquivo como parâmetro.
man	Usado para exibir a documentação de um comando específico.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Comandos de arquivo e diretório

Muitas ferramentas de linha de comando estão incluídas no Linux por padrão.

A tabela lista alguns dos comandos mais comuns relacionados a arquivos e diretórios.

Comando	Descrição
ls	Exibe os arquivos dentro de um diretório
cd	Muda o diretório atual
mkdir	Cria um diretório no diretório atual
cp	Copia arquivos da origem para o destino
mv	Move ou renomeia arquivos e diretórios
rm	Remove arquivos
grep	Pesquisa cadeias de caracteres específicas em um arquivo ou outras saídas de comandos
cat	Lista o conteúdo de um arquivo e espera o nome do arquivo como parâmetro

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

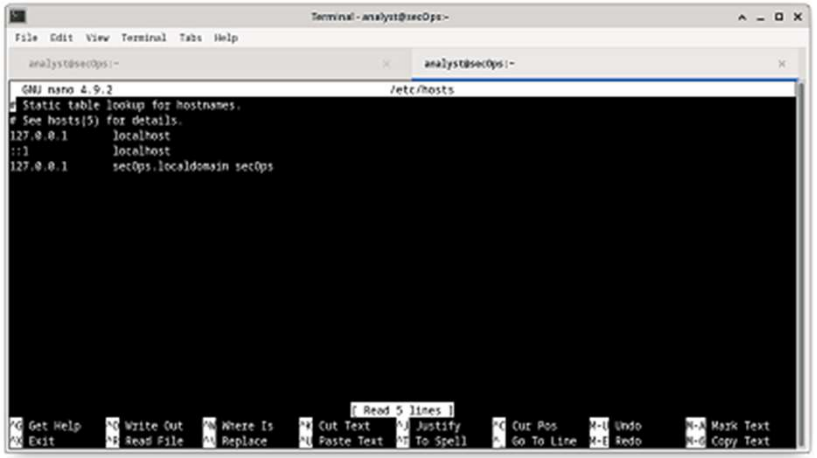
Trabalhando com Arquivos de Texto

- Linux tem muitos editores de texto diferentes, com vários recursos e funções. Alguns editores de texto incluem interfaces gráficas, enquanto outros são apenas ferramentas de linha de comando.
- Cada editor de texto inclui um conjunto de recursos projetado para suportar um tipo específico de tarefa.
- Alguns editores de texto se concentram no programador e incluem recursos como realce de sintaxe, parênteses e verificação de parênteses e outros recursos focados na programação.
- Embora os editores de texto gráficos sejam convenientes e fáceis de usar, os editores de texto baseados em linha de comando são muito importantes para os usuários do Linux.
- O principal benefício dos editores de texto baseados em linha de comando é que eles permitem a edição de arquivos de texto a partir de um computador remoto.
- Considere o seguinte cenário: um usuário deve executar tarefas administrativas em um computador Linux, mas não está sentado na frente dele. Usando o SSH, o usuário inicia um shell remoto para o computador remoto e inicia uma ferramenta baseada em texto para executar as tarefas.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

A importância dos arquivos de texto no Linux

- No Linux, tudo é tratado como um arquivo (memória, os discos,o monitor e os diretórios).
- Praticamente tudo no Linux depende de arquivos de configuração para funcionar. Alguns serviços têm não um, mas vários arquivos de configuração.
- Os usuários com níveis de permissão adequados podem usar editores de texto para alterar o conteúdo dos arquivos de configuração.
- Depois que as alterações são feitas, o arquivo é salvo e pode ser usado pelo serviço ou aplicativo relacionado.
- Na figura, o administrador abriu o arquivo de configuração do host no nano para editar com o comando **sudo nano /etc/hosts.**
- O superusuário ou um usuário com o privilégio de superusuário pode alterar o arquivo host.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Laboratório — Trabalhando com arquivos de texto na CLI

Neste laboratório, você se familiarizará com os editores de texto de linha de comando e arquivos de configuração do Linux e concluirá os seguintes objetivos:

- Parte 1: Editores Gráficos de Texto
- Parte 2: Editores de texto de linha de comando
- Parte 3: Trabalhando com Arquivos de Configuração

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Laboratório — Familiarizando-se com o Shell do Linux

Neste laboratório, você usará a linha de comando do Linux para gerenciar arquivos e pastas e realizar algumas tarefas administrativas básicas.

- Parte 1: Noções básicas do Shell
- Parte 2: Copiando, Excluindo e Movendo Arquivos

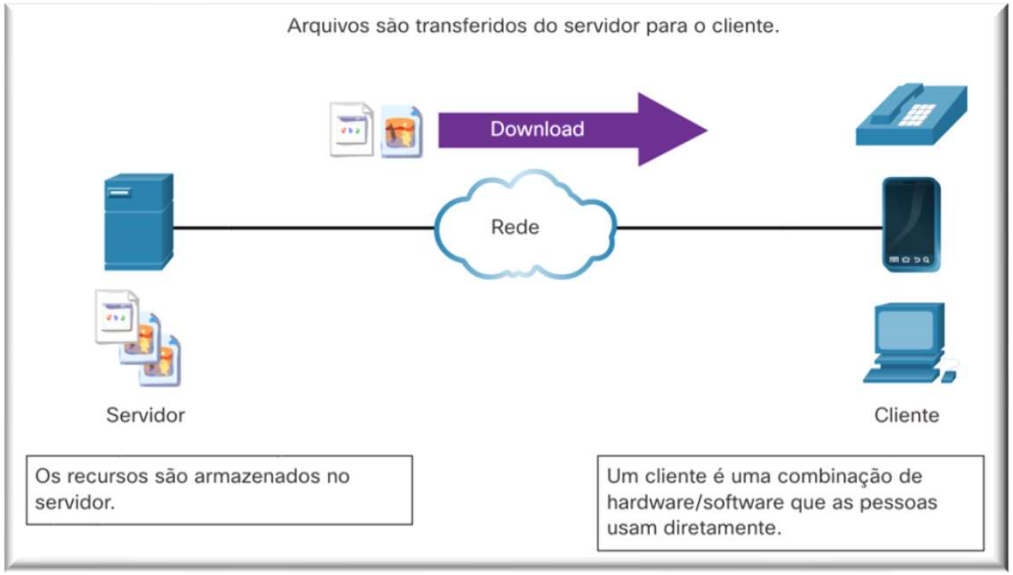
© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

8.3 Servidores e clientes do Linux

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Uma Introdução às Comunicações Cliente-Servidor

- Os servidores são computadores com software instalado que lhes permite fornecer serviços aos clientes em toda a rede.
- Alguns serviços fornecem recursos externos (arquivos, mensagens de e-mail, páginas da web) para clientes e outros executam tarefas de manutenção (gerenciamento de log, gerenciamento de memória, verificação de disco).
- Cada serviço exige um software de servidor separado. Por exemplo, o servidor na figura usa um software de servidor de arquivos para fornecer aos clientes a capacidade de recuperar e enviar arquivos.



suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Servidores, serviços e suas portas

- Para que um computador possa ser o servidor de vários serviços, as portas são usadas.
- Uma porta é um recurso de rede reservado usado por um serviço. Um servidor é dito estar "escutando" em uma porta quando ele se associou a essa porta.
- Embora o administrador possa decidir qual porta usar com qualquer serviço específico, muitos clientes são configurados para usar uma porta específica por padrão.
- É prática comum deixar o serviço em execução em sua porta padrão.

A tabela lista algumas portas comumente usadas ("portas bem-conhecidas") e seus serviços.

Porta	Descrição
20/21	File Transfer Protocol (FTP)
22	Secure Shell (SSH)
23	Serviço de login remoto Telnet
25	Protocolo SMTP
53	Sistema de Nomes de Domínio (DNS)

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Servidores, serviços e suas Portas (Cont.)

Porta	Descrição
67/68	Protocolo de Configuração Dinâmica de Host (DHCP)
69	Protocolo de Transferência Trivial de Arquivo (TFTP)
80	Protocolo HTTP
110	Protocolo POP3 (Post Office Protocol - Protocolo dos Correios)
123	Network Time Protocol (NTP)
143	Protocolo IMAP
161/162	Protocolo de Gerenciamento Simples de Rede (SNMP)
443	HTTP seguro (HTTPS)

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Clientes

- Os clientes são programas ou aplicativos projetados para comunicar com um tipo específico de servidor.
- Cliente (aplicativos cliente) os clientes usam um protocolo bem definido para se comunicar com o servidor.
- Navegadores Web são clientes da Web que são usados para se comunicar com servidores Web através do HTTP na porta 80.
- O cliente FTP (File Transfer Protocol) é um software usado para se comunicar com um servidor FTP.
- A figura mostra um cliente fazendo upload de arquivos para um servidor.



s. Todos os direitos reservados. Documento confidencial da Cisco

Laboratório Vídeo - Use um Scanner de Porta para detectar Portas Abertas

Neste vídeo, o uso de um scanner de porta e ferramenta de mapeamento de rede, Nmap, para detectar portas abertas é discutido e demonstrado:

- Passo 1: Abra uma janela de terminal no CSE-LABVM (PC com o CSE-LABVM instalado no VirtualBox).
- Passo 2: Execute o Nmap.
- Passo 3: Use privilégios administrativos com Nmap.
- Passo 4: Capture chaves SSH.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Laboratório - Use um Scanner de Porta para detectar Portas Abertas

Nesse laboratório, você vai usar o Nmap, um scanner de portas e uma ferramenta de mapeamento de rede, para detectar portas abertas

- Passo 1: Abra uma janela de terminal no CSE-LABVM (PC com o CSE-LABVM instalado no VirtualBox).
- Passo 2: Execute o Nmap.
- Passo 3: Use privilégios administrativos com Nmap.
- Passo 4: Capture chaves SSH.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Laboratório - Servidores Linux

Neste laboratório, você usará a linha de comando do Linux para identificar servidores em execução em um determinado computador.

- Parte 1: Servidores
- Parte 2: Usando Telnet para testar serviços TCP

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

8.4 Administração básica do servidor

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Arquivos de configuração de serviço

- No Linux, os serviços são gerenciados usando arquivos de configuração.
- As opções comuns nos arquivos de configuração são o número da porta, a localização dos recursos hospedados e os detalhes da autorização do cliente.
- Quando o serviço é iniciado, ele procura seus arquivos de configuração, carrega-os na memória e se ajusta de acordo com as configurações nos arquivos.
- As modificações do arquivo de configuração geralmente exigem a reinicialização do serviço antes que as alterações entrem em vigor.
- Como os serviços geralmente exigem privilégios de superusuário para serem executados, os arquivos de configuração de serviço geralmente exigem privilégios de superusuário para editar.
- A saída do comando mostra uma parte do arquivo de configuração do Nginx, que é um servidor web leve para Linux.

```
[analyst@secOps ~]$ cat /etc/nginx/nginx.conf
#user html;
worker_processes  1;
#error_log  logs/error.log;
#error_log  logs/error.log  notice;
#error_log  logs/error.log  info;
#pid        logs/nginx.pid;
events {
    worker_connections 1024;
}
http {
   include      mime.types;
   default_type  application/octet-stream;
   #log_format main '$remote_addr - $remote_user [$time_local] "$request"'
   #                '$status $body_bytes_sent "$http_referer"'
   #                '"$http_user_agent" "$http_x_forwarded_for"';
   #access_log logs/access.log main;
```

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Fortalecimento de Dispositivos (harderning)

- O fortalecimento (harderning) do dispositivo envolve a implementação de métodos comprovados de proteção do dispositivo e proteção de seu acesso administrativo.
- A definição de funções administrativas em termos de acesso é outro aspecto importante da proteção de dispositivos de infraestrutura.
- As atualizações do sistema operacional também são extremamente importantes para manter um dispositivo reforçado. Novas vulnerabilidades são descobertas todos os dias. Os desenvolvedores de SO criam e emitem correções e patches regularmente.

As práticas recomendadas básicas para o fortalecimento de dispositivo são as seguintes:

- Garanta a segurança física
- Minimizar pacotes instalados
- Desativar serviços não utilizados
- Usar SSH e desabilitar o login da conta raiz por SSH
- Manter o sistema atualizado
- Desativar a detecção automática de USB
- Aplicar senhas fortes
- Forçar mudanças de senha periódicas
- Manter os usuários de reutilizarem senhas antigas

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Logs de serviço de monitoramento

- Arquivos de log são os registros que um computador armazena para manter o controle de eventos importantes. Kernel, serviços e eventos de aplicativos são todos registrados em arquivos de log.
- É muito importante que um administrador revise periodicamente os logs de um computador para mantê-lo saudável.
- Ao monitorar arquivos de log do Linux, um administrador obtém uma visão clara do desempenho do computador, status de segurança e quaisquer problemas subjacentes.
- A análise do arquivo de log permite que um administrador proteja contra problemas futuros antes que eles ocorram.

No Linux, os arquivos de log podem ser categorizados como:

- Logs de aplicativos
- Logs de eventos
- Registros de serviço
- Logs do sistema

- Alguns logs contêm informações sobre daemons que estão sendo executados no sistema Linux.
- Um daemon é um processo em segundo plano que é executado sem a necessidade de interação do usuário.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Monitoramento de logs de serviço (Cont.)

A tabela lista alguns arquivos de log populares do Linux e suas funções

Arquivo de log do Linux	Descrição
/var/log/messages	Este diretório contém logs genéricos de atividade do computador. Ele é usado principalmente para armazenar mensagens informativas e não críticas do sistema.
/var/log/auth.log	Este arquivo armazena todos os eventos relacionados à autenticação em computadores Debian e Ubuntu. Qualquer coisa que envolva o mecanismo de autorização do usuário pode ser encontrada neste arquivo.
/var/log/secure	Este diretório é usado por computadores RedHat e CentOS em vez de /var/log/auth.log.Ele também rastreia logins sudo, logins SSH e outros erros registrados pelo SSSD.
/var/log/boot.log	Este arquivo armazena informações relacionadas à inicialização e mensagens registradas durante o processo de inicialização do computador.
/var/log/dmesg	Este diretório contém mensagens de buffer do anel do kernel. Informações relacionadas a dispositivos de hardware e seus drivers são registradas aqui.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Monitoramento de logs de serviço (Cont.)

A tabela lista alguns arquivos de log populares do Linux e suas funções

Arquivo de log do Linux	Descrição
/var/log/kern.log	Este arquivo contém informações registradas pelo kernel.
/var/log/cron	Cron é um serviço usado para agendar tarefas automatizadas no Linux e este diretório armazena seus eventos.
/var/log/mysqld.log ou /var/log/mysql.log	Este é o arquivo de log do MySQL.Todas as mensagens de depuração, falha e sucesso relacionadas ao processo mysqld e ao daemon mysqld_safe são registradas aqui.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Laboratório — Localizando arquivos de log

Neste laboratório, você vai se familiarizar com a localização e manipulação de arquivos de log do Linux.

- Parte 1: Visão geral do arquivo de log
- Parte 2: Localizando arquivos de log em sistemas desconhecidos
- Parte 3: Monitoramento de Arquivos de Log em Tempo Real

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

8.5 O sistema de arquivos no Linux

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Os tipos de sistema de arquivos no Linux

Sistema de arquivos no Linux	Descrição
ext2 (segundo sistema de arquivos estendido)	Era o sistema de arquivos padrão em várias distribuições Linux principais até ser suplantado pelo ext3.
ext3 (terceiro sistema de arquivos estendido)	Ele é um sistema de arquivo registrado projetado para melhorar o sistema de arquivo ext2 existente.
ext4 (quarto sistema de arquivos estendido)	Projetado como sucessor do ext3, foi criado com base em uma série de extensões do ext3, mas o projeto ext3 foi dividido em dois; um mantido como ext3 (desenvolvimento normal) e outro, ext4 (as extensões mencionadas).
NFS (Network File System)	NFS é um sistema de arquivos baseado em rede, permitindo acesso a arquivos pela rede.
CDFS (Compact Disc File System)	O CDFS foi criado especificamente para mídia de disco óptico.
Sistema de troca de arquivos	O sistema de arquivos de troca é usado pelo Linux quando fica sem RAM.
HFS Plus ou HFS+ (Sistema de Arquivos Hierárquico Plus)	Um sistema de arquivos usado pela Apple em seus computadores Macintosh. O kernel Linux inclui um módulo para montar HFS+ para operações de leitura-gravação.
APFS (Sistema de Arquivos Apple)	Um sistema de arquivos atualizado que é usado por dispositivos Apple.
Master Boot Record (MBR)	Localizado no primeiro setor de um computador particionado, o MBR armazena todas as informações sobre a forma como o sistema de arquivos é organizado.

Os tipos de sistema de arquivos no Linux (Cont.)

- Montagem é o termo usado para o processo de atribuição de um diretório a uma partição.
- Após uma operação de montagem bem-sucedida, o sistema de arquivos contido na partição é acessível através do diretório especificado.

A saída do comando mostra parte da saída do comando **mount** emitido na VM Cisco CyberOps .

- Quando emitido sem opções, **mount** retorna a lista de sistemas de arquivos atualmente montados em um computador Linux.
- Observe que o sistema de arquivos raiz (destacado) é representado pelo símbolo “/” e contém todos os arquivos do computador por padrão.
- A saída também mostra que o sistema de arquivos raiz foi formatado como ext4 e ocupa a primeira partição da primeira unidade (/dev/sda1).

```
[analyst@secOps ~]$ mount
proc on /proc type proc (rw,nosuid,nodev,noexec,relatime)
sys on /sys type sysfs (rw,nosuid,nodev,noexec,relatime)
dev on /dev type devtmpfs (rw,nosuid,relatime,size=494944k,nr_inodes=123736,mode=755)
run on /run type tmpfs (rw,nosuid,nodev,relatime,mode=755)
/dev/sda1 on / type ext4 (rw,relatime)
securityfs on /sys/kernel/security type securityfs (rw,nosuid,nodev,noexec,relatime)
tmpfs on /dev/shm type tmpfs (rw,nosuid,nodev)
devpts on /dev/pts type devpts (rw,nosuid,noexec,relatime,gid=5,mode=620,ptmxmode=000)
tmpfs on /sys/fs/cgroup type tmpfs (ro,nosuid,nodev,noexec,mode=755)
cgroup2 on /sys/fs/cgroup/unified type cgroup2
(rw,nosuid,nodev,noexec,relatime,nsdelegate)
cgroup on /sys/fs/cgroup/systemd type cgroup
(rw,nosuid,nodev,noexec,relatime,xattr,name=systemd)
pstore on /sys/fs/pstore type pstore (rw,nosuid,nodev,noexec,relatime)
none on /sys/fs/bpf type bpf (rw,nosuid,nodev,noexec,relatime,mode=700)
cgroup on /sys/fs/cgroup/rdma type cgroup (rw,nosuid,nodev,noexec,relatime,rdma)
cgroup on /sys/fs/cgroup/cpu,cpuacct type cgroup
(rw,nosuid,nodev,noexec,relatime,cpu,cpuacct)
cgroup on /sys/fs/cgroup/blkio type cgroup (rw,nosuid,nodev,noexec,relatime,blkio)
```

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

O sistema de arquivos Linux

Funções do Linux e permissões de arquivo

Considere a saída do comando **ls -l**.

```
[analyst@secOps ~]$ ls -l space.txt
-rwxrw-r-- 1 analyst staff 253 May 20 12:49 space.txt
    (1)  (2) (3)    (4) (5)    (6)        (7)
```

Campo	Descrição
1	Ele exibe as permissões associadas ao arquivo. O traço (-) significa que este é um arquivo. Para diretórios, o primeiro traço seria um “d”. O primeiro conjunto de caracteres é para permissão de usuário (rwx) que é o dono do arquivo. O usuário pode ler, escrever e executar o arquivo. O segundo conjunto de caracteres é para permissões de grupo (rw-) que são os donos do arquivo. O grupo pode ler e escrever no arquivo. O terceiro conjunto de caracteres é para permissão de quaisquer outros usuários ou grupos (r--). Eles podem somente ler o arquivo.
2	Ele define o número de links rígidos (hard links) para o arquivo (o número 1 após as permissões).
3	Exibe o usuário (analyst).
4	Exibe o grupo (staff)
5	Ele exibe o tamanho do arquivo em bytes (253 bytes).
6	Ele mostra a data e hora da última modificação (May 20 12:49).
7	Exibe o nome do arquivo (space.txt).

Funções do Linux e Permissões de Arquivo(Cont.)

Use valores octais para definir permissões.

Binário	Octal	Permissão	Descrição
000	0	---	Sem acesso
001	1	--x	Executar apenas
010	2	-w-	Somente escrita
011	3	-wx	Edição e execução
100	4	r--	Somente leitura
101	5	r-x	Ler e Executar
110	6	rw-	Leitura e Escrita
111	7	rwx	Leitura, edição e execução

Permissões de arquivo são uma parte fundamental do Linux e não podem ser quebradas. Um usuário tem apenas os direitos de um arquivo que as permissões de arquivo permitem. O único usuário que pode substituir a permissão de arquivo em um computador Linux é o usuário root.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Links rígidos e links simbólicos

- Um link rígido é outro arquivo que aponta para o mesmo local que o arquivo original.
- Use o comando **ln**para criar um link rígido (hard link) O primeiro argumento é o arquivo existente e o segundo argumento é o novo arquivo.
- A saída do comando mostra o arquivo space.txt que está vinculado a space.hard.txt e o campo de link agora mostra 2.
- Ambos os arquivos apontam para o mesmo local no sistema de arquivos.
- Se você alterar um arquivo, o outro também será alterado.
- O comando **echo** é usado para adicionar algum texto ao space.txt (o tamanho do arquivo para ambos os arquivos aumentou).
- Se você excluir o novo arquivo com o comando **rm**, o original ainda existirá (comando more **space.txt**).

```
[analyst@secOps ~]$ ln space.txt space.hard.txt
[analyst@secOps ~]$
[analyst@secOps ~]$ ls -l space*
-rw-r--r-- 2 analyst analyst 239 May 7 18:18 space.hard.txt
-rw-r--r-- 2 analyst analyst 239 May 7 18:18 space.txt
[analyst@secOps ~]$
[analyst@secOps ~]$ echo "Testing hard link" >> space.hard.txt
[analyst@secOps ~]$
[analyst@secOps ~]$ ls -l space*
-rw-r--r-- 2 analyst analyst 257 May 7 18:19 space.hard.txt
-rw-r--r-- 2 analyst analyst 257 May 7 18:19 space.txt
[analyst@secOps ~]$
[analyst@secOps ~]$ rm space.hard.txt
[analyst@secOps ~]$
[analyst@secOps ~]$ more space.txt
Space... The final frontier…
These are the voyages of the Starship Enterprise. Its continuing mission:
- To explore strange new worlds…
- To seek out new life; new civilizations…
- To boldly go where no one has gone before!
Testing hard link
```

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Links rígidos e links simbólicos (Cont.)

- Um link simbólico é semelhante a um link rígido em que a aplicação de alterações ao link simbólico também mudará o arquivo original.
- O comando **ln -**s cria um link simbólico.

- Links simbólicos tem um único ponto de falha (o arquivo subjacente) mas têm vários benefícios sobre links rígidos:
  - Localizar links rígidos é mais difícil. Links simbólicos mostram a localização do arquivo original (comando **ls -l**).
  - Links simbólicos podem ser vinculados a um arquivo em outro sistema de arquivos.
  - Links simbólicos podem ser vinculados a diretórios.

```
[analyst@secOps ~]$ echo "Hello World!" > test.txt
[analyst@secOps ~]$
[analyst@secOps ~]$ ln -s test.txt mytest.txt
[analyst@secOps ~]$
[analyst@secOps ~]$ echo "It's a lovely day!" >> mytest.txt
[analyst@secOps ~]$
[analyst@secOps ~]$ more test.txt
Hello World!
It's a lovely day!
[analyst@secOps ~]$
[analyst@secOps ~]$ rm test.txt
[analyst@secOps ~]$
[analyst@secOps ~]$ more mytest.txt
more: stat of mytest.txt failed: No such file or directory
[analyst@secOps ~]$
[analyst@secOps ~]$ ls -l mytest.txt
lrwxrwxrwx 1 analyst analyst 8 May 7 20:17 mytest.txt -> test.txt
[analyst@secOps ~]$
```

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Laboratório - Navegando no Sistema de Arquivos Linux e Configurações de Permissão

Neste laboratório, você se familiarizará com sistemas de arquivos Linux.

- Parte 1: Explorando sistemas de arquivos no Linux
- Parte 2: Permissões de arquivo
- Parte 3: Links simbólicos e outros tipos de arquivos especiais

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

8.6 Como trabalhar com a interface gráfica (GUI) do Linux

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Trabalhando com a GUI Linux

Sistema X Window

- A interface gráfica presente na maioria dos computadores Linux (X ou X11) é baseada no X Window System.
- X Windows [e projetado para fornecer a estrutura básica para uma GUI.
- Ele inclui funções para desenhar e mover janelas no dispositivo de exibição e interagir com um mouse e teclado.
- X funciona como um servidor que permite que um usuário remoto use a rede para se conectar, iniciar um aplicativo gráfico e ter a janela gráfica aberta no terminal remoto.
- Enquanto o aplicativo em si é executado no servidor, o aspecto gráfico dele é enviado por X pela rede e exibido no computador remoto.
- X não especifica a interface do usuário, deixando para outros programas, como gerenciadores de janelas, definir todos os componentes gráficos.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Trabalhando com a interface gráfca (GUI) do Linux

A GUI do Linux

- As GUIs são consideradas mais fáceis de usar do que a CLI.Este módulo se concentra no Ubuntu ao cobrir o Linux, porque é uma distribuição muito popular e amigável.
- Ubuntu Linux usa Gnome 3 como sua GUI padrão. O objetivo do Gnome 3 é tornar o Ubuntu ainda mais amigável. A tabela lista os principais componentes da interface do usuário do Unity.

Componente UI	Descrição
Menu Apps	Ele mostra ícones para os aplicativos que estão instalados no sistema. Um menu com o botão direito do mouse fornece atalhos que permitem iniciar ou configurar os aplicativos.
Dock do Ubuntu	Este é um dock no lado esquerdo da tela que serve como um inicializador de aplicativos e alternador para favoritos de aplicativos. Clique para iniciar um aplicativo e, quando o aplicativo estiver em execução, clique novamente para alternar entre aplicativos em execução.
Barra superior	Esta barra de menu multiuso contém um menu para o aplicativo que atualmente tem o foco. Ele exibe a hora atual e indica se há novas mensagens do sistema.
Calendário e bandeja de mensagens do sistema	Clique no dia e na hora para ver o calendário de compromissos completo e as mensagens atuais do sistema. Acesse o calendário de compromissos a partir daqui para criar novos compromissos.
Atividades	Alterne para a exibição de aplicativo para alternar ou fechar aplicativos em execução.
Menu de Status	Permite a configuração do adaptador de rede e de outros dispositivos em execução.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

8.7 Como trabalhar em um host Linux

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Instalação e execução de aplicativos em um host Linux

- Muitos aplicativos de usuário final são programas complexos escritos em linguagens compiladas.Para ajudar no processo de instalação, o Linux geralmente inclui programas chamados gerenciadores de pacotes.

- Um pacote é o termo usado para se referir a um programa e todos os seus arquivos de suporte. Ao usar um gerenciador de pacotes para instalar um pacote, todos os arquivos necessários são colocados no local correto do sistema de arquivos.

- Os gerenciadores de pacotes variam dependendo das distribuições do Linux. Pacman é usado pelo Arch Linux enquanto dpkg (pacote Debian) e apt (Advanced Packaging Tool) são usados em distribuições Linux Debian e Ubuntu .

- O comando **apt-get update** é usado para obter a lista de pacotes do repositório de pacotes e atualizar o banco de dados de pacotes local.

- O comando **apt-get upgrade** é usado para atualizar todos os pacotes atualmente instalados para suas versões mais recentes.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Trabalhando em um host Linux

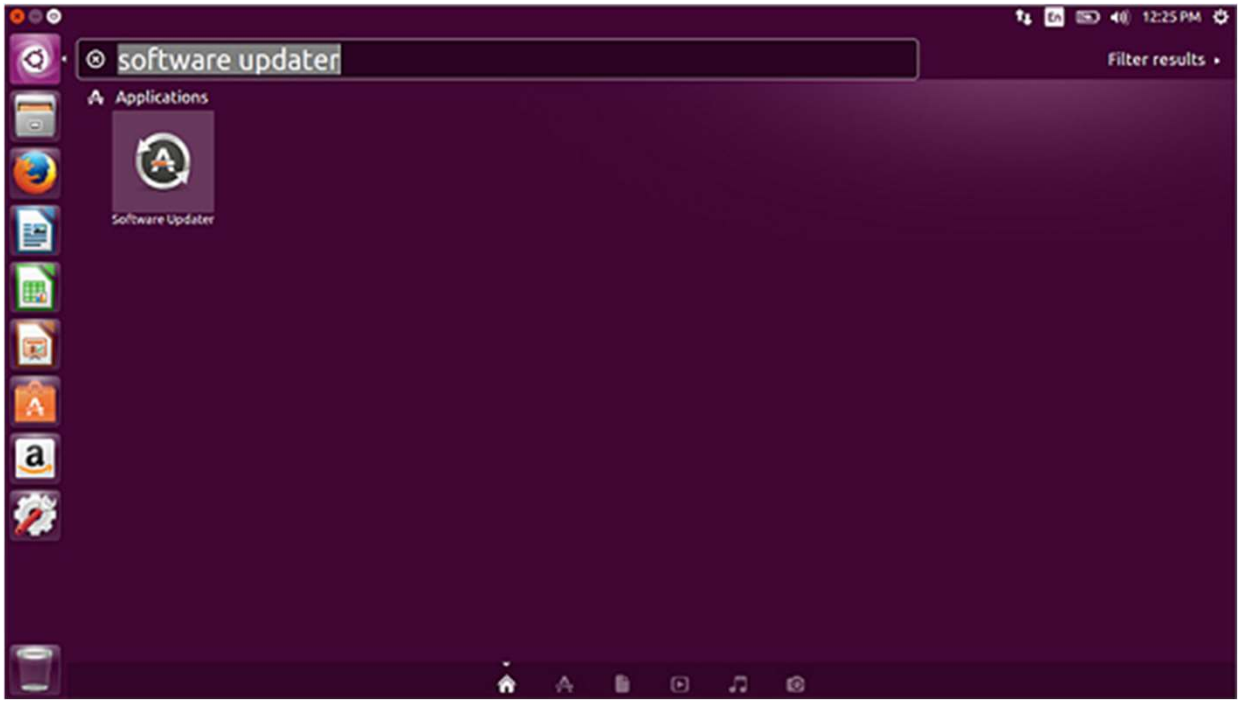
Mantendo o sistema atualizado

- Também conhecido como patches, as atualizações do sistema operacional são lançadas periodicamente por empresas de sistema operacional para resolver quaisquer vulnerabilidades conhecidas em seus sistemas operacionais.
- Embora as empresas tenham programações de atualização, o lançamento de atualizações não programadas do sistema operacional pode acontecer quando uma vulnerabilidade importante é encontrada no código do sistema operacional.
- Os sistemas operacionais modernos alertarão o usuário quando atualizações estiverem disponíveis para download e instalação, mas o usuário pode verificar as atualizações a qualquer momento.
- A tabela compara os comandos das distribuição Arch Linux e Debian / Ubuntu Linux para realizar operações básicas do sistema de pacotes.

Tarefa	Arch	Debian/Ubuntu
Instalar um pacote pelo nome	pacman -S	apt install
Remover um pacote pelo nome	pacman -Rs	apt remove
Atualize um pacote local	pacman -Syy	apt-get update
Atualizar todos os pacotes atualmente instalados	pacman -Syu	apt-get upgrade

Mantendo o sistema atualizado (Cont.)

- Uma GUI do Linux também pode ser usada para verificar e instalar atualizações manualmente.
- No Ubuntu, por exemplo, para instalar atualizações, clique em Dash Search Box, digite Atualizador de Software e clique no ícone Atualizador de Software, conforme mostrado na figura.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Processos e Forks

- Os sistemas operacionais multitarefa podem executar muitos processos ao mesmo tempo.
- Os processos precisam de uma maneira de criar novos processos em sistemas operacionais multitarefa. A operação bifurcação (fork) é a única maneira de fazer isso no Linux.
- Quando um processo é bifurcado (fork), o processo do chamador se torna o processo pai, com o processo recém-criado referido como seu filho.
- Depois da bifurcação, os processos são, até certo ponto, processos independentes; eles têm IDs de processo diferentes, mas executam o mesmo código de programa. A tabela lista três comandos usados para gerenciar processos.

Comando	Descrição
ps	Usado para listar os processos em execução no computador no momento em que ele é chamado.Ele pode ser instruído a exibir processos em execução que pertencem ao usuário atual ou a outros usuários.
top	Usado para listar processos em execução, mas ao contrário do ps, top continua exibindo processos em execução dinamicamente. Pressione q para sair do top.
kill	Usado para modificar o comportamento de um processo específico.Dependendo dos parâmetros, kill removerá, reiniciará ou pausará um processo.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Malware em um host Linux

- O malware do Linux inclui vírus, cavalos de Tróia, worms e outros tipos de malware que podem afetar o sistema operacional.
- Devido a uma série de componentes de design, tais como estrutura do sistema de arquivos, permissões de arquivo e restrições de conta de usuário, sistemas operacionais Linux são geralmente considerados como melhor protegidos contra malware.
- Linux não é imune a malware. Muitas vulnerabilidades foram encontradas e exploradas no Linux.
- Como o Linux é de código aberto, correções e patches são frequentemente disponibilizados em poucas horas após a descoberta de tais problemas.
- Se um programa malicioso for executado, ele causará danos, independentemente da plataforma. Um vetor de ataque Linux comum é seus serviços e processos.
- Como acontece com a maioria das vulnerabilidades, manter o computador atualizado e fechar todos os serviços e portas não utilizados é uma boa maneira de reduzir as oportunidades de ataque em um computador Linux.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Verificação de Rootkit

- Um rootkit é um tipo de malware projetado para aumentar os privilégios de um usuário não autorizado ou conceder acesso a partes do software que normalmente não devem ser permitidas.
- Sua instalação pode ser automatizada (feita como parte de uma infecção) ou manualmente.
- Ele muda o código do kernel e seus módulos, alterando as operações mais fundamentais do próprio sistema operacional.
- A maioria dos comprometimentos de rootkit requer acesso root ou administrador.
- Como a própria natureza do computador está comprometida, a detecção de rootkit pode ser muito difícil.
- Os métodos de inspeção incluem métodos baseados em comportamento, varredura de assinatura, varredura de diferenças e análise de despejo de memória.
- A remoção do Rootkit pode ser complicada e muitas vezes impossível, especialmente nos casos em que o rootkit reside no kernel; a reinstalação do sistema operacional geralmente é a única solução real para o problema.
- Os rootkits de firmware geralmente requerem substituição de hardware.
- **Chkrootkit** é um popular programa baseado em Linux projetado para verificar o computador para rootkits conhecidos.
- Embora útil, tenha em mente que os programas para verificar se há rootkits não são 100% confiáveis.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Comandos de piping

- Muitos comandos podem ser combinados para executar tarefas mais complexas por meio de uma técnica conhecida como tubulação.
- Piping consiste em encadear comandos , alimentando a saída de um comando na entrada de outro usando o caractere "|" (pipe)
- Por exemplo , o comando **ls** é usado para exibir todos os arquivos e diretórios de um determinado diretório. O comando **grep** compara pesquisas através de um arquivo ou texto procurando a string especificada.
- Os dois comandos, **ls** e **grep**, podem ser utilizados juntos para filtrar a saída de **ls**. Isto é mostrado na saída do comando **ls -l | grep host** e do comando **ls -l | grep file**.

```
[analyst@secOps ~]$ ls -l
total 40
drwxr-xr-x 2 analyst analyst    4096 Mar  22  2018 Desktop
drwxr-xr-x 3 analyst analyst    4096 April 2 14:44 Downloads
-rw-r--r-- 1 analyst analyst    9 May 20 10:51 hostfile1.txt
-rw-r--r-- 1 analyst analyst    9 May 20 10:51 hostfile2.txt
-rw-r--r-- 1 analyst analyst    9 May 20 10:52 hostfile3.txt
drwxr-xr-x 9 analyst analyst    4096 Jul 19 2018 lab.support.files
-rw-r--r-- 1 analyst analyst    19 May 20 10:53 mytest.com
```

```
[analyst@secOps ~]$ ls -l | grep host
-rw-r--r-- 1 analyst analyst    9 May 20 10:51 hostfile1.txt
-rw-r--r-- 1 analyst analyst    9 May 20 10:51 hostfile2.txt
-rw-r--r-- 1 analyst analyst    9 May 20 10:52 hostfile3.txt
```

```
[analyst@secOps ~]$ ls -l | grep file
-rw-r--r-- 1 analyst analyst    9 May 20 10:51 hostfile1.txt
-rw-r--r-- 1 analyst analyst    9 May 20 10:51 hostfile2.txt
-rw-r--r-- 1 analyst analyst    9 May 20 10:52 hostfile3.txt
drwxr-xr-x 9 analyst analyst  4096 Jul 19 2018 lab.support.files
```

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Vídeo - Aplicações, Rootkits e comandos piping

Este vídeo aborda o seguinte:

- Uma demonstração de instalação e atualização de aplicativos.
- Verificando um rootkit.
- Uso de comandos piping

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Laboratório - Configurar recursos de segurança no Windows e Linux

Neste laboratório, você criará pontos de restauração e backups para uso em sistemas Windows e Linux. Além disso, você configurará o Windows Defender Firewall para permitir o tráfego desejado. Em um sistema Linux, você configurará o Uncomplicated Firewall (UFW) para bloquear o tráfego Telnet não seguro. Você também vai desativar os serviços Telnet.

- Parte 1: Criar backups e restaurar pontos
- Parte 2: Configurar regras de firewall
- Parte 3: Desativar serviços
- Parte 4: Restauração

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

8.8 Resumo dos conceitos básicos do Linux

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Resumo Conceitos Básicos do Linux

O que aprendi neste módulo?

- Linux é um sistema operacional de código aberto que é rápido, poderoso e altamente personalizável.
- Foi criado e atualmente é mantido por uma comunidade de programadores.
- Ele foi projetado para ser conectado à rede, o que torna muito mais simples para escrever e usar aplicações baseadas em rede
- Uma distribuição Linux (distro) é o termo usado para descrever pacotes criados por diferentes organizações. Ele inclui o kernel do Linux com ferramentas personalizadas e pacotes de software.
- A flexibilidade fornecida pelo Linux é um ótimo recurso para o SOC. Todo o sistema operacional pode ser adaptado para se tornar a plataforma de análise de segurança perfeita.
- No Linux, o usuário se comunica com o SO usando a CLI ou a interface gráfica GUI (padrão)
- Muitas ferramentas de linha de comando estão incluídas no Linux por padrão. Para ajustar a operação de comando, usuários podem passar parâmetros e opções junto com o comando.
- Linux tem muitos editores de texto diferentes, com vários recursos e funções.
- No Linux, tudo é tratado como um arquivo (memória, discos, monitor e os diretórios).
- No Linux, os serviços são gerenciados usando arquivos de configuração. Quando o serviço é iniciado, ele procura por seus arquivos de configuração, carrega-os na memória e se ajusta de acordo com as configurações nos arquivos.
- Arquivos de log são os registros que um computador armazena para manter o controle de eventos importantes. No Linux, os arquivos de log podem ser categorizados como logs de aplicativo, logs de eventos, logs de serviço e logs do sistema.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Módulo 8 : Termos e comandos Conceitos Básicos do Linux

- Centro de Operações de Segurança (SOC)
- ext2 (segundo sistema de arquivos estendido)
- ext3 (terceiro sistema de arquivos estendido)
- ext4 (quarto sistema de arquivos estendido)
- CDFS (Compact Disc File System)
- HFS Plus ou HFS+ (Sistema de Arquivos Hierárquico Plus)
- APFS (Sistema de Arquivos Apple)
- Master Boot Record (MBR)

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco



Módulo 9: Proteção do Sistema e do Endpoint

Segurança de endpoint

Objetivos do módulo

Título do Módulo: Proteção de Sistema e Endpoint

Objetivo do módulo: Avaliar a proteção de endpoints e os impactos do malware.

Título do Tópico	Objetivo do Tópico
Defesa de sistemas e dispositivos	Usar os processos e procedimentos para proteger os sistemas.
Proteção Antimalware	Explicar os métodos de mitigação de malware.
Prevenção de intrusão baseada em host	Recomendar medidas de segurança de endpoint.
Segurança de aplicações	Usar as ferramentas de investigação de malware para saber mais sobre os recursos.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

9.1 Defender sistemas e dispositivos

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Defesa de sistemas e dispositivos

Software de sistema operacional

O que uma organização precisa fazer para fortalecer um sistema operacional e mantê-lo seguro?

Um bom administrador irá:

- configurar o sistema operacional para proteger contra ameaças externas.
- Remover serviços e programas desnecessários.
- Garanta que os patches e atualizações de segurança sejam instalados em tempo hábil para corrigir falhas e mitigar riscos.

Uma empresa deve:

- Manter uma abordagem sistemática para abordar as atualizações do sistema
- Estabelecer procedimentos para monitorar informações relacionadas à segurança.
- Avaliar atualizações para aplicabilidade.
- Planejar a instalação de atualizações e patches de aplicativos.
- Instalar atualizações usando um plano documentado.

Uma linha de base

- Another critical way to secure an operating system is to identify potential vulnerabilities.
- Estabeleça **uma** linha de base para comparar o desempenho de um sistema com as expectativas da linha de base.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Pontos para lembrar

- **Cuidado com os produtos antivírus desonestos:** Os produtos antivírus desonestos podem aparecer durante a navegação na Internet e a maioria exibe um anúncio ou pop-up que se parece com um aviso real do Windows. Clicar em qualquer lugar dentro da janela pode baixar e instalar malware.

- **Os ataques sem arquivo são difíceis de detectar e remover:** o malware sem arquivo usa programas legítimos para infectar um computador. Vírus sem arquivo são difíceis de detectar e usar linguagens de script como o Windows PowerShell.

- **Os scripts também podem ser malware:** linguagens de script como Python, Bash (a linguagem de linha de comando para macOS da Apple e a maioria das distribuições Linux) ou Visual Basic for Applications (ou VBA, usado em macros da Microsoft) podem ser usados para criar scripts que são malware

- **Sempre remova software não aprovado**: software não aprovado ou não compatível pode ser instalado acidentalmente em um computador. Ele pode interferir no software ou nos serviços de rede da organização e deve ser removido imediatamente.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Gerenciamento de patches

- Para ficar um passo à frente dos cibercriminosos, mantenha os sistemas seguros e atualizados instalando patches regularmente.
- Os patches são atualizações de código que os fabricantes fornecem para evitar que um vírus ou um worm recém-descoberto façam um ataque bem-sucedido.
- Sistemas operacionais como o Windows verificam rotineiramente atualizações que podem proteger um computador contra as ameaças à segurança mais recentes.
- Como um profissional de segurança digital, é uma boa prática testar um patch antes de implantá-lo em toda a empresa.
- Uma ferramenta de gerenciamento de patches pode ser usada para gerenciar patches localmente, em vez de usar o serviço de atualização on-line do fornecedor.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Gerenciamento de patches (Cont.)

- Um serviço de patches automáticos fornece aos administradores um ambiente mais controlado.

- Os benefícios são:
  - Os administradores podem aprovar ou recusar atualizações
  - Os administradores podem forçar a atualização de sistemas para uma data específica
  - Os administradores podem obter relatórios sobre a atualização necessária para cada sistema
  - Cada computador não tem que se conectar ao serviço do fornecedor para baixar os patches. Um sistema obtém a atualização de um servidor local
  - Os usuários não podem desativar ou contornar as atualizações

- Além de proteger o sistema operacional, é importante atualizar aplicativos de terceiros, como Adobe Acrobat, Java e Chrome, para lidar com vulnerabilidades que podem ser exploradas.

- Uma abordagem proativa ao gerenciamento de patches oferece segurança de rede e ajuda a evitar ransomware e outras ameaças.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Defesa de sistemas e dispositivos

Segurança de Endpoints

As opções de solução baseada em host são:

- **Firewall baseado em host:**é executado em um dispositivo para restringir as atividades de rede entrantes e saintes para este dispositivo.

- **Sistema de detecção de invasão de host (HIDS): um software instalado em um dispositivo ou servidor para monitorar atividades suspeitas e detectar solicitações maliciosas.**

- **Sistema de prenção de intrusão de host (HIPS):** Um software que monitora um dispositivo em busca de ataques e anomalias (desvios de largura de banda, protocolos e portas), ou descobre sinais de alerta ao avaliar os protocolos em pacotes.

- **Detecção e resposta de endpoint (EDR): solução de segurança integrada que monitora, coleta e analisa continuamente dados de um dispositivo de endpoint e responde a qualquer ameaça que detecta.**

- **Prevenção contra perda de dados (DLP):** Ferramentas DLP fornecem uma maneira centralizada de garantir que os dados confidenciais não sejam interrompidos, perdidos, mal utilizados ou acessados por usuários não autorizados.

- **Firewall de ùltima geração (NGFW):** um dispositivo de segurança de rede que combina um firewall tradicional com outras funções de filtragem de dispositivos de rede.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Criptografia de host

- O recurso Windows Encrypting File System (EFS) permite que os usuários criptografem arquivos, pastas ou um disco rígido inteiro.

- A criptografia de disco completa (FDE) criptografa todo o conteúdo de uma unidade (incluindo arquivos temporários e memória).

- O Microsoft Windows usa o BitLocker para FDE.
  - Antes de usar o BitLocker, o usuário precisa ativar o TPM (Trusted Platform Module, Módulo de plataforma confiável) na BIOS.
  - TPM é um chip específico na placa-mãe que armazena informações específicas do sistema computacional como chaves de criptografia, certificados digitais e senhas.

- Da mesma forma, o BitLocker To Go é uma ferramenta que criptografa unidades removíveis. Ele não usa um chip TPM, mas ainda criptografa os dados, exigindo uma senha para descriptografá-los.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Integridade da Inicialização

- Os invasores podem atacar a qualquer momento, mesmo no curto espaço de tempo que um sistema leva para iniciar. É fundamental garantir que os sistemas e dispositivos permaneçam seguros durante a inicialização.

- A integridade de inicialização garante que o sistema seja confiável e não tenha sido alterado enquanto o sistema operacional é carregado.

- O firmware - instruções de software sobre as funções básicas do computador - é armazenado em um pequeno chip de memória na placa-mãe. A BIOS é o primeiro programa executado quando você liga o computador.

- A Unified Extensible Firmware Interface (UEFI), uma versão mais recente do BIOS, define uma interface padrão entre o sistema operacional, o firmware e os dispositivos externos.

- A inicialização segura é um padrão de segurança para garantir que um dispositivo inicialize usando software confiável.

- A inicialização medida fornece uma validação mais forte do que a inicialização segura.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Recursos de segurança do sistema Apple

- Distribuições Linux e o Windows incluem recursos de segurança projetados para proteger endpoints.

- A Apple oferece hardware de sistema e recursos de segurança de macOS que também oferecem proteção avançada para endpoint.

- Os recursos de segurança da Apple incluem o seguinte:

  - **Hardware com foco em segurança:** A plataforma de hardware possui recursos de segurança aprimorados, como uma CPU especial, boot e um mecanismo de criptografia AES dedicado.

  - **Armazenamento criptografado:** A proteção de dados da Apple e a criptografia de armazenamento de dados FileVault são suportadas pelo mecanismo de criptografia AES baseado em hardware.

  - **Secure Boot:** O Boot ROM protege o hardware baixo-nível e permite apenas a execução de software genuíno e não adulterado do sistema operacional da Apple.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Recursos de segurança do sistema Apple (Cont.)

- **Dados biométricos seguros:** Processado no sistema de hardware de segurança Isso o mantém separado do SO e da execução de software de aplicativo, incluindo malware.
- **O Find My Mac:** ajuda a encontrar dispositivos macOS perdidos ou roubados por meio da função de rastreamento de localização. Ele também permit e o bloqueio remoto do dispositivo e o apagamento do armazenamento se dados essenciais estiverem em risco.
- **XProtect:** Tecnologia antimalware impede a execução de malware através da detecção de malware por assinatura. Ele também alerta os usuários sobre a existência de malware e oferece a opção de remover os arquivos de malware detectados.
- **Ferramenta de Remoção de Malware (MRT):** Detecta e remove as infecções de malware atuais quando as regras de detecção são atualizadas automaticamente pela Apple. Ele também monitora infecções por malware na reinicialização do sistema e no login de usuários.
- **Gatekeeper:** Garante que apenas o software autêntico, assinado digitalmente, criado por um desenvolvedor de software autenticado pela Apple, tenha permissão para ser instalado.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Proteção física de servidores

Medidas de segurança que protegem ameaças de software e hardware:

- **Equipamento de Informática**
  - Use bloqueios de cabo para proteger dispositivos
  - Mantenha as salas de telecomunicações trancadas
  - Use gaiolas de segurança (gaiolas de Faraday) ao redor do equipamento para bloquear campos eletromagnéticos.

- **Travas de portas**
  - Uma fechadura de entrada com chave padrão é o tipo mais comum de fechadura de porta e geralmente é fácil de forçar a abertura.
  - Uma trava de bloqueio pode ser adicionada para aumentar a segurança.
  - Uma fechadura cifrada usa botões que são pressionados em uma determinada sequência para abrir a porta.

- **Sistemas de identificação por radiofrequência (RFID)**
  - A RFID (Radio Frequency Identification, Identificação por radiofrequência) usa ondas de rádio para identificar e rastrear objetos.
  - As etiquetas RFID são pequenas, requerem pouca energia, contêm um circuito integrado conectado a uma antena e podem ser anexadas a qualquer item que uma organização deseja rastrear.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Defesa de sistemas e dispositivos

Laboratório - Fortaleça um Sistema Linux

Neste laboratório, você usará uma ferramenta de auditoria de segurança para descobrir vulnerabilidades do sistema e implementar as soluções recomendadas para proteger o sistema.

- Parte 1: Abra uma janela de terminal no CSE-LABVM.
- Parte 2: Examine a versão atual do Lynis.
- Parte 3: Execute a ferramenta Lynis.
- Parte 4: Revise os resultados de sua varredura e resolva quaisquer avisos.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Defesa de sistemas e dispositivos

Laboratório – Recuperar Senhas

Neste laboratório, você usará uma ferramenta para recuperar senhas de usuário e alterar uma senha de usuário para uma senha mais forte.

- Parte 1: Abra uma janela de terminal no CSE-LABVM.
- Parte 2: Combine senhas e nomes de usuário em um arquivo de texto.
- Parte 3: Execute John the Ripper para recuperar as senhas.
- Parte 4: Altere a senha de um usuário para uma versão mais forte e tente recuperá-la.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

9.2 Proteção antimalware

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ameaças de endpoint

Endpoints são hosts na rede que podem acessar ou serem acessados por outros hosts na rede, incluindo computadores e servidores.

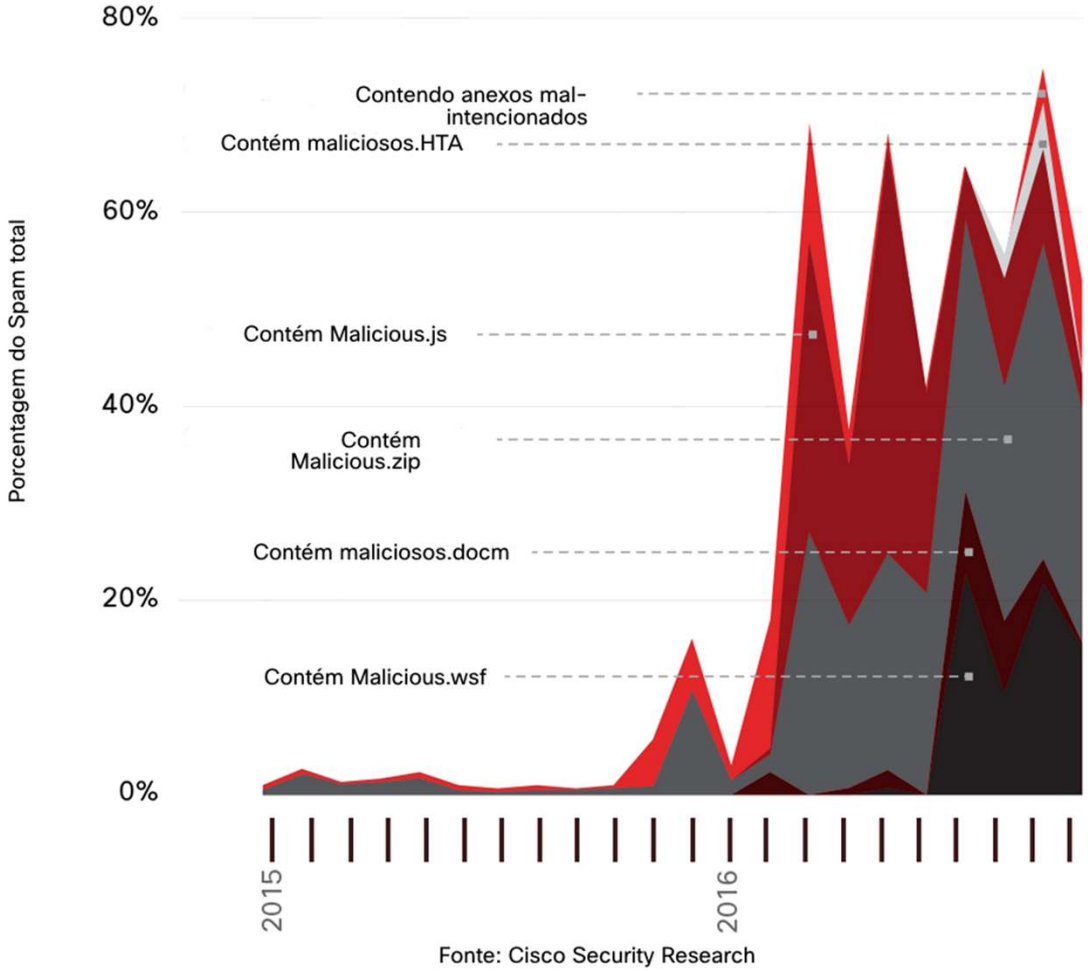
Os pontos a seguir resumem algumas das razões pelas quais o malware continua sendo um grande desafio:

- De acordo com pesquisas da Cybersecurity Ventures, até 2021 uma nova organização será vítima de um ataque de ransomware a cada 11 segundos.
- Os ataques de ransomware custarão à economia global US$6 trilhões por ano até 2021.
- Em 2018, 8 milhões de tentativas de roubar recursos do sistema usando malware de criptografia foram observadas.
- De 2016 até o início de 2017, o volume global de spam aumentou drasticamente. 8 a 10% desse spam pode ser malicioso, conforme mostrado na figura.
- Em 2020, prevê-se que o número médio de ataques cibernéticos por dispositivo macOS aumentará de 4.8 em 2018 para 14,2 em 2020.
- Foram encontrados dários tipos comuns de malware que alteram significativamente seus recursos em menos de 24 horas para evitar detecção.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Proteção Antimalware

Ameaças a Endpoints (cont.)



Fonte: Cisco Security Research

dos os direitos reservados. Documento confidencial da Cisco

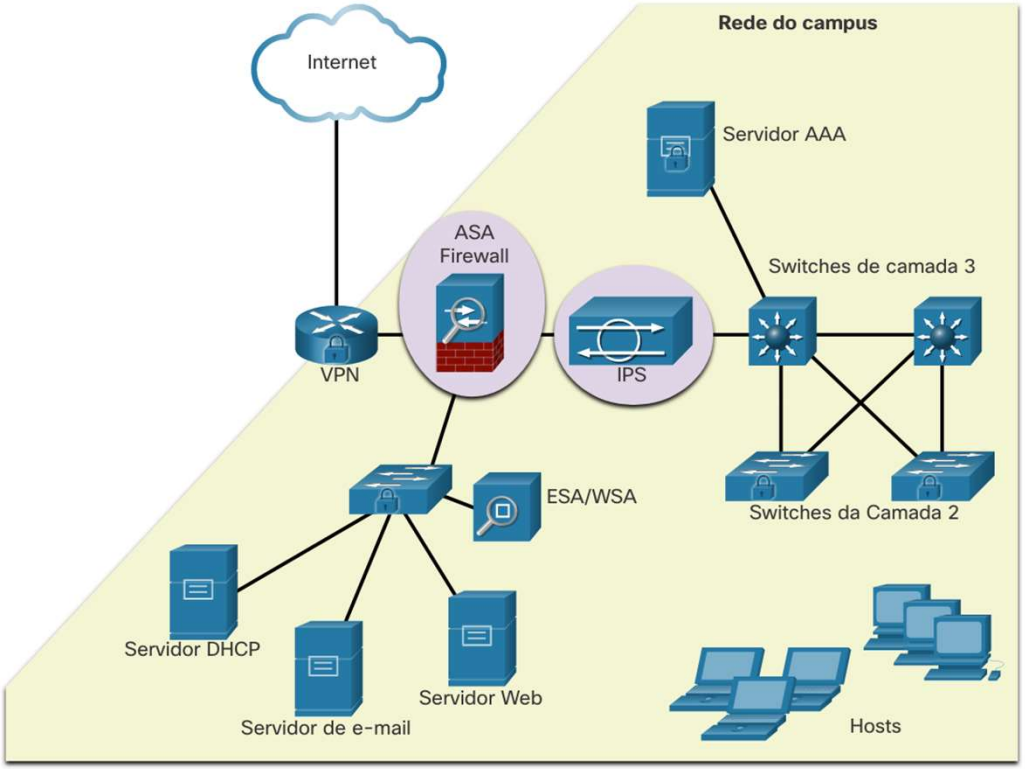
Proteção Antimalware

Segurança de Endpoint

- A imprensa geralmente cobre ataques a redes externas em redes corporativas. Alguns exemplos são:
  - Ataques DoS em uma rede degradam ou até mesmo interrompem o acesso público a ele.
  - Violação de um servidor da web para desfigurar sua presença na web.
  - Violação de servidores e hosts de dados para roubar informações confidenciais.

- Vários dispositivos de segurança de rede são necessários para proteger o perímetro da rede contra acesso externo.

- Esses dispositivos podem incluir um roteador protegido que fornece serviços de VPN, um firewall de próxima geração, um appliance IPS e um servidor de serviços AAA.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Segurança de Endpoint (Cont.)

- Muitos ataques se originam de dentro da rede. Portanto, proteger uma LAN interna é quase tão importante quanto proteger o perímetro externo da rede.

- Sem uma LAN segura, os usuários de uma organização ainda são suscetíveis a ameaças de rede e paralisações que podem afetar diretamente a produtividade e a margem de lucro de uma organização.

- Especificamente, há dois elementos LAN internos para proteger:

  - **Endpoints** - Os hosts comumente consistem em laptops, desktops, impressoras, servidores e telefones IP, todos os quais são suscetíveis a ataques relacionados a malware.

  - **Infraestrutura de rede** - Os dispositivos de infraestrutura de LAN interconectam os endpoints e geralmente incluem switches, dispositivos sem fio e dispositivos de telefonia IP. A maioria desses dispositivos é suscetível a ataques relacionados à LAN, incluindo ataques de estouro de tabela de endereços MAC, ataques de falsificação, ataques relacionados a DHCP, ataques de tempestade de LAN, ataques de manipulação de STP e ataques de VLAN.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Proteção contra malware baseada em host

- As pessoas acessam recursos de rede corporativa com dispositivos móveis que usam tecnologias de acesso remoto, como VPN.

- Esses dispositivos também são usados em redes domésticas e públicas não seguras ou minimamente protegidas.

- Software antimalware/antivírus baseado em host e firewalls baseados em host são usados para proteger esses dispositivos.

- O Software Antivírus/Antimalware é instalado em um host para detectar e mitigar vírus e malware.

- Programas antimalware podem detectar vírus usando três abordagens diferentes:
  - **Baseado em assinatura:** reconhece várias características de arquivos de malware conhecidos
  - **Baseado em heurística:** reconhece recursos gerais compartilhados por vários tipos de malware
  - **Baseado em comportamento:** emprega análise de comportamento suspeito

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Proteção contra malware baseada em host (Cont.)

- Firewall de host
  - Este software está instalado em um host.
  - Restringe conexões de entrada e saída a conexões iniciadas somente por esse host.
  - Alguns softwares de firewall também podem impedir que um host se infecte e impedir que hosts infectados espalhem malware para outros hosts.

- Suites de segurança baseadas em host
  - Recomenda-se instalar um conjunto de produtos de segurança baseado em host em redes domésticas e também em redes comerciais.
  - Eles incluem antivírus, anti-phishing, navegação segura, sistema de prevenção de intrusões baseado em host e recursos de firewall.
  - Ele fornece uma defesa em camadas que protege contra as ameaças mais comuns.

- O laboratório de testes independente AV-TEST fornece análises de alta qualidade de proteções baseadas em host, bem como informações sobre muitos outros produtos de segurança.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Proteção Contra Malware com Base na Rede

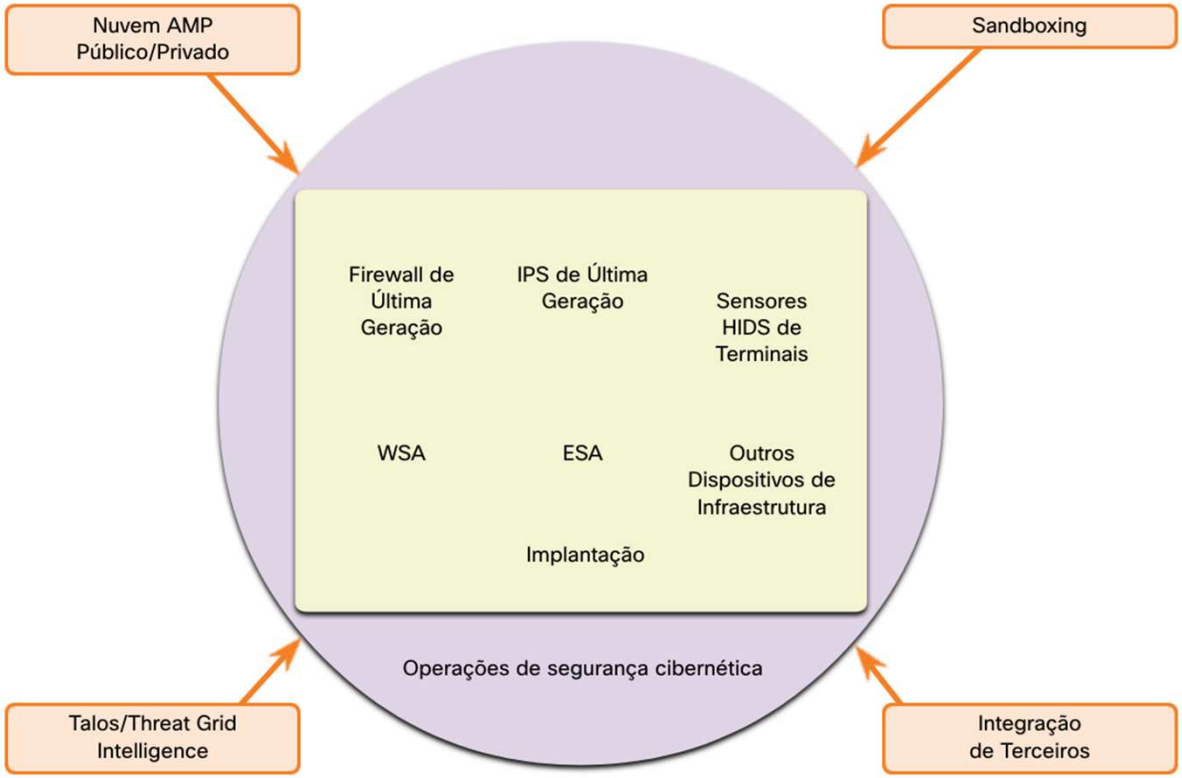
- Novas arquiteturas de segurança para a rede sem fronteiras abordam os desafios de segurança fazendo com que os endpoints usem a varredura de rede.
- A proteção de endpoints em uma rede sem fronteiras pode ser realizada usando técnicas baseadas em rede e em host, como firewalls de última geração, IPSs, controle de acesso à rede, segurança de gateway e segurança de endpoint.

- Exemplos de dispositivos e técnicas que implementam proteções de host no nível da rede:
  - **Proteção Avançada contra Malware (AMP)** - Fornece proteção de endpoint contra vírus e malware.
  - **Email Security Appliance (ESA)** - Isso fornece filtragem de SPAM e emails potencialmente maliciosos antes que eles atinjam o ponto final. Um exemplo é o Cisco ESA.
  - **Web Security Appliance (WSA)** - Isso fornece filtragem de sites e lista negra para impedir que os hosts cheguem a locais perigosos na Web.
  - **Network Admission Control (NAC)** - Permite apenas sistemas autorizados e em conformidade se conectarem à rede.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Proteção contra malware baseada em rede (cont.)

- Essas tecnologias funcionam em conjunto umas com as outras para dar mais proteção do que as suítes baseadas em host podem fornecer, como mostrado na figura.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

9.3 Prevenção de intrusão baseada em host

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Prevenção de intrusão baseada em host

Firewalls baseados em host

- Firewalls pessoais baseados em host são programas de software autônomos que controlam o tráfego que entra ou sai de um computador.
- Firewalls baseados em host podem usar um conjunto de políticas predefinidas, ou perfis, para controlar pacotes que entram e saem de um computador.
- Aplicativos de firewall baseados em host também podem ser configurados para emitir alertas aos usuários se um comportamento suspeito for detectado.
- Os firewalls distribuídos combinam recursos de firewalls baseados em host com gerenciamento centralizado.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Firewalls baseados em host (cont.)

- Independentemente de serem instalados completamente no host ou distribuídos, os firewalls baseados em host são uma camada importante de segurança de rede, juntamente com firewalls baseados em rede.

- Aqui estão alguns exemplos de firewalls baseados em host:

  - **O Windows Defender Firewall** usa uma abordagem baseada em perfil para a funcionalidade do firewall.

  - **O iptables** é um aplicativo que permite aos administradores do sistema Linux configurar regras de acesso à rede que fazem parte dos módulos Netfilter do kernel do Linux.

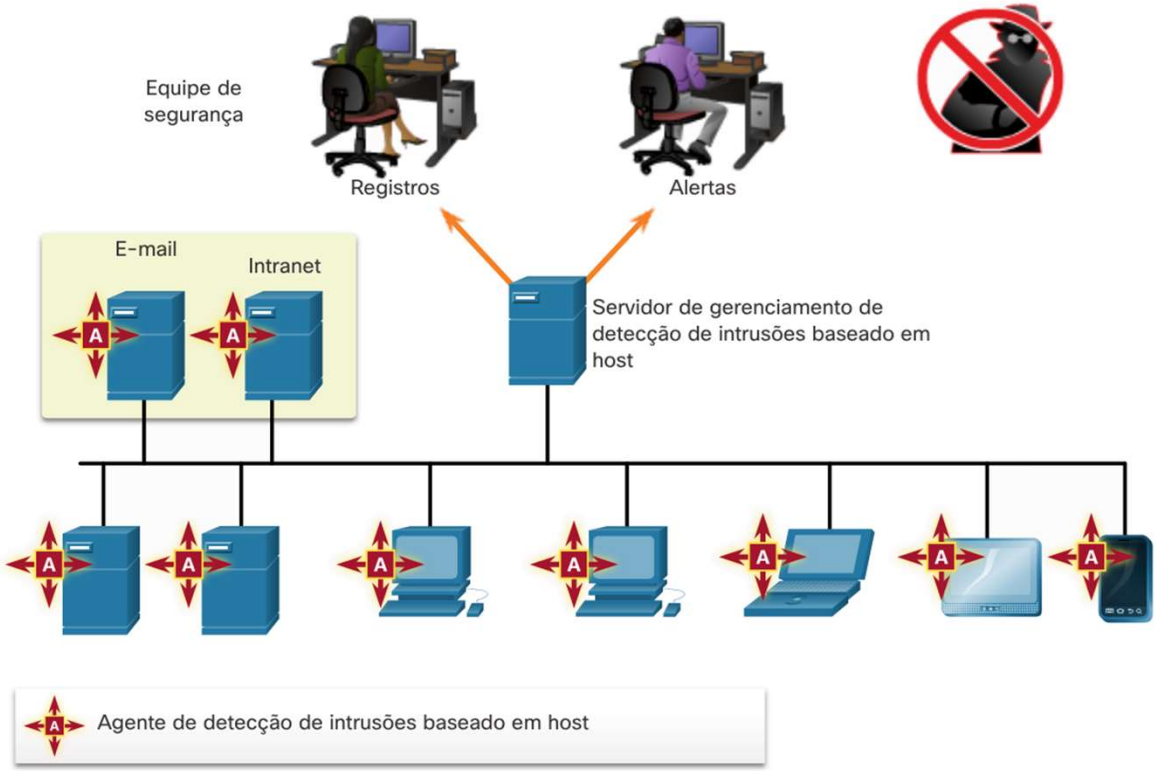
  - **O nftables** é um aplicativo de firewall do Linux que usa uma máquina virtual simples no kernel do Linux.

  - **O TCP Wrapper** é um sistema de registro e controle de acesso baseado em regras para Linux.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Prevenção de intrusão baseada em host

Detecção de intrusão baseada em host



- Um sistema de detecção de intrusões baseado em host (HIDS) foi projetado para proteger hosts contra malware conhecido e desconhecido.
- O HIDS pode realizar monitoramento e relatórios detalhados sobre a configuração do sistema e a atividade do aplicativo.
- HIDS é um aplicativo de segurança abrangente que combina as funcionalidades de aplicativos antimalware com funcionalidade de firewall.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Prevenção de intrusão baseada em host

Operação HIDS

- A HIDS usa estratégias proativas e reativas.
- O HIDS usa assinaturas para detectar malware conhecido e impedir que ele infecte um sistema.
- Um conjunto adicional de estratégias é usado para detectar a possibilidade de intrusões bem-sucedidas por malware que evade a detecção de assinaturas:
  - **Baseado em anomalia -** Se uma invasão for detectada, o HIDS pode registrar os detalhes da invasão, enviar alertas aos sistemas de gerenciamento de segurança e tomar medidas para impedir o ataque.
  - **O HIDS baseado em políticas pode tentar** desligar os processos de software que violaram as regras e pode registrar esses eventos e alertar o pessoal sobre as violações.Com alguns sistemas, os administradores podem criar políticas personalizadas que podem ser distribuídas aos hosts a partir de um sistema central de gerenciamento de políticas.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Prevenção de intrusão baseada em host

Produtos HIDS

- Os produtos HIDS utilizam software no host e algum tipo de funcionalidade de gerenciamento de segurança centralizado que permite a integração com serviços de monitoramento de segurança de rede e inteligência de ameaças.

- Esses são alguns exemplos:
  - Cisco AMP
  - AlienVault USM
  - Tripwire
  - Segurança HIDS de código aberto (OSSEC).

- O OSSEC usa um servidor gerenciador central e agentes que são instalados em hosts individuais e podem receber e analisar alertas de uma variedade de dispositivos de rede e firewalls por syslog.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Prevenção de intrusão baseada em host

Laboratório - Recomendar medidas de segurança de endpoint

Neste laboratório, você atingirá os seguintes objetivos:

- Parte 1: Recomendar Procedimentos de Mitigação para Lidar com Vulnerabilidades
- Parte 2: Recomendar um produto de proteção de endpoint para uma nova rede

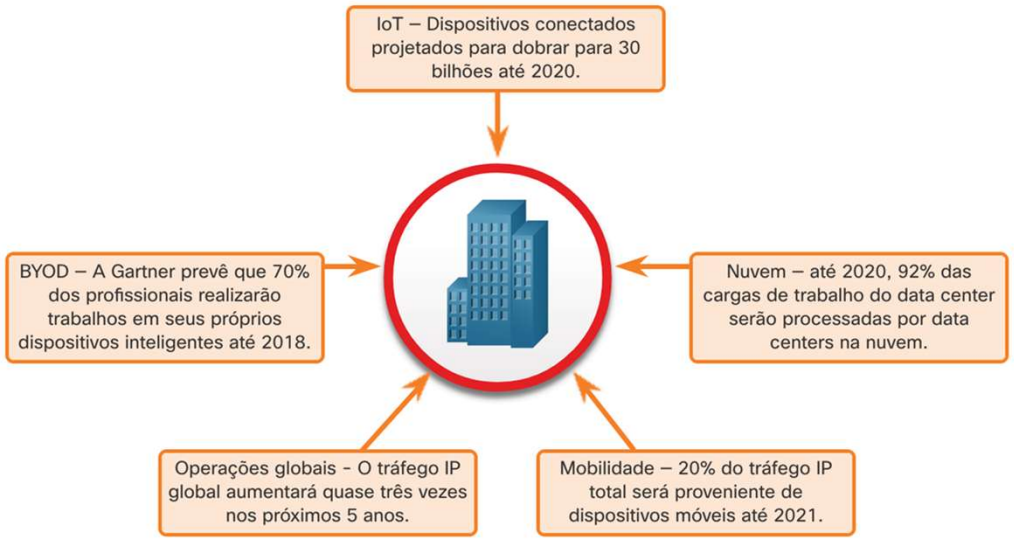
© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

9.4 Segurança do Aplicativo

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Segurança de aplicações

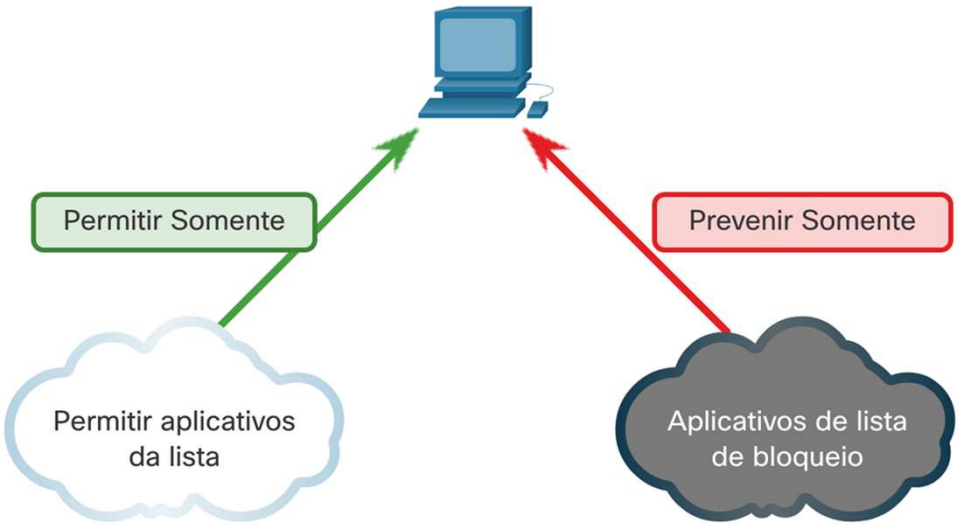
Superfície de ataque



- Superfície de ataque: soma total das vulnerabilidades em cada sistema que é acessível a um invasor e continua a se expandir.
- Mais dispositivos estão conectando redes por meio da Internet das Coisas (IoT) e Traga seu próprio dispositivo (BYOD).
- O Instituto SANS descreve três componentes da superfície de ataque:
  - **Superfície** de ataque de rede - explora vulnerabilidades em redes.
  - **Superfície de ataque de software** - É fornecido por meio da exploração de vulnerabilidades em aplicativos de software baseados na Web, na nuvem ou em host.
  - **Superfície** de ataque humano - explora pontos fracos no comportamento do usuário.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

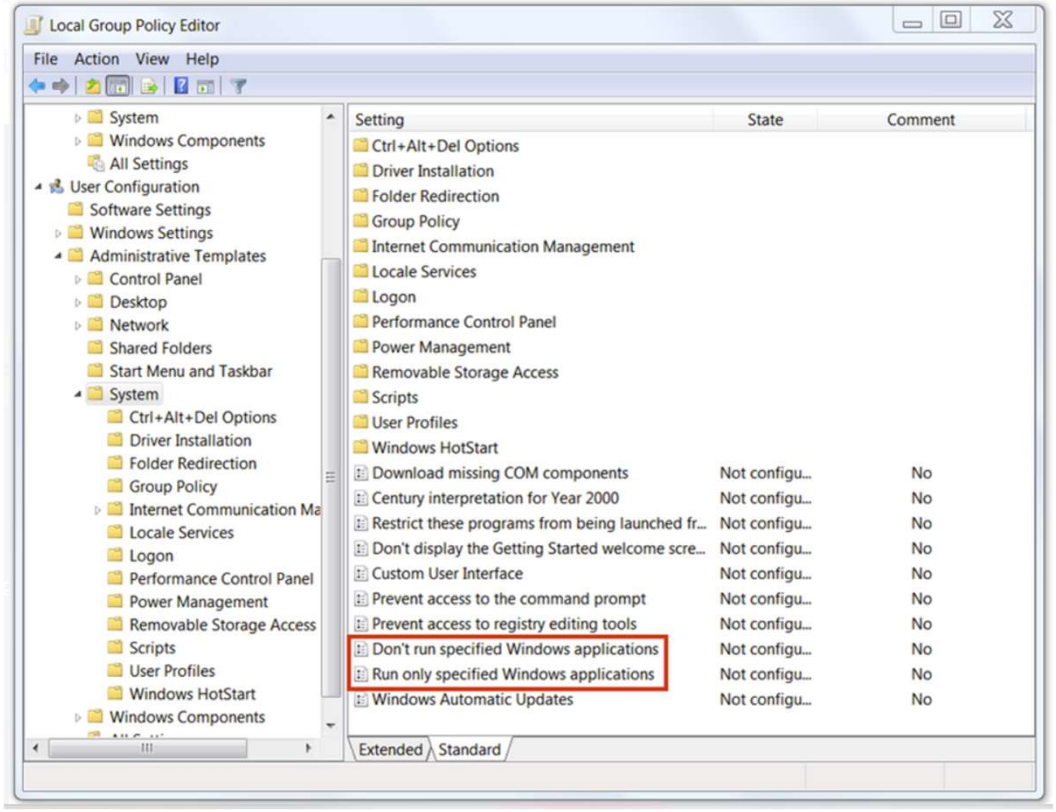
Listade bloqueio de aplicativos e lista de permissões



- **Lista de bloqueio**: limite o acesso a ameaças potenciais criando listas de aplicativos proibidos.
- As listas de bloqueio de aplicativos podem ditar quais aplicativos de usuário não têm permissão para serem executados em um computador.
- Da mesma forma, as listas de permissões podem especificar quais programas podem ser executados, conforme mostrado na figura.
- A figura mostra a lista de bloqueios do Editor de Diretiva de Grupo Local do Windows e as configurações da lista de permissões.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Lista de aplicativos bloqueados e lista de permissões (cont.)



- Os sites também podem ser listados como permitidos e bloqueados.
- Essas listas de bloqueio podem ser criadas manualmente ou podem ser obtidas de vários serviços de segurança.
- As listas de bloqueio podem ser continuamente atualizadas pelos serviços de segurança e distribuídas para firewalls e outros sistemas de segurança que as utilizam.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Sandboxing baseado em sistema

- Sandboxing é uma técnica que permite que arquivos suspeitos sejam executados e analisados em um ambiente seguro.
- O malware entrará na rede apesar dos sistemas de segurança baseados em host e perímetro mais robustos.
- HIDS e outros sistemas de detecção podem criar alertas sobre suspeita de malware que pode ter entrado na rede e executado em um host.
- Cuckoo Sandbox é um sandbox, popular e gratuito, para análise de malware.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Sandbox baseado em sistema (cont.)



- ANY.RUN, mostrado na figura, oferece a capacidade de carregar uma amostra de malware para análise, como qualquer sandbox online.
- Oferece uma funcionalidade de relatório interativo muito rico, cheio de detalhes sobre a amostra de malware.
- ANY.RUN executa o malware e captura uma série de capturas de tela do malware se ele tiver elementos interativos que são exibidos na tela do computador sandbox.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Segurança de aplicações

Vídeo - Usando uma sandbox para iniciar malware

Objetivos:

- Executando malware em um sandbox usando máquinas virtuais
- Executando um estimulador de serviços de rede
- Usando um redirecionador de DNS
- Usando o Process Monitor para capturar e filtrar eventos
- Usando o Process Explorer para rastrear um processo
- Tirando um instantâneo antes e depois do registro do Windows
- Usando wireshark para examinar o tráfego de rede gerado por malware

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Segurança de aplicações

Laboratório - Ferramentas de investigação de malware on-line

Neste laboratório, você completará os seguintes objetivos:

- Parte 1: Realizar Análise Estática
- Parte 2: Revisão de resultados de análises dinâmicas
- Parte 3: Saiba mais sobre a exploração

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

9.5 Resumo da proteção do sistema e endpoint

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Resumo da proteção do sistema e endpoint

O que aprendi neste módulo?

- Para proteger um sistema operacional, os administradores devem remover todos os programas e serviços desnecessários e garantir que as correções de segurança e as atualizações estejam instaladas.
- Malware inclui vírus, worms, cavalos de Troia, keyloggers, spyware, e adware.
- Os patches são atualizações de código que impedem que o malware faça um ataque bem-sucedido.
- Um firewall baseado em host é executado em um dispositivo para restringir a atividade de rede de entrada e saída para ele.
- O software HIDS monitora chamadas e acesso ao sistema de arquivos para detectar solicitações mal-intencionadas.
- O HIPS monitora um dispositivo em busca de ataques e anomalias.
- O EDR monitora e coleta continuamente dados de um dispositivo de endpoint e, em seguida, analisa os dados e responde a todas as ameaças.
- As ferramentas de DLP garantem que dados confidenciais não sejam perdidos ou acessados por usuários não autorizados.
- O NGFW combina um firewall tradicional com outras funções de filtragem de dispositivos de rede.
- Criptografia é uma ferramenta usada para proteger dados usando um algoritmo para tornar os dados ilegíveis.
- O recurso Windows EFS permite aos usuários criptografar arquivos, pastas ou um disco rígido inteiro.
- A integridade de inicialização garante que o sistema seja confiável e não tenha sido alterado enquanto o sistema operacional é carregado.
- Os endpoints são hosts na rede que podem acessar ou ser acessados por outros hosts na rede.
- O Software Antivírus/Antimalware é instalado em um host para detectar e mitigar vírus e malware.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Resumo da proteção do sistema e endpoint

O que aprendi neste módulo?

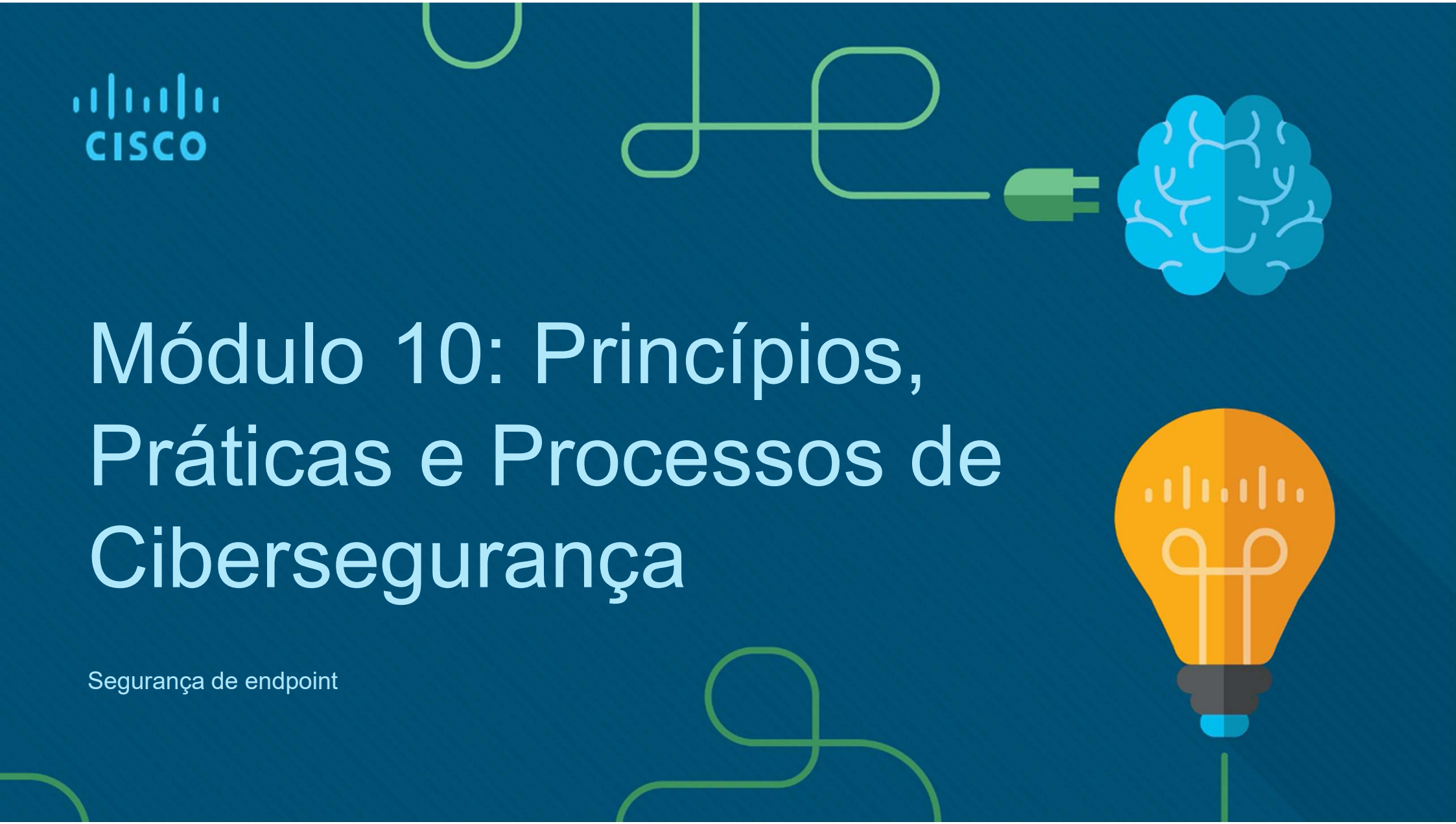
- Firewalls baseados em host podem usar um conjunto de políticas predefinidas, ou perfis, para controlar pacotes que entram e saem de um computador.
- Exemplos de firewalls baseados em host são Windows Defender Firewall, iptables, nftables e TCP Wrappers.
- O HIDS protege os hosts contra malware conhecido e desconhecido e pode realizar monitoramento e relatórios detalhados sobre a configuração do sistema e atividade do aplicativo, análise de log, correlação de eventos, verificação de integridade, imposição de políticas, detecção de rootkit e alertas.
- As assinaturas não são eficazes contra ameaças novas ou de dia zero.
- Algumas famílias de malware exibem polimorfismo.
- Estratégias adicionais para detectar a possibilidade de sucesso de um ataque, incluem detecção baseada em anomalias e detecção baseada em políticas.
- Uma superfície de ataque é a soma total das vulnerabilidades em cada sistema acessível a um invasor.
- Sandboxing é uma técnica que permite que arquivos suspeitos sejam executados e analisados em um ambiente seguro.
- As sandboxes de análise automatizada de malware oferecem ferramentas que analisam o comportamento do malware.
- O malware polimórfico muda com frequência e o novo malware aparece regularmente.
- HIDS e outros sistemas de detecção podem criar alertas sobre suspeita de malware que pode ter entrado na rede e executado em um host.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Módulo 9:

Novos termos e comandos

• Hardware com foco em segurança • Armazenamento criptografado • Sandboxing baseado em sistema • lista de bloqueio • lista de permissões • Inicialização segura • Dados biométricos seguros • Encontre meu Mac • XProtect • Malware Removal Tool (MRT) • Gatekeeper (Guardião) • Network Admission Control (NAC)	• Integridade da Inicialização • Firmware • Unified Extensible Firmware Interface (UEFI) • Endpoint detection and response (EDR) • Prevenção de perda de dados (DLP) • Host-intrusion detection system (HIDS) • Host-intrusion prevention system (HIPS) • Segurança de Endpoint • Gerenciamento de patches	• Segurança do sistema operacional • Windows Defender Firewall • iptables • nftables • TCP Wrappers • Superfície de ataque



Módulo 10: Princípios, Práticas e Processos de Cibersegurança

Segurança de endpoint

Objetivos do Módulo

Título do Módulo 10: Princípios, Práticas e Processos de Cibersegurança

Objetivo do Módulo: Usar as melhores práticas de cibersegurança para melhorar a confidencialidade, integridade e disponibilidade.

Título do Tópico	Objetivo do Tópico
As Três Dimensões	Usar hashes para verificar a integridade dos arquivos.
Estados dos dados	Comparar os três estados dos dados.
Contramedidas de Cibersegurança	Compare os tipos de contramedidas de cibersegurança

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

10.1 As Três Dimensões

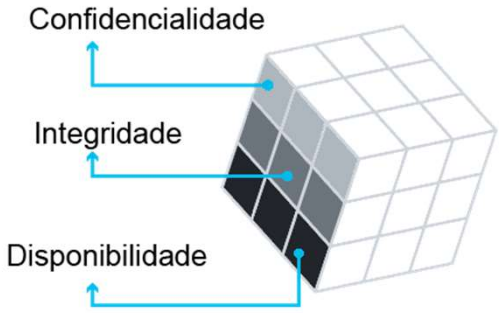
© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

As Três Dimensões

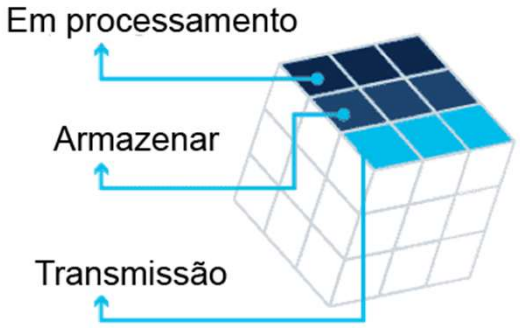
O cubo de Cibersegurança

O cubo de cibersegurança fornece uma maneira útil de pensar sobre a proteção de dados e inclui as três dimensões da segurança da informação.

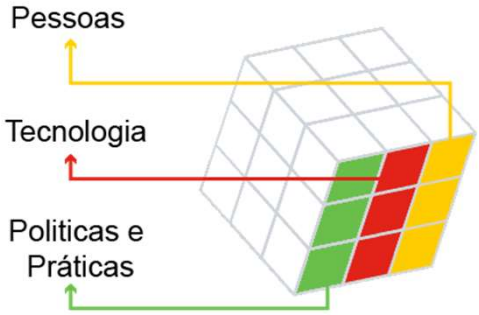
1. Princípios de segurança identificar os objetivos para proteger o ciberespaço.
- **Confidencialidade** dos Dados
- **Integridade**dos Dados
- **Disponibilidade** dos Dados



2. Estados de dados representam os três estados de dados possíveis.
- Dados **em trânsito (data in transit**)
- Dados **inativos ou** em armazenamento
- Dados **em processamento (data in process**)



3. Proteções A terceira dimensão do cubo de segurança digital define os pilares nos quais precisamos basear nossas defesas de segurança digital para proteger dados e infraestrutura na região digital.
- **Tecnologia**
- **Políticas e Práticas**
- Melhorar a educação, o treinamento e a **conscientização das pessoas**



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Tríade da CIA - O Princípio da Confidencialidade

- Tokenização é uma técnica de substituição que pode isolar os elementos de dados da exposição a outros sistemas de dados.
  - A tokenização pode ser usada para obter confidencialidade sem usar criptografia.
  - Um valor aleatório sem relacionamento matemático substitui os dados originais.
  - Fora do sistema, um token não tem valor e não faz sentido.
  - A tokenização pode preservar o formato dos dados (tipo e comprimento dos dados), o que os torna úteis para bancos de dados e processamento de pagamento com cartão.

- O gerenciamento de direitos abrange o gerenciamento de direitos digitais (DRM) e o gerenciamento de direitos de informação (IRM).
  - O DRM protege materiais protegidos por direitos autorais, como músicas, filmes ou livros.
  - O IRM é usado com e-mail e outros arquivos que são relevantes para as atividades e comunicações de uma empresa.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

As Três Dimensões

Integridade de dados

- Integridade é a precisão, consistência e confiabilidade dos dados em todo o seu ciclo de vida.
- Os dados passam por várias operações, como captura, armazenamento, recuperação, atualização e transferência.
- Os dados devem permanecer inalterados por entidades não autorizadas durante todas essas operações.
- Os métodos usados para garantir a integridade de dados incluem hashing, verificações de validação de dados, verificações de consistência dos dados e controles de acesso.
- A integridade de dados é um componente fundamental da segurança da informação.
- A necessidade de integridade de dados
  - Crítico
  - Alto
  - Médio
  - Baixo

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Como assegurar a disponibilidade

Há muitas medidas que as empresas podem implementar para garantir a disponibilidade de seus serviços e sistemas.

- **Manutenção do Equipamento**: A manutenção regular do equipamento pode melhorar bastante o tempo de atividade do sistema. A manutenção inclui a substituição, limpeza e alinhamento do componente.

- **Sistemas Operacionais e Atualização de Softwares e patches:** Sistemas operacionais, aplicativos e softwares modernos são atualizados continuamente para corrigir erros e eliminar vulnerabilidades.

- **Teste de Backup:** O backup de dados da organização, dados de configuração e dados pessoais ajuda a garantir a disponibilidade. Os sistemas de backup e os dados de backup também devem ser testados para garantir que funcionem corretamente e que os dados possam ser recuperados em caso de perda de dados.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Assegurando a disponibilidade (Cont.)

- **Planejamento para Desastres:** O planejamento para desastres é uma parte essencial do aumento da disponibilidade do sistema. A equipe de segurança cibernética deve praticar protocolos de resposta, testar os sistemas de backup, além de estar familiarizada com procedimentos de restauração de sistemas críticos.

- **Implementação de Novas Tecnologias:** A alta disponibilidade requer avaliação contínua e teste de novas tecnologias, para considerar novas ameaças e ataques. Os cibercriminosos usam as ferramentas e truques mais recentes, portanto, os profissionais cibernéticos também precisam acompanhar, usando novas tecnologias, produtos e dispositivos.

- **Monitoramento** de Atividades: Monitoramento contínuo do sistema aumenta a disponibilidade do sistema. O monitoramento de logs de eventos, os alertas de sistema e os logs de acesso fornece ao profissional de segurança digital as informações do sistema em tempo real.

- **Teste de Disponibilidade:** Todos os sistemas devem ser testados para encontrar vulnerabilidades. O teste pode incluir varreduras de porta, varreduras de vulnerabilidade e testes de penetração.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

As Três Dimensões

Laboratório – Quizlet The Cybersecurity Sorcery Cube Scatter

Neste laboratório você vai Identificar as três dimensões do Cybersecurity Sorcery Cube e os elementos de cada dimensão.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Packet Tracer – Verificações de Integridade de Arquivos e Dados

Nesta atvidade do Packet Tracer, você completará os seguintes objetivos:

- Parte 1: Recupere arquivos após um ataque cibernético.
- Parte 2: Use hash para verificar a integridade do arquivo.
- Parte 3: Use hash para verificar a integridade do arquivo.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Packet Tracer – Como explorar a criptografia de dados e de arquivos

Nesta atividade do Packet Tracer, você completará os seguintes objetivos:

- Parte 1: Descubra as credenciais da conta FTP para Mary
- Parte 2: Carregue os dados confidenciais usando FTP
- Parte 3: Descubra as credenciais da conta FTP para Bob
- Parte 4: Baixe os dados confidenciais usando FTP
- Parte 5: Descriptografer o conteúdo de um arquivo sensível

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

10.2 Estados dos Dados

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Estados dos Dados

Dados em Repouso

- Os dados que não estão em trânsito ou em processo são considerados dados em repouso.
- Se você possui dados que precisa armazenar e deseja acessar posteriormente, existem algumas opções de armazenamento:

Armazenamento de conexão direta (Direct-attached storage - DAS)	Ele está conectado a um computador. Por padrão, os sistemas não são configurados para compartilhar armazenamento de conexão direta com outros computadores em sua rede.
Redundant array of independent disks (RAID)	Ele usa vários discos rígidos em uma matriz, combinando vários discos para que o sistema operacional os veja como um único disco. A RAID fornece desempenho melhorado e tolerância a falhas.
Dispositivo de armazenamento conectado à rede (Network attached storage - NAS)	Ele está conectado a uma rede que permite o armazenamento e recuperação de dados de um local centralizado por usuários autorizados da rede. Os dispositivos NAS são flexíveis e escaláveis, o que significa que sua capacidade pode ser aumentada conforme necessário.
Storage area network (SAN)	É um sistema de armazenamento baseado em rede. Os sistemas SAN conectam-se à rede usando interfaces de alta velocidade que permitem desempenho melhorado e a habilidade de conectar vários servidores em um repositório de armazenamento de disco centralizado.
Armazenamento em nuvem	Um armazenamento remoto que usa espaço em um provedor de data center e pode ser acessado de qualquer computador com acesso à Internet, geralmente mediante assinatura.

Desafios da proteção dos dados armazenados

- Para melhorar a proteção do armazenamento de dados, as organizações podem automatizar e centralizar os backups de dados.

Armazenamento de conexão direta (Direct-attached storage - DAS)

- Pode ser um dos tipos mais difíceis de armazenamento de dados para gerenciar e controlar.
- É vulnerável a ataques mal-intencionados no host local.

Dados em repouso (data at rest)

- Ele também incluem dados de backup (quando não estão sendo gravados ou em trânsito).
- Para aumentar a segurança e diminuir a perda de dados, as organizações devem limitar os tipos de dados armazenados em dispositivos de armazenamento de conexão direta.

Sistemas de armazenamento em rede

- Oferece uma opção mais segura.
- Inclui RAID, SAN e NAS, proporcionando maior desempenho e redundância

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Estados dos Dados

Métodos de Transmissão de Dados

- Dados em trânsito são dados que estão sendo transmitidos - não estão em repouso nem em uso.
- A transmissão de dados envolve o envio de informações de um dispositivo para outro.
- Existem várias maneiras de transmitir dados entre dispositivos.
  - **Uma sneaker net:** usa mídia removível para mover dados fisicamente de um computador para outro.
  - **Redes com fio:** inclui mídia de cobre e fibra ótica e pode atender a uma LAN ou abranger grandes distâncias em redes de longa distância (WAN).
  - **Redes sem fio:** usam ondas de rádio para transmitir dados Elas aumentam o número de usuários convidados com dispositivos móveis em pequenos escritórios domésticos (SOHO) e redes corporativas.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Métodos de Transmissão de Dados (Cont.)

- As redes com e sem fio transmitem pacotes.
- O termo pacote refere-se a uma unidade de dados que trafega entre uma origem e um destino na rede.
- Protocolos padrão como o IP e o HTTP definem a estrutura e o formato dos pacotes de dados.
- Esses padrões são de código aberto e totalmente disponíveis ao público.
- Proteger a confidencialidade, a integridade e a disponibilidade dos dados transmitidos é uma das responsabilidades mais importantes de um profissional de segurança cibernética.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

10.2.6 Desafios dos Dados em Trânsito

- Com o crescimento em dispositivos móveis e sem fios, e a crescente quantidade de dados coletados e armazenados por organizações, os profissionais de cibersegurança são responsáveis por proteger enormes quantidades de dados que passam pela sua rede diariamente.

- Para proteger esses dados, existem vários desafios a serem superados:

Proteção da confidencialidade dos dados em trânsito	Os profissionais de segurança digital devem tomar medidas para proteger os dados em trânsito, como a implementação de VPNs, usando SSL e IPsec e vários outros métodos de criptografia de dados para transmissão.
Proteção da integridade dos dados em trânsito	Os profissionais cibersegurança implantam sistemas de integridade de dados que testam a integridade e a autenticidade dos dados transmitidos para combater essas ações. Esses sistemas incluem, por exemplo, hash e redundância de dados.
Protegendo a disponibilidade de dados em trânsito	Os profissionais de segurança de rede podem implementar sistemas de autenticação mútua para combater essas ações. Os sistemas de autenticação mútua exigem que o usuário se autentique no servidor e solicitam que o servidor se autentique no usuário.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Estados dos Dados

Dados em Processamento

- Dados em processamento (data in process) referem-se a dados durante a entrada inicial, modificação, computação ou saída

Entrada	A proteção da integridade de dados começa com a entrada inicial dos dados. As organizações usam vários métodos para coletar dados, como entrada manual de dados, digitalização de formulários, carregamentos de arquivos e dados coletados dos sensores. A corrupção durante o processo de entrada pode incluir rotulagem incorreta e formatos de dados incorretos ou incompatíveis, erros de entrada de dados ou sensores de sistema desconectados e/ou com mau funcionamento ou inoperantes.
Modificação	Modificação de dados é qualquer alteração feita nos dados originais, como usuários modificando dados manualmente e programas processando e alterando dados. Essas alterações são intencionais, mas as alterações nos dados podem ser involuntárias ou maliciosas. Quando dados são modificados de uma forma que impede que sejam legíveis ou utilizáveis, isso é chamado de corrupção de dados.
Saída	A saída de dados refere-se à saída de dados para dispositivos de saída, como impressoras, monitores eletrônicos e alto-falantes. A precisão dos dados de saída é fundamental, pois fornece informações e influencia a tomada de decisões.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Dados em Processamento (cont.)

- Protegendo dados durante o processamento requer sistemas bem projetados. Caso contrário, os resultados para as empresas podem ser graves e onerosos para suas finanças ou até mesmo para sua reputação.

- Os profissionais de cibersegurança criam políticas e procedimentos que exigem teste, manutenção e atualização de sistemas para mantê-los funcionando com o mínimo de erros.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Laboratório - Desafios de Segurança de Dados

Neste laboratório, você vai considerar os desafios para proteger:

- Dados em Repouso
- Dados em Trânsito
- Dados em Processamento

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

10.3 Contramedidas de Cibersegurança

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Contramedidas de Cibersegurança

Tecnologias baseadas em hardware e software

- Tanto software como hardware são utilizados para proteger os dados e os sistemas das empresas.
- As proteções de tecnologia incluem programas e serviços que protegem sistemas operacionais, bancos de dados e outros serviços sendo executados em estações de trabalho, dispositivos portáteis e servidores.
- Os administradores instalam contramedidas ou proteções baseadas em software em hosts ou servidores individuais.

Firewalls de Software	Estes controlam o acesso remoto a um sistema. Os sistemas operacionais normalmente incluem um firewall ou um usuário pode comprar ou fazer download de software de terceiros.
Scanners de rede e porta	Eles descobrem e monitoram portas abertas em um host ou servidor.
Analisadores de protocolo	Dispositivos que coletam e examinam o tráfego de rede. Eles identificam problemas de desempenho e aplicativos com comportamento inadequado, detectam configurações incorretas, estabelecem padrões de tráfego normais e de linha de base e depuram problemas de comunicação
Scanners de Vulnerabilidade	Programas projetados para avaliar pontos fracos em computadores ou redes.
Sistemas de detecção de intrusão (IDS) b aseados em host	Eles examinam a atividade somente em sistemas host. Um IDS gera arquivos de log e mensagens de alarme quando detecta atividade incomum.

Tecnologias baseadas em hardware e software (Cont.)

- Existem várias tecnologias baseadas em hardware usadas para proteger os ativos de uma empresa:

Firewalls	Eles bloqueiam o tráfego indesejado. Eles contêm regras que definem o tráfego permitido dentro e fora de uma rede.
Servidores Proxy	Eles usam um esquema de endereçamento de rede para apresentar à Internet um endereço IP para toda a empresa. Um servidor proxy funciona, portanto, em nome do cliente ao solicitar o serviço, mascarando potencialmente a verdadeira origem da solicitação para o servidor de recursos.
Controle de acesso por hardware	Dispositivos que utilizam tecnologia biométrica, como scanners de impressão digital ou íris, para confirmar a identidade de qualquer pessoa que tente acessar servidores, dados e sistemas.
Switchs de Rede	Switches são comumente usados como um ponto de conexão, vinculando outros dispositivos, por exemplo, em uma rede de área local. Seus recursos permitem que eles aumentem a eficiência de segurança da rede.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Estabelecimento de uma cultura de conscientização de segurança cibernética

- Investir muito dinheiro em tecnologia não fará diferença se as pessoas dentro da empresa forem o elo mais fraco da segurança cibernética.
- Um programa de conscientização de segurança e políticas de segurança sólidas e abrangentes são extremamente importantes para qualquer empresa.
- Um funcionário pode não ser intencionalmente malicioso, mas simplesmente desconhecer quais são os procedimentos adequados.
- Há várias maneiras de implementar o treinamento para evitar isso e garantir que todos os funcionários se sintam bem informados e confiantes para tornar as melhores práticas de segurança digital parte de suas atividades diárias.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Estabelecendo uma Cultura de Conscientização em Cibersegurança (Cont.)

Educação e treinamento

- Torne o treinamento de conscientização de segurança uma parte do processo de integração do funcionário
- Vincule a conscientização de segurança aos requisitos do trabalho ou às avaliações de desempenho
- Realize sessões de treinamento presenciais usando gamificação e atividades (por exemplo, capture os cenários de flag).
- Cursos e módulos online completos, como o que o eLearning @Apollo cria.

Programas de conscientização em segurança

- Um programa de conscientização de segurança ativo depende:
  - Do ambiente da empresa
  - Do nível de ameaça
  - A natureza e as demandas dos dados que a empresa mantém.
- As pessoas são a primeira linha de defesa em segurança digital, e cada empresa é tão forte quanto seu elo mais fraco.
- Cada membro de uma organização deve estar ciente de suas políticas de segurança e implementá-las em suas atividades diárias.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Políticas

- Uma política de segurança define os objetivos de segurança, as regras de comportamento e os requisitos do sistema a serem respeitados.

- Uma política de segurança abrangente realiza várias tarefas:
  - Demonstra um comprometimento da empresa com a segurança.
  - Define as regras para o comportamento esperado.
  - Ele garante consistência nas operações do sistema e aquisição, uso e manutenção de software e hardware.
  - Define as consequências jurídicas das violações.
  - Dá o apoio da gerência à equipe de segurança.

- As políticas de segurança informam os usuários, funcionários e gerentes sobre os requisitos da organização, que protegem os ativos de tecnologia e informação.

- Uma política de segurança também especifica os mecanismos necessários para atender aos requisitos de segurança.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Políticas (Cont.)

Como mostrado na figura, uma política de segurança normalmente inclui:

Políticas de Identificação e Autenticação	Especifique as pessoas autorizadas que podem ter acesso aos recursos da rede e descreve os procedimentos de verificação para esses usuários.
Políticas de senha	Garante que as senhas atendam aos requisitos mínimos e sejam alteradas regularmente.
políticas de usos aceitáveis	Identifique os recursos e o uso da rede que são aceitáveis para a organização. Também pode identificar ramificações para violações de política.
Políticas de Acesso Remoto	Identifique como os usuários remotos podem acessar uma rede e o que é acessível remotamente.
Políticas de Manutenção de Rede	Especifique os sistemas operacionais do dispositivo de rede e os procedimentos de atualização do aplicativo do usuário final.
Políticas de Tratamento de Incidentes	Descreve como os incidentes de segurança são tratados.

- Um dos componentes de política de segurança mais comuns é uma política de uso aceitável (AUP). Esse componente define o que os usuários podem ou não fazer nos vários componentes do sistema.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Contramedidas de segurança cibernética

Padrões

- Os padrões ajudam uma equipe de TI a manter a consistência no funcionamento da rede.
- Políticas de segurança informam os usuários, funcionários e gerentes dos requisitos de uma empresa para a proteção de ativos de tecnologia e de informação.
- Um dos princípios de segurança mais importantes é a consistência.
- Cada empresa desenvolve padrões para suporte de seu único ambiente operacional.
- Um exemplo de padrão seria a política de senha de uma empresa.
  - Por exemplo, o padrão pode estipular que as senhas exijam um mínimo de oito caracteres alfanuméricos maiúsculos e minúsculos, incluindo pelo menos um caractere especial.
  - A política de senha pode especificar que os usuários devem alterar suas senhas a cada 30 dias.
  - Um histórico de senha pode ser mantido para as 12 senhas mais recentes para impedir que alguém reutilize as mesmas senhas durante um período de 12 meses.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Diretrizes

- As diretrizes são uma lista de sugestões sobre como fazer as coisas de forma mais eficiente e com segurança.

- As diretrizes definem como os padrões são desenvolvidos e garantem adesão às políticas de segurança gerais.

- Além das melhores práticas definidas de uma organização, as diretrizes também estão disponíveis em:
  - Centro de recursos de segurança de computador do Instituto Nacional de Padrões e Tecnologia (NIST)
  - Orientações de configuração de segurança nacional (NSA)
  - O padrão Common Criteria

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

10.4 Resumo dos Princípios, Práticas e Processos de Cibersegurança

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Resumo dos Princípios, Práticas e Processos de Cibersegurança

O que aprendi neste Módulo?

- Redes cabeadas usam cabos para transmitir dados Eles incluem mídia de cobre e fibra óptica e podem atender a uma rede de área local (LAN) ou abranger grandes distâncias em redes de longa distância (WAN).
- A primeira dimensão do cubo de segurança cibernética identifica os objetivos para proteger o ciberespaço: confidencialidade dos dados, integridade dos dados e disponibilidade dos dados.
- A segunda dimensão representa os três possíveis estados de dados: dados em trânsito, dados em repouso ou em armazenamento e dados em processamento.
- A terceira dimensão define os pilares nos quais basear suas defesas de cibersegurança. Elas são tecnologias, políticas e práticas e melhoria da educação, treinamento e conscientização das pessoas.
- Tokenização é uma técnica de substituição que pode isolar os elementos de dados da exposição a outros sistemas de dados.
- O gerenciamento de direitos abrange o gerenciamento de direitos digitais (DRM) e o gerenciamento de direitos de informação (IRM).
- Os tipos de informações confidenciais são categorizados como pessoais, comerciais e confidenciais.
- Integridade é a precisão, consistência e confiabilidade dos dados em todo o seu ciclo de vida.
- Os métodos usados para garantir a integridade de dados incluem hashing, verificações de validação de dados, verificações de consistência dos dados e controles de acesso.
- A disponibilidade garante que as informações possam ser acessadas sempre que necessário.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

O que aprendi neste Módulo? (Cont.)

- A segurança da informação exige que os dados sejam protegidos quando estão em repouso, em trânsito e em processmento.
- Os dados estão em repouso quando nenhum usuário ou processo os está acessando, solicitando ou alterando.
- Os dados podem ser armazenados em DAS, RAID, NAS, SAN ou na nuvem.
- Dados em trânsito são dados que estão sendo transmitido.
- Uma rede sneaker usa mídia removível para mover fisicamente os dados de um computador para outro.
- Protocolos padrão como o IP e o HTTP definem a estrutura e o formato dos pacotes de dados.
- Dados em processamento (data in process) referem-se a dados durante a entrada inicial, modificação, computação ou saída
- A proteção da integridade de dados começa com a entrada inicial dos dados.
- As organizações usam vários métodos para coletar dados, como entrada manual de dados, digitalização de formulários, carregamentos de arquivos e dados coletados dos sensores.
- Contramedidas ou proteções baseadas em software podem ser instaladas em hosts ou servidores individuais: firewalls de software, scanners de rede e porta, analisadores de protocolo, scanners de vulnerabilidade e IDS baseado em host.
- Um programa ativo de conscientização de segurança depende do ambiente e da rede da empresa, do nível de ameaça e da natureza e das demandas dos dados que a empresa mantém.
- Uma política de segurança abrangente demonstra o compromisso de uma organização com a segurança.
- Tipos de políticas de segurança incluem identificação e autenticação, senhas, uso aceitável, acesso remoto, manutenção de rede e tratamento de incidentes.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Módulo 10:

Novos termos e comandos

- As Três Dimensões
- Estados dos Dados
- Contramedidas de Cibersegurança
- O cubo de Cibersegurança
- Estados de dados
- Proteções
- Gerenciamento de Direitos Digitais (DRM)
- Gerenciamento de direitos de informação (IRM)
- Manutenção de equipamentos
- Teste de backup
- Monitoramento de atividades
- Teste de disponibilidade
- Dados em repouso
- Direct-attached storage (DAS)
- Redundant array of independent disks (RAID)
- Storage conectado à rede (NAS - Network Attached Storage)
- Storage area network (SAN)
- Armazenamento em nuvem
- Rede sneaker
- Redes com fio
- Modificação de Dados
- Planejamento contra desastres
- Saída
- Entrada
- Firewalls de Software
- Scanners de rede e porta
- Analisadores de protocolo
- Scanners de Vulnerabilidade
- Sistemas de detecção de intrusão (IDS) baseados em host
- Servidores Proxy
- Controle de acesso baseado em hardware